

HARBORING DATA

HARBORING DATA

*Information Security, Law,
and the Corporation*

Edited by Andrea M. Matwyszyn

STANFORD LAW BOOKS

An Imprint of Stanford University Press

Stanford, California

Stanford University Press
Stanford, California

©2009 by the Board of Trustees of the Leland Stanford Junior University.
All rights reserved.

No part of this book may be reproduced or transmitted in any form or by any means, electronic or mechanical, including photocopying and recording, or in any information storage or retrieval system without the prior written permission of Stanford University Press.

Printed in the United States of America on acid-free, archival-quality paper

Library of Congress Cataloging-in-Publication Data

Harboring data : information security, law, and the corporation / edited by Andrea M. Matwyshyn.

p. cm.

Includes bibliographical references and index.

ISBN 978-0-8047-6008-9 (cloth : alk. paper)

1. Data protection--Law and legislation--United States. 2. Computer security--Law and legislation--United States. 3. Business records--Law and legislation--United States. I. Matwyshyn, Andrea M.

KF1263.C65H37 2009

342.7308'58--dc22

2009021883

Typeset by Bruce Lundquist in 10/14 Minion

Table of Contents

Acknowledgments	ix
Author Biographies	xi
Section I: Introducing Corporate Information Security	
Introduction <i>Andrea M. Matwyshyn</i>	3
1 Looking at Information Security Through an Interdisciplinary Lens Computer Science as a Social Science: Applications to Computer Security <i>Jonathan Pincus</i> <i>Sarah Blankinship</i> <i>Tomasz Ostwald</i>	19
Section II: The Dual Nature of Information— Information as a Consumer and Corporate Asset	
2 The Information Vulnerability Landscape Compromising Positions: Organizational and Hacker Responsibility for Exposed Digital Records <i>Kris Erickson</i> <i>Philip N. Howard</i>	33

3	Reporting of Information Security Breaches A Reporter's View: Corporate Information Security and the Impact of Data Breach Notification Laws <i>Kim Zetter</i>	50
4	Information Security and Patents Embedding Thickets in Information Security? Cryptography Patenting and Strategic Implications for Information Technology <i>Greg R. Vetter</i>	64
5	Information Security and Trade Secrets Dangers from the Inside: Employees as Threats to Trade Secrets <i>Elizabeth A. Rowe</i>	92

Section III: U.S. Corporate Information Security Regulation and Its Shortcomings

6	Information Security of Health Data Electronic Health Information Security and Privacy <i>Sharona Hoffman</i> <i>Andy Podgurski</i>	103
7	Information Security of Financial Data Quasi-Secrets: The Nature of Financial Information and Its Implications for Data Security <i>Cem Paya</i>	121
8	Information Security of Children's Data From "Ego" to "Social Comparison"—Cultural Transmission and Child Data Protection Policies and Laws in a Digital Age <i>Diana T. Slaughter-Defoe</i> <i>Zhenlin Wang</i>	145

Section IV: The Future of Corporate Information Security and Law

9	Information Security and Contracts Contracting Insecurity: Software Licensing Terms That Undermine Information Security <i>Jennifer A. Chandler</i>	159
---	--	-----

10	Information Security, Law, and Data-Intensive Business Models	
	Data Control and Social Networking: Irreconcilable Ideas?	202
	<i>Lilian Edwards</i>	
	<i>Ian Brown</i>	
	Conclusion	228
	<i>Andrea M. Matwyshyn</i>	
	Notes	235
	Bibliography	295
	Index	333

Acknowledgments

Many thanks are due in connection with this volume. First and foremost, I thank the stellar group of authors whose work appears here. I am grateful to them not only for their insightful contributions to this compilation, but also for the years of conversations I have had with many of them. They have shaped my own thinking on information security issues.

Thank you to the Carol and Lawrence Zicklin Center for Business Ethics Research at the Wharton School at the University of Pennsylvania, and Director William S. Laufer and Associate Director Laretta Tomasco, for continued financial support of my research. Thanks also to the superb staff of the Legal Studies Department at Wharton, particularly Tamara English and Mia Morgan, who facilitate my work daily and who provided indispensable support in connection with this text. In addition, I owe thanks to the Wharton undergraduates who assisted in preparing this book for publication, especially Jennifer Rowland and Bohea Suh.

Thank you also to Marcia Tiersky, Sharon M. Gordon, and Jacqui Lipton for their comments and critiques on preliminary versions of this volume. Finally, thanks are overdue to my parents for decades of support and encouragement in any and all ventures I have chosen to undertake.

Author Biographies

Editor

ANDREA M. MATWYSHYN is an Assistant Professor of Legal Studies and Business Ethics at the Wharton School at University of Pennsylvania. Her research and consulting focus on U.S. and international issues related to information policy, corporate best practices, data privacy, and technology regulation. Her most recent scholarship can be found at <http://ssrn.com/author=627948>.

Contributors

SARAH BLANKINSHIP is a Senior Security Strategist at Microsoft, working with hackers and InfoSec sellouts alike, one continent at a time. On good days she battles the asymmetry between attacker and defender together with the world's best security response team, the Microsoft Security Response Center. On other days her diplomacy and firefighting skills are applied to some of the world's most challenging security problems.

IAN BROWN is a Research Fellow at the Oxford Internet Institute, Oxford University, and an Honorary Senior Lecturer at University College London. His work focuses on public policy issues around information and the internet, particularly privacy, copyright, e-democracy, information security, networking and health care informatics. He frequently consults for governmental and corporate clients, both in the UK and abroad.

JENNIFER CHANDLER is an Assistant Professor of Law in the Common Law Section of the University of Ottawa School of Law and a leading Canadian expert in information security law. Her primary areas of interest relate to legal issues raised by new and evolving technologies, particularly information and communication technologies.

DIANA T. SLAUGHTER-DEFOE is the Constance Clayton Professor in Urban Education in the Graduate School of Education at the University of Pennsylvania. She was cited by the American Psychological Association for Distinguished Contributions to Research in Public Policy and received a Lifetime Professional Achievement Award from the alumni association of the University of Chicago. Her primary research interests are child development and early intervention and parent-child relations and school achievement.

LILIAN EDWARDS is a Professor at the University of Sheffield School of Law. Her major concern has been the substantive law relating to computers and e-commerce, with a European and comparative focus. Her research has centered on internet content (including pornography, libel, and spam); intermediary/ISP liability on the internet; jurisdictional and other issues of international private law on the internet; privacy online; and consumer protection online.

KRIS ERICKSON is an Instructor in the Department of Geography at the University of Washington. His dissertation research focused on the role of the computer hacker community in the governance of cyberspace.

SHARONA HOFFMAN is Professor of Law and Bioethics, Co-Director of the Law-Medicine Center, and Senior Associate Dean for Academic Affairs at Case Western Reserve University Law School. She has published articles on employment discrimination, health insurance, disability law, biomedical research, the concept of race and its use in law and medicine, and health information technology.

PHILIP N. HOWARD is an Associate Professor in the Communication Department at the University of Washington. His research and teaching interests include political communication and the role of new media in social movements and deliberative democracy, work in new economy and e-commerce firms, and the application of new media technologies in addressing social inequalities in the developing world.

TOMASZ OSTWALD is a Senior Program Manager at the Microsoft Corporation. For the past ten years he has been involved in different aspects of security research. He has coauthored several security-related papers and been a speaker at security conferences, including BlackHat, CCC, and HackInTheBox.

CEM PAYA is an Information Security Engineer with Google. Before joining Google, he was a Senior Program Manager at the Microsoft Corporation, where he headed up security in Microsoft's MPG unit, which encompassed all of Microsoft's internet-based operations.

JON PINCUS's current professional projects include *Tales from the Net* (a book on social networks coauthored with Deborah Pierce), starting a strategy consulting practice, and blogging at Liminal States and elsewhere. Previous work includes leading the Ad Astra project as General Manager for Strategy Development in Microsoft's Online Services Group. His primary research interest is the implications of recasting the field of computer science as a social science.

ANDY PODGURSKI is an Associate Professor of Computer Science in the Electrical Engineering & Computer Science Department at Case Western Reserve University. He has conducted research on software engineering methodology and related topics for nearly twenty years, publishing extensively in these areas.

ELIZABETH ROWE is an Associate Professor of Law at the University of Florida, Levin College of Law. Professor Rowe's scholarship addresses trade secrets and workplace intellectual property disputes. Before entering academia she was a partner at the law firm of Hale and Dorr, LLP, in Boston, where she practiced complex commercial litigation, including intellectual property, employment, and securities litigation.

GREG VETTER is a Professor at the University of Houston Law Center and Co-Director of the Law Center's Institute for Intellectual Property and Information Law. He worked in software for nine years in both technical and business capacities before attending law school. In practice after law school, he obtained U.S. PTO registration as a patent attorney and joined the University of Houston Law Center faculty in 2002.

ZHENLIN WANG is an Assistant Professor in the Department of Early Childhood Education, Hong Kong Institute of Education. She received her Ph.D. in developmental and educational psychology from the Institute of Psychology, Chinese Academy of Sciences, in 2000 and is currently pursuing graduate study at the Graduate School of Education, University of Pennsylvania. Her primary research interests focus on children's cognitive development and early childhood teaching and learning.

KIM ZETTER is an independent, award-winning investigative journalist who until recently was a staff reporter for *Wired News*, covering privacy, security, and public policy. Her series on security problems with electronic voting machines won two awards and was a finalist for a national Investigative Reporters & Editors award—the highest journalism honor after the Pulitzer. Her work has also appeared in *Wired* magazine, *Salon*, the *Economist*, *PC World*, the *Los Angeles Times*, the *San Francisco Chronicle*, and other publications.

HARBORING DATA

Introduction

Andrea M. Matwyszyn

IN JULY 2005, a hacker sitting in the parking lot of a Marshalls store in Minnesota used a laptop and a telescope-shaped antenna to steal at least 45.7 million credit and debit card numbers from a TJX Companies Inc. database.¹ When the breach came to light in 2007, TJX Companies estimated that it would cost more than \$150 million to correct its security problems and settle with consumers affected by the breach.² In addition to TJX's direct losses from this incident, which are estimated to be between \$1.35 billion³ and \$4.5 billion,⁴ the company also faces losses from settlement payouts⁵ and, potentially, court-awarded damages.⁶

Perhaps the most troubling part of this information crime was its avoidability: TJX, a retailer worth approximately \$17.4 billion had simply neglected its information security and was using a form of encryption on its wireless network that was widely known for years to be obsolete.⁷ The network through which the hacker accessed the database had less security on it than many people have on their home wireless networks.⁸ In other words, TJX made itself an easy mark for hackers.

TJX is not alone in its information security mistakes. Reviewing newspaper headlines on any given day is likely to yield an article about a corporate data breach. Otherwise sophisticated business entities are regularly failing to secure key information assets. Although the details of particular incidents and the reasons behind them vary, a common theme emerges: corporations are struggling with incorporating information security practices into their operations.

This book explores some of the dynamics behind this corporate struggle with information security.

The Social Ecology of Corporate Information Security

The year 2007 was a record year for data compromise, and the trend continued upward in 2008. Estimates of the number of personally identifiable consumer records exposed run as high as 162 million for 2007 alone.⁹ For example, approximately one in seven adult Social Security numbers has already been compromised as a result of data breaches.¹⁰ Corporate data losses in particular are staggering: according to estimates, the value of each corporate record lost was approximately \$197 in 2007,¹¹ and consequently, in 2007 U.S. corporations may have lost as much as \$32 billion owing to information security breaches. Despite increasing media and consumer attention, corporate data leakage continues unabated. Why?

The reasons for the continuing escalation in data vulnerability are complex and include dynamics on three levels: the macro or societal level; the meso or group level; and the micro or individual level.

Macro Level—Networked Data, Information Crime, And Law

On the macro level, corporate hoarding of networked, aggregated consumer data, the expansion of information criminality, and the arrival of information security regulation have all affected the ecology of corporate information security.

Corporate Hoarding of Networked, Aggregated Consumer Data Over the past decade, the internet became a regular part of consumer economic behaviors, and a new economic environment emerged. A defining characteristic of this new commercial environment is widespread corporate collection, aggregation, and leveraging of personally identifiable consumer data. Consumers increasingly venture online to engage in information-sensitive activities, such as checking bank balances or transmitting credit card information in connection with purchases,¹² and for many consumers the purchasing of goods through the internet is a routine part of life.¹³ In the course of engaging in this routine, they leave a trail of information behind them.

Corporate entities began to see commercial opportunities in the wealth of readily available, personally identifiable data. Companies began to hoard data; they started to collect as much information as possible about their customers in order to target products more effectively and to generate secondary streams of revenue by licensing their databases of consumer information.¹⁴ Because

the internet allows large amounts of data to be exchanged by remote parties, internet data brokers emerged and further invigorated the market for collecting and reselling consumer data. They began to place a premium on consumer information databases and to change the way consumer data were valued in corporate acquisitions.¹⁵

In the broader business context, the business environment in our society has been dramatically altered by the integration of information technology into corporate governance and operations over the last two decades.¹⁶ Businesses have become progressively more technology-centric and, consequently, organized in large part around their unifying computer systems. Centralization arose because businesses sought to solve communication problems between parts of the company, and for many, overcoming these communication obstacles across machines became a corporate priority.¹⁷ The goal was to allow all parts of the organization to effectively interact with each other and communicate internal data.¹⁸ Business communications progressively shifted from real space to virtual space,¹⁹ and entirely new technology-contingent information businesses have arisen, such as eBay and Google.²⁰ Even the most traditional of companies began to experiment with internet sales through company websites. Increasing computerization and automation of businesses generated enterprise-wide computing and management ripe for data hoarding and leveraging.

Progressively, these new databases of both corporate proprietary information and personally identifiable consumer information became networked with each other and the outside world.²¹ Because these internet-mediated databases frequently operated in the context of a highly centralized corporate technology environment, a large “attack surface” for information theft was created. Pre-existing centralization of computer systems made attacks on key targets easier: access into the system at any one of multiple points gives an attacker an avenue to compromise the targeted databases. In other words, the ease of sharing databases inadvertently resulted in the ease of attacking them.

Expansion in Information Crime These trends of corporate data hoarding and centralization did not go unnoticed by information criminals. As corporate databases of personally identifiable information became larger, they became progressively more useful for identity theft and extortion operations. The more sensitive the information contained in corporate databases, the more attractive the target.²²

Information thievery is highly lucrative.²³ By some estimates, the information crime economy is as lucrative as the drug economy for its participants, or

even more so.²⁴ In particular, the involvement of organized crime in identity theft has brought an additional level of professionalization to these criminal enterprises. Information criminals are frequently highly technologically proficient and in some cases represent the “bleeding edge” of technology research and development. Although they innovate in a socially detrimental manner, they are unquestionably entrepreneurial;²⁵ information criminals adjust their behavior over time in response to industry anti-crime efforts. The competition between information criminals and information security professional is an arms race of sorts.

According to the Federal Trade Commission (FTC), the total economic costs of reported incidents of identity theft amount to approximately \$50 billion per year to consumers and corporations.²⁶ As this statistic implies, information crime does not affect only consumers; it affects businesses as well. Information criminals harm business entities in the process of victimizing consumers. For example, “phishing” fraud losses alone measured between \$500 million and \$2.4 billion annually in the early 2000s.²⁷ Phishing presents a severe threat to corporate goodwill as well as to information security. The goal of phishing is to leverage the goodwill of a trusted services provider,²⁸ and through an email trick consumers into revealing personal financial information, usernames, passwords, Social Security numbers and the like.²⁹ Phishing attacks frequently include registered domain names that appear to be associated with the targeted company and otherwise infringe on the intellectual property of the targeted company. During a phishing attack, an assailant simultaneously victimizes both entities and their consumers with “spoofing”³⁰ emails to deceive recipients into believing that the email originated from a credible source with which the consumer may possess a trusted commercial relationship, such as a financial services provider.³¹ In some instances, information criminals will pretend to act on behalf of a company and use information stolen from that company to send out more effective phishing attacks directly to consumers.³² Because the consumer has a preexisting relationship with the company, the consumer is likely to be more easily victimized by this type of falsified communication. Similarly, legitimate email communications from business entities may be ignored by cautious consumers who mistake a legitimate communication for a phishing attack.³³ Consumers victimized by phishing attacks are frequently aware that the company whose email is spoofed is not directly responsible for the phishing attack. Nevertheless, such consumers may develop a negative view of the company, particularly if the victimized company does not aggressively and publicly pursue the attacker.

For example, Monster.com was recently compromised by hackers using stolen credentials to harvest data from the Monster job-seeker database. The harvested data were then used, among other things, for sending targeted messages to job seekers purported to be from Monster.com. These messages contained a malicious attachment,³⁴ a Trojan called Infostealer.Monstres, which uploaded more than 1.6 million pieces of personal data belonging to several hundred thousand people to a remote server.³⁵ The likely goal behind this attack on Monster.com was to facilitate the criminals' subsequent phishing attacks on consumers. The criminals obtained information from Monster.com that was potentially directly useful for identity theft. But it was also useful for sending phishing emails that appeared to be highly credible and from an allegedly trusted source—Monster.com. As such, the information criminals not only compromised Monster.com's databases, but also leveraged Monster's name in their criminal phishing enterprise in order to compromise users' machines.

The criminals who illegally accessed Monster's records sought to compromise as many job seekers' machines as possible not only for identity theft purposes but also for zombie drones.³⁶ The end-product of these types of phishing attacks is frequently the creation of zombie drone armies or botnets³⁷—coordinated groups of security-compromised consumer and corporate machines remotely controlled by criminals. Approximately 250,000 new zombies are identified per day³⁸ with approximately 100 million total zombies currently in operation, by some expert estimates.³⁹ Botnets are a significant threat to corporations. Organized crime syndicates have begun launching extortion rackets against businesses, threatening them with attacks from zombie drones in botnets.⁴⁰ Depending on the size of the army of zombie drones, such an attack could cripple a business, disrupting operations for an extended period of time. The attack may target a company directly, or the attacker may disrupt the infrastructure upon which the company relies. For example, according to the CIA, power outages in multiple cities have been traced to these types of cyberattacks.⁴¹ As such, national security interests are also clearly implicated.

Rise of Information Security Regulation Legally speaking, the field of information security regulation is in its infancy; it is a little over a decade old. In 1996, three years after the Mosaic browser was launched,⁴² questions of data security and privacy began to gain momentum within the United States, partially as a result of international influences. In 1995 the European Union passed the EU "Data Directive."⁴³ The Data Directive took effect in November 1998,⁴⁴ and multinational business interests in the United States were concerned; they were

beginning to increase investment in internet operations, and many had already established websites.⁴⁵ The Data Directive contains provisions that prohibit transfer of the data of any European person outside the European Union without consent, and they require contractual imposition of a minimum level of care in handling on any third parties receiving the data.⁴⁶ However, despite the EU's aggressive stance toward data protection,⁴⁷ the United States did not have any consumer information security legislation⁴⁸ in effect until April 2000.⁴⁹

At this writing in early 2009, the information security legal regime adopted in the United States is a patchwork of state and federal laws. On the federal level, health data, financial data, and children's data are statutorily regulated, through the Health Insurance Portability and Accountability Act,⁵⁰ the Gramm-Leach-Bliley Act,⁵¹ and the Children's Online Privacy Protection Act,⁵² respectively. In addition to enforcing these statutory regimes, the Federal Trade Commission has instituted a number of prosecutions for inadequate security practices under unfair trade practices regulation.⁵³ On the state level, state data breach notification laws have been passed in over 80 percent of states since 2003.⁵⁴

However, much of information crime involves data not necessarily deemed particularly "sensitive" by federal statutes at present, and many entities that aggregate large amounts of information do not fall into any of the legal categories of restricted data set forth in the previous section. Therefore, not all business entities are currently proactively regulated by information security statutes. At most, state data breach notification statutes impose on them a duty to disclose the existence of a breach. Specifically, the biggest economic losses are not the result of illegal leveraging of the statutorily protected categories of data; rather, losses result from stolen personally identifiable information, such as Social Security numbers and credit card information, as was the case in the TJX breach.

Meso—Transitive Information Risks of Data and Reputation

On the mesosystem/interpersonal level, information vulnerability erodes commercial trust and imposes costs on third parties. Part of the reason for this erosion and cost transference arises from the nature of information risk. The impact of information risk is inherently transitive: a fundamental tenet of security is that a system is only as strong as its weakest links, not its strongest points.⁵⁵ This transitivity means that risk follows the information itself, and the security of the whole system depends on the lowest common denominator—the security of the least secure trusted party. Therefore, a company's information security is only as good as the information security of its least

secure business partner. If a company shares sensitive corporate information with a business partner and that partner experiences a data leak, the negative effects to the shared data are similar to those that would have occurred if the first company had been breached itself. Stated another way, each time a company shares data, it acquires dependency on another company. Companies suffer economic harms and reputational damage as a consequence of both their own suboptimal security practices and their business partners' inadequate security practices.⁵⁶

For example, in the TJX breach detailed at the beginning of this chapter, TJX, the company that suffered the breach, was not the only affected business entity. Banks that had issued the compromised credit card numbers had to reissue those cards and blamed TJX for the cost of doing so. Not surprisingly, TJX found itself a defendant in several class-action suits as a consequence of its data breach. Litigants pursuing TJX for damages included not only consumers, but also a group of banking associations from Massachusetts, Connecticut, and Maine that included over 300 banks whose customers were implicated in the breach. In April 2007, these associations sued TJX, seeking to recover the “dramatic costs” that they absorbed to protect their cardholders from identity theft risks resulting from the TJX breach.⁵⁷ The banks argued that as corporate data breaches such as the TJX breach become more frequent and larger in scale, banks cannot continue to absorb the downstream costs of other companies' information security mistakes.⁵⁸ As the TJX suits demonstrate, data breaches never occur in a corporate vacuum.

Micro—Recognizing Internal Corporate Deficits

Individual companies frequently ignore information security or believe the return on investment in information security to be inadequate. These suboptimal approaches result from, first, a failure to recognize the losses caused by weak information security, and second, an absence of thorough risk management planning.

Recognizing Asset Value Diminution and Resource Usurpation as a Consequence of Security Breaches Many companies do not yet recognize that security breaches cause losses: they diminish the value of corporate assets and usurp resources. Confidentiality, integrity, and the availability of corporate assets are all negatively affected by corporate information vulnerability and information crime. In fact, certain corporate assets, such as databases of customer information and preferences, are valuable only because they are confidential.⁵⁹ Similarly,

corporate proprietary information protected solely by trade secret law could, in effect, lose all of its value in an information crime incident because the information's status as a trade secret is entirely contingent on its confidentiality.⁶⁰ Ignoring information security can quickly become more expensive than investing in it. One data breach can greatly diminish the value of such an intangible asset.⁶¹ For example, the damage that a corporate insider can generate in one episode of information theft has been, in at least one instance, approximated to be between \$50 million and \$100 million.⁶²

Suboptimal security also jeopardizes the integrity of corporate systems. By some estimates, corporations sustained more than \$1.5 trillion in losses in 2000 owing to security breaches, such as computer viruses.⁶³ In 2007 the average cost of a data breach rose to \$6.3 million from \$4.8 million in 2006.⁶⁴ Corporate integrity is further affected by a parallel diminution in brand value and corporate goodwill. A company considered to be vulnerable usually suffers bad press and a corresponding decrease in the value of its investments in brand identity building. A brand can become damaged in the minds of business partners and consumers if it is associated with lax information security.⁶⁵ Finally, some integrity losses are related to opportunity costs. Occasionally, certain types of vulnerabilities, such as name-your-own-price vulnerabilities, deprive a company of revenue it would otherwise have received.⁶⁶

The availability of other corporate assets also becomes limited when security issues arise. During an attempt to compromise a company's network, a remote attacker may usurp technological resources such as bandwidth and employee time. Employee time devoted to responding to an incident does not diminish or end when the attack ends; numerous hours are subsequently logged performing forensic examinations, writing incident reports, and fulfilling other recordkeeping obligations. Finally, if a security incident results in a violation of consumer data privacy, the availability of capital is further diminished by expenses for fines, court costs, attorneys' fees, settlement costs, the bureaucratic costs of setting up compliance mechanisms required by consent decrees, settlement agreements, and court decisions.

Changing Risk Management Planning For many companies struggling to implement information security throughout their organizations, building security into a legacy environment unfamiliar with information security principles is a challenge. Frequently, proponents of stronger security face internal corporate resistance to setting new security-related corporate priorities and investment levels.⁶⁷ In part because of such tensions in risk management

planning, certain types of information security mistakes recur. The five most common information security errors visible today in corporate information security risk management include a lack of planning, nonresponsiveness to external reports of breaches, letting criminals in, theft by rogue employees, and a failure to update existing security.

Lack of Planning For the reasons elaborated in the preceding pages, there is a lack of adequate information security risk management in business worldwide. According to the fifth annual Global State of Information Security Survey conducted in 2007, a worldwide study by *CIO* magazine, *CSO* magazine, and PricewaterhouseCoopers of 7,200 information technology (IT), security, and business executives in more than 119 countries in all industries, companies are slow to make improvements in corporate information security.⁶⁸ Perhaps the most disturbing finding of the study was that only 33 percent of the responding executives stated that their companies keep an accurate inventory of user data or the locations and jurisdictions where data is stored, and only 24 percent keep an inventory of all third parties using their customer data.⁶⁹ Although data breaches are driving privacy concerns, encryption of data at rest, for example, remains a low priority despite its being the source of many data leakage issues.⁷⁰ Only 60 percent of the organizations surveyed have a chief security officer or chief information security officer in place. Similarly, 36 percent stated that their organizations do not audit or monitor user compliance with security policies, and only 48 percent measured and reviewed the effectiveness of security policies annually.⁷¹ Most companies responding to the study also indicated that their organizations do not document enforcement procedures in their information security policies, and only 28 percent of policies include collection of security metrics.⁷²

Ignoring External Reports One of the most easily avoidable information security mistakes is not taking external reports of problems seriously. Companies, and individual employees within companies, sometimes believe that quashing an external report of a vulnerability or breach will make the problem go away. For example, in November 2002, a security hole in the Victoria's Secret website allowed a customer to access over 500 customers' names, addresses, and orders. The customer who discovered the hole contacted Victoria's Secret directly and advised Victoria's Secret of the problem. Despite promises of data security in their website privacy policy, Victoria's Secret employees informed the customer that nothing could be done. In anger, he contacted the press and the New York

State attorney general. Victoria's Secret was subsequently prosecuted by the New York State attorney general and ultimately entered into a settlement that included a \$50,000 penalty.⁷³

Letting Criminals In Sometimes companies let hackers into their own databases because of inadequate monitoring practices. For instance, in February 2005, ChoicePoint, Inc., a data aggregator, revealed that it had sold data about more than 145,000 consumers to information criminals. According to the FTC complaint that resulted from this breach, ChoicePoint had prior knowledge of the inadequacy of its customer screening process and ignored law enforcement warnings of fraudulent activity in 2001. It willingly sold data to companies without a legitimate business need for consumer information, even in circumstances where these purchasers looked suspicious. According to the Federal Trade Commission at least 800 consumers became victims of identity theft as a result of this breach. Ultimately, ChoicePoint entered into a settlement agreement with the FTC, agreeing to pay a fine of \$15 million.⁷⁴

Theft by Rogue Employees Companies frequently forget about internal threats to their security. The greatest threats to corporate intangible assets frequently arise from rogue employees. Limiting access by employees to sensitive information on a "least privilege" / need-to-know basis can be a critical step in avoiding information theft. For example, on June 23, 2004, a former AOL employee was charged with stealing the provider's entire subscriber list of 37 million consumers (over 90 million screen names, credit card information, telephone numbers, and zip codes) and selling it to a spammer who leveraged and resold the information.⁷⁵ The software engineer who stole the data did not have immediate access to the information himself, but he was able to obtain it by impersonating another employee. Although the initial sale price of the list on the black market is unknown, the spammer paid \$100,000 for a second sale of updated information with 18 million additional screen names. The list was then resold to a second spammer for \$32,000 and leveraged by the first spammer in his internet gambling business and mass-marketing emails to AOL members about herbal penile enlargement pills.⁷⁶

Failure to Update Existing Security Revisiting the TJX data breach once more, the importance of viewing security as an ongoing process becomes apparent. Security cannot be viewed as an off-the-shelf product; vigilance and constant updating of security measures are mandatory. The encryption protocol that TJX used, WEP, was widely known to be broken for four years before the TJX

breach.⁷⁷ It was common knowledge in the information security community at the time of the breach that WEP could be easily compromised in one minute by a skilled attacker.⁷⁸ Companies must constantly reevaluate their information security measures in order to respond to changing criminal knowledge.

The Future of Corporate Information Security Policy

In the chapters that follow, this book engages in a bottom-up, multidisciplinary analysis of some of the changing corporate information security dynamics introduced to this point. As the previous sections have made clear, an analysis of corporate information security policy requires adopting an evolutionary approach that recognizes the emergent nature of information threats.

Chapter 1, “Computer Science as a Social Science: Applications to Computer Security,” argues the importance of adopting this multidisciplinary lens in analyzing information security. Jon Pincus, Sarah Blankinship, and Thomas Ostwald write that developing the best information security practices requires broadening the scope of our current perspectives on information security: “Computer security has historically been regarded primarily as a technical problem: if systems are correctly architected, designed, and implemented—and rely on provably strong foundations such as cryptography—they will be ‘secure’ in the face of various attackers. In this view, today’s endemic security problems can be reduced to limitations in the underlying theory and failures of those who construct and use computer systems to choose appropriate methods.” Although computer science is not traditionally viewed as a social science, problems in its domain are inherently social in nature, relating to people and their interactions. Pincus, Blankinship, and Ostwald argue that applying social science perspectives to the field of computer security not only helps explain current limitations and highlights emerging trends, but also points the way toward a radical rethinking of how to make progress on this vital issue.

Chapters 2 and 3 present two perspectives on the public-facing aspects of corporate information security. Chapter 2, “Compromising Positions: Organizational and Hacker Responsibility for Exposed Digital Records,” by Kris Erickson and Philip Howard, sets forth an analysis of the empirical extent of known corporate information security compromise. Erickson and Howard analyze over 200 incidents of compromised data between 1995 and 2007. They find that more than 1.75 billion records have been exposed, either through hacker intrusions or poor corporate management, and that in the United States there have

been eight records compromised for every adult. They conclude that businesses were the primary sources of these incidents.

In Chapter 3, “A Reporter’s View: Corporate Information Security and the Impact of Data Breach Notification Laws,” Kim Zetter presents an insider’s view of how information about corporate information security breaches reaches the public. She says that “[d]espite the passage of state-level data security breach notification legislation in many states, journalists still often have to rely on sources other than the companies and organizations that experience a breach for information about a breach—either because the breach is not considered newsworthy or because the data that are stolen do not fall into the category of data covered by notification laws.” Journalists learn about breaches from a number of sources. Rarely, though, are companies or organizations that experienced the breach the first to reveal it. Zetter describes some of the practical limitations of data breach notification laws with regard to public disclosure of corporate security breaches. She says that companies fear that disclosing such information would place them at a disadvantage with competitors and make them vulnerable to lawsuits from customers as well as to other potential intruders.

In contrast to Chapters 2 and 3, Chapters 4 and 5 present two sets of internal corporate information security concerns relating to protecting intellectual property assets. In Chapter 4, “Embedding Thickets in Information Security? Cryptography Patenting and Strategic Implications for Information Technology,” Greg Vetter discusses the strategic concerns companies face in deciding whether to patent information security methods. Vetter argues that the full promise of cryptography for information security is unrealized. Companies are increasingly patenting security technologies in an effort to expand their portfolios and better protect corporate intangible assets. Cryptographic methods can enable authentication in an electronic environment and help secure information storage, communications, and transactions. Patenting in the field has expanded aggressively, and greater patent density, sometimes described as a “thicket,” affects both developers and users and brings with it the potential to chill innovation. This greater patent density, argues Vetter, suggests the need for countermeasures such as patent pooling, patent-aware standard setting by firms and the government, and portfolio management of patents.

Chapter 5, “Dangers from the Inside: Employees as Threats to Trade Secrets,” by Elizabeth Rowe, discusses the risks that rogue insiders present to corporate information security, particularly with regard to trade secrets. Says

Rowe, “The loss of a trade secret is particularly devastating to a company because a trade secret once lost is lost forever. The widespread availability and use of computers, together with an overall decline in employee loyalty, provides fertile ground for the dissemination of trade secrets.” Rowe argues that the biggest computer security threats and accompanying threats to a company’s trade secrets originate with the company’s own employees. Put in criminal law terms, employees often have the motive and the opportunity that outsiders lack. Employees usually have legal access to the trade secret information by virtue of their employment relationship and can use that access to misappropriate trade secrets. “Examples abound of employees who have either stolen trade secrets for their own or a new employer’s benefit, or have destroyed them completely by disclosing them over the internet. Recent statistics indicate that the large majority of computer crimes are committed by employees.” Rowe provides background on trade secret law, presents examples of disclosures that have occurred using computers, and ends with some lessons for trade secret owners.

Chapters 6, 7, and 8 consider information security in connection with the three categories of statutorily protected data: health data, financial data, and children’s data. Chapter 6, “Electronic Health Information Security and Privacy,” by Sharona Hoffman and Andy Podgurski, addresses the regulatory, policy, and social impacts of electronic health data security vulnerabilities and the mechanisms that have been implemented to address them. The electronic processing of health information provides considerable benefits to patients and health care providers, but at the same time, argue Hoffman and Podgurski, it creates material risks to the confidentiality, integrity, and availability of the information. The internet creates a means for rapid dispersion and trafficking of illegally obtained private health information. The authors describe the wide-ranging threats to health information security and the harms that security breaches can produce: “Some of the threats are internal, such as irresponsible or malicious employees, while other threats are external, such as hackers and data miners. The harms associated with improper disclosure of private medical data can include medical identity theft, blackmail, public humiliation, medical mistakes, discrimination, and loss of financial, employment, and other opportunities.” In order to address security risks related to electronic health data, the U.S. Department of Health and Human Services enacted the Health Insurance Portability and Accountability Act (HIPAA) Security Rule, part of the more general HIPAA Privacy Rule. The Security Rule requires the implementation of administrative,

physical, and technical safeguards for the storage and transmission of electronic health information. Hoffman and Podgurski present a critique of the Security Rule from both legal and technical perspectives. They argue that the rule suffers from several defects, including its narrow definition of “covered entities,” the limited scope of information it allows data subjects to obtain about their health information, vague and incomplete standards and implementation specifications, and lack of a private cause of action. They offer detailed recommendations for improving safeguards for electronically processed health records.

Chapter 7, “Quasi Secrets: The Nature of Financial information and Its Implications for Data Security,” by Cem Paya, presents a technical critique challenging the most basic premises underlying the Gramm-Leach-Bliley Act—that “financial data” refers to data held by financial institutions. Instead, Paya argues that a better analysis starts with looking to the data, not the holder. He points out that financial information appears to be the type of data most frequently targeted by malicious actors. After providing a primer on the basics of information security engineering, he asks whether there is something inherent in the nature of financial information that makes it a challenge for information security and any regulatory framework. Analyzing the two most common forms of financial information—credit card numbers and Social Security numbers—Paya concludes that although the credit card industry appears to successfully mitigate risks of disclosure, the use of Social Security numbers as a financial identifier is inherently problematic and should be eliminated.

In Chapter 8, “From ‘Ego’ to ‘Social Comparison’—Cultural Transmission and Child Data Protection Policies and Laws in a Digital Age,” Diana Slaughter-Defoe and Zhenlin Wang discuss the evolution of child protection and information security online. In the past quarter-century, child development scholars have embraced ecological paradigms that expand the identified cultural transmitters beyond parents to include the broader cultural context. All forms of mass media, including the internet, form part of children’s cultural context. The Children’s Online Privacy Protection Act and other internet child protection legislation were enacted in order to create a safe internet space in which children can interact with commercial enterprises and other users. Defoe and Wang believe that current laws addressing internet child protection are ineffective. They assert that “future legislation should take into account children’s developmental attributes” and emphasize empowering parents in guiding their children’s development and securing their children’s information.

Chapters 9 and 10 present international perspectives on two challenges to the evolution of information security best business practices: changing contract norms and new business models. In Chapter 9, “Contracting Insecurity: Software Terms That Undermine Information Security,” Jennifer Chandler argues that contract law provides one of the most effective means by which companies can impose obligations of data security on others. However, contract law can simultaneously provide a means for companies to shirk their information security obligations. This chapter highlights a selection of terms and practices that arguably undermine information security. One series of clauses undermines information security by suppressing public knowledge about software security vulnerabilities. Such clauses frequently prevent research by barring reverse-engineering clauses or anti-benchmarking clauses and suppressing the public disclosure of information about security flaws. Other practices that undermine information security according to Chandler are those where “consent” to the practices is obtained through the license and the software is difficult to uninstall, abuses the software update system for non-security-related purposes, or obtains user consent for practices that expose third parties to possible harm.

In Chapter 10, “Data Control and Social Networking: Irreconcilable Ideas?,” Lilian Edwards and Ian Brown present the challenges to information security from social networking websites and the new business models they represent. The success of this new generation of data-intensive virtual-space enterprises raises heightened concerns about information security. It is already known that identity thieves are making extensive use of personal information disclosed in such virtual spaces to commit fraud, while unaccredited writers of subapplications for these spaces can also gain access and evade security around vast amounts of valuable data. Edwards and Brown argue that although the law may provide some data control protections, aspects of the code itself provide equally important means of achieving a delicate balance between users’ expectations of data security and privacy and their desire to share information.

Finally, the Conclusion reiterates the four major themes of the preceding chapters—first, a need to focus on the human elements in information security; second, a need to recognize the emergent nature of information security threats; third, a need to consider the multiple simultaneous contexts of information risk; and, fourth, a need for immediate improvements in corporate self-governance. In the short term, companies must put in place rigorous codes of

information security conduct and exercise vigilant enforcement. In the long term, companies must learn to build cultures of information security and develop a sense of collective corporate responsibility for information security, regardless of whether regulation requires them to do so. Meaningful improvements in information security require a commitment to security as an ongoing, collaborative process.

1 Looking at Information Security Through an Interdisciplinary Lens

Computer Science as a Social Science: Applications to Computer Security

Jonathan Pincus, Sarah Blankinship,
and Tomasz Ostwald

Computer scientists have historically identified either as mathematicians (ah, the purity) or physicists (pretty good purity and much better government funding) . . . my response to yet another outbreak of the “math vs. physics” debate was “we don’t want to admit it, but we should really be debating whether we’re more like sociologists or economists.”

Jonathan Pincus, Computer Science Is Really a Social Science

ALTHOUGH COMPUTER SCIENCE is not traditionally viewed as a social science, problems in its domain are inherently social in nature, relating to people, their interactions, and the relationships between them and their organizational contexts. Applying social science perspectives to the field of computer science not only helps explain current limitations and highlight emerging trends, but also points the way toward a radical rethinking of how to make progress on information security. The social aspects of computing are becoming particularly visible in the discipline of computer security.

Computer security has historically been regarded primarily as a technical problem: if systems are correctly architected, designed, and implemented—and rely on provably strong foundations such as cryptography—they will be “secure” in the face of various attackers. In this view, today’s endemic security problems can be reduced to limitations in the underlying theory and to failures of those who construct and use computer systems to choose (or follow) appropriate methods. The deluge of patches,¹ viruses,² trojans,³ rootkits,⁴ spyware,⁵

spam,⁶ and phishing⁷ that computer users today have to deal with—as well as societal issues such as identity theft, online espionage, and potential threats to national security such as cyberterrorism and cyberwar—illustrate the limitations of this approach.

In response, the focus of much computer security research and practice has shifted to include steadily more aspects of economics, education, psychology, and risk analysis—areas that are traditionally classified as social sciences. The relatively recent definition of the field of “security engineering”⁸ explicitly includes fields such as psychology and economics. “Usable security” includes perspectives such as design, human-computer interaction, and usability. The commonality here is a view that computer security today can be better addressed by defining the field more broadly.

The early work to date, however, only scratches the surface of these disciplines—or the greater potential for a redefinition of computer security. Anthropology, cultural studies, political science, history of technology and science, journalism, law, and many other disciplines and subdisciplines all provide important perspectives on the problems, and in many cases have useful techniques to contribute as well. Continued progress on computer security is likely to require all of these perspectives, as well as traditional computer science.

Social Science Perspectives on Computer Security

There are many different definitions for computer science. Wikipedia, for example, defines it as “the study of the theoretical foundations of information and computation and their implementation and application in computer systems,”⁹ but devotes a parallel page on “Diversity of computer science” to alternative definitions.¹⁰ For the purposes of this paper, we will use Peter Denning’s definition from the *Encyclopedia of Computer Science*.

The computing profession is the people and institutions that have been created to take care of other people’s concerns in information processing and coordination through worldwide communication systems. The profession contains various specialties such as computer science, computer engineering, software engineering, information systems, domain-specific applications, and computer systems. The discipline of computer science is the body of knowledge and practices used by computing professionals in their work.¹¹

Denning’s definition is broader than most, but most accurately captures the role that “computing” fills in the world of the twenty-first century. The list of

subdisciplines associated with computer science gives a very different picture. The *Encyclopedia of Computer Science*, for example, groups its articles into nine main themes: Hardware, Software, Computer Systems, Information and Data, Mathematics of Computing, Theory of Computation, Methodologies, Applications, and Computing Milieux.¹² Where are the people?

The social sciences, conversely, are fundamentally about the people; viewing computer science as a social science thus fills this huge gap in the discipline of computer science. A billion people use computers directly; even more interact with banking, credit cards, telephones, and the computer-based systems used by government, hospitals, and businesses. It is not just that computer systems today are invariably used in a human, organizational, and societal context; it is that, increasingly, the human context dominates. In 2005, Pincus called out “network and software security” as one of the areas in computer science where social science perspectives have a major foothold:

In the security space, the now-obvious economic aspects of the problem, “social engineering” attacks, and what is often mistakenly referred to as “the stupid user problem” make it hard to avoid. Many people point to the relatively new field of “usable security” (starting with Alma Whiten’s seminal “Why Johnny Can’t Encrypt”) as another example of considering broader perspectives. Work by people like Ross Anderson at Cambridge, Hal Varian at UC Berkeley, Shawn Butler at CMU, and Eric Rescorla at RTFM starts from an economic perspective and asks some very interesting questions here; it seems to me that traditional computer science techniques aren’t really able to address these problems. There are now workshops devoted to Economics and Information Security.¹³

Second, social sciences, like security threats, are by their nature evolutionary, while hard sciences are less so. Studying human norms of behavior and interaction trains sensitivity toward the types of evolutionary situations that pervade information security. As software security evolves, for example, so does the nature of threats. The focus of attackers moves away from the core operating system toward other, less-secure components such as third-party drivers,¹⁴ proprietary applications deployed on closed networks, user applications, and finally users themselves. Attackers use constantly evolving methods for tricking users and refine these methods based on knowledge gained from failed attacks.¹⁵

Indeed, perspectives from diverse social science disciplines are relevant to the field of computer security and are beginning to yield important insights. For example, in economics,¹⁶ the costs and benefits of various information

security responses are weighed in terms of both microeconomic and macroeconomic efficiency outcomes.¹⁷ Game theorists model security to gain insight into optimal strategies, frequently modeling security as a two-player game between an attacker and a network administrator.¹⁸ In psychology, computer criminal behavior is being studied empirically,¹⁹ as well as the psychological reactions to threats and countermeasures.²⁰ Ethnographers are studying information technology professionals' responses to security incidents using traditional ethnographic techniques,²¹ as well as examining the culture of security researchers.²² Design increasingly affects the usability of privacy and security features.²³ Epidemiology provides useful frameworks for examining the spread of computer viruses²⁴ and malware.²⁵ Sociologists and anthropologists examine aspects of hacker culture(s)²⁶ and observe the different choices of mainstream and marginalized teens in panoptic social networks.²⁷ International relations theorists are considering issues of cyberwar,²⁸ including concerted attacks on an entire country's infrastructure.²⁹ The discipline of science and technology studies is debating the evolution of information security as a field. Finally, the legal academy is engaged in active debate over legislation requiring disclosure of security incidents³⁰ and legal remedies against spammers,³¹ for example. The movement toward an interdisciplinary lens in the discipline of information security is beginning to take hold.

Three Information Security Topics for Further Interdisciplinary Study

Three information security topics in particular are ripe for further interdisciplinary study—user error, measurement, and vulnerability disclosure.

User Error—and Human Error

User errors cause or contribute to most computer security failures.³²

People are an integral part of all computer-related social systems, and so issues related to fallibility or “human error” are an integral part of system engineering. The security of systems depends on user decisions, actions, and reactions to events in the system. Actions or decisions by a user that result in an unintended decrease in a system's security level are typically classified as “user error.” Focusing on this term ignores the role of the rest of the system in causing user confusion. User errors frequently have more to do with the system's failure to reduce the likelihood of mistakes by users—or failure to limit the damage from these mistakes.

Consider the case in which a system is broken into because the administrator set up an account with a password that was guessed via a “dictionary attack.”³³ While the natural initial response is to blame the administrator’s “user error” for the vulnerability, there are other questions worth asking as well, for example:

Why did the system fail to check proposed passwords and reject those that were likely to be vulnerable to such an attack?

Why did the system allow multiple repeated failed attempts to log in (a necessary requirement for dictionary attacks)?

Why is the system’s security compromised by the guessing of a single password?

The social science aspects of this problem have long been recognized; Jerome Saltzer and Michael Schroeder specifically refer to user psychology in two of their ten *Principles*—“fail-safe defaults” and “psychological acceptability.”³⁴ Until relatively recently, however, these user-related issues were treated as separate from the “hard” aspects of computer security such as cryptography and secure system architecture. Alma Whitten and J. D. Tygar’s 1999 paper “Why Johnny Can’t Encrypt” examined students’ failed efforts to encrypt their email using PGP, and is generally regarded as a catalyst to the relatively new subfield of “Usable Security.”³⁵ “Usable security” has had a significant impact, and the papers from many workshops and publications show how pervasively social science perspectives currently inform this aspect of computer security.³⁶ However, little, if any, work has focused on the more general issues around “user error.”

Meanwhile, the changing domains of computer security only serve to highlight the need for more work adopting the user perspective. Given richer user interfaces and interactions, we expect to see attacks aimed at affecting users’ perceptual and cognitive capabilities.³⁷ These are practical problems that cannot be solved by technologies and methodologies that are known today. For example, phishing has become a common and very real threat,³⁸ but the effectiveness of currently available technical mitigations is still very limited.³⁹ In particular, the rise of social networking applications helps not only users but also attackers understand where trust relationships exist within social networks and between individuals. Attacker awareness of trust relationships may allow attacks to become very precise and effective, even when conducted in a highly automated way, such as in context-aware phishing.⁴⁰

Several ideas from the philosophy of technology and science help explain the lack of earlier and faster progress on this important issue, as well as pointing

to possible remaining obstacles. For example, standpoint theories suggest that it is the exclusion of the user from the software design process that leads to the failure of the system to meet the user's needs.⁴¹ Similarly, it is the marginalization of the user in the evaluation and analysis process that leads to the "blame" of user error. Combining these concepts with the perspective of user-centered design may respond to Whitten and Tygar's insight that security requires different design methodologies than those currently in use.⁴²

Other avenues point to additional possibilities. "Human error" has been studied for years in fields such as safety engineering and patient safety, and starting in the 1980s researchers began taking new perspectives,⁴³ arguing, for example, that the right approach was to take a more general view of human *action*,⁴⁴ including the role of users in compensating for weaknesses in the system caused by failures of the system designers.⁴⁵ This work has strongly influenced the relatively new field of "resilience engineering." This field's paradigm for safety management focusing on helping people cope with complexity under pressure to achieve success "strongly contrasts with what is typical today, a paradigm of tabulating error as if it were a thing, followed by interventions to reduce this count."⁴⁶

Finally, from a different perspective, "human errors" also occur in the creation of software systems. A software security vulnerability results from one or more human errors made during the software development process, introduced at different phases of the development by different actors, inaccurate management decisions, flawed design, and coding bugs.⁴⁷ One or more human errors typically also contribute to situations where the vulnerability was not identified and removed before the software shipped—for example, insufficient testing or incomplete communication with end users.

Measurement

Although essential, empirical validation of design methods is not easy . . . I seek help in the research methods of social scientists, organizational behaviorists, and design researchers and I believe that their research methods will improve the empirical validation techniques of other software engineer researchers.

Shawn Butler⁴⁸

Today, it is not, in general, possible to give a good absolute answer to the question "how secure is a computer-based system?" This unfortunate situation has been the case for several decades.⁴⁹ Safes, which provide physical security, are

rated according to how long they can resist an attacker with specific tools—for example, a TRTL-30x6 safe can resist an attacker with torches (TR) and tools (TL) for 30 minutes.⁵⁰ The ideal of providing similar ratings for computer software is far from reality—and many argue that an attempt to pursue this would be seriously misguided.⁵¹ A few small aspects of a security such as strength of cryptographic implementations can currently be analyzed this precisely; in practice, however, attackers focus on the weakest links in a system's security, so these do not typically add up to any indication of overall system security.

Recently, attention has turned to more specific questions such as “which of these two different software packages providing roughly equivalent functionality is more secure in a given context of use?” and “how much more secure will a given change make a system?” It has been surprisingly difficult to make progress on even these more pointed questions, but some new promising techniques are starting to emerge, and most of them spring, explicitly or implicitly, from a social science perspective.

Shawn Butler's ongoing work has developed two such approaches. Multi-attribute risk assessment uses techniques from decision sciences to provide a framework for developing assessments that can be used to prioritize security requirements.⁵² In addition to incorporating uncertainty and sensitivity analyses, this approach explicitly takes into account the multiple (and potentially conflicting) objectives of providing security for a computer-based system. SAEM (security attribute evaluation method) takes a similar multiple-attribute approach to cost-benefit analyses of alternative security designs.⁵³ Paul Li has also applied actuarial techniques from the insurance industry to topics such as defect prediction.⁵⁴

Several interesting measurements focus on questions related to security patches. The time between when a vulnerability is first broadly known and when a patch is issued and installed on a system is the period during which systems are at the highest risk of attack from the broadest variety of people. The “days of risk” measurement looks at this time between public disclosure of a vulnerability and when the patch is issued;⁵⁵ while there is substantial controversy over whether the specifics of how this measurement is calculated inherently penalize open-source methodologies,⁵⁶ there does appear to be agreement that it is measuring something useful. Follow-on work has looked at applying “days of risk” to systems in particular contexts such as web servers.⁵⁷

Once vendors issue a patch, the details of the vulnerability rapidly become

broadly known, and in many cases enough information is available that exploits are easy to find. As a result, unpatched systems are prime targets. Balanced against this, when a patch is first issued, it may contain bugs or trigger compatibility problems, and so administrators may wish to delay installation; Beattie and his coauthors examined the optimal timing of patch installation to maximize uptime.⁵⁸ In response to this, the trend is increasingly automated patching systems, either as a service from the software providers⁵⁹ or a third-party offering such as Altiris,⁶⁰ Novell's ZENworks,⁶¹ or AutoPatcher.⁶²

A radically different approach to estimating the security of a system focuses on "attack surface."⁶³ Intuitively, the smaller the system and the fewer paths by which an attacker can get access to it, the more secure the system is; in practice, this intuition is borne out by experiences related to OpenBSD and Linux, where in many cases potential vulnerabilities in code shared by the two operating systems cannot be exploited in the default OpenBSD installation because functionality is minimized by default. Microsoft, for example, now tracks attack surface as part its engineering process and establishes explicit goals of reducing it from release to release.

The common thread among all of these measurements is that they do not focus on the underlying data structures, algorithms, or code that is traditionally viewed as comprising a software-based system. Nor is the focus narrowly on the "bugs" or flaws in the code. Instead, these measurements focus on the system as it is used in a real-world organizational and human context.

Vulnerabilities and the Security Ecosystem

The industry adopted responsible disclosure because almost everyone agrees that members of the public need to know if they are secure, and because there is inherent danger in some people having more information than others. Commercialization throws that out the window.

*Jennifer Granick*⁶⁴

The "security ecosystem" consists of organizations and individuals around the world with a stake in information security: corporations, governments, individual security researchers, information brokers, bot herders,⁶⁵ and so on. Viewing this system from political, economic, and sociological perspectives yields valuable insights complementary to the traditional technical view of secure software engineering. One aspect of this ecosystem involves policies related to vulnerability disclosure.⁶⁶ A vulnerability is any flaw within a software system that can cause it to work contrary to its documented design and could

be exploited to cause the system to violate its documented security policy. A malicious attacker can take advantage of the vulnerability via an exploit.⁶⁷

Historically, when independent security researchers identified vulnerabilities in a shipping product, they had three options: they could disclose their “finds” to the software provider; or, by publishing on the internet directly to the users of the software, sell the information to somebody who wanted to exploit the vulnerability; or keep the information private. Since the different players in the system have different incentives, many protocols may fail in practice to serve the interests of end users (for example, if all vulnerabilities are disclosed only to the software providers, they may not have any incentive to provide information or fixes to end users; if a vulnerability is disclosed publicly before it goes to the software provider, it is likely to be exploited before a patch is ready). A series of discussions in the period 1999–2001 led to agreement on a protocol known as “responsible disclosure,”⁶⁸ in which researchers first disclose information to the software provider, who in turn agrees to work quickly toward a patch and in many cases acknowledges the researcher’s contribution.

However, an economy has recently emerged around software vulnerabilities. Knowledge of undisclosed or partially disclosed vulnerabilities is valuable information; a “o-day” (meaning previously unpublished) vulnerability with an accompanying exploit for a major database system or Web server can be worth over \$100,000.⁶⁹ Unsurprisingly, markets have evolved: an underground market in which criminals pay for vulnerabilities that will allow them to exploit systems, and the more recent public markets established by corporations such as Verisign (with iDefense) and 3Com (with TippingPoint) starting in 2002. These companies attempt to turn vulnerability information into a competitive advantage—for example, by providing information to their subscription customers.

WabiSabiLabi, a Swiss vulnerability brokerage firm founded in July 2007 to buy and sell vulnerabilities as a market commodity, is a recent example. Firms such as WabiSabi provide a legitimate way for security researchers to profit from their work; they also allow private interests to acquire information and provide it only to their subscribers or allies. Vulnerability brokers have no direct incentive to protect end users or provide vulnerability information to the affected vendor: only the subscribers know about the problem; and the resulting under-publication of vulnerabilities may be suboptimal from the perspective of the ecosystem as a whole.⁷⁰

In addition to the purely market viewpoint, the security research community also is a ripe area for ethnographic and sociological study. Books like *Hacker Culture*⁷¹ and *The Hacker Crackdown*⁷² illustrate the complex interactions among geography, technology, culture, and race that provide a backdrop for these interactions. An interesting recent trend is the emergence of a “conference circuit.” These conferences typically mix high-quality (although nonacademic) technical presentations by security researchers and security experts at various corporations and universities with a significant social element: lock-picking contests or capture the flag at DefCon,⁷³ for example. Well-entrenched events such as Black Hat,⁷⁴ DefCon, and RSA⁷⁵ have recently been supplemented by researcher-oriented events such as CanSecWest,⁷⁶ Hack-in-the-Box,⁷⁷ XCon,⁷⁸ and phNeutral.⁷⁹ For example, Microsoft’s Blue Hat series,⁸⁰ in which outside security researchers are invited to give talks to the developers charged with building secure software, intersects the resulting social network with the internal “trustworthy computing” efforts. From a corporate and government perspective, the resulting shared experiences and tested, informal lines of communication can prove useful in evaluating and responding to potential future threats; from a security researcher’s perspective, the increased sharing of information provides better grounding for future research, and to the extent that cooperation works successfully, increased likelihood that results will have a positive impact on end-user security.

Conclusion

While traditional computer science elements of computer security—access control, authentication mechanisms, software engineering, cryptography—remain vital, progress and innovations are increasingly coming from the social science disciplines. The three areas briefly explored in this chapter are only the tip of the iceberg.

Some of the most significant challenges related to computers and security today can only be meaningfully discussed from a social science perspective. Can the economic solution of introducing a small cost per email help address spam?⁸¹ What effect would this have on freedom of information,⁸² and would it restrict political organizing on the internet to the more affluent? How should the need to prevent scammers and spammers on social networks be balanced with the loss of anonymity in a panoptic social network like Facebook—and how does this balancing interact with existing societal class and subcultural divisions? Are digital rights management (DRM) hardware

and software solutions that prevent copying or reuse of content an example of effective computer security—or an unconstitutional restriction on fair-use rights? Will legislated or court-enforced liability lead to incentives for corporations to improve security⁸³—and will the effects on innovation,⁸⁴ economic growth, and free or open-source software be catastrophic?

For the discipline to remain relevant, “computer security” needs to broaden its scope and redefine itself. Encouragingly, as the wide range of activities cited in this chapter and the rest of this volume attest, this is already happening: in interdisciplinary workshops, unexpected collaborations, and ongoing work in many universities and corporations. As this redefinition happens over the next few years, the discipline of computer security will become substantially more effective at addressing user and societal needs.

2 The Information Vulnerability Landscape

Compromising Positions: Organizational and Hacker Responsibility for Exposed Digital Records

Kris Erickson and Philip N. Howard

DATA COLLECTION, management (or mismanagement), and unwanted disclosures of personal information have become the subjects of public debate. In early 2005 a series of high-profile cases culminating in the loss of more than 140,000 customer credit records by ChoicePoint helped generate significant public interest in the dangers associated with digital records of personal information.¹ Then, in the summer of 2006, the Department of Veterans Affairs admitted that some 26.5 million personal records had been compromised.² In 2007 the Chicago Board of Elections was accused of compromising voter files,³ and the Census Bureau admitted to posting records for over 300 households online.⁴

The threats to information security are varied: for example, search engines increasingly index Web pages that may not be meant for public consumption, and employee use of file-sharing software exposes many different kinds of files to communication networks. Organizations use various levels of passwords and encryption to try to prevent access to data on stolen laptops. Data security is never perfect, and credit card companies, universities, and government agencies cannot perfectly predict security lapses. But the growing number of news stories about compromised personal records reveals a wide range of organizational mismanagement and internal security breaches: lost hard drives and backup tapes, employee theft, and other kinds of administrative errors.

So far, blame has been directed at all parties involved: at the state, for being lackadaisical in regulating organizations that deal with electronic records; at

the private sector, for not giving personal privacy and information security enough priority; and finally at the end users themselves, for not taking better care of managing their online identities in order to mitigate the risk of fraud. A significant amount of the information in these records concerns health and credit records, which are often combined to generate a convincing electronic portrait of an individual, thus effectively reconstituting their identity.⁵ These stolen identities can also be used to fraudulently deceive government agencies and credit organizations.

The threat of electronic data theft also has serious implications for societies that increasingly rely on the security of data networks to conduct daily life. For example, as more of our political system becomes computerized, there is a stronger possibility that electronic data could contain information about an individual's political beliefs or voting records, which are now both easier to access and highly detailed.⁶ Yet most U.S. citizens report being uninterested in learning how to better manage their personal data or in learning about the ways organizations mine for data.⁷ However, both policy makers and computer software and hardware companies are, nevertheless, aggressively enrolling individual consumers in the task of securing their own data against loss or theft.

Often at the center of these privacy breaches is the hacker archetype. Using intellectual property law, court challenges, and amicus briefs, corporate and government leaders have reframed the meaning of the term "hacking" from a character working for freedom of access to technology and information to one that is deviant and criminal.⁸ However, the actual role of hackers in the computer security sector is considerably more complex. Many hackers not only enjoy technical challenges but are sometimes even enlisted by corporations and governments for their specific skills.⁹ Even though the campaign against hackers has successfully cast them as the primary culprits to blame for vulnerability in cyberspace, it is not clear that constructing this target for blame has resulted in more secure personal digital records.

This chapter explores how responsibility for protecting electronic data is currently attributed and examines legislation designed to manage the problem of compromised personal records. In our investigation we compare the aims of legislation with an analysis of reported incidents of data loss for the period of 1980–2007. A discrepancy between legislative responses to electronic data loss and the actual damages incurred reveals that responsibility for maintaining the security of electronic personal records has been misplaced and should be reexamined. We conclude with a brief discussion of the options for public policy oversight.

Legal Evolution—from Regulating Hackers to Regulating Corporations

Scholars often point out that new information technologies consistently present legislators with the challenge of regulating issues for which there are no readily apparent legal precedents. Lawmakers are frequently cast as lagging behind technological innovation, as they struggle to catch up with new forms of behavior enabled by rapidly evolving technology. Traditional legal concepts such as private property and trespass often become problematic when applied in online contexts enabled by information and communication technologies. For example, E. A. Cavazos and D. Morin have argued that the law has struggled to adequately account for the nuances of computer-mediated communication.¹⁰ These tensions become particularly apparent when lawmakers have attempted to regulate behavior across several legal jurisdictions, such as in the case of music piracy and online gambling.¹¹ Particularly in the context of information security of digital information, legislation has been questionable in its effectiveness as a deterrent. The law first turned to regulating the act of computer intrusion committed by “hackers” and now has turned to regulating the consequences of intrusion and data leakage through data breach notification statutes.

Regulating Computer Intrusion and Hackers

The Computer Fraud and Abuse Act (CFAA) was passed in 1984 in response to growing political and media attention surrounding the dangers of computer crime. The act criminalized exceeding authorized access to private computer systems, making it a felony offense when trespass leads to damages over a certain monetary threshold. The CFAA underwent major revisions in 1986 and 1996, and it was further strengthened by the passage of the USA Patriot Act in 2002. Overall, these revisions have served to make the act more broadly applicable to various kinds of computer crime, while also increasing the punitive response to these offenses.¹²

For example, the revisions in 2002 were tailored to make it easier to surpass the \$5,000 felony threshold. The threshold was waived in cases where the computer systems involved are used for national security or law enforcement purposes. In cases not involving national security, the definition of “damage” was broadened to include costs relating to damage assessment and lost revenue during an interruption of service. The \$5,000 threshold is also cumulative over multiple machines if more than one system is involved in a single attack.¹³ In

addition, the maximum sentence for felony computer trespass was raised from five to ten years for first-time convictions, and from ten to twenty years for repeat offenses.¹⁴

Given the relatively harsh penalties for computer intrusion in comparison with those for other crimes in which victims suffer personal physical harm, it is surprising that the CFAA has not been more effective as a deterrent. The apparent surge in computer-related offenses, including the theft of online personal records, suggests that the punitive nature of this legislation is not having the desired effect.¹⁵ The belief that all hackers are malicious is essentially a myth—many members of the computer hacker subculture do not condone destructive behavior and do not consider their activities to be particularly malicious.¹⁶

Arguably the most significant threat posed by computer criminals comes not from the core group of white, black, or gray hat hackers but from individuals who use hacker techniques to invade systems for monetary gain.¹⁷ Since knowledge and tools developed by more experienced hackers can easily be obtained on the internet, the capability to penetrate insecure networks has propagated outside of the original hacker community to other groups, ranging from inexperienced teenagers to international crime syndicates.¹⁸ These individuals may feel protected from the law by the relative anonymity of computer-mediated communication, or they may be located in jurisdictions where harsh criminal penalties for computer fraud do not apply.

Regulating Corporate Data Leaks Through Breach Notification Statutes

Although the CFAA aids in the prosecution of criminals who engage in electronic data theft and trespass, individual states have taken additional legal steps to regulate the management of electronic records. In 2003 the state of California introduced a new provision to the Information Practices Act, the “Notice of Security Breach.” This addition to the California Civil Code obliges any business or agency that has been the victim of a security breach to notify any parties whose personal information might have been compromised. The California legislation defines “personal information” as an individual’s full name, in combination with one of the following types of data:

- (1) Social Security number
- (2) Driver’s license number or California Identification Card number
- (3) Account number, credit or debit card number, in combination with any required security code, access code, or password that would permit access to an individual’s financial account

The organization responsible for handling the compromised data must notify potential victims individually, unless the cost of notification exceeds a threshold amount of \$250,000, or if the total number of individuals affected is greater than 500,000. In these cases, substitute notification can be made using a combination of email notification and disclosure to major media outlets. Notification must be carried out “in the most expedient time possible and without unreasonable delay, consistent with the legitimate needs of law enforcement [. . .] or any measures necessary to determine the scope of the breach and restore the reasonable integrity of the data system.”¹⁹ Following in California’s footsteps, at least forty additional states had enacted similar legislation by 2007. Unlike the CFAA, however, this legislation does not directly address the issue of network security. It does not formalize standards or rules for information security; nor does it make organizations accountable for poor security practices that make them vulnerable to attack. The legislation punishes businesses only for failing to notify the public, rather than for negligence in securing electronic records. Since adequately securing a computer network from intrusion is an expensive prospect, this legislation essentially lets businesses off the hook by making them liable for damages only when they fail to notify affected individuals that their data have been compromised. Interestingly, by failing to assign responsibility for data loss to those agencies that manage electronic personal information, this legislation serves in part to shift that responsibility to the individual users, since they are the ones who must take steps to protect their identity once notified of a breach.²⁰

So far, the legal responses to electronic identity theft in the United States have sought to minimize the direct involvement by the state, instead relying on a partnership between the interests of private firms and the consumers of those services. The two major forms of legislation governing the security of computer records in the United States—the CFAA and the California data breach notification laws—closely resemble offline governmental strategies that seek to place responsibility on individual consumer-citizens while disciplining those who do not adequately protect themselves.²¹ Moreover, the hesitation of public agencies in the United States to draft legislation that would directly influence the terrain of data security is consistent with the overall trend of regulatory devolution, a shift that began before the information sector occupied such a primary position in the national economy.

The legislative choices that policymakers in the United States have made to combat the problem of data insecurity have been shaped by the tenet that

governments should interfere only minimally with markets. Thus, legislative initiatives have eroded public policy oversight of corporate behavior. In the arena of data security for private information, this erosion has meant deemphasizing the role of government and public policy oversight in data security, encouraging industry self-regulation among the firms benefiting in the retention of personal data, and increasing individual responsibility for managing our personal data.

Analysis of Compromised Electronic Records, 1980–2007

We conducted a search of incidents of electronic data loss reported in major U.S. news media from 1980 to 2007. These included print publications with national circulation, such as the *New York Times*, the *L.A. Times*, and *USA Today*, along with major broadcast news media. Because some news reports contained references to more than one incident, we employed a snowball methodology to expand our analysis by including additional security breaches mentioned in the same article. Duplicate entries were eliminated by comparing news stories on the basis of organizations involved, dates, and other incident details. In instances where papers reported different quantities of lost records, we chose the most conservative report. We also consulted lists of electronic data breaches compiled by third-party computer security advisories, such as the Identity Theft Resource Center (www.idtheftcenter.org) and Attrition.org. Our method yielded 852 incidents, 39 of which were discarded because they involved citizens of other countries. Of the remainder, 813 incidents were successfully cross-checked with LexisNexis and Proquest to ensure accuracy.²²

Our list of reported incidents is limited to events in which one or more electronic personal records were compromised through negligence or theft. We acknowledge that there are occasions when end users consider their personal information compromised when the data are sold among third parties for marketing purposes without their informed consent. For this study, we look only at incidents of compromised records that are almost certainly illegal or negligent acts. For the purposes of this chapter, we define electronic personal records as data containing privileged information about an individual that cannot be readily obtained through other public means. Rather than become involved in the broader debate about the virtues and dangers of online anonymity, we have chosen to focus only on data that are more sensitive than the information that we regularly volunteer in the course of surfing the Web (such as one's name or

internet protocol [IP] address). We define “personal data” to be information that should reasonably be known only to the individual concerned or be held by an organization under the terms of a confidentiality agreement (such as between a patient and a care provider). Electronic personal records therefore could include individuals’ personal credit histories, banking information such as credit card numbers or account numbers, medical records, Social Security numbers, and grades earned at school. We focused only on incidents in which compromised personal records were kept for a legitimate purpose by a firm, government agency, or other organization. Consequently, “phishing” or spoofing scams in which victims are deceived into volunteering their own personal information are not included in our analysis. All of the incidents in our analysis deal with data that were maintained in electronic form, although in some cases compromised data were contained on lost or stolen computer hardware.

Between 1980 and 2007, some 1.9 billion records were reported compromised by government agencies, firms, hospitals, universities, and the military. This is the sum of compromised records from 813 incidents in which some estimate of the volume of lost records was offered, though in 61 of these incidents the volume of the security breach was unknown. In a sense, this number of lost records is larger than one might expect because a few landmark incidents account for a large portion of the total number of records compromised. On the other hand, we conservatively recorded the number of records lost in each incident: if a range of the number of compromised records was offered, we recorded the lowest number; if no exact number was reported, we recorded zero compromised records; in news stories where it was reported only that “hundreds” or “thousands” of personal records were compromised, we recorded 100 or 1,000 compromised records. Moreover, the number of confirmed incidents—813 in all—may seem smaller than expected given the twenty-seven-year time frame of our search. Some articles report multiple incidents, and of course many incidents were covered by journalists on multiple occasions. In 2004 the Census Bureau estimated that there were 217 million adults living in the United States. We can conservatively estimate that for every U.S. adult, in the aggregate, nine private records have been compromised. Unfortunately we cannot know how many of these compromised private records have actually been used for identity theft, or how many were sold to marketing companies.

Table 2-1 shows the number of reported incidents and volume of compromised records between 1980 and 2007, along with their distribution by sector.

TABLE 2-1 Reported Incidents and Volume of Compromised Records by Sector, 1980–2007

Time Period		Commercial	Educational	Government	Medical	Military	Total
1980–1989	Records	N 90,000,002	0	0	0	4,190,000	94,190,002
		% 96	0	0	0	4	100
	Incidents	N 3	0	1	0	3	7
		% 43	0	14	0	43	100
1990–1999	Records	N 53,369,339	0	20	3,010	461	53,372,830
		% 100	0	0	0	0	100
	Incidents	N 16	0	1	2	3	22
		% 73	0	5	9	14	100
2000–2007	Records	N 1,764,690,029	9,050,483	74,101,500	5,506,212	999,356	1,854,347,580
		% 95	0	4	0	0	100
	Incidents	N 275	244	173	79	13	784
		% 35	31	22	10	2	100
Total	Records	N 1,908,059,370	9,050,483	74,101,520	5,509,222	5,189,817	2,001,910,412
		% 95	0	4	0	0	100
	Incidents	N 294	244	175	81	19	813
		% 36	30	22	10	2	100

NOTE: A zero value in sectors with no incidents indicates that no records were compromised. A zero value in sectors with incidents indicates that the volume of compromised records was not recorded.

The majority of incidents involved commercial actors; less than a third of the incidents involved colleges, universities, or nonprofit agencies; and the remainder involved government, hospitals, and the military. When the exceptional loss of 1.6 billion personal records by Acxiom Corporation is removed, the commercial sector still accounted for approximately 308 million individual compromised records, four times that of the next-highest contributor, the government sector.²³ The education and nonprofit sector accounted for a small percentage of the overall quantity of lost records, but accounted for 30 percent of all reported incidents, suggesting that educational organizations suffer from a higher rate of computer insecurity than might be anticipated. This could be explained by the fact that colleges and universities maintain large electronic databases on current and past students, staff, faculty, and alumni, and have an organizational culture geared toward information sharing. However, medical organizations—which presumably also maintain large quantities of electronic data—reported a significantly lower number of incidents of data loss. These differences may be the result of strong privacy legislation in the arena of medical information, but comparatively weak privacy legislation in the arena of educational and commercial information.

Although Table 2-1 has aggregated twenty-seven years' worth of incidents, the bulk of the reports occur between 2005 and 2007, after legislation in California, Washington, and other states took effect. There were five times as many incidents in the period between 2005 and 2007 as there were in the previous twenty-five years. Interestingly, the mandatory reporting legislation seems to have exposed educational organizations as a major source of private data leaks. Since 1980, 36 percent of the incidents involved commercial firms, but in the three most recent years, 33 percent of the incidents involved educational organizations. These kinds of organizations may have been the least equipped to protect the data of their students, staff, faculty, and alumni.

For the majority of incidents, the news articles report some information about how the records were compromised. A closer reading of each incident, however, reveals that most involved different combinations of mismanagement, criminal intent, and, occasionally, bad luck. The hacker label was often used, even when the theft was perpetrated by an insider, such as a student or employee. Moreover, company public relations experts often posited that personal records were only “exposed,” not compromised, when employees posted private records to a website or lost a laptop and the company could not be sure that anyone had taken specific advantage of the security breach.

TABLE 2-2 Reported Incidents and Volume of Compromised Records by Type of Breach, 1980–2007

Time Period		Administrative Error	Exposed Online	Insider Abuse or Theft	Missing or Stolen Hardware	Stolen-Hacked	Unspecified Breach	Total
1980–1989	Records	N	0	0	0	0	90,000,002	4,190,000
		%	0	0	0	0	96	4
	Incidents	N	0	1	0	0	3	3
		%	0	0	14	0	43	43
1990–1999	Records	N	0	3,030	20	20,000	33,430	53,613,350
		%	0	0	0	0	0	100
	Incidents	N	0	0	1	1	10	7
		%	0	0	5	5	45	32
2000–2007	Records	N	35,322,843	5,984,901	11,011,773	53,278,191	1,712,595,473	36,154,399
		%	2	0	1	3	92	2
	Incidents	N	26	145	34	325	204	50
		%	3	18	4	41	26	6
Total	Records	N	35,322,843	5,987,931	11,011,793	53,298,191	1,802,628,905	93,660,749
		%	2	0	1	3	90	5
	Incidents	N	26	148	36	326	217	60
		%	3	18	4	40	27	7

NOTE: A zero value in a type of breach with no incidents indicates that no records were compromised. A zero value in sectors with incidents indicates that the volume of compromised records was not reported.

Table 2-2 shows that the legislation has also seemed to have the effect of forcing the reporting organizations to reveal more detail about the ways these private records get compromised. In the early reports, most incidents were described as an unspecified breach or as the general result of hacker activity. However, for the period between 2000 and 2007, 27 percent of the incidents were about a breach caused by a hacker, 7 percent of the incidents involved an unspecified breach, and 66 percent of the incidents involved different kinds of organizational culpability. For example, sometimes management accidentally exposed private records online, administrative error resulted in leaked data, or employees were caught using the data for activities not related to the work of the organization. On some occasions, staff simply misplaced backup tapes, while on others, computer equipment such as laptops were stolen.²⁴

A single incident, involving 1.6 billion compromised records at the Acxiom Corporation, accounts for a large portion of the volume of records lost in the period 2000–2007.²⁵ If this event is removed from this period, then 44 percent of the compromised volume and 26 percent of the incidents were related to hackers, 42 percent of the compromised volume and 68 percent of the incidents involved organizational behavior, and 14 percent of the compromised volume and 6 percent of the incidents remain unattributed. If this event is removed from the volume of compromised records for the whole study period—between 1980 and 2007—then 50 percent of the total volume of compromised records was related to hackers, 27 percent of the volume was attributed to the organization, and 23 percent remained unattributed. Removing this event from the total number of incidents for the whole study period does not change the overall allocation of responsibility in major news reports: 66 percent involved organizational management, 27 percent of the incidents involved hackers, and 7 percent remain unattributed. Regardless of how the data are broken down, hackers account at most for half of the incidents or the volume of compromised records.

If we distinguish the reported incidents that clearly identify a hacker from those related to some other form of breach, the organizational role in these privacy violations becomes clear. Figure 2-1 separates the stories in which a hacker was clearly identified as the culprit from those in which the cause of the breach was unspecified, and from those in which the cause of the breach was related to organizational action or inaction. In this latter category, we consider organizational behavior to include four types of security breach: accidental exposure of personal records online, insider abuse or theft, missing

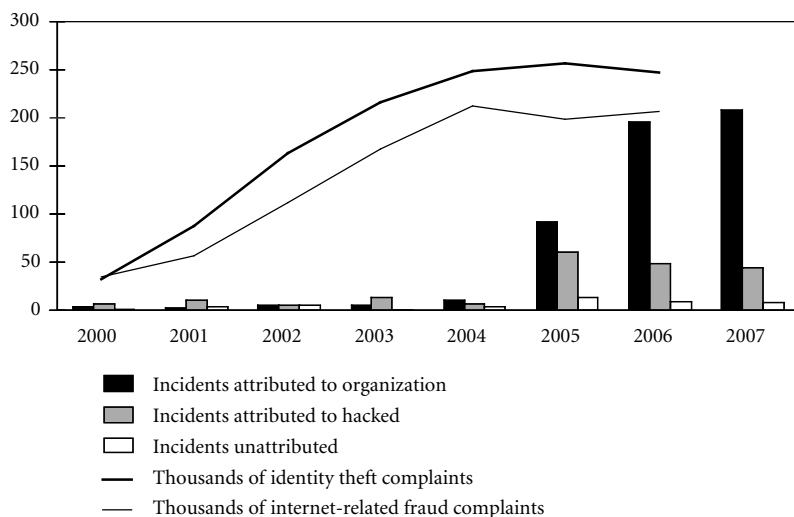


FIGURE 2-1 Incidents of Compromised Personal Records, Identity Theft Complaints, and Internet-Related Fraud Complaints, 2000–2007

SOURCE: Based on authors' calculations of incidents of compromised personal records, 2000–2007. Identity Theft Complaints and Internet-Related Fraud Complaints from the U.S. Federal Trade Commission Consumer Sentinel Project Team, *National and State Trends in Fraud and Identity Theft, 2000–2003 and 2003–2006*.

or stolen hardware, or other administrative error. First, it is notable that as more states required organizations to report compromised digital records, the volume of annual news stories on the topic increased significantly. In fact, there were more reported incidents in the period 2005–2007 than in the previous twenty-five years combined. We found 126 incidents of compromised records between 1980 and 2004, and 687 incidents between 2005 and 2007. Just summing these incidents, when mandatory reporting legislation was in place in many states, we find that 72 percent of the stories concern data that were accidentally placed online or exposed through administrative errors, stolen equipment, or other security breaches such as employee loss of equipment or backup tapes.

Several factors might explain the pattern of increasing incidents and volume of compromised data over time. First, there is the possibility that the results are skewed by the relative growth of new, fresh news stories devoted to this issue and the loss of older stories that disappeared from news archives as time passed. Perhaps there have always been hundreds of incidents every

year, but only in recent years has the severity of the problem been reported in the news. If this were the case, we would expect to see a gradually decaying pattern with a greater number of reported cases in 2007 than in 2006, 2005, and so on. However, the dramatic difference in reported incidents between later years and early years suggests that this effect does not adequately explain our observations. A second possibility is that greater media attention or sensationalized reporting in 2005 and 2006 led to a relative over-reporting of incidents, compared with previous years. Literature on media responses to perceived crises or “moral panics” would suggest that a similar effect commonly accompanies issues that are granted a disproportionate amount of public attention, such as the mugging scare in Great Britain in the 1970s or the crackdown on the rave subculture in the 1990s.²⁶ Although it is unlikely that media outlets have exaggerated the amount of electronic personal record loss, it is possible that in previous years a certain number of events went unreported in the media owing to lack of awareness or interest in the issue of identity theft. A third possibility is that there were more reported incidents of data loss between 2005 and 2007 because organizations are maintaining and losing a larger quantity of electronic data and because a changing legislative environment in many states is obliging organizations to report events publicly that would have gone unreported in previous years. The fourth possibility, and the most plausible one, is that mandatory reporting legislation has exposed both the severity of the problem and the common circumstances of organizational mismanagement.

It is likely that a combination of factors explain our observations. Data breach notification legislation that requires the prompt reporting of lost records in California came into effect in 2003; however, the legislation was not widely adopted and implemented by other states until 2005, which might help to explain the dramatic increase in reported cases. Data breach notification legislation in California, as in many other states, requires notification when a state resident has been a victim of data loss, regardless of where the offending organization resides. Therefore, organizations located in states without data breach notification laws, such as Oregon, are still required to report cases to victims who live in states that have enacted this type of legislation, such as New York. The nature and complexity of many databases means that, in many cases, compromised databases are likely to contain information about residents who are protected by data breach notification legislation, thus increasing the total number of reported cases.

Conclusion

The computer hacker is one of the most vilified figures in the digital era, but are organizations just as responsible as hackers for compromised personal records? To examine the role of organizational behavior in privacy violations, we analyzed 852 incidents of compromised data between 1980 and 2007. In the United States, some 1.9 billion records have been exposed, either through poor management or hacker intrusions: about nine personal digital records for every adult. There were more reported incidents between 2005 and 2007 than in the previous twenty-five years combined, and while businesses have long been the primary organizations hemorrhaging personal records, colleges and universities are increasingly implicated. Mandatory reporting laws have exposed how many incidents and how many records have been lost because of organizational mismanagement, rather than hackers. In the period since these laws came into force, 7 percent of incident reports do not attribute blame, 27 percent blame hackers, and 66 percent blame organizational mismanagement: personally identifiable information accidentally placed online, missing equipment, lost backup tapes, or other administrative errors.

Surveying news reports of incidents of compromised personal records helps expose the diverse situations in which electronic personal records are stolen, lost, or mismanaged. More important, it allows us to separate incidents in which personal records have been compromised by outside hackers from incidents in which breaches were the result of an organizational lapse. Of course, we should expect organizations to perform due diligence and safeguard the digital records holding personal information from attack by malicious intruders. But often organizations are both the unwilling and unwitting victims of a malicious hacker. Through this study of reported incidents of compromised data, we found that two-fifths of the incidents over the past quarter-century involved malicious hackers with criminal intent. Surprisingly, however, the proportion of incident reports involving hackers was smaller than the proportion of incidents involving organizational action or inaction. While 27 percent of the incidents reported clearly identified a hacker as the culprit, 66 percent of the incidents involved missing or stolen hardware, insider abuse or theft, administrative error, or the accidental exposure of data online. The remainder of news stories record too little information about the breach to determine the cause—either organizations or individual hackers might be to blame for some of these incidents.

Figure 2-1 helps put the trend line analyzed in this chapter into the context of identity theft complaints received by the Federal Trade Commission.

In 2006 and 2007, the FTC received roughly 250,000 consumer complaints of identity theft and 200,000 consumer complaints of internet-related fraud annually. Such official consumer reports can serve as an indicator of the outcome of compromised digital records, and it is interesting to note that until 2004 fewer than fifty news stories about compromised digital records were reported each year. Beginning a year later, the rate of such news reports increased dramatically, bringing into view a clearer picture of the ways in which personal electronic records get compromised.

Organizations probably can be blamed for the management practices that result in administrative errors, lost backup tapes, or data exposed online. And even though an organization can be the victim of theft by its employees, we might still expect organizations to develop suitable safeguards designed to ensure the safety of client, customer, or member data. Even using the news media's expansive definition of hacker as a basis for coding stories, we find that a large portion of the security breaches in the United States are due to some form of organizational malfeasance.

One important outcome of the legislation is improved information about the types of security breaches. Many of the news stories between 1980 and 2004 report paltry details, with sources being off the record and vague estimates of the severity of the security breach. Since the enactment of mandatory reporting legislation in many states, most news coverage provides more substantive details. In 2007 only one of the 263 news stories did not make some attribution of responsibility for a security breach.

Legislators at the federal and state level have adopted two main strategies to address the problem of electronic record management. On one hand, they have directly targeted individuals (computer hackers) whose actions potentially threaten the security of private electronic data. The CFAA has been repeatedly strengthened in response to a perception that electronic data theft represents a material and growing concern. However, our data suggest that malicious intrusion by hackers makes up only a portion of all reported cases, while other factors, including poor management practices by organization themselves, contribute more to the problem.

The second strategy employed by regulators might be thought of as an indirect or "disciplinary" strategy. Data breach notification legislation obliges organizations that manage electronic data to report any data loss to the individuals concerned. Companies, wary of both the negative publicity and the financial costs generated by an incident of data loss, are encouraged to adopt

more responsible network administration practices. Similarly, end users are urged to weigh both the risk of doing business electronically and the costs associated with taking action once they are notified of a breach. The practice of using a risk/reward calculus to achieve policy objectives through legislation has been termed governing “in the shadow of the law” by some contributors to the critical legal studies and governmentality literature.²⁷

One potential problem with this strategy is that the risks and rewards will be unequally distributed among individual, state, and corporate actors. While a large corporation might possess the resources and technical skill necessary to encrypt data, secure networks, and hire external auditors, other organizations in the private or public sector might not find the risk of potential record loss worth the expenditure necessary to secure the data. Governing through this type of market discipline is likely to result in a wide spectrum of responses from differentially situated actors.

There are a number of alternatives open to lawmakers and policy advisers that could materially strengthen the security of electronic personal records in this country. Alternatives include setting stricter standards for information management, levying fines against organizations that violate information security standards, and mandating the encryption of all computerized personal data. However, the introduction of legislation to directly regulate organizations that handle electronic information would certainly be controversial. A wide variety of agencies, companies, and organizations manage personal records on a daily basis. This complexity would hinder the imposition of standardized practices such as encryption protocols. Corporations would probably balk at the prospect of having to pay fines or introduce expensive security measures and accuse the government of heavy-handed interference. Others might argue that the imperatives of free-market capitalism demand that the government refrain from adopting punitive legislation, especially in order to maximize competitiveness. In the incidents studied here, most of the security breaches were at commercial firms and educational organizations, rather than breaches of individuals' security. However, identity theft can have a significant impact on individuals whose identities are stolen; it can also have a significant impact on the reputation of the organization that was compromised.

Although computer hacking has been widely reframed as a criminal activity and is punished increasingly harshly, the legal response has obfuscated the responsibility of commercial, educational, government, medical, and military organizations for data security. The scale and scope of electronic record loss

over the past decade would suggest that organizational self-regulation or self-monitoring is failing to keep our personal records secure and that the state has a more direct role to play in protecting personal information. State-level initiatives have helped expose the problem by making it possible to collect better data on the types of security breaches that are occurring, and to make some judgments about who is responsible for them. If public policy can be used to create incentives for organizations to better manage personally identifiable information and punish organizations for mismanagement, such initiatives would probably have to come at the state level. Electronically stored data might very well be weightless, but the organizations that retain personally identifiable information must shoulder more of the heavy burden for keeping such data secure.

3 Reporting of Information Security Breaches

A Reporter's View: Corporate Information Security and the Impact of Data Breach Notification Laws

Kim Zetter

REPORTING ABOUT computer security and privacy breaches has changed significantly in the decade that I have been covering the information security beat. The threats have changed, many companies' attitudes and security practices have changed and, perhaps most important, disclosure norms and public awareness have changed, particularly owing to the passage of data breach notification legislation. People frequently ask me how I uncover information for the information security stories I write and why journalists often know about data losses before anyone else knows about them. Like other journalists, I get my information about corporate data security breaches from many sources, including victims and personal contacts, whistleblower information security professionals, bragging criminals, conference presentations, and public hearings and documents. I discuss some aspects of those issues in this chapter.

Corporate Information Security Behavior— the Early Years

When I first began covering computer security and privacy for *PC World* magazine in the late 1990s, computer security and data breaches were not even recognized “beat” areas for reporters, except by a few very specialized publications that were devoted to computer security. Although there were reporters in the mainstream media who covered privacy and security issues, their stories were focused on civil liberties and national security issues; they

rarely, if ever, addressed the kinds of data breaches and personal privacy issues that are prevalent in mainstream media today. Information security and corporate data were not on their radar. Other than the occasional virus outbreak story, computer security was beyond the scope of their interest. This has now changed to some degree. Mainstream media outlets have begun to cover information security issues, in large part because of the passage of data breach notification laws.¹

Not only were newspapers and magazines not covering computer security as specialized issues when I first started on this beat, but companies also were not taking computer security seriously. Initially the problem lay in the fact that most companies naively and erroneously believed that no one would want to break into their systems. They thought only online banks and large retailers like Amazon had to worry about being targeted by data attackers. Similarly, hospitals, universities, and government agencies also believed they were under the hacker radar.

Even when companies did make attempts to employ some security measures, they often gave the task to people who were inexperienced in computer security matters. For example, companies would expect their information technology manager—someone who might have been skilled at plugging cables into computers to build a network, but had little experience with installing intrusion detection systems or testing a system for security vulnerabilities—to simply “handle” security.² Most companies failed to recognize that computer security was a specialized subcategory of information technology administration that required extensive knowledge of computer vulnerabilities and the ability to think the way hackers do.

Similarly, companies rarely understood that security was a process, not a one-time installation. I heard many complaints from security professionals about companies that understood the need to install firewalls and intrusion-detection systems but then failed to monitor the systems they installed.³ They would spend money installing alert systems, but then neglect to read the computer logs designed to alert them when a break-in had occurred; or they would read the logs, but only once a month, after the intruders had already been in and were long gone with the company’s data. It took a number of years to convince companies like this that just having the software installed was not enough. They also had to have someone with knowledge about security reading the logs every day. Another common problem lay with companies that installed firewalls but configured them incorrectly or left the default factory

settings in place, believing that all they had to do to secure their system was install the firewall.

Seven years later, the situation has improved somewhat, but not to the extent one might expect. More companies understand the need for security but still fail to implement it properly. Many companies fail to understand that computer security is an ongoing issue, not a static problem that can be addressed once and then forgotten. Partially as a consequence of this failure, corporate information security breaches are still rampant.

Breaches—Reported and Unreported

Before states passed the recent spate of notification laws requiring companies to disclose data breaches to people who might be affected by them, journalists learned about breaches from various sources. Very rarely, however, did the information come from the companies or organizations that experienced the breach. Companies feared that disclosing such information would place them at a disadvantage with competitors and open them up to lawsuits from customers; they also feared that discussing such breaches would broadcast to other potential intruders that their data were vulnerable to attack.

The Breaches We Hear About

Since the passage of data breach notification laws in many states, things have changed to a certain extent. Companies and organizations are starting to report breaches to the people affected by them. That said, this does not always mean they report them as soon as a breach occurs,⁴ or that they report the information to journalists as well. So, despite the existence of breach notification laws, journalists still often have to rely on sources other than the companies and organizations that experience a breach for information—either because the breach is not considered newsworthy or because the data that were stolen do not fall into the category of data covered by notification laws.⁵

Where do journalists get their information about corporate data security breaches? Information on breaches can come from many sources, including victims and personal contacts, whistleblower information security professionals, bragging criminals, conference presentations, and public hearings and documents.

Victims, Particularly Victimized Personal Contacts Reporters frequently hear about information security breaches from victims, particularly personal contacts. The victims of a security breach who receive a letter from a company

or organization saying their data have been compromised will sometimes pass the letter to a reporter or post the information to a listserv. Similarly, when a friend or relative is victimized in an information crime, they frequently pass along the information. For example, in 2005 I discovered that customers who used their credit and debit cards at a gas station in California were the victims of a skimming operation.⁶ A skimming operation occurs when a thief places an electronic skimmer inside a card reader to record a victim's card and personal identification number as the card is inserted into the reader. The skimmer transmits the data to the thief at the same time that the real reader transmits the information to the bank for authorization. I found out about the gas station skimmer only because my brother was one of the victims. After discovering fraudulent charges on his credit card, he filed a report with his local police department, which told him that thieves had placed a skimmer at a gas station he frequented. Authorities knew about the problem, as did the gas station and the banks whose customers were affected. But customers did not learn that their cards had been compromised until after they discovered fraudulent charges on the cards. The information did not appear in the press until weeks afterward, when a spate of skimming attacks made it clear that the problem at the gas station was not isolated.

Whistleblower Information Security Professionals Engineers and computer security experts who grow frustrated by employers who repeatedly ignore warnings about vulnerabilities in a computer system sometimes share information about security problems with reporters. Two years ago, I received a tip from an American programmer who helped set up the computer network for a large bank in another country. He told me the bank's website had a major flaw that would allow thieves to install malicious code on a third-party server that delivered ads to the bank's website. As he explained it, the vulnerability would allow thieves to serve up a phony bank site to customers to record the account number and password when customers typed them into a Web form. While the bank had taken care to secure its own servers, the programmer explained, it opened its system to a serious vulnerability because it allowed a third party to serve ads to its site. The engineer warned the company several times about the vulnerability, but the warnings fell on deaf ears.

Bragging Criminals Credit card and identity thieves in the underground are eager to brag about their successful exploits.⁷ Usually they tell reporters about their exploits after they have been arrested. Some decide to talk about

their crimes after they have turned over a new leaf and want to help educate consumers about ways in which their information is vulnerable. But there are also hackers who tell reporters about their exploits before they are arrested simply to brag about them—because, from their perspective, there is no point to owning a computer system if everyone in the world doesn't know that you own it.⁸ Hackers also discuss their exploits in private chat rooms on IRC;⁹ credit card and identity thieves congregate at websites like the now-defunct Shadowcrew and CarderPlanet, where they discuss their activities, often recklessly.¹⁰ For example, those who hacked Lexis-Nexis fell into this category.¹¹ They bragged in hacker chat rooms and on IRC channels about breaking into a subsidiary of Lexis-Nexis and stealing addresses and Social Security numbers. They also shared information with other hackers about how to breach the account themselves. It was no surprise that the FBI dubbed its investigation of the Lexis-Nexis hack as Operation Boca Grande, which is Spanish for “big mouth.”

Conference Presentations Conferences are another source of useful information about information security breaches. Computer security experts, law enforcement agents, lawyers, and academics often talk about case studies in panel discussions. Although the name of the company involved in the case study might not be revealed, the information can provide important details about the kinds of breaches companies do not discuss publicly.

Public Hearings and Documents Congressional hearings frequently publicly disclose new information relating to information security breaches, particularly hearings on identity theft and money laundering. Sometimes buried in the transcripts and reports generated by hearings, you can find interesting depositions from criminals with detailed information about how they conducted their crimes. Reporters can also find testimony from law enforcement investigators discussing cases they have worked and from congressional staff members who sometimes conduct their own investigation of issues for lawmakers.

Court documents such as indictments, affidavits, and complaints can contain a wealth of information about a breach that a company or organization never discloses publicly. Even when a company announces a breach, it may provide only a broad description of how the breach occurred. It is only after a suspect is arrested and indictments are issued that details about how the breach occurred become public, details that can reveal important information pointing to a lack of due care.

The Breaches We Don't Hear About

The breaches we never hear about, or seldom hear about, include banking breaches, brokerage breaches, user name/password breaches, and legal acquisition of data for illegal purposes.

Banking Breaches A hacker sometimes breaks into a bank's system or a customer's account and steals money without the customer ever knowing it happened. Often the bank simply replaces the funds, and the customer is none the wiser. It happens more often than banks are willing to admit. No one makes a fuss about it because usually the customer never knows it happened and suffers no loss. This is becoming a bigger problem as banks force customers to conduct their banking online. Some banks simply entice customers to bank online through incentives. But others are more forceful about it, imposing penalties on customers who refuse to go online—such as fees for using a teller. But while the banks force customers to go online, they are not always creating the safest environment for customers to do their banking. Banks sometimes knowingly place online customers at risk, adopting the attitude that secure computing is the responsibility of the customer. For example, one man's computer was infected with a keystroke-logging Trojan horse that allowed hackers to steal his bank account number and password when he entered them on the bank's website. After hackers withdrew money from the victim's bank account, the bank refused to restore the funds because it said the victim was responsible for securing his computer against malicious code. Banks can employ authentication measures on their websites to help thwart keystroke loggers, but not all of them do so.¹²

Brokerage Breaches Brokerage houses sometimes experience breaches and replace lost customer assets without reporting the breach. I recently encountered the case of a brokerage firm customer who lost more than \$100,000 when a thief drained his account with information obtained from a keystroke logger and credit reports. The victim had used a computer infected with a keystroke logger to access his email. This gave the thief the victim's user name and password for his email. Armed with this, he was able to read the victim's email at random and discovered that the victim had a brokerage account through electronic statements the firm sent the victim. Then, knowing the victim's name, the thief was able to obtain credit reports listing the victim's Social Security number and other personal data through an information broker who sold the data illegally online. The thief then used these personal details to gain access

to the victim's brokerage account and order a wire transfer of funds from the victim's account. A day before draining the money, the thief changed the user name and password on the victim's brokerage account to prevent him from checking his balance, and also changed the contact information on the account so that the brokerage firm would call the thief instead of the victim if it grew suspicious of the wire transfer request and wanted to verify the transaction. Apparently this did not raise any alarms with the brokerage firm because it allowed the transfer to go through. The case ended on a positive note, however. The thief was eventually arrested, and the brokerage firm gave the victim his money back, but only after he placed several calls to the firm complaining about its lack of security measures. This case, by the way, has never been in the news. I found out about it only while researching a story about identity thieves. An associate of the thief who was arrested told me about the case and I was able to confirm it after tracking down the victim and speaking with authorities.

User Name and Password Breaches Another type of data breach that we do not often hear about involves the theft of online user names and passwords. For example, AOL used to be a popular target for script kiddies—the term for young hackers who possess few skills but lots of swagger and recklessness.¹³ Some internet service providers (ISPs) have suffered numerous breaches involving the theft of screen names and passwords. But customers do not always hear about these attacks.

Legal Acquisitions for Potentially Illegal Purposes A type of breach that is seldom reported is a legal acquisition of sensitive data by someone who has no legitimate use for it. We do not hear about these incidents because they do not often involve the kind of activity that normally occurs in a breach. The data are not stolen or lost, as in most breaches; instead they are given away or sold freely. For example, in 2004 I wrote a story about a company named Aristotle that sells voter registration lists online. State laws vary on who can purchase voter registration data and how buyers can use the data. Some states allow only political parties and groups associated with election education to obtain voter registration data, while some states allow commercial marketers to obtain and use the data. Aristotle collected voter registration databases from counties across the country and did a brisk business reselling the data to political parties. Voter registration databases can contain a lot of sensitive information that would be useful to identity thieves, such as a voter's date of birth, Social Security number, current address, and phone number. Counties that collect Social Security numbers for voter reg-

istration are supposed to black them out before selling them to Aristotle and others, but this does not always happen. In the case of Aristotle's files, the company also combined voter registration data with commercial records (although the company spokesman assured me that Aristotle never augmented the voter files with commercial data). The company claimed that it followed careful procedures to ensure that only account holders who had been vetted by its salespeople were able to purchase voter data online, to ensure that the data were being purchased only by responsible parties for legally acceptable purposes. But contrary to those assurances, I was able to easily purchase several voter lists through Aristotle's website with no vetting, using accounts that I opened under the names "Britney Spears" and "Condoleezza Rice." Further, I purchased the lists using two different credit cards, neither of which matched the names on the Aristotle accounts I opened. Aristotle made no attempt to verify my identity or my reason for purchasing the data. The files I purchased included information about the ethnic and religious affiliation of voters, the number of children in their household, and whether the voters had purchased products from mail-order catalogues. When I called a handful of voters from the lists I purchased, they were surprised to learn that information they had given their county for voting purposes was available for anyone to purchase on the internet. This is an example of a data breach that is perfectly legal but can result in the same kind of harm to victims as any data breach involving a hacked computer system.

Another type of data breach in this category involves a federal website. There is one website where thousands of Social Security numbers are exposed on a daily basis—the Pacer website for the federal court system, which publishes records filed at civil, criminal, and bankruptcy courts across the country. Although some courts take care to black out Social Security numbers and other sensitive data written on court forms before the documents are placed online, not all of them bother with this extra step. Thus, a wealth of data exists in court records for identity thieves and others to mine. Ironically, I was investigating an identity thief recently and found the suspect's Social Security number as well as the Social Security numbers of his parents listed on the court forms. His date of birth, place of birth, and signature were all there for other identity thieves to exploit.

Common Corporate Information Security Mistakes

Although some basic industry standards for security exist, the actual practices vary widely and there are many reasons companies fail to institute better practices.¹⁴ Common mistakes made by businesses include outright lack of concern

leading to a lack of reasonable care, lack of money to invest in security, lack of equipment or skilled personnel to implement a sound information security policy, falling victim to social engineering attacks, and unnecessary data hoarding practices.

Lack of Concern Leading to a Lack of Reasonable Care

Some companies still operate under the “obscurity is security” myth, which posits that as long as no one knows about a vulnerability it cannot be exploited. For example, in 2005 a security researcher braved litigation to report a serious security vulnerability in the Cisco router, which runs on most of the networks on the internet.¹⁵ Cisco had announced the vulnerability six months earlier and released a patch. But the company had failed to tell customers just how serious the vulnerability was, so many customers declined to install the patch. Cisco feared that if hackers knew the significance of the security hole, they would jump at the chance to exploit it. But the company miscalculated the response that its customers would have to such a low-key announcement. All of that changed when the researcher disclosed the vulnerability to the audience, against Cisco’s wishes. Before his talk was even completed, you could see the glow of cell phones lighting up the darkened conference hall, as administrators called their companies to immediately patch their systems.

Lack of Money to Invest in Security, Lack of Equipment, and Lack of Skilled Personnel

Companies that do not invest sufficiently in equipment and skilled personnel create an easy target for information criminals. Every time a company installs new hardware, upgrades its software, or reconfigures its network it creates new vulnerabilities that need to be addressed. Similarly, the complicated issue of patch management requires an information technology department to stay on top of vulnerability announcements and software patch releases. The sophistication level of today’s information criminals creates a need for an equally sophisticated corporate response.

Falling Victim to Social Engineering Attacks

Sometimes the most serious information security breaches happen offline. For example, in 2006 Verizon Wireless reported that it had received hundreds of thousands of fraudulent calls from online data brokers who posed as Verizon customers. The brokers posed as customers in order to obtain copies of private cell phone records belonging to those customers and to sell them online. The method used is referred to as “pretexting”—that is, using a pretext to obtain records or-

dinarily unavailable to the callers.¹⁶ Computer hackers have engaged in the same kinds of activities for years under the broader label of social engineering.¹⁷

Who would buy cell phone records from a data broker? Private investigators and lawyers seeking evidence against cheating spouses in divorce cases would find such records valuable, as would journalists and political strategists looking for signs of a politician's philandering or unseemly business connections. In fact, according to one private investigator I spoke with, lawyers are big customers for such records, as are law enforcement agents looking to skirt official and more time-consuming methods for obtaining them. Criminals have also been known to purchase the cell phone records of police officers and FBI agents in order to ferret out the identity of a confidential informant who was informing on them to law enforcement.

One of the other ways in which the fraudsters obtained these records was to call Verizon's customer service department and pose as an employee from another Verizon department, in this case a nonexistent "special needs group." The "special needs" representative would claim to be calling on behalf of a voice-impaired Verizon customer who was unable to request the records on his own. Believing that he was speaking with a fellow Verizon employee, the customer representative would let his guard down and hand over the requested record. In the case of Verizon, the ruse apparently worked quite well before the company finally noticed a pattern to the calls and tracked the activity to data brokers.

Verizon did not say how often it complied with these fraudulent requests, but it is likely that at least several thousand of them succeeded. It is hard to imagine that the data brokers would have continued to make hundreds of thousands of calls to Verizon if their tactics weren't working. What this means is that thousands of Verizon customers likely had their privacy breached when the company gave away their phone records to brokers. The records included phone numbers the customers called, the phone numbers of people who called them, and the dates and times of those calls.

Similarly, Verizon did not make the information public in a way that most of us would expect. The company did not issue a press release saying it had experienced a data breach that affected the privacy of thousands of its customers. Nor did Verizon send letters to customers who were affected by this security failing—despite the fact that some of the customers likely lived in California and other states where laws require companies to notify people when their private data have been compromised. However, many of these laws did not cover the case of pretexting.

What Verizon did do after discovering the security breach was issue a press release touting its success at obtaining a court injunction against some of the data brokers to prevent them from calling Verizon again. The release, however, did not mention the number of times data brokers had already made such calls or the number of customers who were potentially affected by them. In fact, we only know that Verizon received hundreds of thousands of fraudulent calls because the company disclosed this information in a lawsuit it brought against some of the data brokers. The fact that Verizon disclosed this information in a lawsuit is unusual. Companies seldom like to admit to being duped so easily and repeatedly by fraudsters. In this case, Verizon disclosed the details in the lawsuit to impress upon the judge how serious and extensive the problem of pretexting was in order to obtain an injunction against the data brokers. Had the company not taken legal action against the data brokers we might still not know the extent of the breaches Verizon experienced.¹⁸

Unnecessary Data Hoarding

Lax computer security practices are just one threat to privacy. Another involves companies that collect sensitive information needlessly. These companies ask for private information just for the sake of collecting it, even when they have no immediate need to use it.

Companies frequently collect sensitive data, such as Social Security numbers, for no good business reason, and in most cases consumers hand over the data without any resistance. Not long ago someone hit my parked car and tore off my front fender. When the driver's insurance company, Geico, called to discuss the claim for repairs, the company representative asked me for my Social Security number to use as a password on my claim. This way they would know it was me whenever I called in the future, she said. When I balked at giving her my Social Security number for this purpose, she relented and said she could just as easily assign a random number to the claim instead. There was no reason the company needed my Social Security number or anyone else's for this purpose. And yet I am sure that few people reject the request when Geico asks for their number. My phone company also inexplicably uses my Social Security number as an identifier, instead of the perfectly good account number that appears on all of my phone records. Every time I speak with a customer representative at the phone company, I am asked for my Social Security number, not the account number. Even after extensive publicity about identity theft, large companies still use Social Security numbers for identification purposes. And consumers let them.

Similarly, in 2007 I registered for the TED (Technology Entertainment Design) conference,¹⁹ which draws 4,000 people annually, many of them technology and entertainment industry leaders, such as the founders of Google and the heads of Disney. Once registered, participants were invited to log in to its social networking website to meet other conference attendees. To log in, attendees had to establish an account with a user name, password, and security question (in case they forgot their password). What were the options for the security question? Nothing innocuous like the name of your favorite teacher or favorite dance club. The website asked attendees, including Al Gore, Meg Ryan, and other notables, to type in either their mother's maiden name or their city of birth. Your mother's maiden name is an important piece of information for identity thieves to have, as is the city of birth because it tells thieves where to search for the birth certificate of an intended victim. It was a bit surprising to see a website asking for these kinds of details in an age of rampant identity theft and bank fraud; it was even more surprising to realize that none of the attendees had been bothered by the request. Apparently I was the only one who raised any concern about it. To their credit, the conference organizers changed the website once I brought it to their attention. But by then the conference registration had long since closed and thousands of people presumably had already handed over this highly sensitive information. This was a case of an organization simply being unaware of the significance of the information it was requesting.

The Impact of Data Breach Notification Laws

Notification laws clearly have gone a long way toward making the general public aware of how vulnerable their information is. Before the passage of these laws, breaches were no less common, but no one was talking about them outside of computer security circles.

The Positives

Data breach notification laws have unquestionably helped educate the public about the need for better security on their home computers and about the need to monitor their credit reports and bank accounts for suspicious activity. In addition to a public education benefit, data breach notification laws created greater interest in the mainstream media in reporting on information security issues. Data breach notification laws have forced the mainstream media to begin paying attention to information security, if only in the broadest sense.

Breach laws have also had another benefit—they have forced companies to realize that they must fix their security problems or face the wrath of customers. Before the passage of these laws, when companies experienced breaches and no one knew about them, companies had little incentive to improve their security practices. Now the spotlight of publicity brought on by the new laws is helping to shame companies and organizations that do not take security seriously, since the publicity makes it much more likely that they will face public relations and potentially legal consequences if they do not fix a known vulnerability.

The Shortcomings

Despite these positives, however, the arrival of data breach notification laws has also made it clear that there is room for improvement. The newfound media interest in information security is both positive and slightly troubling. Computer security reporting is a specialized area of reporting that, to be done well, requires the reporter to know the difference between good security and bad security—to know what kinds of questions to ask in order to understand if the company's explanation of how a breach occurred makes sense. But few publications realize this. Although a newspaper would not send a reporter with no knowledge of legal matters to cover the Supreme Court, many media outlets send general assignment reporters to cover computer security breaches. In other words, reporting on the issue of data breaches has changed to some degree, but not enough.

Similarly, although the statutes provide for a way to prosecute companies for deficiencies in notice about breaches, regulatory prosecutions are not always instituted under the statutes. On the civil litigation side, even assuming a company could be sued for lack of due diligence if customers discovered that the company failed to implement basic procedures to protect their data, few customers have the resources to engage in such a legal battle.²⁰

Also, breach notification and the threat of lawsuits cannot fix all security failings; this is because not all security holes are found in computer software. When a hacker breaks into a computer system through an application vulnerability or a hole in a firewall, it is a clear case of a security breach. But when a thief poses as a legitimate customer to obtain access to a company or organization's records and then uses the information for criminal purposes, it is much easier for a company to distance itself from responsibility and claim innocence. For example, after an identity thief in California was arrested for setting up a bogus business account with ChoicePoint to download people's records in ChoicePoint's database, ChoicePoint initially said it could do little to prevent similar breaches in the future because it had no way to determine if

customers who obtain data from them use it appropriately.²¹ The company later changed its statement and said it would tighten its procedures to ensure that people opening accounts with it are connected to legitimate businesses. But there are many other ChoicePoints out there—companies and state offices that are willing to sell information to anyone who is willing to buy it. And there are many agencies that give away private data—such as the federal court system—to which the breach notification laws do not apply. Therefore, data breach laws can go only so far to improve the security of private and sensitive information.

Finally, sometimes there is a reason why information about a breach does not come first from the company that experienced the breach. Sometimes the company that has been breached is the last to know about it. In this circumstance in particular, breach notification statutes do not offer the best option for addressing the problem. The smart companies monitor their networks and find the leaks when they happen or shortly thereafter. But sometimes companies learn about a breach only when a hacker brags about it to a reporter. And other times the leaks are discovered only when police arrest a suspect while trying to use the stolen data or even while committing a crime completely unrelated to the stolen data. For example, police in California discovered a breach at a Lexis-Nexis subsidiary after arresting a suspect for another crime and discovering printouts from the Lexis-Nexis subsidiary in the thief's house. Police in another case uncovered a huge cache of identity documents after arresting a woman for a simple traffic violation and discovering that her driver's license was falsified. A search of her house uncovered card-making equipment and dossiers on some 500 individuals that she and her husband had amassed through illegally obtained credit reports and other data.

Conclusion

The information security reporting landscape has changed dramatically in the past decade, as have consumer awareness of information security problems and corporate information security best practices. Data breach notification laws have played an important part in bringing about some of these changes; however, without additional steps to bolster them, data breach notification statutes are not enough to generate stronger information security corporate behaviors.

4 Information Security and Patents

Embedding Thickets in Information Security? Cryptography Patenting and Strategic Implications for Information Technology

Greg R. Vetter

IN FITS AND STARTS, but persistently, the United States patent system has come to pervade information technology and thus is increasingly entangled with modern cryptographic technology. The resulting policy considerations go beyond the broad implications of increased software and business method patenting. Cryptographic methods can help secure information storage, communications, and transactions, as well as enable authentication in an electronic environment. Cryptography is a widely applicable and embeddable technology with many uses complementary to computing and information technology, yet its full promise for information security remains unrealized. After an initial period in which a few prominent patents drew attention, patenting in the field has expanded dramatically. Greater patent density affects developers and users. Such density, sometimes described as a “thicket,” carries with it the potential to chill new technology entrants or innovations. Greater patent density suggests the need for countermeasures such as patent pooling, patent-aware standard setting by firms and the government, and portfolio management of patents. Pooling and patent-aware standard setting help reduce competitive blockage from greater patent density. Companies with patent portfolios can use the portfolio within a pool, or follow the alternative strategy to differentiate their offerings based on the patented technology. To some degree, all these mea-

tures have emerged as cryptography patenting expands. User concerns derive from developer challenges: users lessen their risk by engaging technology providers who can navigate the increasingly patent-dense landscape of applied cryptography.

Patent Basics: Protection for Applied Ideas Implemented in Software

Patent law allows one to protect an applied idea. The patent owner has legal power, through an infringement lawsuit, to stop others from making, using, selling, offering to sell, or importing whatever the patent validly claims.¹ The patent owner can also allege indirect liability, which charges that someone helped a third party do these things.² To understand more about this, and about what makes a patent valid, the next section reviews the life cycle of a patent.

The Life Cycle of a Patent and Its Claims

The patent process starts with an application to the United States Patent and Trademark Office (PTO). Inventors, who must be human persons, not corporate persons, file for a patent at the PTO.³ Although only human inventors can file, typically they assign ownership to a corporation or other institution.

The patent application consists of technical information. Often drawings are included. The PTO has very detailed requirements about the content and structure of the application, but it is usually a document in the range of ten to twenty pages. At the end of the application are the claims.

The claims are the most important part of a patent because they define the scope of the holder's legal right to exclude. Most patents have multiple claims that describe the invention in several different ways. Think of each claim like a facet on a diamond: each provides a different view of the invention. At the same time, however, each claim is somewhat independent from the others. One claim might be deemed valid and others invalid. The first time you read a claim you will find that it has an awkward expression. The reasons for this are historical and functional and beyond this sketch of the patent system.⁴ To briefly illustrate, below is a hypothetical, very broadly written, example of a claim. Some of the key claim language is in ***bold italics***.

Example Hypothetical Patent Claim

A **firewall** for restricting transmission of messages between a first site and a plurality of second sites in accordance with a plurality of administrator selectable policies, **said firewall comprising:**

a **message transfer protocol relay** for causing said messages to be transmitted between said first site and selected ones of said second sites; **and**

a **plurality of policy managers**, responsive to said relay, for enforcing administrator selectable policies, **said policies comprising**

at least a first source/destination policy, at least a first content policy and at least a first virus policy, said policies characterized by a plurality of administrator selectable criteria, and a plurality of administrator selectable exceptions to said criteria,

said **policy managers comprising,**

an access manager for restricting transmission of messages between said first site and said second sites in accordance with **said source/destination policy;**

a content manager for restricting transmission of messages between said first site and said second sites in accordance with **said content policy;** and

a virus manager for restricting transmission of messages between said first site and said second sites in accordance with **said virus policy.**

NOTE: This hypothetical claim is loosely styled after claim 8 of United States Patent No. 6,609,196.

The hypothetical claim above illustrates several important points about patent protection. First, if someone programs and operates a firewall that does what the claim describes, then that person infringes the claim, if the claim is valid. Second, the claim's words matter, a lot. For example, the claim discusses "messages." With this word, a reasonable interpretation (without knowing more about the patent or its history) is that the claim would cover an email firewall or an instant-messaging firewall. The claim could have been written with the term "email message" instead. If so, the claim would have narrower coverage. The narrower "email message" claim probably would not prevail if the patent holder were to sue the seller of an instant-messaging firewall that otherwise fits within the claim's language. Third, the example illustrates the odd, passive, functional, and dry style of writing claims. Along with longstanding legal doctrines for claim interpretation, the style serves to somewhat reduce ambiguity

and helps the claim apply linguistically to as many real-world products and processes as possible.⁵ The owner of an issued patent can enforce the patent until it expires, which occurs about twenty years after the PTO filing date. Also, the owner must pay fees to the PTO to keep the patent in force. These fees become progressively higher. As a result, about half of issued patents are not kept in force after the twelfth year.⁶

Once the PTO issues a patent, it is presumed valid, but the validity of any of its claims can be challenged later during its life. Most validity challenges occur in the context of an infringement suit. The patent owner sues an alleged infringer. The infringer counters with various defenses, one of which is to argue that the asserted claims are invalid. Validity before the PTO, as well as during an infringement suit, depends on five criteria: (1) statutory subject matter; (2) utility; (3) novelty; (4) nonobviousness; and (5) disclosure. The next section explains each of these.

Patent Validity—the Five Criteria for Patentability

A valid patent meets all five criteria set forth above. The PTO initially assesses validity; however, the law expressly allows courts to rule on validity post-issuance. One of the reasons for this review is to account for newly discovered “prior art.” Two of the five criteria, novelty and nonobviousness, are art-based criteria. In rough terms, this means that under these two tests something that existed before the inventor’s date of invention, called prior art, may preclude patent protection.

As a policy matter, precluding patentability for technology in the prior art makes sense: why allow someone a right to exclude others’ use of a technology when the technology already existed? One common justification for the patent system is the quid pro quo of disclosure for the twenty-year exclusive right. The argument is that the quid pro quo creates an incentive to invent and patent. The social benefit arises from the benefits the patent-stimulated technology provides society, and after the patent expires, when the claimed technology falls into the public domain for all to use without account to the patent holder. Augmenting this argument is the notion that the patent system channels intellectual property protection out of trade secrets and into patents. This is thought to be beneficial because technology under trade secret protection may never enter the public domain.⁷ These justifications for the patent system support the policy of precluding patent protection for preexisting technology. No one needs an incentive to invent a technology that already exists. Prior art, via the novelty and nonobviousness criteria, is the mechanism patent law uses to implement this policy choice.

More specifically, prior art is defined by U.S. patent law to include the following: patents and publications anywhere in the world; use of the technology in the United States; knowledge of the technology in the United States by the relevant artisans—that is, those technologists who have ordinary skill in the art; and a few other more exotic forms of prior art beyond this discussion.

The remainder of this section discusses each patentability test in turn. All five are relevant before the PTO and may be relevant in an infringement suit if raised as grounds for invalidity. Two of the five, novelty and nonobviousness, are tests that compare the claims to the prior art. The other three, statutory subject matter (sometimes called patentable subject matter), utility, and disclosure, are also measured against the claims. All five, however, must be satisfied for the patent to be valid.

Statutory Subject Matter Today, the statutory subject matter test presents little trouble for most patent applications.⁸ Initially, though, some questioned whether software fit within statutory subject matter. The law has developed the test into a weak filter, allowing almost all aspects of commerce, including software and business methods, to meet the statutory subject matter requirement.

Like much of patent law, the test starts with words from the federal patent statute, but ends on an interpretation of those words from the federal courts, including the Supreme Court of the United States. To meet the statutory subject matter test, the technology must fit within the following statutory words, which are often grouped into two categories: (1) process or (2) machine, manufacture, or composition of matter.⁹ The shorthand expression is that there are process claims and product claims. A patent can have some of each, or have hybrid claims with elements of both. The statutory language shows why the test has become a weak filter: almost all information processing or business processes can fit within the meaning of the word “process,” and almost all physical items can fit within the words in the product category.¹⁰

While the category of process claims is broad, it is not unlimited. Generally, statutory subject matter excludes laws of nature, natural phenomena, and abstract ideas. Oftentimes mathematical formulas or algorithms fit within one of these categories, particularly the abstract ideas exclusion.¹¹ The mathematical algorithm exception is particularly relevant to software; this exception until recently clouded the question whether, or how, software was properly statutory subject matter. Although the mathematical algorithm exception has been narrowed for software, it has not completely disappeared like the business methods exception. Rather, for software and processes implemented with information

technology, a patented process is not purely a mathematical algorithm when there is something concrete or tangible in its result—that is, when the operations are not merely an abstraction. This is a difficult line to police in practice. Given that most information technology patenting is for applied technology, the mathematical algorithm categorization offers little obstacle to classifying such as statutory subject matter.

Among the five criteria, the statutory subject matter test most blatantly carries a policy judgment about what technology should be subject to patent protection. The statutory words prescribe a domain for patents. This is not to suggest that policy does not underlie the other criteria. But the other four tests are different. They determine whether some advance, once adjudged as qualified subject matter, qualifies for patent protection based on the pre-invention state of the technology and the sufficiency of the applicant's disclosure. In other words, if Congress wanted to exclude software from the patent system, that change would likely be implemented in the statutory subject matter criteria. Such a change, however, is politically inconceivable. The trend is the opposite—a steady expansion of statutory subject matter for dramatic new advances, such as biotechnology and software.

Utility Like statutory subject matter, the utility requirement is easily met. It is sometimes called the usefulness requirement. The federal patent statute authorizes the PTO to issue patents for “useful” inventions. Like the first criterion, statutory subject matter, the utility criterion has developed into an increasingly weak barrier to patent protection. A *de minimis* practical utility will suffice.

The claimed technology must provide some practical, identifiable benefit. The utility need not meet any particular moral or other standards, but the claimed invention must do something to accomplish its described purpose.¹²

The utility criterion joins the statutory subject matter criterion as typically and easily satisfied. Both are broad filters letting a great degree of technology, and even human activity of all sorts, flow into the U.S. patent system for evaluation. The remaining three criteria complete the evaluation, but are not so easily satisfied.

Novelty and Statutory Bars Novelty is one of two patentability criteria based on prior art, the other being nonobviousness. A patent claim must be novel. This means that no single prior art reference anticipates the claim. An item of prior art is often called a “reference.” Thus an article published in a relevant technical journal before the asserted date of invention is a potential prior art reference.

The published article will invalidate a claim as an anticipating prior art reference if the article discloses what the patent claim describes. Thus the novelty requirement implements the common-sense policy notion that the patent system should not grant rights for technology that already exists.¹³

The mere fact that one developed a technology totally unaware that the prior art already disclosed the technology does not help the inventor argue that her patent is valid. Conversely, the independent creation of the technology by someone else after the patent holder's date of invention is no defense to infringement liability. Independent creation *before* such a date, however, may create an invalidity defense—the previously developed technology may constitute prior art that invalidates the patent under the novelty or nonobviousness criteria.

In addition to invalidity via anticipation, within the general topic of novelty there is a second class of patent invalidating events: the statutory bars. The patent statute says that even if no one else has developed the claimed technology before the inventor, the inventor may be prohibited (barred) from using the patent system to protect the technology if the inventor commercializes the technology in particular ways more than one year before filing for a patent.

The most common barring activities include (i) using the claimed technology for commercial ends; (ii) selling or offering to sell the technology; and (iii) publishing the technology. Thus a common barring scenario is that a scientist, excited about a new development, quickly publishes a paper on the discovery. The scientist now faces a one-year clock. She must file for patent protection in the United States before this one-year “grace period” expires or will be forever barred from receiving patent protection for the development.

The statutory bars support two important policies for patent law: promoting prompt disclosure of newly discovered technology, and limiting the period of control over patented technology. The predominant justification for patent protection is that it implements a social bargain in which the inventor gets a limited term of protection and the public receives technology disclosure. That technology eventually falls into the public domain. The statutory bars limit the effective period during which the inventor can control the technology to the statutorily prescribed term of twenty years.¹⁴ The novelty criterion is the first of two art-based criteria for patentability. The second is the requirement that the claimed invention not be obvious to artisans of ordinary skill in the art.

Nonobviousness Even if a patent claim is novel, it still might not warrant patent protection. Patent law has the obviousness test for this assessment. The gist of the test comes from the plain meaning of the word “obvious”: do not grant

the patent right for claimed technology that is obvious. In other words, before granting a patent, the law requires a greater technical advance than a merely trivial or minor improvement. Evaluating obviousness, however, is easier said than done.

To help resolve this problem, patent law compares the claim to the prior art. The comparison is similar to the anticipation test for novelty, but multiple prior art references can work together to invalidate the claim under obviousness.

In novelty and the statutory bars, a single prior art reference must disclose what the claim recites. In other words, the examiner must parse the claim into elements and see if any single reference has all the elements. In obviousness, multiple prior art references can supply the elements. Even if no single reference combines the elements as claimed, the claim might still be invalid if an artisan in the technology would find it obvious to make the claimed combination.¹⁵

By cataloging the most relevant prior art, one takes the first step in evaluating obviousness. The rest of the test is to look at the context of the invention and the typical artisan's skill level with the technology. Also important is whether the prior art suggests the claimed combination or discourages it. (A list of other factors can be used to argue for or against obviousness, but this sketch does not enumerate them all.) Ultimately, when one challenges a claim's validity for obviousness, a fact-finder such as the PTO or a court determines whether the claim is obvious. That challenge can occur anytime during the patent's life. Thus defendants want to find prior art the PTO did not discover during examination of the patent.

Prior art, through the novelty and nonobviousness criteria for patentability, is patent law's bulwark against socially nonproductive patents. The patent right has social costs: it puts exclusionary power in the hands of the holder, who can therefore limit others' use or charge for use of the technology. This has the potential to impede productive activity with the technology. Consequently, society's quid pro quo must demand that the patent right cover a true advance. The law measures that advance against the prior art.

To take this measurement, the patent instrument, a document typically in the range of ten to twenty pages, must recite the claims and describe the context of the invention. This is the topic of the next subsection.

Disclosure The patent instrument ends with the claims, which define the legal right to exclude. The preceding pages, typically a handful to several dozen, support the exclusory right and allow society to benefit from the technology

disclosed in the patent. When the patent expires, it leaves a document that gives no one a right to exclude, but that is significant for its technical content.

Sometimes commercial researchers comb the patent databases along with their review of technical journals and other research sources. In some instances, they do this in order to design around existing patents, but sometimes it is for general research. The U.S. patent system has more than 7 million issued patents at the time of this writing. This creates a vast database of technical information.¹⁶ For this trove to be useful, each patent has to provide sufficient information to allow artisans to practice the claimed technology.

This is one of two important purposes for the disclosure requirement: enabling artisans to make and use the invention. As such, the disclosure requirement has multiple subtests, one of which is “enablement.” Along with a related requirement, the “written description” test, the enablement test determines whether the patent document gives a person of ordinary skill in the technology enough information to make and use the claimed invention without undue experimentation. The other two subtests under the disclosure requirement are “best mode” and “definiteness.” For best mode, the patentee must disclose her best way of practicing the claimed technology, if she has one. The definiteness requirement applies to the claims: they must be sufficiently specific to provide some sense of the boundary of the invention.

Definiteness suggests the other purpose of the disclosure requirement: providing public notice about the patent claim and its scope and applicability. The hope is that companies scan the patent database for legal rights that might disrupt plans to develop or deploy products or technology. For this scanning to work, the patent document must contain definite claims. It must also contain contextual information supporting the claims that allow companies to understand how the patented technology works in order to avoid infringement or to design around it. Society needs to know how it works when the patent expires so that anyone can practice the technology for the benefit it brings.¹⁷

The two purposes of the disclosure criterion for patentability—allowing others to practice the invention and public notice—support the other four criteria and help ensure that society can grasp whatever benefit is available from the technology. The benefit before expiration is through manufacturing and licensing based on the patent and, after expiration, the patent document’s contribution to the public domain. Before expiration, however, there is the possibility of infringement liability.

Patent Enforcement and Infringement Liability

The defining feature of patent protection is the potential (typically not realized) for a claim to have very broad scope. A patent issued by the United States PTO may or may not withstand a validity challenge during litigation. As long as it does, however, depending on how the claims are written, a wide variety of products or services might infringe.

Claim Language and Types of Infringement Using the hypothetical claim from above as an example, a firewall having the claimed elements would infringe whether it ran on a Windows-based computer, or a Linux-kernel-based computer, or a computer without a traditional operating system. In fact, given the language of the claim, the firewall need not run on a computer at all, but could be implemented in hard electronics of the type found in a network switch or router. This is the power of broad, encompassing language in a claim. The example extends to the other elements of the claim: a variety of content policy manager implementations may fit within the claim language. It probably will not matter which programming language (C or Java, for example) was used to write the content policy software.

Patent claims do not always have broad language because the breadth heightens the invalidity risk, particularly from the prior-art-based criteria of patentability (novelty and nonobviousness). This is why patents have multiple claims. Some are written broadly, but others are written narrowly as a “backup plan” in case the broad claims are later found invalid. Claims with narrow language are easier to design around. Assume that the “message transfer protocol relay” element from the claim above instead read as follows: “message transfer protocol relay for the UDP protocol.” Would a firewall that only implemented the relay for the TCP protocol infringe? Not literally, because TCP is not UDP even though both are protocols that rely on the IP layer.

Beyond literal infringement, however, patent law has a second form of infringement called the doctrine of equivalents. Under the doctrine, the TCP system might still infringe, although it does not infringe literally if the accused firewall’s TCP protocol relay performs a substantially similar function, in a substantially similar way, and with a substantially similar result as the claimed UDP protocol relay. This function-way-result test gives the patent holder a greater possibility to successfully sue infringers and enforce the patent. This extra leverage is justified on the policy that without some way to enforce the claims within the penumbra of their language, it is too easy for free-riders to

use the technology by making insubstantial variations that take the implementation outside the literal claim language.

Beyond the distinction between literal infringement and infringement under the doctrine of equivalents, patent infringement has a number of other intricacies. The most relevant are explained below.

Infringement Litigation and Patent Invalidity Risk Patent owners enforce their patents by finding and suing alleged infringers. There is no governmental entity charged with general patent enforcement. When a patent owner sues, she knows that the defendant will try to invalidate the patent. Thus, each time the owner asserts the patent, she risks its validity: a defendant may find prior art that helps invalidate it.

Despite the invalidity risk, some patent owners litigate. The successful litigant can obtain damages payment(s) from infringers for past infringement, and secure a court-ordered injunction against future infringement. Patent law has no “fair use” doctrine like that in copyright law. Nor does it matter if you independently arrived at the technology after the patent was invented.

Although hundreds of thousands of patents issue each year, only about two thousand patent infringement suits are filed each year. The reasons for this are mixed, but an underlying theme is that only a small percentage of patents are truly valuable.¹⁸ Think of a valuable patent as an experienced, battle-scarred warrior. First, its claims must be sufficiently broad to cover the relevant technology. It must have power in the commercial battlefield. Second, it must survive successive invalidity challenges in lawsuit after lawsuit. The longer it survives the more valuable it becomes. The later defendants are more likely to settle because they are aware of the earlier failures to invalidate the patent. Third, owners have an incentive to litigate patents that protect technology underlying a commercial offering, so the mere fact of litigation is a signal that the patent may be valuable.

A variation on the last point is when the patent holder does not manufacture, produce, or provide any product or service based on the patent’s claims. This does not diminish the patent owner’s right to exclude others from practicing what is claimed. What sometimes results is patent-hoarding activity by non-producing entities who hope to find a patent in the portfolio that will become valuable through litigation. Value in this sense is a form of legal extortion: once infringement is adjudged, the infringer, who probably has been sued because its business critically depends on a technology covered by the patent’s claims, must cease producing or pay the patent holder a royalty. This is not a pleasant nego-

tiation for the defendant-infringer. On the other hand, some patent-hoarding entities perform research and seek to license technology upfront to potential users, sometimes with affiliated products, and sometimes without such.

A valuable patent that is an experienced and battle-scarred warrior is, like a soldier, more valuable in a group. Thus, a portfolio of patents gives a company the greatest chance to have some valuable patents. It is a numbers game. Some soldiers are better than others, as are some patents. Competitors in certain industries must have their own portfolio to participate in an intellectual property arms race. Otherwise, without a countervailing threat from their own patent portfolio, their mainline business operations will be at too great a risk of patent infringement.

These are the essential characteristics of patent enforcement and litigation. Claim language is the starting point. Broad language has a greater chance of capturing infringers, but carries a greater risk of invalidity. Competitors can design around overly narrow language unless the doctrine of equivalents helps the patentee assert infringement. Only a small percentage of patents are ever litigated because only a small percentage have any commercial significance. This leads to portfolio models for patent ownership by the most sophisticated users of the system. It also leads to product coverage by multiple patents, including the perhaps amusing example of a paper manufacturer obtaining about thirty patents to cover a new premoistened toilet paper product.¹⁹ These themes manifest in the recent phenomena of patenting for software, business methods, and cryptography.

History of Technology Patents

Historically, the U.S. patent system concerned itself with technology in an industrial setting. This mostly removed the system from many business operations, including planning, marketing, finance, tax, and legal/regulatory compliance. For example, a widget manufacturer in the 1970s might have risked that its product infringed a patent covering widget technology. But the manufacturer did not need to worry about patent infringement by its method of allocating distribution territories, or by its corporate structure with advantageous tax consequences.

Developments in patent law during the 1990s, however, destroyed this insulation. Almost all new and innovative business operations are now subject to at least the theoretical possibility of patent infringement. In conjunction with developments starting in the 1980s affirming that new biotechnologies

are subject to patent protection, since then, the patent domain has swelled well beyond historical boundaries.

The expansion in patent protection for information technology was two-fold. Slowly, the law evolved to give greater recognition to patent protection for software apart from the computers on which it ran, which were patentable from their beginning. Rapidly, in a key case in 1998, the law swept aside a longstanding interpretation that patent protection could not extend to business methods.²⁰ In the pre-computer era, business methods were not related to software. A classic example is a method for accounting, or a technique to demonstrate a product. Only later, when software began to underlie more business operations, did patent law for business methods and for software begin to merge and influence each other.

By 2006, both software and business methods were clearly subject matter qualifying for patent protection. This development allows the owner of a valid patent effective control over the technology described in the patent. A patent could protect software that does not necessarily implement a business method, or protect a business method not implemented in software. Or a patent could protect a business method implemented in part or in whole through software and information technology. This last case is the most common.

The patent holder has the unilateral right to stop someone else's activity or the sale of goods or services that fall within the scope of a valid patent's coverage. Today, for example, if a widget manufacturer's method of allocating distribution territories infringes a valid patent, the patent owner can request that a court issue an injunction prohibiting the manufacturer's use of that method. Similarly, if the manufacturer's tax-advantageous corporate structure infringes a valid patent, the patent owner can extract a remedy, which might require the manufacturer to reorganize. In either case, the patent owner may, but need not, grant the manufacturer a license, with accompanying royalty payments.

This twofold expansion in the patentability of information technology coincided with the rise of mass-market computing, the internet, and increasing business process automation.²¹ Computing morphed from isolated ponds to an ocean. Its huge, new, interconnected undertow churned up a variety of information security and data protection problems.

Cryptography, applied through information technology, holds some promise against these problems. It is not a full remedy, but may be a partial solution, if it can achieve critical mass in deployment.²² Current deployment is spotty but growing. As a technology, cryptography exhibits what economists call "network

effects.” This is not a reference to the computer network, but to the idea that the technology becomes more valuable as more people use it. This “network value” springs from interconnectivity: the more individuals with whom I can communicate are securely using a particular cryptographic implementation, the more valuable that implementation. The value also springs from familiarity: the more individuals who use, and know how to use, an implementation, such as the Pretty Good Privacy (PGP) email cryptography tool,²³ the easier it is for companies to deploy the implementation.

Despite its benefits, applied cryptography is not controversy-free. Some worry that it provides corporate interests, content and entertainment providers, and government too much control over the computing devices and information they hold that are increasingly indispensable to the daily lives of many citizens in the developed world.

As an actively researched and commercialized technology, cryptography has become a field in which developers are patenting their outputs. This follows the general trend. Most information technology research and commercial outputs have seen a dramatic increase in patenting similar to the rise in patenting cryptographic technology. The United States Patent and Trademark Office (PTO) shows only a few hundred patents classified as cryptography technology in the late 1970s. By 2005, the number was an order of magnitude higher.²⁴

For developers, the patentability of cryptographic information technology creates opportunity and risk in the competitive environment: one developer’s risk is that its competitors will grab the opportunity a greater patent domain provides by inventing and patenting or by innovating with patent protected technology.

Users, on the other hand, usually want functionality from cryptography: secure information storage, communications, and content control.²⁵ They want these things without getting caught in a crossfire between developers using patents as bullets.

Cryptography is a versatile, foundation technology with wide applicability. It can hide information in data or implement secure communications.²⁶ The commercial environment for the technology likely has a pyramid structure: at the top, a small number of core developers of the technology (both institutions and individuals); in the middle, a greater number of adopters who deploy the technology via incorporation into other products and technologies; and at the bottom, a potentially vast user base including entities and individuals.

The top two levels are the most likely to obtain patent protection as they develop or deploy cryptography. If the pattern follows other industries with

significant rates of patenting, when companies in the top two levels enforce patents they typically do so against others at those levels, and less so against users. Thus the commercial environment touched by cryptography technology is also touched with the patent hazard: selling or using the technology implies possible infringement risk. The flip side is the patent opportunity: those who obtain valid patents on innovations might be able to extract royalties, control usage, and differentiate their products.

These risks and opportunities for patented cryptography arise because the U.S. patent system is nondiscriminatory. The system operates mostly without exceptions for specific technologies or industries, leaving it up to participants in a technology or industry to determine what and how often to patent. Although the PTO issues patents, it imposes neither quotas nor restrictions based on industrial, technological, or policy preferences. To be sure, there are requirements to obtain a patent, which this chapter discusses below, but these requirements are nondiscriminatory as to industry or technology. The system does not say, for example: there are too many patents for technology related to shoes, so we will limit the number of shoe technology patents or limit the term of these patents.²⁷

Within each industry or technology, many factors influence the rate of patenting and the use of patents. The effect and interaction of these factors, however, is not well understood; nor is there even agreement about what goes on the list of influencing factors. The result is that it is difficult to characterize the reasons for industry-to-industry variances in patent system use.²⁸ In some cases, the use might be ad hoc, and in others it might reflect some type of industrial or technological self-ordering. Regardless, companies in industries and technologies with high patenting rates face a different strategic environment than industries with little patenting.

Patenting for cryptographic technology is on the rise, meaning that corporate information security relying on the technology faces potential patent hazards.²⁹ This fits with the general pattern for software and business method patents.³⁰ Given their relatively recent qualification for patent protection, patenting rates for software and business methods are also rising.³¹ Similarly, interest in cryptography is on the rise, often by corporations that want to secure information and computing resources in an internet age where malware such as worms and viruses can cripple networks.

The resulting policy considerations go beyond general concerns about increased patenting. Cryptography is an embedded technology with many com-

plementary uses for information technology.³² Greater patent density has the potential to affect developers and users. Users increasingly want information security, as long as it is easy to obtain. The individual user's willingness to invest time, attention, or money in information security is easily squelched. Corporate users are increasingly willing to invest, especially as the internet underlies more of their operations.

Developers should make it easy to implement cryptographic solutions for information security problems, but their efforts have greater reach when standards promote interoperability. Users will require developers to manage intellectual property rights for the technology provided.³³ These developer responsibilities are more difficult in a patent-dense technology. Such density is sometimes described as a "thicket" with the potential to chill new technology entrants or innovations. Whether such "thickets" actually chill or not, greater patent density suggests countermeasures among developers such as patent pooling, portfolio management of patents, and patent-aware cooperative standard setting. To some degree, all these measures have emerged as cryptography patenting expands, indicating partial self-ordering among a responsive industry of cryptographic technology providers.

To proceed with these themes, the first section of this chapter sketches the U.S. patent system. Against this background, the next section discusses cryptography patenting and the policy implications arising from increasing patent protection for cryptography applied to information technology. The concluding section emphasizes the strategic and policy implications for developers and users.

Patenting Information Security by Patenting Cryptography?

Cryptography is useful in the context of human communications and information management. Even before we had computers, we had cryptographic ciphers: ways to encode and decode messages and information. Various commercial and social situations suggest a need to keep secrets, or at least to limit information disclosure to those who need to know. In cryptography, the original message or information is called "plaintext" and the encoded message or information is called "ciphertext." A "key" of some sort translates from one to the other.³⁴ Computation, even of the kind before the electronic computer existed, powers the translation.

In principle, computing and information technology revolutionized cryptography. Keys are now much more effective and derived from mathematical precepts that make attempts to translate the ciphertext extremely difficult. Often the attack is effectively impossible, unless one is willing to wait lifetimes for it to

complete successfully. Information technology also opened up many new applications for cryptography. While physical security measures are still important, storing and communicating information with information technology creates new needs to secure the information.

The practical implementation of cryptography, however, often does not fulfill its promise owing to a variety of human and institutional factors.³⁵ First, it is difficult to pervasively embed interoperable cryptography because many competing organizations must agree. Some companies may not even want interoperable cryptography under the logic that their internal communication and data security is better with a proprietary system, perhaps one with features particularly useful to the organization. Second, the opportunity to obtain patent protection allows developers the capability to differentiate their technological offerings, and shelter any resulting competitive advantage during the patent term. Compounding these developer issues (and this is not an exhaustive list) is that users' demand for information security is fickle. There does not seem to be a demand for perfect security, and such a level of information security might be inherently inefficient. Imperfections are readily tolerated, at least until they cause a major problem.

So, users want the computer and the internet (along with the cell phone and the PDA). They want functionality to create documents and content, to share them with others for work or for play, and to communicate. But for some of those communications sometimes users want some magic to secure the information. In this way, cryptography is a mostly embedded technology. A user might have to indicate that she wants to send a secure message or store information to an encrypted hard-drive folder, but she expects the information technology to handle the magic. Cryptography serves that need as part of a larger machine or network that serves us. It can add the pixie dust of information security to information technology.

Where does cryptographic pixie dust come from? From technology developers who either provide an end-to-end solution, or create technology that interoperates with other cryptographic systems to allow a secure system or communication channel. The rest of this chapter therefore focuses on these developers and their patenting activity. The historical pattern of patenting sets the stage for the boom in cryptography patenting in the late 1990s and 2000s.

Cryptography's story includes nonpatent legal issues. The U.S. government controls the export of cryptographic technology.³⁶ Basically, the more effective the cryptographic technology, the more stringently the government regulates

it. The details of the export regulations are beyond this chapter's scope, but cryptography's main public and press notoriety comes from disputes about the extent of this regulation.³⁷ There is a rich literature reviewing the debates, which include concerns by U.S. developers that they will lose market share to foreign cryptography developers. Some foreign countries do not regulate the export of cryptographic technology.

The other nonpatent legal issue is the U.S. government's involvement in de facto standard setting with respect to cryptographic technology. This technology leadership involves both the government's own significant use of cryptography and its broad interest in security for the informational assets that support the economy.³⁸ This governmental role in selecting a cryptography standard for its use appears in the next section, discussing early, yet still important, cryptographic patenting. Ongoing government standard setting also influences patenting effects later.

Pioneer Patents in Modern Cryptography Modern cryptography emerged in the 1970s from new solutions to the key exchange problem for encrypted communications. A cryptographic function, whether complex and implemented in software, or simple and implemented by hand, uses a key to convert plaintext to ciphertext, and to reverse the operation when necessary. When the encryption's only use is to keep data on one's hard drive secret, there is no need to share the key with anyone else. Only the user needs the key when she accesses the data. The purpose of cryptography in that case is to keep anyone else from accessing the protected data. But when users want to communicate over an insecure channel, such as the internet, they can do so by sending ciphertext so long as they each have the key. This creates a chicken-and-egg problem: how does someone send the key, which must be kept secret, to someone with whom he or she has never communicated, when the only channel to that person is insecure?³⁹

The cryptography system that requires both sender and recipient to have the secret key is called "symmetric." The pioneer patents that spawned modern cryptography and gave it applicability to the internet did so by splitting the key into a public part and a private part. This is why the system is called public key cryptography. The sender looks up the recipient's public key (which is available through the internet),⁴⁰ encodes a message with it, sends the resulting ciphertext to the recipient over an insecure channel (such as much of the internet), and the recipient can use her private key to decode the message. The discovery that made public key cryptography possible was how to arrange the mathematics so that it was nearly impossible to derive the private key from

the public key. It is also nearly impossible to derive the plaintext from the ciphertext and the public key. This innovation arrived just as computers were becoming increasingly interconnected in a commercial setting, and becoming sufficiently powerful to quickly solve the equations required by these cryptographic functions.

Two groups secured patent rights related to these innovations. Professor Martin E. Hellman at Stanford University and his graduate students first patented an approach for generating a shared private key for a sender and recipient using communications across an insecure channel. This is called the Diffie-Hellman patent.⁴¹ That same professor and another graduate student also patented the “split” key approach described above. This formed the basis of the public key infrastructure system that underlies much of the internet’s information security apparatus.⁴² This second patent is known as the Hellman-Merkle patent.⁴³ These patents are also known collectively as the “Stanford patents.”

Following in part the work at Stanford, a group of three professors at the Massachusetts Institute of Technology patented an implementation of the public key approach. This patent is known as the RSA patent, each of the letters standing for the first letter of the last name of the three inventors.⁴⁴ The acronym also became the name of a Boston company that is an important provider of information security technology and products.⁴⁵

These three patents are among the pioneer patents of modern cryptography. Another notable pioneer is IBM’s Data Encryption Standard (DES) patent.⁴⁶ This patented cryptographic technology was the U.S. government standard for nonclassified sensitive data for over twenty years, from 1976 to 1997.⁴⁷

The federal government is a big customer. When it specifies a technology as its standard, vendors work to supply products that use the standard. But if the standard is patented, and the patent is held by a third party such as IBM, do all these vendors have patent infringement liability to IBM if they sell products embodying the standard to the government? The answer is yes—unless there is a license.

A license is a permission that acts as a defense in the event of a lawsuit. The simplest example comes from property law: if I pass you a note that says “come into my front yard and let’s play catch,” I will not succeed in suing you for trespassing when you step onto my grass. Your defense is the license, the permission I gave in the note. I granted you permission to violate a right I otherwise have: to exclude you from my property. Your act was technically a

trespass, but one that was licensed. Sometimes the word “license” also means a contract spelling out this permission, along with other promises between the parties.

In the case of DES, the government announced that IBM would grant nonexclusive, royalty-free licenses for use of the standard even if the resulting device, software, or technology infringed the DES patent.⁴⁸ The government needed IBM to do this so that vendors could develop and supply products without fear of patent infringement liability.⁴⁹

Each pioneer patent holds a unique place in modern cryptography’s early history. The DES patent became notorious because it was the government’s standard. There was suspicion that a “back door” existed, a concern that aligned with separate but highly controversial government efforts in the 1990s to promulgate, through a variety of indirect pressures, cryptography technology that gave government access to the decrypting keys for law enforcement.⁵⁰

The RSA patent and the Stanford patents had some commercial activity spring from their technology.⁵¹ In particular, the lineage of the RSA patent led to a primary vendor in the marketplace for cryptographic technology, software, solutions, and systems in 2005.⁵² Unlike the DES patent, the RSA and Stanford patents were not licensed under royalty-free generally applicable terms. As a result, there was some occasional patent litigation between developers and vendors. This litigation tended to follow a pattern in which the pioneer patent holders sought to assert their patents against potential market entrants.⁵³ For a time, the pioneer patents were managed as a “pool”: complimentary technology holders could cross-license the patents and offer all the patents in the pool as a licensing package to others.⁵⁴ The pioneer patents were so broad that they cast an influential shadow across the entire industry.⁵⁵ Even so, there was plenty of room to patent aspects of cryptography, as the next section describes.

The Growth in Cryptography Patenting In raw numbers, cryptography patenting has grown dramatically since the pioneer patents issued. Table 4-1 presents the quantity of patents issued in the United States system over time that are classified to cryptography.

Although the table shows dramatic patenting increases each year, more information would be necessary to understand the numbers in full context. Undoubtedly, the increases are significant in their own right. One wonders, however, how the patenting increase compares to: (i) increases in research and development expenditures for cryptography; (ii) increases in cryptography products introduced; or (iii) increases in cryptography-implementing code

written and/or deployed. Another perspective would be to compare increases in cryptography patenting with increases in all software patenting, or with information technology patenting, during the time frames presented in the table. The goal would be to understand, among other questions, whether the increase in cryptography patenting is simply part of a larger phenomenon, or whether it outpaces the general rise in information technology patenting observed during the 1990s and early 2000s.

This chapter does not take the additional empirical steps suggested in the preceding paragraph. Even without these comparative baselines, the growth in cryptography patenting is fascinating. It illustrates that even with pioneer patents as a backdrop, the patent system allows for significant patenting growth in a technology. The Stanford patents expired in 1997, and the DES and RSA patents expired in 1993 and 2000, respectively.

Even while the pioneer patents were active, there was still room in the field of cryptographic technology for patents to issue. This is in part due to the nature of the patent system. Most of these patents will never be litigated, and thus their validity remains unchallenged after they issue from the PTO. And while the PTO applies the prior-art-based novelty and obviousness criteria, it is well known that PTO examiners spend a relatively small amount of time on each patent application, perhaps one to three dozen hours.

Moreover, applicants can always claim narrowly, which increases the possibility of issuance but decreases the likelihood that the patent will be valuable. As patenting increases in a field of technology, patent attorneys might be heard to say that the prior art in a field is “crowded.” As patent density increases, it can decelerate the rate of patenting because there is now more prior art to overcome for new applicants. This observation may explain in part the smaller increase in cryptographic patenting observed in the period 2000–2004 (as shown in Table 4-1).

The table shows that the number of patents classified to cryptography in most cases at least doubled for each five-year period from 1980 to 2000. There were increases in the next five-year period, 2000 to 2004, but not a doubling in all classes. One cannot total the counts in Table 4-1 to arrive at the number of cryptography patents issued because some of the patents are classified in multiple classes or subclasses, meaning that they would be counted multiple times in the total.⁵⁶ A little investigation and spot checking for the extent of the overlap suggests that the total ranges from 11,000 to 13,000. About 1,000 would have expired by the time of this writing.

The increase in patenting does not appear to have launched an equivalent increase in cryptography patent litigation. The patent infringement suits involving cryptography that persisted long enough to generate a reported opinion from the federal court system number only in the several dozen since the early 1980s.⁵⁷

TABLE 4-1. Patents Linked to Cryptographic Classifications in the U.S. Patent System

<i>Years</i>	<i>Patents in PTO class 380^a</i>	<i>% increase</i>	<i>Patents in PTO class 705^b</i>	<i>% increase</i>	<i>Patents in PTO class 713^c</i>	<i>% increase</i>
1970–1974	0		0		0	
1975–1979	210		9		30	
1980–1984	310	48	54	500	84	180
1985–1989	608	96	131	143	223	165
1990–1994	1,145	88	215	64	583	161
1995–1999	1,809	58	670	212	1,689	190
2000–1004	2,151	19	954	42	3,393	101
Total	6,233		2,033		6,002	

a. U.S. Class 380 includes equipment and processes that (a) conceal or obscure intelligible information by transforming such information so as to make the information unintelligible to a casual or unauthorized recipient, or (b) extract intelligible information from such a concealed representation, including breaking of unknown codes and messages. Class 380 does not include all cryptography, however, because it excludes cryptography in “the specific environments of (a) business data processing or (b) electrical computer or digital processing system support. Such subject matter is classified elsewhere in the classes.” (Class Definitions, Class 380, at 380 1, n.d.) Note that in item (b) the word “support” means technical, internal operational capabilities that enable the computer to function. “Support” does not mean human assistance to help users with the computer or digital processing system.

The search in Class 380 used the following search text in the U.S. PTO’s Advanced Patent Search page, with the years changed accordingly for each entry in the table:

ISD/1/1/1970–12/31/1974 and ccl/380/\$

b. U.S. Class 705 is for data processing and calculation where “the apparatus or method is uniquely designed for or utilized in the practice, administration, or management of an enterprise, or in the processing of financial data.” (Class Definitions, Class 705, at 705 1, n.d.) The search in Class 705 used the following search text to target subclasses related to cryptography in the U.S. PTO’s Advanced Patent Search page, with the years changed accordingly for each entry in the table:

ISD/1/1/1970–12/31/1974 and (ccl/705/5? or ccl/705/6? or ccl/705/7? or ccl/705/8?)

c. U.S. Class 713 is for the internal aspects of electrical computers and digital processing systems, including items such as memory management, hardware interfacing, and system security and protection. (Class Definitions, Class 713, at 713 1, n.d.) The search in Class 713 used this search text to target subclasses related to cryptography in the U.S. PTO’s Advanced Patent Search page, with the years changed accordingly for each entry in the table:

ISD/1/1/1970–12/31/1974 and (ccl/713/15\$ or ccl/713/16\$ or ccl/713/17\$ or ccl/713/18\$ or ccl/713/19\$ or ccl/713/20\$)

The character of these patent infringement suits is typical of patent litigation generally: developers suing other developers and/or their distributors. In other words, it is likely that only a small percentage of the commercial disputes among cryptography technology providers resulted in a patent infringement suit. This assumes many more disputes than suits, but if the logic is correct, the most likely explanation is twofold. First, parties are probably willing to license their technology, perhaps to help promote user adoption of the technology. Second, perhaps developers can readily patent around the existing patents. This second explanation is especially plausible when an entire field of technology is growing and many practical advances are occurring to apply the principles in a wide variety of technological contexts.

For example, just because the pioneer patents discussed issues related to cryptographic keys does not mean that there are not many opportunities to claim new inventions for keys. A search in the U.S. PTO's patent database at the time of this writing for patents in the general cryptography class (denoted with the number 380) with the word roots "key" and "manage" in the patent title returns seventy-two results, with issue dates beginning in 1995 and running through 2005.⁵⁸

Responses to Increased Cryptographic Patent Density The PTO's classification scheme for cryptography highlights its embeddable characteristic and effectively optional nature for most systems where it might be embedded. The broad cryptography class, number 380, excludes two classes, 705 and 713, where cryptography is, respectively, embedded in enterprise information technology or in a computer or its operating system. By total patent classifications in Table 4-1, the patents issued and classified for the embedded classifications probably outnumber those in the general class, assuming that the overlap due to patents with multiple classifications does not upend this estimation.

The embeddable nature of cryptography, however, is more pronounced than this comparison suggests: the technology is usually deployed as part of a larger system for communications, computing, or entertainment delivery. For example, personal computers and notebook computers can now contain internal smartcard readers for reading a smartcard that might hold cryptographic key information and perform some information security functions. Just because cryptography can be embedded, however, does not mean that it always is: information technology systems provide plenty of value without the high degree of information security modern cryptography promises. Their use

has grown even in the face of spotty and incomplete information security, and while patenting for information security is on the rise.

Strategic or competitive policy responses to increased patenting should keep in mind the challenge of gaining critical mass with an embedded technology with wide applicability. An embedded component of a larger system can infringe a patent claiming only the component. Thus, for example, if a patent claim covers a smartcard interface method, a smartcard with the method implemented in its software would infringe. However, a notebook computer would also infringe if it practiced the method. A patent can have a laser-beam focus, targeting some small component of an overall system or device. But if making, using, or selling that component is patent infringement, then making, using, or selling the entire system or device is also infringement. If the component is critical to the overall system or device, the patent can inhibit the entirety even though its claims cover only the component. Patent attorneys sometimes state this result as follows: adding extra “elements” to a device that satisfies the claim does not avoid infringement of the claim.

There are several related vehicles to minimize patents in the product development and deployment landscape and minimize the patent risk for embedded cryptographic components: patent pools; privately governed patent-aware standard setting organizations; and patent-aware government-driven standards. Cryptography has seen all three. The pioneer patents were managed as a patent pool during the early 1990s.⁵⁹ In this arrangement, each company in a group of companies agrees to allow the others in the group to use their patents under a cross-licensing arrangement.⁶⁰ The entire pool is sometimes available to others to license, perhaps by joining the group or pool, or perhaps at arm’s length.⁶¹

Standard-setting organizations are closely related to patent pools. Depending on how the standard-setting organization deals with intellectual property, it may create mechanisms similar to patent pools by clearing a zone, defined by the standard, where competing developers can operate without fear of patent infringement liability from organization members. Smart policy demands that practicing the standard does not infringe any patents, or at least does not infringe any patents held by those organizations associated with, or who helped form, the standard. Within computing generally there is a widely observed variety in how such organizations deal with intellectual property: some organizations have done a good job setting ground rules upfront for patents, while others have not, sometimes to the detriment of the standard-setting effort.⁶² Good ground rules typically require standard-setting patent holders to commit in

advance to at least reasonable and nondiscriminatory (RAND) licensing terms, as well as perhaps identify all the patents that might cover the standard.

A recent example of private standard setting for embedded cryptographic functionality is the trusted computing initiative. The Trusted Computing Group (TCG) formed in 2003 to develop a secure PC architecture.⁶³ From this effort, personal computers became available with Trusted Platform Module (TPM) security chips.⁶⁴ TCG requires RAND licensing from its members.⁶⁵

The cryptographic capabilities in TPM arose from critical mass in both demand-side need and supply-side feasibility. For the TCG, intellectual property management facilitated the supply-side feasibility. As a consortium of hundreds of companies, the TCG founding members had to decide *ex ante* how to deal with intellectual property rights, including patent rights. The TCG operates as a nonprofit corporation. Its bylaws prescribe patent licensing conditions for member companies. The consortium's goal is to develop a private standard with sufficient market potential to create a bandwagon effect: many companies build to the standard so user adoption reaches critical mass with network economies. To do this, each member agrees to license any patented technology it contributes. They must grant licenses appropriate for the field of use as it maps to the consortium's standard. Also, when additions to the TCG specifications come from other members, each member has a review period: if a member does not withdraw from the organization, it is agreeing to license any patent claims that would be covered. Thus the TCG's bylaws implement a type of patent pool. It is a standard-setting organization with an embedded patent pool guarantee.

Besides recently established standards organizations like the TCG, there are a number of longstanding industry association standardizing efforts. Within cryptography, one prominent organization is the Institute of Electrical and Electronics Engineers (IEEE). Standard setting by the IEEE (or other industry associations)⁶⁶ needs patent-aware mechanisms similar to those illustrated in the discussion about TCG. Even government-promulgated standards must pay attention to patent law.

One of the pioneer patents, IBM's DES patent, was the government standard for nonclassified data for about twenty years. In the late 1990s the National Institute of Standards and Technology (NIST) ran a competition for a new standard, which it called the Advanced Encryption Standard (AES). Its new standard became effective in 2001, specifying the Rijndael algorithm.⁶⁷ The Rijndael algorithm was not believed to be covered by any patents, and the cryp-

tographers who submitted the algorithm did not desire patent protection for it. In addition, the NIST had the following to say about patents:

NIST reminds all interested parties that the adoption of AES is being conducted as an open standards-setting activity. Specifically, NIST has requested that all interested parties identify to NIST any patents or inventions that may be required for the use of AES. NIST hereby gives public notice that it may seek redress under the antitrust laws of the United States against any party in the future who might seek to exercise patent rights against any user of AES that have not been disclosed to NIST in response to this request for information.⁶⁸

The AES efforts led to a significant number of companies embedding their products with the AES algorithm and submitting their implementation to the government for conformity testing. Thus the AES program not only promulgates a patent-aware open standard, it provides a certification for vendors who wish to prove that their implementation works according to the standard.⁶⁹ The number of certified implementations totals over 250 at the time of this writing. Certification was more plausible for vendors because they did not have to be as concerned with patent infringement risk for the AES algorithm. In this way, the government's patent-aware standard-setting activity virtually eliminated patent risk for the core algorithm, enabling developers to compete on nonpatent benefits. It is also plausible that the winning algorithm's anti-patent stance helped it in the NIST evaluation.

In patent pooling and in private or public standard-setting efforts, patents influence the competitive environment, but these mechanisms can ameliorate direct blocking effects. In other words, while patents cast a shadow on industrial self-ordering, they might not, under a patent-aware open standard or a patent pool, prohibit technology deployment by those in the pool or subscribing to the standard.

In the future, free and open source software sharing and collaborative development techniques may also engender these effects for cryptography. Open source software is a copyright-based licensing system. It requires that those who distribute such software ensure its free and open nature by not charging a royalty and by making the source code available.⁷⁰ While open source software may have patent liability like any other technology, the exposed source code is prior art that can inhibit future patent density. Open source software can help the prior art for some programming technology become "crowded," which makes future patenting more difficult, or produces narrower patents in the future.⁷¹

The free and open source software movement has already indirectly influenced cryptography patenting. IBM is the leading patent holder of United States patents. In the early 2000s, IBM embraced the GNU/Linux operating system and generally converted to certain aspects of the open source software movement. The move was not altruistic. Open source software is complementary to IBM's hardware and service offerings. GNU/Linux is a more standardized and affordable operating system than IBM's proprietary version of UNIX, and this makes IBM's offerings more competitive. Owing to its immersion in free and open source philosophy, however, IBM reevaluated which patents in its portfolio should be leveraged for product differentiation and which ones should be contributed, royalty-free, to support open standards and open source software: in early 2005 it decided to make hundreds of patents freely available for use by others.⁷² It also pledged that any future patent contributions to an important information technology standard-setting organization, the Organization for the Advancement of Structured Information Standards (OASIS), would be freely available. The free and open source community applauded this move because freely available patents are viewed as better than patents available under RAND licensing terms (although for the free and open source software movement, not better than being patent-free). OASIS is the source of a number of technical standards in the forefront of cryptography.⁷³ IBM saw benefits in helping clear the patent-dense field for cryptography to obtain critical mass, and these benefits must have outweighed any potential benefit of following a product differentiation strategy with the contributed patents.

Not all companies have IBM's business mix, however, so some will choose the alternative to these cooperative approaches: product differentiation using patents. Companies sometimes base marketing claims on the fact that a "product is patented"—which really means that the company owns patent(s) with claims that presumably cover the product. Touting the patent(s) as a marketing benefit is not the only way to use them competitively: competitors risk infringement if their designs fall within the claim language. Some technology developers use portfolios of patents to create a buffer zone around a new product where competitors perceive risk to enter. One or two patents is usually a weaker buffer zone than a handful or dozen(s) of patents.⁷⁴ In cryptography, some companies are following the portfolio approach to technology differentiation.⁷⁵ This is typically effective when vendors already have significant market share and can license a portfolio that comprehensively covers an important technological strand or covers a user function end-to-end.

While many companies both in cryptography and in other fields build patent portfolios, there is no consensus on what ultimate effect this produces. Proffered explanations range from shielding future in-house product development and innovation, to having the portfolio available for cross-licensing in a patent pool or standard-setting organization, to defensive patenting where the portfolio is an arsenal in the case of a patent litigation war.⁷⁶ Portfolio building will also “crowd” the prior art, making it more difficult for new entrants to both obtain broad patents and design around existing patents, unless the new company has a truly unique technological advance.

Conclusion

Cryptography patenting has produced collaborative responses in pooling and standard setting, and differentiating responses with portfolio building. Sometimes the two responses combine: a developer may build a portfolio for a differentiation strategy, but later decide to place the portfolio into a pool or offer it as a standard.

This reflects a vibrancy and dynamism in the field as developers perceive a growing market and try to meet the information security needs of individual and corporate users. Corporate users and even individual users have a heightened appreciation of the need for information security, even if individuals tend to do little to improve the security of their own information. Increased patenting is a marketplace fact for this embeddable technology. Given that cryptography’s primary uses are in communications and information storage and delivery, it needs critical mass for greatest effect. Critical mass on the internet comes from the interoperability of standards and the resulting beneficial network economies from greater use.

The patent challenge to embedding cryptography is unlikely to go away. New responses, such as approaches based on open source software collaboration, may provide additional options for the future. Even as these take hold, the new patent landscape for software and business methods that took shape in the late 1990s continues to swell the patent rolls. No amount of information security will hide that fact.

5 Information Security and Trade Secrets

Dangers from the Inside:

Employees as Threats to Trade Secrets

Elizabeth A. Rowe

THE PHRASE “data security” tends to conjure up thoughts of hackers and viruses invading computers. The most likely threat, however, is often overlooked. The biggest information security threats to a company’s trade secrets originate inside the company, with its employees. Put in criminal terminology, employees often have the motive and the opportunity that outsiders lack.¹ Employees usually have legal access to trade secret information by virtue of their employment relationship and can take advantage of that access to misappropriate trade secrets, especially when they become dissatisfied with their employers.

Losses due to theft of proprietary information can potentially cost companies millions of dollars annually,² but the nonfinancial costs are even more significant but harder to quantify. The loss of a trade secret is particularly devastating because a trade secret once lost is lost forever. The widespread availability and use of computers, together with an overall decline in employee loyalty, provides fertile ground for the dissemination of trade secrets. Examples abound of employees who have either stolen trade secrets for their own or a new employer’s benefit, or have destroyed them completely by disclosing them over the internet. Recent statistics indicate that the large majority of information and computer crimes are committed by employees.³ This chapter provides some brief background on trade secret law, presents examples of disclosures that have occurred using computers, and ends with some lessons to trade secret owners.

What Is a Trade Secret?

In a nutshell, any information that is secret and derives value from its secrecy can be a trade secret. There is no federal statutory law governing trade secrets; trade secrets are protected by state law. Most states have adopted the Uniform Trade Secrets Act (UTSA),⁴ which provides some uniformity in defining trade secrets and trade secret misappropriation. The states that have not adopted the UTSA tend to rely on common law, based on the Restatement of Torts.⁵ Most courts appear to rely on the definitions in the UTSA or in the Restatement of Torts.⁶

What Can Be a Trade Secret

Under the UTSA, a trade secret may take many different forms, and almost anything of competitive value to a company can be a trade secret. In general, the key to transforming valuable information into a trade secret is to keep it secret. The owner of a trade secret is required to take reasonable precautions to maintain its secrecy. Accordingly, a wide range of confidential business information, including customer lists, sales records, pricing information, and customer information such as sales volume, prospective future business, special needs of customers, supplier lists, and profitability, can be protected trade secrets. However, this broad array of information must still not be disclosed to third parties and not generally known in the trade in order to qualify for protection.⁷ Some jurisdictions have also granted trade secret protection to secret contract terms, marketing strategies, and industry studies. Further, under the UTSA, a trade secret does not need to be in use to be protected; protection can be preemptive in cases of threatened disclosure,⁸ and negative information⁹ (comprising failed research or an ineffective process) is also protected.¹⁰

Misappropriation

According to the UTSA, misappropriation occurs when a trade secret is acquired by a person who knows (or has reason to know) that the trade secret was attained through improper means.¹¹ “Improper means” under the UTSA includes theft, bribery, misrepresentation, breach or inducement of a breach of a duty to maintain secrecy, or espionage through electronic or other means.¹² Disclosure by persons who knew or had reason to know that their knowledge of the trade secret was acquired or derived from one who either used improper means to acquire it or owed a duty to the person seeking relief to maintain its secrecy also is considered misappropriation.¹³ Thus a wide range of activities by employees, as the cases below will reveal, can constitute misappropriation.

An employer who has been harmed may have misappropriation claims, including civil claims and criminal penalties against the employee. However, these remedies may be unsatisfactory and unable to fully redress the devastating harm resulting from the loss of a trade secret. Most employees, for instance, do not have deep pockets, limiting the amount of financial restitution available to cure the misappropriation.

An even more serious problem, though, is that if the trade secret information passes into the hands of a third party, such as a competitor or the press, the trade secret owner may not have any recourse against the third party or any ability to stop the dissemination or use.¹⁴ This harsh reality is due to the fact that trade secret law protects only secret information. Accordingly, a third party who obtains what may have once been trade secret information over the internet is entitled to freely use the information, assuming that she did not employ improper means to obtain the trade secret, has no knowledge that it was obtained by improper means, and is not bound by any contractual or special relationship with the trade secret owner.¹⁵

The Confidential Nature of the Employer/Employee Relationship

The general rule is that the employee stands in a confidential relationship with his or her employer with respect to the employer's confidences.¹⁶ An employee's duty not to disclose the secrets of her employer may arise from an express contract or may be implied by the confidential relationship that exists between the employer and employee, and an employee may not use this secret information to the detriment of her employer.¹⁷ The courts have made clear that this protection applies to an employer's trade secrets even after the employee no longer works for the employer.¹⁸

Duty of Loyalty

Some courts view the employee's duty of confidentiality to the employer as a fiduciary obligation.¹⁹ While working for the employer, the employee has a duty of loyalty to the employer and consequently must not behave in any manner that would be harmful to the employer.²⁰

Nondisclosure Agreements

In addition to common-law confidentiality obligations, many employers will condition hiring, especially for higher-level employees, on an agreement acknowledging that the employment creates a relationship of confidence and

trust with respect to confidential information. Confidential information may be broadly defined in these agreements to include trade secrets as well as other proprietary business information.

Such confidentiality agreements express in writing the common-law obligation of an employee to maintain the confidential nature of the employer-employee relationship. On a more practical level, confidential agreements are helpful for (i) delineating the confidentiality expectations between the employer and employee; (ii) showing that the employer takes trade secret protection seriously; and (iii) demonstrating the employer's reasonable efforts to maintain the secrecy of his or her confidential information.²¹ Employees typically do not need to provide additional consideration for nondisclosure agreements, employees usually are not hesitant to sign nondisclosure agreements (unlike noncompetition agreements). Accordingly, most employers should consider nondisclosure agreements a mandatory part of their security program.

Rise of Computer Use in the Workplace and a Decline in Loyalty

Computers are present in virtually every workplace. A reported 77 million people use a computer at work. Employees most often use computers to access the internet or to communicate by email.²² The wide use of computers in workplaces and the ensuing ease with which trade secrets can be misused and disseminated over the internet provide one explanation for the threat to employers' trade secrets. Coupled with technological advances, however, is an even more powerful nontechnological phenomenon—the decline of loyalty in the workplace.²³ It is no wonder, then, that the opportunity created by computers, combined with the motivation to be unfaithful to an employer, has led to the prevalence of employees disclosing trade secrets.

The decline in loyalty stems in part from the changing nature of expectations in the workplace, particularly the lack of job security.²⁴ For instance, the expectation of long-term employment until retirement with any company is a thing of the past.²⁵ Instead, there has been an increase in the use of temporary employees, part-timers, and independent contractors.²⁶ Even among full-time employees, most change jobs several times over the span of their career.²⁷ That mobility, in itself, creates more opportunities for employees to transfer trade secrets to new employers or to their own competing ventures.²⁸ Furthermore, dissatisfied and angry employees are more likely to leave their companies quietly without discussing their departure with their employers, fueling the likelihood of misappropriation in the process.²⁹

Dangerous Disclosures

Theft of trade secrets by insiders of an organization is far more prevalent than theft by outsiders.³⁰ As the examples below reveal, employees can either use or disclose the trade secrets themselves or convey them to third parties, who in turn publish them or otherwise make use of them. A trade secret owner may then have misappropriation claims against those who use the information privately or divulge it to their new employers. However, blatant public disclosures over the internet cause the most damage and generally leave a trade secret owner with very little recourse.³¹ As the following examples demonstrate, preventing trade secret disclosures and obtaining recourse after an instance of disclosure present significant challenges for employers.

Examples of Private Disclosures

The Kodak Corporation had a process designed to enhance the speed and the quality of film manufacture, known as the 401 machine. Kodak undertook steps to protect the secrecy of the 401 machine.³² It compartmentalized and restricted information on the process to relatively few employees; only a handful of employees were provided information on the process on a need-to-know basis.³³

Harold Worden was one of the few employees who had access to all of the information on the process.³⁴ He used his authority to secretly acquire the important details about the process, even attending an internal company debate over whether to keep the 401 machine a trade secret or file for patent protection. After leaving Kodak, he tried to offer the trade secret information to Kodak's competitors. His plan was eventually thwarted by an FBI sting operation, but before that he was nonetheless successful in transferring Kodak trade secret information related to the 401 machine to Kodak's competitors.³⁵

In another example, a researcher who was responsible for developing and manufacturing veterinary diagnostic kits for IDEXX became dissatisfied with her job and began to consider leaving the company. As part of her plan to find new employment, she exchanged emails with a competitor who tried to lure her with promises of potential employment opportunities. During her email exchanges she disclosed proprietary information and transmitted software and computer files containing a variety of IDEXX trade secrets. Ironically, her activities were discovered only after she accidentally sent her supervisor one of the emails meant for the competitor. Her employer's discovery was especially fortuitous because she had resigned from the company the day before she in-

advertently sent the email to her supervisor.³⁶ Absent her mistake, it is very unlikely that she would have been caught.

In a final example, a research chemist at Avery Dennison, unbeknownst to his employer, started consulting with a competitor in Taiwan. He visited the competitor's operations and provided seminars to the competitor's employees. Over a period of several years he transferred trade secret information about Avery Dennison and its manufacturing processes to the competitor.³⁷ His activities came to an abrupt end when he appeared on a hidden video camera burglarizing the files of one of his superiors.³⁸ After he was discovered, he helped the FBI to apprehend the competitor in Taiwan by arranging a meeting in a hotel room under the pretense of turning over more confidential information. During the videotaped encounter, the competitor was shown tearing off the "confidential" stamps on the information, which he was later arrested for misappropriating.³⁹

Examples of Public Disclosures

While the preceding examples involved employee disclosures to competitors where injunctions could potentially have been helpful to stem use and dissemination of the trade secrets, not all misappropriation cases end as well.⁴⁰ When an insider publishes a trade secret on the internet, the consequences are often dire. Once the trade secret becomes public, the trade secret owner may be rendered powerless to stop third parties, including competitors, from using it, and also faces the complete loss of trade secret status.

In *Religious Technology Center v. Lerma*, a disgruntled former member of the Church of Scientology published documents taken from a court record on the internet.⁴¹ The Church of Scientology considered these documents to be trade secrets and sued the former employee, Lerma, to enjoin him from disseminating the alleged trade secrets.⁴² The court refused to issue the injunction, though, because by the time the church sought the injunction, the documents no longer qualified as trade secrets. The court explicitly stated that "once a trade secret is posted on the Internet, it is effectively part of the public domain, impossible to retrieve."⁴³

In another Scientology case, the church sought an injunction against another disgruntled former member who posted church writings on several USENET groups. Examining the church's claim that the writings were trade secrets, the court stated that while the defendant could not rely on his own improper posting of the writings to the internet to support the argument that the writings were no longer secrets, evidence that an unrelated third party posted

them would result in a loss of secrecy and a loss of trade secret rights. Despite being “troubled by the notion that any Internet user . . . can destroy valuable intellectual property rights by posting them over the Internet,” the court held that since the writings were posted on the internet, they were widely available to the relevant public and there was no trade secret right available to support an injunction.⁴⁴

In *Ford Motor Co. v. Lane*, the defendant, Lane, operated a website that contained news about Ford and its products. Because of the site, Lane received confidential Ford documents from an anonymous source and initially agreed not to disclose most of the information. However, Lane eventually published some of these documents on his website relating to the quality of Ford’s products, thinking that the public had a right to know. He did so despite knowing that the documents were confidential. Ford sought a restraining order to prevent publication of the documents, claiming the documents were trade secrets. Ultimately, however, Lane’s First Amendment defense prevailed, with the court reasoning that an injunction to prevent Lane from publishing trade secrets would be an unconstitutional prior restraint on speech.⁴⁵

Lessons for Trade Secret Owners

The lesson to trade secret owners from these cases is that they must be vigilant and proactive in maintaining and protecting their trade secrets. More specifically, a corporate security program cannot overlook the threat posed by employees to trade secrets. Vigilance is an ongoing process that requires comprehensive security measures. Granted, viewing employees simultaneously as valued members of the corporate family and as threats to the company’s trade secrets can be a delicate balancing act. Yet, considering the risks objectively, it would not be prudent to overestimate employee loyalty and trustworthiness. In addition to the high risks associated with blind trust, from the standpoint of trade secret law the employer would not be taking a “reasonable step” to protect his or her trade secrets if the employee threat were ignored or not effectively addressed.

Employers should consider establishing and implementing trade secret protection programs tailored to their specific needs. The first step in implementing any such program is to identify the specific information that qualifies as a trade secret. The second step will involve efforts to maintain secrecy of the information. It is with this step that the threat posed by employees should be asserted and addressed. The options available to employers are varied and will depend on the organization.

Computer monitoring of employees is one option available to employers who wish to keep a close eye on their trade secrets.⁴⁶ Employers may engage in various levels of employee computer monitoring that range from tracking keystrokes to monitoring emails, as long as they provide notice to employees that they are subject to such monitoring.⁴⁷ The decision to monitor must be balanced against the need to maintain a workplace where employees feel comfortable and are thus able to be productive.⁴⁸ It is also important to establish clear policies regarding personal use of computers for email and other internet activities.⁴⁹ Employers should also be mindful of their policies governing telecommuting employees and should try to restrict other employees whose work outside of the office permits access to trade secrets.⁵⁰ Finally, and of great import, employers should monitor the internet for potential breaches of their security programs and disclosures of their trade secrets, and be prepared to address any disclosures.

Conclusion

While employees have a duty of loyalty to their employers, including a duty not to misappropriate trade secrets, the duty alone is insufficient to safeguard trade secrets. Computers provide ready access to trade secrets and even easier means to disseminate those secrets. Adding fuel to the fire is the fact that because most computer crimes are committed by employees, most employers' can no longer reasonably expect loyalty from their employees. Accordingly, any employer would be remiss in excluding employees from trade secret protection programs.

6 Information Security of Health Data

Electronic Health Information Security and Privacy

Sharona Hoffman and Andy Podgurski

IN RECENT YEARS there has been a surge of interest in health information technology (HIT) and the computerization of health data. In 2004, President George W. Bush announced a plan to computerize all Americans' health records by 2014 and to establish a National Health Information Network (NHIN). Several congressional bills have proposed measures to promote HIT, and numerous states have undertaken legislative initiatives. These include the establishment of HIT commissions, the development of HIT studies, and the setting of target dates for the adoption of electronic health records (EHR) systems.

The advantages of health data computerization are numerous and go far beyond speed and efficiency. While health insurers, health care clearinghouses, and other parties may find it useful to process health information electronically, HIT may be of greatest benefit in the health care provider setting. EHR systems can lead to better medical outcomes, save lives, promote efficiency, and reduce costs.¹ Physicians using EHRs can conduct electronic searches for patients' medical histories, drugs, allergies, and other information and need not look through voluminous paper files for documents that could be misplaced, missing, or illegible. EHR systems can provide clinical alerts and reminders concerning routine tests, medication renewals, or allergies. They can also provide decision support in the form of suggested diagnostic procedures, diagnoses, and treatment plans, as well as links to medical literature. Some EHR systems feature computerized physician order entry mechanisms that enable doctors to transmit prescriptions directly to pharmacies and that alert doctors

to dangers such as potential dosage errors or drug interactions.² Ideally, EHR systems should also be interoperable so that patient records can be transmitted electronically to physicians in different locations or in different networks.³ Thus, for example, emergency room physicians would not have to treat patients without access to their medical histories contained in files that are stored elsewhere. Electronically available information can be safety-critical because it might inform emergency room physicians who are treating an unconscious patient that the individual could have a deadly reaction to a particular antibiotic or to the dye used to conduct a scan.

Unfortunately, many of the attributes that make HIT beneficial also create serious risks to the confidentiality, integrity, and availability of the data. Very large amounts of electronic health information can be processed by small organizations or individuals who do not have the expertise or resources to protect the data. The internet also provides a conduit for rapid and uncontrolled dispersion of illicitly obtained private health information, with far-reaching consequences to the unsuspecting victims. Without proper safeguards, EHR systems can be vulnerable to hacking, data leaks, and other intentional and inadvertent security breaches.

This chapter analyzes electronic health data security vulnerabilities and the legal framework that has been established to address them. We describe the wide-ranging threats to health information security and the harms that security breaches can produce. Some of the threats arise from sources that are internal to organizations, including irresponsible or malicious employees, while other threats are external, such as hackers and data miners. The harms associated with improper disclosure of private medical data can include medical identity theft, blackmail, public humiliation, medical mistakes, discrimination, and loss of financial, employment, and other opportunities.

In order to protect the privacy and security of medical records through federal regulations, the U.S. Department of Health and Human Services enacted the Health Insurance Portability and Accountability Act (HIPAA) Privacy and Security Rules. The Security Rule specifically addresses computerized medical data, requiring the implementation of administrative, physical, and technical safeguards for its storage and transmission.⁴ However, the federal regulations suffer from significant gaps and shortcomings, which this chapter critiques. We also discuss other federal laws, state laws, and common-law causes of action that address patient privacy rights and health information security. Finally, we offer recommendations for improving safeguards for electronically processed health records.

The Prevalence of Electronic Health Information

Numerous parties possess health information that is stored in electronic form. Most obviously, such information is used by health care providers. A fall 2006 survey by the American Hospital Association found that 68 percent of hospitals in the United States had fully or partially implemented EHR systems.⁵ A 2005 study concluded that approximately 24 percent of physicians in ambulatory settings used EHRs.⁶

Another form of electronic health information, the personal health record (PHR), is gaining popularity. PHRs are databases of medical and claims information that can be accessed and controlled by patients themselves. They enable patients to record, store, and transmit their health information to doctors and hospitals and to conduct other functions, such as risk assessments and wellness planning.⁷ Some PHRs can also incorporate data provided directly by doctors, hospitals, laboratories, and others. The first online PHR service was initiated by WebMD in 1999. Currently, PHRs are offered by physician practices, hospitals, health insurers, drug companies, employers such as Wal-Mart, Intel, British Petroleum (BP), and other companies. Some software giants, including Google and Microsoft, are also reportedly contemplating entering the PHR market.

Health insurers selling individual policies, life insurers, disability insurers, and long-term care insurers also use health information to process claims and to evaluate the coverage eligibility and risk status of potential customers. In addition, employers often conduct pre-placement testing of newly hired employees and continue requiring employees to undergo drug testing and other medical examinations throughout their tenure. Employers may be interested in employee health not only for benevolent reasons but also because of concerns about absenteeism, productivity, and the cost of supplying the workforce with health insurance. Many employee medical records are stored on computers.

Marketers and advertisers of drugs and devices may wish to develop databases with information concerning patients who need particular products and doctors who prescribe various treatments so that they can effectively tailor their advertising materials and target receptive customers. Several electronic databases sell lists of persons suffering from particular ailments and compilations of physicians' prescribing records to pharmaceutical companies that use them for marketing purposes.⁸

Various websites sell prescription and nonprescription medications or dispense medical advice online. Others offer medical assessments to those who answer particular health inquiries. Drugstore.com, for example, allows patients

to fill prescriptions and to purchase health and beauty products through its website and collects personal and billing information in order to ship the merchandise. The Cleveland Clinic allows patients to make appointments online as well as to chat online by submitting questions electronically to a nurse.⁹ HealthStatus.com offers users assessments of their cardiac-disease risk, diabetes risk, and other health risks.¹⁰ ClinicalTrials.gov invites patients to register for email updates regarding clinical trials in which they might participate.¹¹ All of the personal information submitted to these websites is vulnerable to security breaches if it is not adequately protected. In addition, many websites track users and the pages they have visited through “cookies,” or encoded messages stored by web servers on web browsers. These enable websites to create user profiles that identify the services, products, and information sought by each visitor and to deliver specially tailored information to users based on their previous website activities.¹²

Electronic Health Information Security Vulnerabilities

The threats to electronic health information (EHI) security are numerous, and the press abounds with stories of security violations. EHI confidentiality could be compromised because of actions or omissions on the part of an entity’s own employees or external parties who engage in either intentional wrongdoing or unintentional carelessness.

Ensuring the security of a computer system is an extremely challenging task. Operating systems and many application programs are very complex, consisting of millions of lines of program code developed and modified by hundreds of programmers over the course of years. It is common for such software to contain unknown defects and security vulnerabilities, even after years of use. Connecting computers via a network multiplies overall system complexity while creating new avenues of attack. Much older software was designed without regard for network security. Computer hackers are often able to discover and exploit vulnerabilities by violating the basic assumptions of designers about how their systems will be used. Many hackers are experts in arcane details of system implementation that few professional programmers know about. Hackers exploit the internet to launch attacks, share information with each other, and enlist help in perpetrating attacks. The nature of the internet makes it easy for them to conceal their identities and even to masquerade as legitimate users of a system. Security can also be compromised by mistakes in system configuration and administration and by failure to promptly install

security updates to software. Finally, the human users of a computer system are often vulnerable to “social engineering,” in which someone who wishes to attack the system contacts them and, taking advantage of their good nature, dupes them into revealing a password or other sensitive information.

Incidents of security violations have involved the theft of computers, sale of used computers without appropriate expunging of data, hacking, inadvertent disclosure of confidential data, and deliberate misuse of information by those with access to it. For example, an unencrypted disc containing the EHI of 75,000 members of Empire Blue Cross and Blue Shield in New York was lost in March of 2007.¹³ Similarly, on April 26, 2006, Aetna announced that a laptop computer containing EHI for 38,000 insured individuals had been stolen and that the confidentiality of the data might have been compromised.¹⁴ In a different type of incident, a Maryland banker who served on the state health commission determined which of the bank’s customers were cancer patients and canceled their loans.¹⁵ A report concerning discarded hard drives and disk sanitization practices revealed that in August 2002 the United States Veterans Administration Medical Center in Indianapolis sold or donated 139 of its computers without removing confidential information from their hard drives, including the names of veterans with AIDS and mental illnesses.¹⁶ Other reports document the accidental electronic posting of details concerning the sexual and psychological problems of patients and an incident in which overseas hackers accessed hospital computers, potentially obtaining 230,000 patient records from Children’s Hospital in Akron, Ohio.¹⁷

Outsourcing of health information processing to overseas service providers can create particularly significant security vulnerabilities. According to one scholar, about \$10 billion in U.S. medical transcription business is outsourced to foreign countries.¹⁸ Offshore business associates often evade the reach of U.S. regulatory authorities, and it is entirely possible that businesses or individuals processing EHI in distant locations will begin selling the information to third parties who believe it offers opportunities for profit or will otherwise abuse it. The American Medical Association (AMA) has itself recognized that contracts with foreign business associates require special privacy safeguards.¹⁹

Many different parties might be interested in patients’ health data. As described above, employers, insurers, advertisers, and marketers all have reasons to try to obtain personal health information. Other service providers might find medical records useful as well. Lenders, for example, could benefit from knowing which borrowers have significant health risks that might interfere

with their ability to work and repay their loans. Educational institutions can also benefit from enrolling healthy students with the greatest potential for professional success, whose achievements will enhance the schools' reputations and whose fortunes will enable them to become generous donors. While many of these entities are subject to the requirements of the Americans with Disabilities Act, which prohibits disability-based discrimination, the law features several important exemptions to its general anti-discrimination rule and does not forbid the use of information concerning health risks that do not constitute existing disabilities.²⁰

Like organizations, individuals may seek EHI about other persons for a variety of purposes. Those seeking romantic partners might wish to avoid mates who are at high risk for serious illness or for passing hereditary diseases to their children. Blackmailers may use private health information to extort payments from individuals who have much to lose from disclosures concerning details of their medical histories, such as HIV status or psychiatric conditions.²¹ In the context of political campaigns, some might attempt to besmirch the reputations of particular candidates or cause voters to lose confidence in them by revealing damaging medical information.

Particularly troubling is a finding in a 2006 report, "Medical Identity Theft: The Information Crime that Can Kill You," that up to 500,000 Americans may have been victims of medical identity theft.²² Such theft can be perpetrated by doctors, nurses, hospital employees, other computer-savvy individuals, and increasingly, organized crime rings. Typically, the medical data are used to submit false bills to Medicare and health insurance providers. False entries placed in victims' medical records can lead to inappropriate medical treatment, the exhaustion of health insurance coverage, and the victims' becoming uninsurable. Because medical records also can contain Social Security numbers, billing information, and credit card numbers, medical identity theft can result in financial hardship for its victims, as perpetrators engage in credit card fraud and other financial crimes using the information they have obtained.

Americans are aware of these dangers. A 2005 National Consumer Health Privacy Survey, which included 2,000 people, found that 67 percent of respondents were "somewhat" or "very concerned" about the confidentiality of their medical records. Furthermore, 13 percent claimed that in order to protect their privacy they had avoided medical tests or visits to their regular physicians, asked doctors to distort diagnoses, or paid for tests out-of-pocket so that no medical documentation would be sent to health insurers.²³ Likewise, a 2005

Harris Interactive survey showed that 70 percent of Americans are concerned that flawed EHI security could compromise their sensitive medical data, and 69 percent worry that electronic medical record systems would lead to disclosure of EHI without patient knowledge or consent.²⁴ A subsequent report estimated that one out of eight adults living in the United States believe that their private health information has been disclosed improperly.²⁵

The Legal Landscape

Federal and state legislatures and regulators have addressed privacy and security threats associated with EHI. The most well known response to these threats is the Health Insurance Portability and Accountability Act (HIPAA) Privacy and Security Rules, but many other relevant laws exist as well. We will now proceed to summarize the major legal standards that govern the confidentiality and security of EHI.

State Laws

State laws address the confidentiality of health information and patients' right of access to their health records in a variety of ways.²⁶ Some state statutes grant patients a general right of access to medical records retained by health care providers and insurers.²⁷ Many states also restrict the disclosure of personal health information.²⁸ Other states do not have comprehensive laws addressing health information privacy but have established protection in laws governing specific health care entities or addressing particular medical conditions.²⁹

A number of states, including New Hampshire, Maine, and Vermont, have passed laws that prohibit pharmacies, insurance companies, and other entities from transferring or using individually identifiable health data for particular commercial purposes.³⁰ These laws have often faced legal challenges based on First and Fourteenth Amendment theories, and New Hampshire's law was overturned by a district court in 2007.³¹

Common-Law Causes of Action

Several causes of action relating to privacy violations exist in tort law. The tort of public disclosure of private facts consists of four elements: (a) public disclosure, (b) of a private fact, (c) that would be objectionable and offensive to a reasonable person, and (d) that is not of legitimate public concern.³² This theory of liability is of limited applicability to EHI disclosures because most courts have required plaintiffs to prove widespread dissemination of personal information to

the public, such as through the media.³³ EHI that is obtained through hacking, stolen computers, or careless processing is rarely shared with the public at large.

A second tort theory is breach of confidentiality. Liability can be established when the perpetrator and the victim of the breach of confidentiality had a direct patient-provider relationship or when a third party knowingly induced a provider to reveal confidential information. In *Horne v. Patton*, for example, the court found that a physician breached his duty of confidentiality by disclosing medical information to the patient's employer.³⁴ The court ruled that a doctor has a duty to maintain confidentiality with respect to patient information obtained in the course of treatment and that a private cause of action exists in cases where the duty is breached. An action for breach of confidentiality can be maintained regardless of the degree to which the information has been publicly disseminated or of its offensiveness, and plaintiffs need not prove the intent of the perpetrator.

Finally, patients whose EHI was improperly disclosed may be able to establish claims of negligence against those who were responsible for securely storing their data. The elements of a negligence claim are (1) a duty of care owed by the defendant to the plaintiff, (2) breach of that duty through conduct that fails to meet the applicable standard of care, (3) harm or injury, and (4) a causal link between the injury and the breach of duty.³⁵ It must be noted, however, that in many instances, EHI disclosures that arise from malicious or careless activity do not lead to identifiable harm or injury to specific individuals. Negligence, therefore, could only be proven by those who could establish adverse consequences such as financial loss due to identity theft or damage to one's reputation linked to leaks of private medical data.

Federal Laws

A number of federal laws regulate certain aspects of health information privacy. A few examples of such laws follow, though our list is not exhaustive.

The Privacy Act of 1974 regulates the collection, storage, use, and dissemination of personal information by government agencies and prohibits disclosure of records without the data subject's consent unless permitted by law. The Privacy Act specifically includes medical history within its definition of "record."³⁶

The Freedom of Information Act of 1966 allows for public access to certain federal agency records. However, the law explicitly excludes medical files whose disclosure would constitute an invasion of personal privacy.³⁷

The Americans with Disabilities Act places boundaries on the timing, content, and use of employer-conducted medical inquiries and examinations. It

also requires that medical information about applicants and employees be treated as confidential and be stored in files that are separate from other personnel records.³⁸

The Family Education Rights and Privacy Act (FERPA) provides privacy protection and parental rights of access to education records held by educational institutions receiving federal funding. “Education records” are defined as those that “contain information directly related to a student” and “are maintained by an educational agency or institution or by a person acting for such agency or institution.” Such records, therefore, may include medical information. FERPA’s definition of “education record,” however, generally excludes medical records of students 18 years of age or older or health records of post-secondary students that are created specifically for treatment purposes.³⁹ Thus parents could not gain access to information contained in these files.

Under the Fair Credit Reporting Act, a consumer reporting agency generally may not furnish a consumer report that contains medical information about a consumer for employment purposes or in connection with a credit or insurance transaction without the individual’s consent.⁴⁰ Similarly, creditors generally may not use or obtain medical information to make credit decisions. In addition, consumer reporting agencies may not report the name, address, and telephone number of any medical creditor unless the information is provided in a manner that does not identify or suggest the health care provider or the patient’s medical condition.⁴¹ These protections are significant because the name of a facility alone could inadvertently reveal a patient’s underlying medical condition.

The HIPAA Privacy and Security Rules

The most ambitious effort to protect EHI comes in the form of federal regulations known as the HIPAA Privacy and Security Rules. The HIPAA legislation, enacted in 1996, required the secretary of the Department of Health and Human Services (HHS) to establish federal privacy and security protections for individual health information.⁴² The HIPAA Privacy Rule, issued under this authority, went into effect on April 14, 2003. Subsequently, the HIPAA Security Rule became effective on April 20, 2005, for most covered entities. Under the rules, protected health information (PHI) includes “individually identifiable health information” that is electronically or otherwise transmitted or maintained. The rules cover a limited range of health-related entities, namely, health plans, health care clearinghouses, and health care providers who transmit health information electronically for particular purposes, generally claims or benefits activities.⁴³

Privacy Rule The HIPAA Privacy Rule provides patients with access to their PHI. Specifically, the regulations establish that “an individual has a right of access to inspect and obtain a copy of protected health information about the individual in a designated record set” with some exceptions, such as psychotherapy notes and information compiled for purposes of litigation or administrative proceedings.⁴⁴ In addition, individuals have a right to receive privacy notices from covered entities. The notices must contain several elements, including the following: (1) a description of anticipated uses and disclosures of PHI by the covered entity; (2) a statement of the covered entity’s duties concerning PHI, including protection of privacy; (3) individuals’ rights with respect to their PHI, such as the rights to inspect and amend their PHI, to request an accounting of PHI disclosures, and to file complaints concerning regulatory violations with HHS; and (4) contact information for an individual who can provide patients with further information concerning the entity’s privacy policy.⁴⁵

The Privacy Rule’s “uses and disclosures” provision prohibits the utilization and dissemination of PHI without the patient’s consent except in specific circumstances related to medical treatment, payment, public health needs, or other obligations established by law. Furthermore, the Privacy Rule requires covered entities that use or disclose PHI or request it from other entities to limit the PHI that is handled to the minimum necessary to accomplish the task at issue.⁴⁶

The rule also addresses the fact that many covered entities retain other parties to perform legal, financial, and administrative services and that such “business associates” may process sensitive health information. Thus the rule instructs that contracts between covered entities and business associates restrict the use and disclosure of health information, as specifically delineated in the rule, and requires business associates to implement safeguards to protect the information.⁴⁷ However, because of the HIPAA Privacy Rule’s narrow definition of “covered entity,” many business associates will not be directly governed by the rule.

The HIPAA Security Rule The HIPAA Security Rule is of particular relevance to EHI. The Security Rule imposes four general requirements on covered entities. They must (1) ensure the “confidentiality, integrity, and availability” of PHI; (2) safeguard against reasonably anticipated security threats to the data; (3) protect against reasonably anticipated prohibited uses and disclosures of the data; and (4) ensure that their workforces comply with the rule.⁴⁸

The HIPAA Security Rule’s requirements appear in two forms: standards and implementation specifications, with the latter being designated either

“required” or “addressable.” Covered entities enjoy some flexibility with respect to addressable implementation specifications, because, in appropriate cases, entities are authorized to document why implementation of these criteria is not “reasonable and appropriate” and implement an equivalent measure if a suitable one is available.

One section of the HIPAA Security Rule is devoted to administrative safeguards. The general standards established in this section focus on the following areas: security management processes, workforce security, information access management, security awareness and training, security incident procedures, and contingency plans. The implementation specifications require risk assessment, the creation of a sanctions policy for noncompliant employees, workforce clearance procedures, log-in monitoring, password management, and many other measures.⁴⁹

The physical safeguards section of the Security Rule articulates four standards relating to facility access controls, workstation use, workstation security, and device and media controls. Under the implementation specifications, covered entities must develop a number of plans and procedures, such as ones related to facility security, access control and validation, and data backup and storage.⁵⁰

The rule’s technical safeguards section includes five standards. These mandate the establishment of procedures to control PHI access, to audit activity in information systems that process PHI, to protect PHI from inappropriate modification or eradication, to obtain authentication from PHI users, and to protect PHI. The implementation specifications address matters such as encryption, decryption, and authentication mechanisms.⁵¹

Enforcement The HIPAA Privacy and Security Rules allow for administrative enforcement of the regulations but not for a private cause of action.⁵² Aggrieved individuals may file complaints with the secretary of HHS, and HHS may also conduct compliance reviews on its own initiative.⁵³ The government enjoys discretion as to which complaints it will choose to investigate. If HHS finds a violation, it will attempt to resolve the matter informally. However, the secretary may also sanction offenders with civil penalties in an amount not to exceed \$100 per violation or \$25,000 during a calendar year “for all violations of an identical requirement.”⁵⁴ Furthermore, violators may be prosecuted by the Justice Department for criminal offenses under a statutory provision entitled “[w]rongful disclosure of individually identifiable health information.”⁵⁵ Those convicted may be fined up to \$250,000 and imprisoned for up to ten years.

Health Information Confidentiality Is Not Sufficiently Protected Under U.S. Law

Although many state and federal laws address medical data privacy, existing legal interventions are limited in scope and do not provide patients with comprehensive protection. A 2007 report by the U.S. Government Accountability Office focused on EHI confidentiality in anticipation of nationwide implementation of health information technology. It found that HHS is only “in the early stages of identifying solutions for protecting personal health information and has not yet defined an overall approach for integrating its various privacy-related initiatives and for addressing key privacy principles.”⁵⁶ Unfortunately, self-regulation on the part of private industry is often deficient. For example, a review of the privacy policies of thirty personal health record service providers revealed that existing policies were incomplete and left worrisome gaps.⁵⁷

The prospect of a national, interoperable health information network raises serious and novel concerns. With an NHIN, each patient’s EHR will be potentially accessible to any health care provider in the country and information will be frequently transmitted electronically and shared with various medical team members. These capabilities will require enhanced mechanisms to achieve patient identification, user authentication, data integrity, access control, and confidentiality.

Critique of the HIPAA Privacy and Security Rules

The HIPAA Privacy and Security Rules suffer from several significant flaws. First, as noted above, the rules cover only health plans, health care clearinghouses, and health care providers who transmit electronic PHI for claims or benefits purposes.⁵⁸ Consequently, employers, marketers, operators of websites dispensing medical advice or selling medical products, and all other parties who possess and process EHI are exempt from the requirements of the HIPAA Privacy and Security Rules. Even physicians who require cash payments from patients upon provision of care and therefore do not bill any party or interact with insurers fall outside the jurisdiction of the rules. This narrow scope of coverage is troubling because some of the most serious threats to confidentiality are associated with entities that possess EHI but are not governed by HIPAA. Such entities could potentially use health data in ways that lead to employment discrimination, insurance discrimination, lending and educational discrimination, blackmail, identity theft, and severe difficulties in custody battles, adoption efforts, parole proceedings, and personal injury litigation.⁵⁹

Second, the HIPAA Privacy Rule limits the information patients can gain about their EHI. It allows patients to inspect and obtain copies of their medical records from covered entities as well as to request revisions of incorrect information.⁶⁰ However, the rule does not enable data subjects to verify the origins of information or to inquire about the purposes for which it is maintained. As more and more parties process and utilize EHI for their own business objectives, there are growing dangers of hacking, theft, the development of illicit health information markets, and other forms of malfeasance. Thus patients might increasingly find that unexpected people or organizations possess their EHI and become increasingly concerned that the data will be used in harmful and inappropriate ways. Without an ability to submit inquiries to covered entities concerning the origins and use of their medical data, health care consumers have little power to track their EHI and try to prevent its exploitation.

Third, the HIPAA Privacy Rule does not provide aggrieved individuals with a private cause of action.⁶¹ Instead, enforcement is achieved through HHS investigations, hearings, and fines or through criminal prosecutions.⁶² The absence of a right to sue significantly weakens the privacy regulations' deterrent powers and means that those who have been injured by confidentiality or security breaches cannot obtain personal relief. If enforcement is left exclusively to the government, then budgetary constraints, political pressures, and administrative priorities can determine the degree of regulatory enforcement. With feeble enforcement, covered entities may have little incentive to comply with onerous regulatory requirements. By contrast, the threat of private litigation may lead covered entities to conclude that some violations could be costly. In addition, judicial scrutiny could contribute to the efficacy of the Privacy and Security Rules by providing opportunities for the interpretation of vague regulatory language, establishment of significant precedents, and education of the public concerning their legal rights and obligations through cases that are published or capture media attention.

According to its website, as of December 31, 2007, HHS had received 32,487 complaints of Privacy Rule violations. It investigated 8,199 of the complaints and referred approximately 419 cases to the Department of Justice for potential criminal prosecution and 215 cases of alleged security breaches to the Centers for Medicare and Medicaid Services (CMS), which enforces the HIPAA Security Rule.⁶³ HHS states that it found no violation in 33 percent of the cases it investigated and obtained "corrective action" in the remaining 67 percent.⁶⁴ However, the HHS website does not explain what "corrective action" means.

There is no indication that any civil fines were imposed, and only a handful of criminal prosecutions have been initiated.⁶⁵

According to a summer 2006 survey of 178 providers and 42 insurers conducted by the Healthcare Information and Management Systems Society and the Phoenix Health Systems, covered entities were, in fact, largely failing to comply with the HIPAA Security Rule. Only 56 percent of providers and 80 percent of payers represented that they had achieved HIPAA Security Rule compliance. Upon further inquiry, the researchers determined that even those who claimed to have complied fully had significant compliance gaps. Perhaps not surprisingly, 39 percent of providers and 33 percent of payers acknowledged having suffered security violations during the six months before the survey.⁶⁶

Fourth, the HIPAA Security Rule provides only minimal compliance guidance to covered entities. The Security Rule boasts a “flexibility of approach” that allows covered entities to choose the mechanisms for “reasonably and appropriately implementing the Rule’s standards and specifications.”⁶⁷ However, most covered entities are unlikely to have the expertise or resources to make competent decisions concerning which security technologies to employ. Furthermore, entities with sophisticated HIT capabilities could take advantage of the rule’s vagueness in order to implement suboptimal security measures that circumvent the purpose of the rule.

When the Security Rule speaks of encryption, for example, it states only that covered entities should “[i]mplement a mechanism to encrypt electronic protected health information whenever deemed appropriate.”⁶⁸ It does not provide any instruction as to how encryption should be implemented, such as specifying acceptable encryption algorithms or their properties. Similarly, the Security Rule fails to offer guidance as to how appropriate risk analysis should be conducted, even though accurate risk analysis is essential to a determination of what security risks a covered entity faces and consequently, what solutions and safeguards it should implement. Lack of specificity and detail characterize most other Security Rule requirements as well.

Finally, the HIPAA Privacy Rule has been criticized for providing ineffectual privacy protections because it fails to adequately limit disclosures and empower data subjects. For example, some argue that the Privacy Rule compromises patient protection by allowing disclosure of PHI to third parties for purposes of treatment, payment, and health care operations without patient consent.⁶⁹ While the rule requires that patients receive notice of a covered entity’s anticipated uses and disclosures, it does not enable individuals to prohibit

transmission of their PHI for such purposes. In addition, some have noted that the Privacy Rule allows parties who obtain authorizations for release of information from patients to obtain limitless amounts of data rather than restricting the contents of disclosures to information that is actually needed by such parties because it is business-related.⁷⁰ Thus if an employer requires applicants to sign authorizations for release of all their medical records, the employer can gain access to intimate details about candidates that will have no impact on job performance.

Recommendations for Improving Protection of EHI

Development of a comprehensive solution to the problem of EHI confidentiality and security threats is beyond the scope of this chapter. However, it is appropriate to outline a few basic modifications to the HIPAA Privacy and Security Rules that could significantly enhance EHI protection.⁷¹

Covered Entities Many entities other than health care providers, insurers, and clearinghouses routinely obtain personal health data, and the data that they handle are vulnerable to abuse without sufficient security and privacy safeguards. Consequently, the definition of “covered entity” in the HIPAA legislation⁷² and the Privacy and Security Rules must be significantly expanded. We recommend that the definition be modified to include: “any person who knowingly stores or transmits individually identifiable health information in electronic form for any business purpose related to the substance of such information.” The privacy regulations define the term “person” as “a natural person, trust or estate, partnership, corporation, professional association or corporation, or other entity, public or private.”⁷³ The term “business” should be defined as an “activity or enterprise undertaken for purposes of livelihood or profit.”

This definition would remedy the current problem of under-inclusiveness without being overly inclusive. Employers, financial institutions, educational institutions, website operators, and others who process EHI for business reasons and have a financial interest in the data subject’s health status would be required to implement appropriate security and privacy measures. These safeguards should address the threats of both inadvertent and malicious data disclosures. However, the revised definition would not cover benign circumstances such as private citizens emailing each other about a friend’s illness or volunteers organizing food or transportation for the sick and disabled. Thus the rules would not intrude upon private conduct and would not be overzealous in imposing onerous requirements in inappropriate circumstances.

Right of Inquiry We recommend that the HIPAA Privacy Rule be revised to allow individuals to submit inquiries to covered entities concerning the origin and use of their health information. These inquiries could be submitted through websites that are established by covered entities, and responses could be provided by email, where possible. Covered entities could also charge fees for the processing of these requests, since the rule already permits organizations to require payment for information that is provided to patients pursuant to their inquiries.⁷⁴ Thus those who become aware that unanticipated parties possess their information might be able to determine how and why their data were obtained without their authorization. This mechanism could serve as a deterrent to malfeasance by covered entities, and because processing charges would be imposed, organizations should not be overburdened by frivolous queries.

Private Cause of Action To bolster regulatory compliance, a private cause of action should be added to the enforcement provisions of the Privacy and Security Rules, alongside the existing administrative procedures and penalties. HHS describes the most frequent complaints of violations as follows:

1. Impermissible uses and disclosures of protected health information;
2. Lack of safeguards of protected health information;
3. Lack of patient access to their protected health information;
4. Uses or disclosures of more than the Minimum Necessary protected health information; and
5. Lack of or invalid authorizations for uses and disclosures of protected health information.⁷⁵

Some of these regulatory breaches may cause specific damage to data subjects, while others may have no identifiable victims. With an approach of combined administrative enforcement and private litigation, the government could pursue violations that did not give rise to a private cause of action, while aggrieved individuals would be able to obtain redress in appropriate cases. The specter of private litigation might induce compliance on the part of some covered entities that would otherwise believe that they could escape liability because of anemic administrative enforcement.

The private cause of action provision should authorize aggrieved individuals to file suit in federal district court. It should allow for the award of actual damages or liquidated damages in a particular amount, whichever is greater. In addition, it should provide for the award of punitive damages upon proof

of willful or reckless misconduct as well as reasonable attorneys' fees, litigation costs, and appropriate equitable relief.

We note that it is particularly challenging to litigate and prosecute privacy and security violations that originate in foreign countries, because the reach of American law is limited in such cases. As an increasing amount of medical work is outsourced and EHI is more frequently processed internationally, such violations are a growing concern. In the future, regulators might consider placing appropriate restrictions on the transfer of EHI to foreign parties.

Best Practices Standard for the HIPAA Security Rule Crafting clear guidance for computer security is a challenging task. Because both computer technology and security threats are continually evolving, it is difficult to fashion static rules to govern these dynamic areas. To address this problem, we recommend a "best practices" standard that would apply to all Security Rule standards and implementation specifications. Software best practices are needed to ensure that software used to process EHI is not faulty or improperly configured.

Specifically, the rule's "general requirements" section⁷⁶ should include an additional element that requires covered entities to "make reasonable efforts to identify and employ best practices relating to security measures, software development, validation, maintenance, and software system administration that are either commonly used by similarly situated business entities and governmental institutions or can be clearly demonstrated to be superior to best common practices." This approach would provide useful guidance while maintaining flexibility and sensitivity to the fast-changing computer technology environment.

In order to determine best practices for particular functions, most covered entities would need to hire security product vendors. These vendors should be certified either directly by the government or by certifying organizations that are themselves licensed by CMS. Many tools and technologies that can improve EHI security already exist. The National Institute of Standards and Technology (NIST), for example, has issued the NIST Risk Management Guide for Information Technology Systems, providing thorough guidance concerning risk assessment and management.⁷⁷ Likewise, the International Organization for Standardization (ISO) and the International Engineering Council (IEC) have published a variety of standards addressing sound information security practices. ISO 27799 entitled "Health informatics—security management in health using ISO/IEC 17799" appears particularly relevant and is currently under development. Security alerts and solutions are also offered through the website of

a well-respected, federally funded organization, the Computer Emergency Response Team (CERT).⁷⁸ Furthermore, a Google search reveals numerous products that advertise themselves as turnkey solutions for HIPAA Security Rule compliance. It is likely that as public awareness and demand for EHI security rise, increasingly sophisticated, effective, and reasonably priced technologies will be developed.

The government and privacy advocacy groups could also play a role in facilitating compliance with the Security Rule. Public interest organizations could research and distribute materials concerning computer security best practices. In addition, CMS could maintain publicly accessible websites with lists of available products and with comment areas in which covered entities could post input concerning security practices that they have utilized.

Conclusion

As evidenced by numerous studies and reported incidents, Americans' private health information faces grave threats from a large number of sources. The dangers of privacy and security violations will only intensify in the future as greater numbers of providers transition from hardcopy medical files to electronic health records. Health data vulnerabilities can have significant social, policy, and economic impacts. Inappropriate EHI disclosures can cause victims to suffer discrimination, medical mistakes, financial ruin, and a variety of serious legal problems.

The federal and state governments have enthusiastically promoted health information technology and have responded to concerns about privacy by enacting various laws and regulations. The existing legal scheme, however, does not provide health care consumers with comprehensive protection. Focusing on the HIPAA Privacy and Security Rules, this chapter has outlined several recommendations to rectify some of the regulatory shortcomings.

As medical practice increasingly transitions to electronic and automated formats, we must not remain complacent about privacy and security threats to EHI. It is only with appropriate legal interventions that the great promise of health information technology will be realized and that its valuable benefits will outweigh its significant risks.

7 Information Security of Financial Data

Quasi-Secrets: The Nature of Financial Information and Its Implications for Data Security

Cem Paya

IN THE THREE-YEAR PERIOD 2005–2008, the incidence of data breaches rose alarmingly.¹ As of February 2008, over 200 million total records had been compromised.² A review of the incidents and affected parties suggests that the problem is not confined to a particular type of organization. For-profit businesses, not-for-profit entities, government entities, and educational institutions have all experienced their share of data breaches. Some incidents were small in scale, localized to individuals in one geographic area or sharing an affiliation with a particular institution. Others were large in scale, reaching millions of individuals spread around the country.³

Failure to implement particular security measures or best practices is often singled out as the reason for information security breaches.⁴ This chapter suggests a different root cause, which may be working against the improvements taking place in security assurance: security of financial information has not been adequately considered in the larger context of the overall financial and social system. Specifically, the status assigned to financial information as an information asset has become inconsistent and self-contradictory over time. Financial information is at times considered highly sensitive and accompanied by an expectation of confidentiality. Yet in the larger context of the overall lifetime of the asset, it is liberally shared, replicated, distributed, retained for long time periods, and exposed to completely avoidable risks. This contradiction is not a simple oversight or implementation flaw that can be mitigated with incremental changes. It is a direct consequence of highly established business processes

around the use of financial information. The assumptions underlying these processes, such as the suitability of Social Security numbers for authentication, are becoming increasingly questionable owing to the emergence of two trends. The first trend is the explosive growth of e-commerce beginning in the late 1990s, which drastically expanded the scale of data collection and sharing. The second is the rise in computer crime and its evolution into an activity dominated by organized, profit-driven criminal enterprises. Although current methods of protecting financial information from information criminals are failing, the sheer scale of the installed base of older systems makes it very difficult to upgrade systems. Because of this “legacy design” problem, the same business models that once enabled easy access to credit and convenient payment instruments are now creating challenges for securing financial information.

Identifying and Mitigating Financial Information Security Risks

Broadly speaking, financial information refers to any information related to the economic activities of an individual in the capacity of a consumer, employer, employee, taxpayer, or investor. There is consensus that at least parts of this large body of data are considered sensitive by individuals. The problem of placing economic value on disclosure or privacy of data is complicated by the individual-level variation in the perceived trade-offs of information sharing. For example, one investor may treat the performance of his stock portfolio as strictly confidential, while another may publish it in full detail on a public website. Similarly, legal regimes around data protection and the definition of “personally identifiable information” are different in different jurisdictions.⁵ These definitional uncertainties impact the way we measure the harms arising from exposed financial data.

However, a small subset of financial data can be singled out as particularly sensitive because it is frequently targeted by criminals for committing fraud. These are payment instruments, such as credit card numbers or bank account numbers, and Social Security numbers (SSNs).⁶ Payment instruments and Social Security numbers represent unique targets from a risk management point of view. There are abundant Experian estimates that on average U.S. consumers have more than four open credit cards,⁷ and every U.S. resident has an SSN.

Criminal Threats from Exposed Financial Information

Financial fraud as it relates to consumers has various forms. This chapter focuses on two broad categories that capture the majority of problems faced by

U.S. consumers—payment card fraud (a type of “existing account fraud”) and new account fraud.

Payment Card Fraud Knowledge of a credit or debit card number and associated meta-data allows one to make unauthorized purchases on that card. This is possible because of the increasing popularity of so-called card-not-present or “CNP” class of transactions involving credit cards. CNP includes mail-order, phone-order, and online-shopping transactions. Typically, a merchant requires a customer to supply her card number and expiration date to authorize payment. The merchant may also request optional elements for validation, including the CVV2 number printed on the card,⁸ the billing address, or the billing zip code. Regardless of the type of validation used, there is a fixed amount of information that is stable across different transactions that acts as the “secret code” for authorizing payments on that card. Anyone in possession of this information can authorize charges and use the available credit.

Not surprisingly, the CNP category has been associated with the highest levels of fraud because the merchant cannot verify the customer’s physical possession of the card in question.⁹ Copying and reusing pure abstract payment card information is often easier than either stealing or forging perfect replicas of physical objects. It is also more difficult to detect CNP fraud than the theft of an object. The primary point of detection occurs long after the transaction, when the cardholder is confronted with his or her statement.

New Account Fraud Knowledge of SSNs carries a different and more severe risk than payment cards: new account fraud, or as it is more commonly known “identity theft.” The perpetrator of new account fraud creates new accounts in the name of the victim and assumes debt obligations such as a mortgage, credit card, or automobile lease. The criminal then uses the resulting credit and defaults on the loan, leaving the victim responsible for the consequences.

The link between SSNs and new account fraud is not obvious. Strictly speaking, SSNs are not even financial data. They do not directly identify funds, credit, or debt obligations associated with an individual. Yet their proximate relationship with individuals’ finances predates the internet: SSNs were introduced during the New Deal era as a way to identify beneficiaries of programs introduced by the Social Security Act.¹⁰ Later they were used as a taxpayer identification number to uniquely identify taxpayers in the United States. In both instances the SSN acted as an identifier only, a sequence of digits meaningful in a very narrow context defined by certain government agencies.

Two subsequent developments changed that. The first was the emergence of private data aggregators. The 1960s witnessed the development of business models around collecting and selling information about individuals. Perhaps the most notable examples were credit reporting agencies. Taking a cue from the Internal Revenue Service, these private data aggregators started using the SSN as a unique identifier to efficiently index a growing collection of records. The SSN was a stable key, remaining constant as individuals changed employment, state of residence, marital status, and even their legal name. This consistency allowed it to become the glue linking unrelated records about an individual from different sources into a single virtual dossier.¹¹ The eventual migration of the records into modern relational database systems cemented the role of the SSN. Unlike when a person compares records manually, the databases required very precise semantics. The fact that one SSN corresponds uniquely to one individual and that this mapping does not change served as a very convenient design assumption in building large databases. The scope of the identifier expanded. As more databases were indexed by the SSN, it also became increasingly common to collect the SSN from individuals in order to reference one of these data sources.

Increased use of a single identifier can have adverse effects on privacy; any constant identifier shared across different contexts allows for easier tracking. In the case of SSNs, this widespread use coincided with an unrelated development—repurposing of the SSN for authentication and authorization. This coincidence created a dangerous combination that paved the way for widespread identity theft. Initially the SSN was an identifier only; having knowledge of one person's SSN did not grant any special rights or privileges to another person. Today the SSN is widely used as an *authenticator*: many processes assume that if you know the SSN for a particular person, then *you are that person or authorized to act on behalf of that person*.¹² Disclosing the SSN has become a rudimentary protocol for verifying one's identity. It is very common to be asked to recite an SSN for "verification purposes" during both online and phone-based interactions related to banking, telecommunications, and insurance. Some systems use even weaker versions of this protocol, such as requesting only the last four digits. Under this arrangement, knowledge of a person's SSN can grant meaningful new privileges to another person by allowing for easy impersonation. In other contexts, the SSN is used to grant authorization to consult a third party on behalf of the user. For example, lease applications require the applicant to list her SSN, which is used to obtain a credit report or criminal background check on the applicant. This arrangement is largely a matter of convention. In

principle, background checks can be done relatively accurately without an SSN, using a person's full legal name or driver's license number, for example.¹³ The convenience of using SSNs has driven its use. It has been standard practice in many industries to consider SSNs as necessary and sufficient for the purposes of authenticating customers.

Underlying these authentication and authorization processes is the assumption that the SSN is private information. The theory is that only the person or a small number of highly trusted entities with whom he or she conducts business will ever be in possession of the number. Therefore, critical decisions, such as releasing credit history or opening a new account, can be based on the presence of a valid SSN corresponding to the claimed identity. In terms of information security risks, this means that a person who knows the SSN, date of birth, and a few pertinent pieces of information about someone else can easily impersonate that other person in commercial transactions. The most damaging example of this type of impersonation in a financial setting takes place in the form of obtaining new loans. An identity thief can secure a new loan in the name of the victim and use the resulting credit with no intention to repay. The consequences of default on the loan are borne by the identity theft victim.

Comparing Payment Card Fraud and New Account Fraud The major difference between simple credit card fraud and new account fraud is that credit card fraud takes place in a closed system. A card network can, in principle, fully compensate the consumer for any damages by refunding the fraudulent charges, revoking the original card, and issuing a replacement. This is exactly the model used by the major credit card networks in the United States today. The Fair Credit Billing Act caps consumer liability at \$50 for credit cards,¹⁴ and the Electronic Funds Transfer Act similarly places a \$500 limit (reduced to \$50 if the institution is notified within two business days) on damages resulting from fraudulent use of ATM and debit cards.¹⁵ Most issuers have moved beyond that baseline and completely indemnify customers against all losses originating from fraudulent charges, provided that the customer takes basic due diligence steps, such as promptly reporting a lost card and filing disputes for unauthorized charges. Typically the merchant where the fraudulent charge was made is responsible for absorbing the cost of the fraud, unless the merchant can provide evidence of having verified customer identity, such as a signed receipt, in which case the issuing bank or the card network will accept the loss.¹⁶ Either way, consumers have zero liability if they respond in a timely manner. Card issuers frequently feature this "zero liability for fraud" approach

prominently in advertising campaigns. But of course, consumers do pay for fraud indirectly. The illusion of zero liability is sustained by distributing fraud losses into a risk pool. While the merchant may be stuck with absorbing the loss from an individual instance of fraud, in the aggregate these losses are simply passed on to customers in the form of higher prices. Similarly, card networks can charge higher transaction fees to merchants, which pass them on to consumers through higher product prices; and the issuing banks can charge higher interest rates or annual fees in order to compensate for the expected amount of fraud. Credit card fraud then functions as a risk pool similar to automobile insurance, with the important restriction that the premiums are not influenced by individual risk-averseness.

The risks appear to be relatively well contained for U.S. consumers in instances of credit card fraud. From the point of view of card networks, a tolerable amount of fraud is the cost of doing business. Since merchants bear the immediate costs of fraud, or more precisely, fraud that exceeds any premium already reflected in pricing, they are motivated to take steps to minimize losses. Common procedures include comparing the signature on the receipt against the card and requesting identification bearing a photograph. In principle this arrangement should create a moral hazard: the costs of fraud are borne by the merchant while the benefits of the payment instrument—the convenience of avoiding cash and amplified purchasing power on credit—are exclusively enjoyed by the consumer, who is not cognizant of membership in a distributed risk pool. In reality, few consumers appear to have interpreted this arrangement as a license to engage in cavalier behavior online. Surveys consistently find that the security of payment instruments remains one of the top cited concerns among consumers considering an online transaction.¹⁷

In contrast, new account fraud does not take place in a closed system. The perpetrator may obtain loans at any number of financial institutions. In this case, no single entity is in a position to make up for all the losses suffered, repay the fraudulent debt obligations, or repair the consumer's credit rating. More important, no single entity has any economic incentive to do so. Unlike credit card fraud, the losses are not capped by the limit on a particular card. The victim may not even be a customer of the businesses that suffered losses associated with the crime. For example, weak information security at one lending bank may lead to theft of a borrower's identity. The perpetrator then obtains loans in the victim's name from a different lender located in a different state with no connections to the victim. This second lender will report the borrower as hav-

ing defaulted on the loan, damaging her credit rating and initiating a collection process that may lead to seizure of assets. The fact that the loan itself was made in error or that the customer was a victim of identity theft is not relevant to the lender. Often the collection process on defaulted loans is outsourced to other agencies, and it is only during this stage that the customer even becomes aware of the existence of a loan she has not authorized. Without an existing relationship to the borrower in question, there is no incentive for the defrauded lender to resolve the situation. Even if such a relationship did exist, loans are not a repeat business driven by volume. Most loans involve big-ticket purchases such as housing or automobiles that happen infrequently, and a lender has very little ability to create “lock-in” effects that give the borrower an incentive to return to the same lender for future borrowing. The lender’s loss from a default may exceed future revenue it can reasonably expect to recoup from continued business with that customer. There is simply no economic incentive in these situations to help the customer recover from the consequences of identity theft, let alone absorb the losses. By contrast, merchants in a typical card network are contractually obligated to refund unauthorized charges, regardless of affiliation with the individual. It is the affiliation with the payment network that decides how losses are distributed.

Lessons from Information Security Engineering

When assessing the most effective ways to protect financial information, it is useful to review the broader information security engineering context. Security engineers employ several principles for protecting secrets in designing systems. These principles include the principles of least privilege, limiting retention on systems using the secret, building auditing and monitoring capabilities, and designing for failure and recovery.

Least Privilege Benjamin Franklin once said that “three may keep a secret if two of them are dead.”¹⁸ Least privilege embodies this sentiment—it means that dissemination of a secret should be on a “need-to-know” basis only. The more widely distributed a secret, the greater the risk of disclosure. Beyond the simple question of numbers is a more subtle point about incentives. Those with need-to-know ideally coincide with the individuals who have a vested interest in protecting the information. For example, in a military context, when encryption keys used to communicate between two allies are compromised, both sides are at risk of sustaining losses in battle. Both parties have an incentive to protect the confidentiality of those keys.

However, their incentives are not always symmetrical: the harm resulting from unauthorized disclosure may fall disproportionately on one of the participants in an exchange. In this case, the need-to-know principle points toward redesigning the system to remove the need for that participant to share the secret with any other entities. The application of public-key cryptography provides several case studies of this idea in action. Before the emergence of public-key techniques, verifying the authenticity of a broadcast message was cumbersome because it required the publisher to share cryptographic keys with all the recipients. Sharing a different key with each recipient made for very difficult key distribution. On the other hand, sharing a single key placed the system at great risk; the secret became available to every recipient, each of whom was now in a position to jeopardize the entire system. Public-key cryptography provided a solution more in the spirit of need-to-know. Instead of a single key shared by both sides, there are two related keys. The sender has one, which can be used for generating messages, and the recipient has the second one, which can only be used for verifying them. In this model, a recipient no longer has to be entrusted with keeping a secret, and compromise of the recipient's information no longer threatens other actors in the system.

Limiting Data Retention on Systems Using the Secret For systems and processes that handle confidential information, an important risk mitigation strategy is to reduce the window of time during which data are vulnerable. This principle reflects the recognition that it is often necessary to perform computations with sensitive data and that during that time the information is placed at greater risk. Once the processing is complete, keeping sensitive data at high risk of attack adds no value. Data should be accessed only for the duration of the task. Although records may need to be retained for long periods of time to meet specific business requirements, some methods of storage are less vulnerable than others. Unless data are immediately in use, storage solutions with fewer exposure points, such as off-site archives, should be used. The data in question continue to be valuable after being purged from a particular active system, but the risk of exposure has decreased. The data are no longer at risk of being compromised by a breach of systems actively handling data, which are the most attractive targets for attack.

Building Auditing and Monitoring Capabilities In addition to preventing disclosure, risk management objectives also include using monitoring to promptly detect violations of security policy. Monitoring is an example of the principle

of defense-in-depth: instead of relying on a single countermeasure to resist all attacks, a good system is engineered with layers of independent defenses. Each layer is designed to provide additional protection in the event that all of the previous layers are breached.

Detection can operate on different levels. At the most basic level, auditing access to a system increases accountability and allows asset owners to identify inappropriate use after the fact. This is important in defending against threats from rogue insiders. Although the need-to-know principle may whittle down the number of individuals with access, there will inevitably be a group of trusted individuals who have access to sensitive information. At any point, one of them could decide to take advantage of that privilege for unauthorized actions. An accurate audit trail is an important instrument to deterring, identifying, and investigating these cases. Still, experience has shown that any large system contains security vulnerabilities, which allow insiders or external attackers to bypass the ordinary authentication, authorization, and audit processes.¹⁹ In these cases, the audit trail cannot provide a correct picture. However, additional defense-in-depth can be obtained by focusing on the secondary signals from disclosure of data. For example, if the information in question pertains to the quarterly results of a publicly traded company, a secondary signal may be a set of unusual trading patterns before the public announcement of quarterly results. By monitoring events where the confidential information would be used or whose outcome is correlated with the information, it is often possible to detect violations of security policy or defects in implementation that were not reflected in audit trails.

Life-Cycle Management: Designing for Failure and Recovery Because no complex system can be expected to have perfect security, it is important to plan for failure and recovery in case the system's security is circumvented. Breaches of confidentiality, defined as unauthorized access to data, pose a particular challenge for recovery. There is no automatic way to return to a previous state in which the secret was known only to authorized users.²⁰ Instead, recovery takes the form of actively devaluing the compromised secret by no longer relying on it for critical tasks. This is achieved by creating a new version of the secret, canceling the previous one that is suspected of having been compromised, and taking steps to prevent anyone in the system from making decisions based on the compromised version of the secret. In cryptographic contexts, this is the concept of *revocation*: when a key or credential is suspected of having been disclosed to unauthorized entities, the associated credentials can be revoked.

The effectiveness of revocation varies depending on the purpose of the secret in question. For example, revoking a key used for authentication places a strict limit on the extent of damage going forward. Any *future* use of the key to impersonate the legitimate owner will be declined. By contrast, revoking an encryption key cannot change the fact that a large amount of private information might already have been encrypted in that key: any surviving copies of that data can be decrypted using the compromised key at any time in the future. For these reasons, limiting the useful lifetime of a secret is a preemptive strategy employed in conjunction with revocation capabilities. For example, encryption keys are rotated periodically to ensure that the breach of any one key will grant an adversary access to only a limited amount of past traffic. Similarly, credentials such as passwords are periodically refreshed or reissued to ensure that unauthorized access is limited in time and not indefinite going forward. As an example, the Payment Card Industry Data Security Standards (PCIDSS) that govern merchants' handling of credit card transactions make specific recommendations on the frequency of password changes.²¹

The "Quasi-Secret" Problem

When these security engineering principles are applied to the financial data security context, a problem becomes evident: the challenges that private and public actors have had in protecting financial information against data breaches arise from the nature of financial information itself. Financial information's status as an information asset is self-contradictory. Credit cards and SSNs are considered highly confidential because of the dangers resulting from unauthorized use, but they are also associated with patterns of use—widespread sharing, lifetime management, inadequate monitoring—that work to undermine their status as secrets. Financial information is, at best, "quasi-secret."

Comparing these patterns with information security engineering norms suggests a fundamental definitional problem: the existing uses of financial information make it inconsistent with the notion of a "secret." On the other hand, financial information is also clearly not public information. System designers expend considerable effort implementing standard protections such as encryption for financial data. Similarly on the business side, e-commerce merchants seek to assure customers that their information will be protected. In the most familiar example, websites frequently feature some messaging to the effect that credit cards are encrypted in transit over the network. Many e-commerce sites erroneously equate the use of the Secure Sockets Layer (SSL) protocol, which provides encryption, with solving their information security problems.

Although information transmitted over a hostile environment such as the internet is subject to attacks, and encryption serves an important purpose here, the single-minded focus on one particular risk and associated countermeasures only serves to distract from the bigger picture. Information is also exposed to risks elsewhere—in storage with the merchant, in the possession of its employees, or in transit between the merchant and one of its business partners.

Many consumers check for encryption before providing sensitive information to a website. Yet most consumers have no problem with swiping a card through a reader installed by the merchant, providing the card to a cashier, or writing their Social Security number on a piece of paper. Such inconsistencies in evaluating risks are rampant. Payment cards and SSNs have, therefore, become “quasi-secrets.” They are information that is at once guarded carefully at certain points against specific threats at great cost, and yet in the context of the full system, shared widely and exposed to unnecessary risk at other points. More important, this widespread exposure and high attack surface is by design.²² It is not an oversight in the implementation of systems handling payments or personal information. The efficient functioning of the card payment and credit reporting systems in the United States depends on consumers’ willingness to share this information frequently, taking on faith the security assurances of the recipients.

Comparing Against Best Practices

In applying the dynamics of quasi-secret financial information to the lessons learned from information security engineering, several discrepancies become apparent.

Widespread Distribution

“Need-to-know” is defined very generously and broadly in the case of financial information. Most transactions using a credit card involve the disclosure of the full card information to the merchant. Authorizing a payment involves the disclosure of one or more secrets—typing a card number and CVV on the internet, swiping a card through a point-of-sale device that reads the magnetic strip, or typing a personal identification number (PIN) for a debit card into a PIN entry device furnished by the merchant. This disclosure, in turn, grants the other party all necessary privileges for carrying out identical authorizations subsequently without the consumer’s consent. The use of the SSN to authenticate individuals suffers from the same problem: the

secret underlying the protocol is disclosed. In principle, information is being provided to indicate consent for *one* specific transaction, such as obtaining a loan. This act of disclosure places the recipient in a position to repeat the authentication or authorization processes in the future; the recipient can effectively impersonate the consumer without permission. In other words, the proof of identity is *transferable* and *replayable*, which are undesirable properties in a well-designed authentication protocol.

Although these properties may appear to be inherent in any authentication or authorization process, they are, in fact, an artifact of the very primitive information security techniques being employed. There is no problem *per se* with depending on a secret for implementing security protocols, but the process needs to be carefully constructed. Three types of secret information are used most often to prove identity: (1) something you know, (2) something you have, and (3) something you are. “Something you know” refers to a confidential piece of information, such as a password, that serves to prove your identity. “Something you have” includes physical objects or devices that are intended to demonstrate your identity. These include physical tokens such as access cards. Finally “something you are” refers to immutable information used to prove identity such as biometric data, including fingerprints. All three ways of proving identity are based on a fundamental asymmetry, a property that holds true only for the legitimate individual. In the familiar example of using passwords, the protocol is predicated on the assumption that the password is known to only one user. Disclosing the secret to third parties violates this assumption.

The state of the art in cryptography has progressed to use vastly improved and practical protocols for authentication without disclosing the underlying secrets. Similarly strong protocols and accompanying legal frameworks exist for making statements that are binding and cannot be repudiated, such as an assertion of payment authorization. Many of these techniques have been deployed successfully in large-scale real-world applications, including financial services. For example, credit cards containing chips have been widely deployed in Europe in order to reduce fraud. Instead of being passive containers for data encoded on the magnetic strip, as is typical of cards in the United States, these cards feature embedded hardware and software. This combination allows the cards to implement more elaborate authorization protocols that do not divulge sensitive information and remain secure against replay attacks. In the United States there have been limited attempts to implement this embedded hardware approach. The original incarnation of the Blue Card

from American Express was a notable attempt. The Blue Card was successful in helping American Express establish a sizable presence in the market for balance-carrying cards²³ (a segment that American Express already dominated), but a survey suggested that its smart-card features were rarely used.²⁴ The card was later discontinued and replaced with a contactless version based on radio-frequency identification or RFID, which proved susceptible to unauthorized charges.²⁵ Similarly, Target discontinued a smart card in 2005.²⁶

From this point of view, payment systems using traditional magnetic strip cards, including PIN-based debit and ATM cards, represent “legacy designs” that can provide only weak proof of the user’s intent to enter into a transaction. As a practical matter, swiping a card or entering a PIN for a debit card allows the merchant to charge an arbitrary amount on the card as many times as the merchant wishes, as long as the credit card network grants authorization.²⁷ The merchant is supposed to follow a protocol and charge only the amount the user authorized, a requirement implemented by requiring the user to attest to the amount charged by signing a receipt. This convention enables dispute resolution only after the fact: the merchant is still free to charge any amount, and the consumer can later claim that she was overcharged by pointing out a discrepancy with the receipt. In cases where the signature is captured electronically, even that fallback does not work: given the electronic copy of the signature, the merchant is free to forge a receipt for any amount.

The design assumptions built into this protocol underscore a deep asymmetry in the relationship between consumers and merchants/lenders. In the first case, a merchant is trusted to not reuse the card data out of context for other transactions. In the second case, the lender or agency receiving the SSN must be likewise trusted not to use it for secondary purposes. These assumptions can fail for two reasons. The first possibility is incompetence on the part of the merchant in failing to follow robust information security practices, resulting in third parties gaining access to the data. The second possibility is outright malicious behavior by the merchant, such as a corrupt insider using his legitimate access privileges for personal gain. From the point of view of possible harms, the effects of a breach by a malicious merchant (an admittedly unlikely scenario that can probably be mitigated using legal deterrence) and breach of a merchant with weak security by criminals are identical. Any damage that an unscrupulous merchant can do can also be accomplished by an attacker who has gained access to the same data by exploiting a weakness in the merchant’s information systems. The security of a typical transaction involving

the disclosure of financial information depends on the assumption that neither of these two situations will arise.²⁸

A good design minimizes the number of trusted parties, such as merchants and lenders, because each one adds one more possible failure mode to the system. The preceding discussion indicates that maintaining confidentiality in this context involves a large number of such trusted actors. The next task is to determine the extent to which they are motivated to live up to that expectation. The question of incentives must take into account many factors, all of them revolving around the cost/benefit structure of information security for a particular actor. The determining factor then is the amount each one stands to lose from an unauthorized disclosure incident.

For credit cards, as argued earlier, the risks are relatively well contained for consumers in the United States. Any loss is absorbed either by the merchant with a charge-back or by the issuing bank. However, the merchant is responsible only for the losses caused by accepting fraudulent payment charges. The merchant is not responsible for losses incurred by other merchants or issuing banks due to an information breach in their operations. Credit cards stolen from one merchant can be used to make fraudulent purchases from a second merchant, but it is not always possible to demonstrate a direct causal link. Even in cases of large-scale theft of credit card numbers, the merchants responsible have not been held liable for losses incurred elsewhere. Case law has been evolving rapidly since the TJX Companies breach.²⁹ There are a number of lawsuits under way and at least one settlement involving banks and a merchant.³⁰

Accordingly, the actor in the system with the least incentive to ensure confidentiality of customer data is the merchant. The economic incentives are driven by the current transaction. The merchant does not want to accept a fraudulent method of payment; this is the main priority. The security of the payment instrument after a successful transaction is secondary. As long as the payment has cleared, any breach resulting in the disclosure of data after the fact has only indirect, second-order effects on future revenue for the merchant. The original charge will not be reversed. The only costs to the merchant are the secondary costs of recovering from a data breach,³¹ and combating reputational damage and negative publicity.³² Even these secondary costs are hard to assess, and some earlier research suggests that public disclosure of breaches has not resulted in a decline in the valuation of public companies who have suffered data breaches, an indication that the market may discount this signal.³³ In most cases there is no direct penalty, no fees

are imposed, and there are no costs commensurate with the cost borne by individuals whose information was breached.

Third parties contracted to handle financial information downstream have even less accountability to the customer because they are chosen by a merchant/lender and have no direct interactions with the consumer. The consumer does not usually know which agents are being employed by a merchant for order fulfillment and other sensitive tasks. But even if this information were known, the consumer would have no way to force the merchant or lender to use a different agent. In some cases the relationship with an agent can even be contractually mandated. For example, credit reporting bureaus collect information from lenders regarding the payment history of consumers. A consumer has no way to opt out of this secondary data sharing.

In contrast to merchants and lenders, the card networks and issuing banks have a strong incentive to keep fraud levels low. Because their revenues are generated by commissions on transactions, high levels of fraud or the perception of risk may increase customers' reluctance to use their cards, resulting in fewer commissions. This is consistent with the emergence of new security assurance programs such as PCIDSS, which contractually set minimum information security standards on companies handling credit cards.

SSNs and demographic information that enable new account fraud present an even bleaker picture in terms of incentives. As noted earlier, this is an open system without an umbrella organization comparable to the card network that binds all the participants contractually. Each lender's risk management objectives are determined independently of others, focusing only on the problem of reducing bad loans for that lender. There is no single entity with incentives to reduce total fraud in the system. The cost for new account fraud is distributed to lenders. There is no contractual arrangement similar to that which exists between merchants or issuing banks and the card network. Nothing forces lenders to absorb losses and compensate the consumer. Not surprisingly, there is no equivalent to PCIDSS for entities trafficking in SSNs and related personally identifiable information.

Generous Data-Retention Policies

Merchants and lenders frequently hold on to financial information long after the information is needed for the original transaction and any dispute resolution. They do this in part because of contractual arrangements that require keeping details of a transaction up to several years for auditing purposes. Also, the decreasing cost of storage makes it much easier for system designers to

retain all data indefinitely. Meanwhile, merchants and lenders who retain large amounts of data are attractive targets for criminals.

The evolution in business models toward subscription services and away from individual transactions also contributes to the problem of long-term data retention. A subscription-based service requires periodic billing processes over the lifetime of the subscription. Each instance involves processing the same financial data over again, exposing it to risks anew. By contrast, a transaction occurs at a single point in time, and after that point the payment instrument is relevant only for record-keeping purposes. This is an important distinction because data committed to long-term, offline archives are often much easier to protect than data that are moved around and periodically accessed.

Finally, there are business incentives for retaining payment information even if the information has no obvious immediate use. E-commerce merchants that operate on the transaction model prefer to retain the credit card for long-term storage as a convenience, in the hope that streamlining future transactions by removing one step in the transaction will lead to increased sales. For example, several popular e-commerce merchants use a checkout process that saves the provided credit card information for future use *by default*. A customer with a stronger preference for privacy has to be vigilant and opt out each time by making the appropriate selection in the user interface. In some cases there is no opt-out opportunity; the customer has to manually delete the payment instrument from the system after making a purchase. The opt-out nature of this decision leaves it up to customer diligence to minimize the risks associated with unnecessary data retention.

Indirect Monitoring and Auditing

Fraud detection is an integral component of credit card networks and is often touted in commercials as a feature that increases the overall trustworthiness of the system. Sophisticated monitoring systems are developed and operated by card networks to flag unauthorized use of financial information. These systems are not controlled by or directly accessible to card holders. The precise details of the algorithms used for this purpose remain carefully guarded trade secrets. The reasons for secrecy could be a combination of competitive advantage or reliance on security-through-obscurity, since greater transparency may enable criminals to better disguise fraudulent activity.³⁴

Payment card networks easily lend themselves to monitoring solutions because of their centralized architecture. A small number of points in the system have complete visibility into all transactions; payment authorization requires

information from the merchant to be submitted to one of a small number of clearing points. With such a comprehensive picture of activity data available, it becomes possible to build very accurate, personalized models of expected behavior. Owing to the real-time nature of the transaction, it becomes possible to spot divergences from the template quickly. On the other hand, these systems cannot infer user intent. They can spot only statistical anomalies in spending patterns. For example, charges from a location geographically distant from the billing address cannot be automatically classified as fraud because that would pose problems for card holders on vacation or traveling on business. The algorithms must be conservative by nature and err on the side of not flagging possible misuse. Consumers have the upper hand in that they can distinguish between these two scenarios and instantly identify a purchase they have not made. But they must contend with reduced visibility and delay in getting access to the transaction stream. A monthly statement may not arrive in the mail until several weeks after an unauthorized charge is made. Increasing acceptance of online banking is closing this feedback loop to the point that a savvy consumer can view transactions within hours of their clearing and regularly check for any suspicious activity.³⁵ This arrangement is clearly onerous for customers and favors those with a high degree of comfort in using the internet for financial services.

For SSNs and new account fraud, there is no corresponding entity that provides complete visibility into all transactions. Credit reporting bureaus come the closest to fulfilling this role because they routinely receive data about loans. However, the bureaus usually have no direct relationship with the consumer.³⁶ This is an important difference: the credit card holder is a customer of the card network, as well as of the issuing bank. The network derives revenue from the commissions generated each time the payment instrument is used, and for this reason the card network has incentives to retain the business of that customer. Combating fraud in the system is easily justified in this scenario. In contrast, a credit reporting bureau derives revenue from brokering information about consumers to other businesses. There is no direct accountability to the individuals whose credit history is at stake, except in narrowly defined terms delineated by regulations such as the Fair Credit Reporting Act.³⁷

Because this information is not directly available, several companies have stepped in to fill the void, offering to monitor an individual's credit history for signs of identity theft. Some of these companies are affiliated with the reporting bureaus and data aggregators. Others tap into the same data stream and add value in the form of pattern detection algorithms. Again, however, the onus is on

the consumer to exercise due diligence and pay for these services. Congress took an important step with FCRA in entitling all individuals in the United States to a free credit report every year from every major credit reporting agency. However, considering the speed with which identity fraud can be perpetrated, even several spot checks per year cannot take the place of real-time monitoring.

Designing for Recovery

Lifetime management is another area where practices associated with financial information are not consistent with the notion of sensitive information. Again, the credit card system is better designed than the Social Security system in this regard. Typical payment cards have a lifetime of several years by default. This default is a trade-off between security and convenience. Card issuers could improve security by shortening the credit life of the card, but they would then pay more to send out replacement and activate cards more frequently. Some issuers have also experimented with one-time credit card numbers, which are valid only for a single transaction and harmless if compromised afterward.³⁸ Revocation is straightforward because most card transactions are verified in real time; the merchant contacts the network before accepting payment. As soon as the card holder reports a card missing or stolen, it can be deactivated and all future transactions declined. From the customer's point of view, the process is as simple as a toll-free call. Revocation has no long-term repercussions. The inconvenience is limited to a period of time when the payment instrument is not usable until a replacement arrives.

SSNs pose a greater challenge. They are valid permanently.³⁹ Because the SSN is assigned by the Social Security Administration, rather than given on demand, it is not possible for an individual to unilaterally drop the identifier. This is a significant difference from the freedom to close a credit card account at any time. At most, a consumer can opt to place a "freeze" on his or her credit history with credit reporting agencies. This amounts to placing a note on the file to the effect that no new loans should be opened for this person without additional validation.⁴⁰ Not only does the SSN never expire, but the system makes few provisions for revocation and replacement. It is very difficult to get a new SSN even when identity theft can be demonstrated as the reason for requesting one. On the subject of applying for a new SSN, the Social Security Administration website states:

If you have done all you can to fix the problems resulting from misuse of your Social Security number and someone still is using your number, we may assign you a new number.

You cannot get a new Social Security number:

[...]

**If your Social Security card is lost or stolen, but there is no evidence that someone is using your number.*

If you decide to apply for a new number, you will need to prove your age, U.S. citizenship or lawful immigration status and identity. For more information, ask for Your Social Security Number And Card (Publication Number 05-10002).

*You also will need to provide evidence that you still are being disadvantaged by the misuse. [emphasis added]*⁴¹

This is an unduly strict requirement. It positions a change in SSN as the last resort after all other schemes for combating identity theft have failed, instead of a precautionary measure. This is designed to prevent individuals with a negative reputation, such as a bad credit rating, from being able to start over with a clean slate and evade accountability. The flip-side is that individuals with a good reputation attached to their SSN will also suffer a setback and have to start from scratch when issued a new SSN. In fact, such a cautionary note accompanies the above statement in the Social Security Administration publication.

If the conditions were relaxed, it is true that changing a SSN would carry significant costs for companies relying on SSNs, given the number of databases indexed by the SSN. However, the inability to purge incorrect data attached to the revoked SSN is strictly a design limitation in the credit reporting system, not in the Social Security system. It is possible for companies to upgrade systems and link new and old identifiers, carrying over the records associated with the revoked identifier. For the systems deployed today, this appears to have been implemented in an inconsistent fashion. For example, the Federal Trade Commission states: “[a] new Social Security number does not necessarily ensure a new credit record because credit bureaus may combine the credit records from your old Social Security number with those from your new Social Security number.” This design limitation is another factor in making it very difficult to recover from unauthorized disclosure of an SSN.

Risk Management Beyond Secrets

The intermediate quasi-secret state of financial data cannot be easily addressed with incremental improvements. Strictly applying the information security lessons discussed in the previous section to credit card numbers and SSNs would require fundamentally overhauling business models around the

use of financial information. Another alternative is more promising, and credit card networks have already moved closer to achieving this ideal: a state of affairs in which even the unauthorized disclosure becomes a manageable risk, accepted as the cost of doing business. The previous sections argued that the assumption of confidentiality around payment cards and SSNs does not hold in the larger context of the business processes that depend on them. Even when an individual consumer goes to great lengths to control the initial disclosure of information, such as by using encryption for online transactions, once he shares information with any service provider, data will flow through an interconnected network of public and private entities. It is susceptible to security risks at many points, and these risks are beyond the control of the consumer.

It may be more appropriate to view payment cards, bank accounts, and even SSNs not as “personal information” belonging to the user, but rather as information that is properly owned by an external entity—the payment card network, the bank, and the Social Security Administration, respectively—and merely loaned to the user temporarily. This is a tempting way to frame the issue because it implies that a data breach is no longer the consumer’s problem; it is a problem for the asset owner responsible for that information. In other words, provided the incentives are structured correctly, the fact that the information is quasi-secret may be perfectly acceptable from the point of view of the consumer. If the costs of unauthorized disclosure were borne by someone other than the consumer, this arrangement might succeed. The important point is that someone must be willing to accept the risks of disclosure of financial data and underwrite any losses.

It may seem counterintuitive that any for-profit entity would agree to underwrite such losses when there are so many possible points of failure. Payment information is handled by different entities, and a data breach can occur anywhere in the chain, potentially caused by the actions of any participant in the system. Yet the success of payment card networks in the United States suggests that zero liability for consumers may well be the optimal solution in the market.⁴² By contractually obligating merchants to absorb the costs of fraud and to implement minimum security requirements, the credit card networks limit damages from fraud, on the one hand, and create the illusion of zero liability for card holders, on the other. This approach works in a closed system because the card network overall stands to gain from retaining customer loyalty. Revenue is derived from the so-called interchange fee, taken as a percent-

age of each consumer transaction. Therefore, shifting loss away from the consumer is a reasonable course of action that would protect the card network's revenue stream.

Achieving the same worry-free status for SSNs would require a fundamental change in how individuals are authenticated in the context of commercial transactions. A consumer could shrug off disclosure of the SSN only if one of two conditions held: either the SSN becomes no longer useful for committing fraud, or all the costs associated with the fraud are offloaded to another entity.⁴³ The first condition is not true today because the SSN is an authenticator. If there were a reliable way to authenticate consumers that did not depend on disclosing the SSN or other personal information, the SSN would return to its original role as an abstract identifier. Credit reporting and consumer profiling businesses could operate as before, using the SSN as a unique identifier convenient for indexing databases. Provided that lenders and merchants did not confuse knowing an SSN for some individual with *being* that individual, there would be no identity theft possible resulting from a disclosure of the SSN. Unfortunately that vision calls for an ambitious new identity management system with universal reach throughout the nation.⁴⁴ More robust identity management systems based on two-factor authentication have been fielded for limited scenarios, such as using smart cards in conjunction with public-key infrastructure for managing identity within an enterprise. The Department of Defense's Common Access Card (CAC) is one of the largest efforts to date.⁴⁵ Yet there does not appear to be a realistic short-term substitute for the SSN that meets three key criteria. It must be available to any U.S. resident for proving his or her identity for commercial and noncommercial purposes; it must be simple to use without requiring special hardware; and it must be suitable for authentication in person, by phone, or over the internet. In addition, any new identity management system would face a significant uphill battle for adoption. Given that switching over every commercial activity at the same time to the new system is unlikely, it would take a very gradual transition phase lasting several years before the benefits were fully realized. Until the migration was complete, the SSN would still create identity-theft risks in scenarios where the perpetrator can prey on the laggards still using the weaker authentication scheme. Assuming that the technical and logistical problems could be surmounted, an even greater challenge would remain in political viability. Past "national ID" proposals advanced in the United States have been met with strong opposition on privacy and security grounds.⁴⁶ However, several European countries have moved

to adopt electronic ID (“eID”) systems, which mandate issuing every citizen a smart card for authenticating to any endpoint online.⁴⁷ The United States may have moved one step closer to a national identity system with the passage of the REAL ID Act in 2005, but as the implementation deadline of May 2008 loomed closer, vocal opposition from states remained.⁴⁸

The second condition, that all costs associated with SSN fraud be imposed on a party other than consumers, is not the law today. It is even less likely to change than the first condition. There is a large ecosystem of businesses trafficking in personal information, but there is no single entity comparable to the card network with incentives for managing risk across the system. With the possible exception of insurance-based approaches, it is difficult to envision a scenario in which any for-profit business steps in to absorb costs from new account theft incurred by consumers.

More important, SSNs operate in a space that lacks certain market mechanisms. Market dynamics cannot operate in the absence of consumer choice. Payment card networks are free to compete on their merits, including both their data security systems and their indemnification structure for any resulting fraudulent activity. Customers can make decisions based on these factors. They are under no obligation to carry a card issued by a particular issuer or network, and consumers are free to close an account at any point. Many of the data aggregators and brokers implicated in breaches, however, are immune from this type of opt-out decision. A significant fraction of compromised records were taken from “third parties” such as Acxiom, ChoicePoint,⁴⁹ and Card Systems, with whom the consumer has no direct relationship. Most U.S. consumers have no ability to opt out from having their data percolate through these third parties once the information is initially disclosed to one of the participants.

Although data breach notification laws passed by individual states, such as California,⁵⁰ have succeeded in raising the visibility of the problem, consumers are just beginning to understand the risks to which they are subjected. Visibility alone is not enough to create competitive dynamics, because consumers have no say on whether they have an SSN, and more important, which entities will be in possession of it at any given point in time.

Conclusion

Summarizing the preceding discussion, we can identify three trends that have changed the status of credit cards and SSNs as “personal financial information.” The first trend is the arrival of business models that depend on compelling

customers to disclose financial information in the course of transactions and then share this financial information with other entities. This raises a question about who indeed owns the information; the individual consumer has very little control over the disclosure and sharing aspects of this financial information. It is difficult to consider credit cards and SSNs as secrets in the traditional sense of information security because several best practices around managing secrets are violated in the context of the overall system.

Although this first trend applies equally well to card data and SSNs, the remaining two trends tug in opposite directions. The second trend concerns the adoption of the risk-pool model for dealing with fraud in payment card networks. This model is contractually imposed by the network operator on merchants and issuing banks. When individuals have no direct liability for fraudulent purchases, the risks from data breaches are diffused throughout the system, instead of falling disproportionately on card holders. Diffusing the impact of the loss is not the same as reducing the losses, but it does align the incentives of all participants in the network with those of the consumer card holder. It creates incentives for merchants and lenders to avoid data breaches and puts pressure on all entities handling payment card information to improve their security posture.

The final trend is the growing reliance on personal information, specifically SSNs, as the underlying credential for verifying the identity of consumers. Improvements in data security can benefit systems handling SSNs as much as they can benefit systems handling payment instruments. Greater awareness of and investment in information security can be expected to reduce the likelihood and severity of data breaches. But as was argued in the preceding section, the system is fragile: recovering from unauthorized disclosure of SSNs is very difficult. A comprehensive solution to the problem—such as the adoption of a strong new identity management system based on two-factor authentication that can substitute for the current uses of SSN—is very unlikely in the near future. Authentication using SSNs takes place in the context of an open-ended, highly decentralized system where there is no single entity responsible for overseeing the security of the protocol. Even the Social Security Administration, which is responsible for issuing the credential in the first place, does not oversee the system. The reluctance of the Social Security Administration is understandable, considering that the SSN was not originally intended to be used to authenticate buyers in commercial transactions. It is becoming even less suitable over time: increased use and accompanying data breaches render

the assumption that an SSN is “secret” completely untenable. Greater exposure of SSNs simultaneously increases the risk of data breaches and their consequences, since a compromised SSN is now useful for impersonating a victim in additional contexts. This ease of impersonation does not bode well for the future incidence of new account fraud.

8 Information Security of Children's Data

From "Ego" to "Social Comparison"—Cultural Transmission and Child Data Protection Policies and Laws in a Digital Age

Diana T. Slaughter-Defoe and Zhenlin Wang

THE INTERNET has brought radical social change. From an educational perspective, the internet facilitates teaching and learning. From a social-emotional perspective, however, the internet has also brought data protection concerns, particularly for children. Children are using the internet in ever-increasing numbers,¹ and they are avid consumers who readily share their personal and family information online. According to *Business Week*,² in 2005 the teen consumer spending market was estimated to be \$175 billion a year. In that same year the Pew Internet and American Life Project found that 43 percent of the online teens had made purchases online.³ That translates to approximately 9 million people, a 71 percent increase in teen online shoppers from 2001.⁴ Children have the right to share in the opportunities presented by emergent internet culture. However, a critical question is, how do we protect children and their information as they enter this online commercial and non-commercial world?⁵

In the past quarter-century, child development scholars have embraced ecological paradigms. These paradigms expand the identified cultural transmitters beyond parents to include mass media, such as the internet, as a critical part of children's cultural context that influences development.⁶ What has not been addressed adequately in the child development and other literature is the extent to which risks to children's data security and informational privacy are increasing.

In this chapter we argue that successfully protecting children's information online requires understanding the development of children through adolescence and acknowledging the powerful role of cultural transmission in the emergence of their cognition, personalities, behaviors, and skills. The Children's Online Privacy Protection Act (COPPA) of 1998, which specifically addresses the collection of data about children, appears to be relatively ineffective legislation that is not adequately sensitive to developmental concerns.⁷ Consequently, the present chapter argues that to ensure children's healthy development, future legislation should take into account children's developmental attributes more directly. In addition, a more successful law would empower parents in their attempts to protect their children's information, instead of diminishing parental control. Parents are naturally concerned about their children's online activity and exposure to information, but frequently they do not know how to protect them.

The Children's Online Privacy Protection Act (COPPA)

The Pew Internet and American Life Project reports that 81 percent of parents and 79 percent of teens say teens are not careful enough when sharing personal information online.⁸ The first federal law to directly address the issue of children's informational privacy in cyberspace was the Children's Online Privacy Protection Act (COPPA) of 1998.⁹ The law, which took effect in 2000, requires websites targeted at children to post privacy policies and to obtain verifiable parental consent before collecting, using, or disclosing personal information about customers who are under 13 years of age.¹⁰ After roughly ten years in force, it is fair to say that COPPA is widely considered a regulatory failure and is frequently ignored and circumvented by both websites and children.¹¹

COPPA has been criticized as hard to implement.¹² In particular, parental involvement in monitoring children's internet usage, one of the express goals of the legislation, is not adequately facilitated. Although the law anticipates greater parental involvement in children's internet activity, the practical reality is that parents usually lag behind their children in mastering the technology. For example, although 62 percent of parents report checking on their children's online habits, only 33 percent of the teens say they believe their parents actually do so. Parents frequently do not have the technical know-how to become more effectively involved in internet monitoring. Especially in new immigrant families where parents speak English poorly or not at all, monitoring children's internet activity is difficult, if not impossible.¹³

A corollary criticism of COPPA is that, in addition to inadequately accounting for the parent-child dynamic, it also demonstrates a suboptimal understanding of the drivers of child development. COPPA adopts a bright-line age-based approach that does not seem to have been thoughtfully chosen. Any successful attempt to protect children and their data online must start with an understanding of the multiple stages and contexts of child development.

Decentering—from “Ego to Social Comparisons”

The internet has a powerful influence on children from a developmental and psychological perspective, and children are engaging with technology at progressively earlier ages. In other words, using the internet changes a child's developmental progress.

Psychologists and other professionals pay considerable attention to the transition that children make between roughly ages 3 and 6. Thanks to the research and theorizing of Jean Piaget, John Flavell, and many others, we know that children essentially cognitively “decenter” during this period of their lives.¹⁴ They no longer perceive the world as if they are the center of it; rather, they become capable of perspective-taking, role-taking, and genuine empathy, and of making social comparisons. From a developmental perspective, this process is an extremely gradual one, appearing during infancy in children's behaviors, but increasingly being associated with children's emergent thought and language. For example, when children become mobile during infancy and toddlerhood, they become able to adjust their movements to remain in close proximity to caregivers, and later they begin to anticipate parental moves.¹⁵ Children's interpersonal environments facilitate the increasing ability for perspective- and role-taking. Parents and teachers of young children encourage them to respect the needs and wishes of others, young and old alike.¹⁶ Adults and older peers encourage the developmental transition, and also encourage children to engage in early social comparisons.¹⁷ Children gradually learn to gauge how they are doing by comparing themselves to peers, and even to themselves at earlier points in time.¹⁸ From all indications, these processes are culturally universal. However, what differs are the contextual and interpersonal environs that permeate the children's worlds while these developmental processes emerge.

In cultures heavily affected and influenced by the digital age and technology tools, these tools influence children's consciousness, social relations, feelings, and physical well-being. First, these tools and products are associated with cultural transmission in this age, and second, are typically used to transmit

ideations and values representative of the macro-societal culture. On both dimensions, children gradually come to compare themselves with siblings and peers. They compare their competence in tool usage, and they compare the ideations and values that they are exposed to by virtue of using technology tools, such as the internet.

There are two paths of developmental influence by electronic media: direct and indirect. The direct path is obvious: a child's solitary play with any of the electronic media is likely to result in new learning, whether negative or positive.¹⁹ The indirect path should also be obvious, given what has been stated to this point: children are influenced by what their peers convey to them about their own exposure(s) to electronic media. Children's natural tendency to compare themselves socially could heighten the impact of even small and infrequent exposures to technology because they are taught and encouraged to value the society, counsel, and opinions of identified peers. The younger the child, the less likely she can buffer those influences without assistance from others. Conversely, however, the younger the child, the more resilient she is likely to be in responding to longer-term, potentially detrimental effects, with the proviso, of course, that the exposure not be especially intense or traumatic. In other words, as progressively younger children use the internet and disclose information through social networks, blogs, and online communities, they will encourage their peer groups to engage with these tools as well. Consequently, progressively younger children will begin to regularly disclose information about themselves online.

The child development literature on the impact of the internet is in its nascence. Therefore, turning to a well-developed body of media literature, the child development literature on the impact of television and broadcasting, we here consider the developmental impacts of media and apply them to the internet child data protection context to the extent possible.

Television and Broadcasting— Unresolved Electronic Media Issues

There is a respectable body of both legal literature and child development research related to television and broadcasting. The struggles to limit negative developmental impacts from television are still ongoing. Studying patterns of corporate and consumer behavior in response to legislation aimed to address the developmental impacts of television can assist us in considering the most promising legislative approaches in the children's data security context.

In the 1990s the Children's Television Act was passed as an amendment to the Communication Act of 1934, requiring educational programming for children, and in 1996 this requirement was amended to include what has become known as the "Three-hour Rule." Specifically, broadcasters serving the public must provide three hours of programming per week that could appeal to children's pro-social or cognitive development, but education must be a main or primary purpose. As Amy Jordan states: "Thus, according to the FCC's Report and Order 'Educational and informational television programming' is defined as any television programming that furthers the educational and informational needs of children 16 years of age and under in any respect, including children's intellectual/cognitive or social/emotional needs."²⁰ It had been the hope of many that the mandatory three hours would be hours of structured curriculum content (e.g., science, math). However, by 1996 broadcasters had convincingly argued that it was more cost-effective to focus on pro-social characteristics that would appeal to larger, and even international, audiences of children, and that would enable them to compete effectively with emergent niche markets.²¹

Jordan reports that the three-hour rule has had little impact on what she considers educational programming for children. Insisting that the question of whether prosocial programming can impart valuable lessons to young audiences remains viable today, Jordan writes:

A meta-analysis of the effects of prosocial programming by Mares and Woodard [2001], conducted with 34 studies and a total sample of 5,473 children, supports the notion that television can have a small but measurable impact on attitudes [counterstereotyping] and behaviors [altruism, friendliness, and reduced aggression]. Importantly, however, the relation is strongest for children younger than 8 years. The authors hypothesize that preschool children are more susceptible to television's messages in general and are more likely, as a group, to have positive programming directed to them. It may also be the case that once the children have become familiar with the rhetoric of social and emotional lessons, they no longer learn anything that is truly new in this realm."²²

Jordan learned that broadcasting corporations do not want to spend revenues for programming that is unlikely to reach large audiences, including large audiences of children. Broadcasters do not promote programs based on how good or relevant to the educational needs of children and their families they are.²³

What are the lessons to be learned from this brief overview? First, children are indeed susceptible to television broadcasting, a potent form of electronic

media. Second, from parental and familial perspectives, it is possible to identify both positive and negative influences and, through research, to specify conditions under which children are more susceptible. Third, technological advances (such as the “V-chip”) have empowered parents and given families more control over children’s susceptibility to the direct influence of television broadcasting. Fourth, corporate investment and entrepreneurial activity have been barriers to child protection in the television and broadcasting arenas. Fifth, and finally, lower-income and ethnic minority children spend more time viewing television and related broadcasting programming than majority children. In these communities, television and other electronic media are frequently used as “baby sitters,” substituting for family activities and interactive fun-filled experiences, given the parents’ heavy work schedules and limited resources to spend on family activities.

Like television, the internet is a potent form of electronic media. However, unlike television, because of its interactive format and data collection practices, the internet also presents new types of risks and influences. Children who play internet games can request and receive immediate interactive feedback. This feedback, when offered properly, has high educational value, but it can also be a source of extensive, unregulated, and negative time use. Television, although it shares similar positives and negatives with the internet, from the vantage point of children is primarily a passive, rather than active or proactive, media form. Television collects little if any information about an individual child. Given what we know about the potent impact of interactive feedback on persons, particularly developing persons, we think that whatever the documented effects of television broadcasting have been, the impact of the internet on children’s future and development is likely to be tenfold greater.

Restricted Freedom in Virtual Space: The Internet Phenomenon Among Youth

The widespread use of the internet inevitably influences almost every aspect of social life.²⁴ The internet is an effective learning medium from an educational perspective, and it simultaneously functions as a social networking platform from a social perspective. Empirical evidence suggests that the internet has a positive effect on facilitating students’ learning by encouraging engagement and participation, giving frequent interaction and feedback, and connecting learning to real-world contexts.²⁵

In 2005 the Pew Internet and American Life Project surveyed a national representative sample of 1,100 teens about their internet use.²⁶ Of 24 million U.S. teens from 12 to 17 years of age, 87 percent used the internet, 65 percent used instant messaging, and 51 percent went online everyday. Fifteen- to eighteen-year-olds spent 1 hour and 22 minutes a day on average on the computer for activities such as social networking. This number is almost three times higher than a similar Pew survey found in 2000.

A 2001 survey of 728 teens from British Columbia, Canada, suggests that the primary purpose of teens' internet use is to entertain.²⁷ Teens' favorite online activities include downloading music/shareware, using e-mail, surfing for hobbies, chatting with friends, gathering information, watching videos/multimedia, online games, education/school work, surfing for no particular purpose, and shopping/buying things.²⁸ Each of these internet uses involves transfers of data about the child.

Over a child's lifetime, the extent of aggregated information available about her resulting from internet activities will greatly surpass the data collected about her parents. Because of the data retention practices of websites and corporate databases, youthful indiscretions, purchases, friendship groups, and the like will follow her wherever she goes. Digital information storage capacity greatly exceeds that of any traditional file cabinet, so the information stored can literally exist forever. Second, records exist about almost every move users make while online: the user's internet provider address, websites the user visited, business transactions, credit card information, banking information, health records, and so on. As Ellen Alderman and Caroline Kennedy wrote, it is almost like "having another self living in a parallel dimension."²⁹

Both parents and teens think teens are not careful about spreading personal information on the internet.³⁰ A 2005 online poll of 1,468 U.S. minors (ages 8–18) revealed that youth frequently take risks with their personal information and communicate with people they have only met through the internet.³¹ Two in five (42 percent) of online teens (ages 13–18) said they had posted information about themselves on the internet so others could see it and contact them:

- Online teens frequently communicate virtually with someone they have never met: 54 percent had done so using Instant Messaging; half via e-mail; and 45 percent in a chat room.
- More than half of the respondents (56 percent) said they had been asked personal questions online. One-fourth said they received such questions weekly; one in 10 received such requests daily.

- Significantly more online teen girls than boys (ages 13–18) reported posting a profile (56 versus 37 percent), sharing personal information (37 versus 26 percent), and being asked about sexual topics (33 versus 18 percent).

The last bullet point was confirmed by a Pew report on teens' Web content creation. Pew found that older girls (15- to 17-year-olds) lead in online communication and information seeking. They also lead the blog population. Twenty-five percent blog, compared to 15 percent of 15- to 17-year-old boys, and 18 percent of all younger teens online. Overall, 57 percent of online teens create content for the internet, be it a blog, personal and other Web pages, or by sharing and mixing Web content.³²

Why do so many youth expose themselves on the internet? One of the drivers for these behaviors may be developmental.³³ Children, especially young children, need to establish a sense of autonomy and independence by exploring their surrounding environment. They have a "can do" attitude and are willing to face the world's challenges. They are eager to take on responsibilities, learn new skills, and feel purposeful. They want to demonstrate that they have control over their lives. The internet is an ideal playground for children's growing sense of self. Through personal profiles and blogs, internet content generates an illusion among children that they are in control of themselves, which provides them a great sense of power, especially without adult supervision. In other words children are likely to engage in more information sharing behaviors than adults.

Teens also go through developmental periods that may encourage them to share data online. Adolescence, in particular, is an important period for identity development.³⁴ Identity refers to knowing who you are and how you fit into your community and the world community. Western teens use the internet as a place to experiment with building their own personally meaningful identities. Given its distinctive culture, an online community can help adolescents to identify aspects of their own identity.³⁵ Sometimes these community-constructed identities are undesirable or destructive; but being "unique" or even being "bad" is better than having no identity.

At the same time that children are developing initiative in response to the world, they also need a sense of secure attachment and emotional and social bonding with people. Social networking websites allow youth to chat live with other people. It is real-life interaction, and therefore it is possible to become emotionally involved with strangers. For many youths, however, once they have spoken with someone on the internet, that person is no longer a stranger to

them. Two people who meet online can become friends, even lovers. But because online communication does not happen face-to-face, it is easier for a person to lie or misrepresent himself. Since youth are often more trusting than adults, they may fail to recognize the potential danger of their virtual "friends."

The target of the bonding can also be fictional characters, or in the media age, role models in the virtual world. Children identify with characters and role models, imitate their behaviors, and even copy their clothing and hairstyles. For example, when playing video games, children assume the role of the hero in the game's plot, such as Harry Potter, and attempt to solve the same kinds of problems that Harry would. The player's identity and Harry Potter's become inseparable: the child becomes Harry Potter.³⁶ The case of Harry Potter also illustrates the links between economics and business interests, the child and its family as consumers, and the interplay of numerous electronic media, including the internet, with the child's imagination and overall development. Youth indulge in an active and extensive fantasy life, and they frequently find it hard to distinguish imagination and fantasy from reality. The virtual world breaks the physical boundaries of real space, and therefore it is full of "impossible" possibilities that make it extremely attractive to children. The problem, of course, is children are unaware of the consequences of online behaviors. When they provide personal information to someone on the internet, the full range of what that person could do with the information is unknown to them.

What We Can Do to Better Secure Children's Information: Empowering Parents

One strategy that has not adequately been explored, either legislatively or through independent private sector efforts, is empowering parents to protect their own children more effectively. Although parents frequently attempt to use technologies such as filters to assist them in monitoring their children's data sharing online, they don't always succeed. According to the Pew Internet and American Life Project,³⁷ by November 2004, 54 percent of internet-connected families with adolescents were already using filters such as Net Nanny and Cyberpatrol, up from 41 percent in December 2000. However, the burden of understanding filter technology and monitoring child's online activity is beyond many parents' technological capabilities.

Second, skilled young users can easily find ways to circumvent or disable filters. Current filters fail to accurately screen conduct.³⁸ Therefore, even though more than half the families with online teens use filters, 65 percent of parents

and 64 percent of teens state that teens still do things online that they “would not want their parents to know about.”³⁹

One approach to improving parental supervision is to create shared computing spaces in the home. The British Columbia survey by Stephen Kline and Jackie Botterill in 2001 reported that teens spent much more time on the internet when the connection was in their own rooms.⁴⁰ The Pew Internet and American Life Project reported in 2005 that 74 percent of American teens online had access to the internet in open areas at home;⁴¹ that leaves the other 26 percent who use the internet in their bedrooms without adult supervision.

Many parents feel that their ability to influence their children’s development is limited by their lack of technological adeptness. Few sources of assistance for parents exist, and parents feel their requests to companies to protect their children’s data go unheeded.⁴² For example, some parents are furious that their children, especially underage children, are able to create profiles on social networking websites like MySpace. One reader of the *Business Week* article “The MySpace Generation” left this comment under the name “Outraged Dad”:

MySpace is totally irresponsible, and undermines parental authority. There is nothing to prevent a child of any age from making a profile and being subjected to all the vile sexual junk that is passed along by teens and preteens, and, according to correspondence I’ve received from MySpace, there’s no way you can delete your own child’s account unless they volunteer to give you their password. That’s not likely. I’ve investigated the numbers: MySpace is cashing in big on advertising revenues aimed at kids—they have every reason to keep potential advertising targets of any age, or of any “reported” age. If these people could make money by taking your kid to a strip club, they’d do it in a heartbeat. Is anyone else willing to do something about this?⁴³

Another “Concerned Parent” expressed similar worry about MySpace’s failure to restrict access by young children:

I agree the parents need to monitor their children. The problem is other children set up myspace sites for your child and post pics of your child with personal information. There are too many weirdos out there for this to keep happening. I have tried contacting myspace to have a site shut down containing pics of my daughter when she was 13 and all I have received from the request is spam. MySpace needs to step up to the plate and remove sites per parents’ requests. In the next town over from where I live the 12–14 yr old students hacked

the school firewall to get into the MySpace site from school. What about those parents? They are monitoring their child's usage at home. How can myspace say at 14 yrs old children are responsible enough to make safe Web surfing decisions. The US Govmnt and US State's state they are not responsible by making the average age to drive 16 and Drink 21. A child is not even of the age of consent until they are 16. MySpace needs to start helping parents.⁴⁴

The most popular "solution" to the child data security problem is self-regulation by the private sector.⁴⁵ The argument is that the market is already adequately accounting for privacy concerns.⁴⁶ The market provides incentives for companies to respect privacy and be honest about how they handle customers' personal information in order to avoid negative press coverage. Companies are already adopting privacy policies, limiting the use and the trade of customer information. In addition, they are also providing information, products, and services for websites that require personal information for access. Customers give up a certain degree of privacy for the "equal exchange" of services, and therefore the information becomes a "price" of some sort. Companies use the information to profile and better serve customers. Thus, in the long run, the "equal exchange" allegedly benefits the consumer. However, the downside of the market solution is that customers have no bargaining power in the privacy contract. This is especially true in the case of young customers who are perhaps more willing than adults to give up privacy for products or services and even less likely to consider the consequences. As demonstrated by the posts of concerned and frustrated parents, companies knowingly disregard the wishes of parents in connection with their children's data. The small print in privacy agreements on websites becomes the "devil's bargain" because there is no mechanism for customers to have a meaningful choice about how their data are used, and parents become disempowered in protecting their children.⁴⁷ Consequently, this type of industry self-regulation in the context of child data protection has not succeeded. New approaches should require that collectors of children's data enforce the wishes of parents.

Parents are and should be the primary directors of their children's development. However, the power to control their children's information is increasingly taken out of the hands of parents and placed into the hands of private businesses; we are undercutting parents' ability to raise their children as they see fit. Parents cannot protect their children from negative developmental influences on the internet if their attempts to shield their children's data can be ignored.

Conclusion

Child protection policies and laws, to be maximally effective, need to affirm parents' authority to protect their children's data. Parents have a right to worry about the exposure of their children's information to persons, events, activities, projects, and products that potentially threaten their children's healthy cognitive, social, emotional, and physical development. Further, the best ways to protect children and their information vary according to the developmental stage they are in. Infants, toddlers, and preschoolers, elementary school, middle-school, early adolescent, and adolescent "children" all pose different challenges to those who would protect and defend them from societal predators. Any successful legislative approach to protecting children's information will take both these concerns into consideration and be coupled with research to evaluate such initiatives.

Regulation of children's internet privacy and safety from the government and self-regulation by business and families are both needed to ensure the healthy development of children in the digital age. Current legislation concerning the protection of youth in cyberspace is in need of much closer examination and critical scrutiny. This is an issue of public health and well-being. Therefore we believe public education regarding youth internet privacy and safety needs to come from multiple institutions and venues.⁴⁸ Whatever the challenges, we also believe contemporary digital literacy should be an entitlement of all children, as should protection of the privacy of their information.

9 Information Security and Contracts

Contracting Insecurity: Software License Terms That Undermine Information Security

Jennifer A. Chandler

THE CASE LAW and secondary literature on software licensing reveals disagreement on numerous issues, particularly over whether current practices of contract formation are acceptable, whether private contracts may add to or remove rights created by federal intellectual property law, and whether the common terms covering quality, remedies, and other rights are appropriate.¹ Efforts to reform the law applicable to software licensing have been ongoing for over a decade, culminating in the controversial Uniform Computer Information Transactions Act (UCITA),² and continuing in the American Law Institute's project to state the "Principles of the Law of Software Transactions."³

This chapter takes a narrower approach in thinking about software licenses. The objective is to examine software contracting through the lens of cybersecurity in order to analyze terms and practices that arguably reduce the general level of cybersecurity. The inspiration for this approach is the growing recognition that the cybersecurity problem is not merely a technical one, but is also dependent upon social and economic factors, including the applicable law.⁴ Since security flaws in widely deployed software are among the reasons for the cybersecurity problem, the laws governing software, including tort and contract, may prove to be a useful target for efforts to improve cybersecurity.⁵

This chapter will highlight a selection of license terms and practices that arguably undermine cybersecurity. The first part of the chapter considers a series of clauses that undermine cybersecurity by suppressing public knowledge

about software security vulnerabilities. This is done by preventing research through anti-reverse-engineering clauses or anti-benchmarking clauses and by suppressing the public disclosure of information about security flaws. The next part shifts gears to consider a range of practices (rather than license terms) that undermine cybersecurity. In these cases, the practices are the problem, but the licenses contribute by creating an aura of legitimacy when “consent” to the practices is obtained through the license. The practices addressed include making software difficult to uninstall, abusing the software update system for non-security-related purposes, and obtaining user consent for practices that expose third parties to risk of harm.

This chapter leaves for another day an obvious set of terms that affect cybersecurity. Nearly all mass-market licenses contain a disclaimer of implied warranties and a limitation or exclusion of liability for any damages. Evidently such terms affect cybersecurity by weakening legal incentives to avoid carelessness in software development.⁶ Whether or not the disclaimers of the implied warranties are effective depends on the jurisdiction, as some jurisdictions make these warranties non-waivable in consumer transactions.⁷ Although such liability avoidance clauses are relevant to cybersecurity, the size and complexity of this topic require that it be left to another time. Terms such as mandatory arbitration clauses or choice of law or forum clauses, which can undermine the deterrent effect provided by the threat of customer lawsuits, will also be set aside for now.

The final section of the chapter turns to the question of what should be done, if anything, about license terms that undermine cybersecurity. In particular, it is suggested that there are reasons to believe that such terms are the product of various market failures rather than a reflection of the optimal software license terms. The general contract law doctrines available to police unreasonable terms are unlikely to be sufficient to address the problem. Instead, specific rules adapted to the software licensing context are desirable.

License Terms That Suppress Public Knowledge About Software Security Vulnerabilities

Software licenses often include a term that directly undermines cybersecurity by impeding testing or examination of the software and/or prohibiting the public disclosure of the results of such examinations. One such term is the “anti-benchmarking” clause, which affects comparative performance testing of

software. These clauses usually prohibit testing or the publication of the results of the testing without prior approval by the software vendor.

Anti-reverse-engineering clauses have also been used to threaten security researchers with legal liability for disclosing information about security vulnerabilities in software, as is discussed below. Such clauses, in addition to uncertainty about liability under the Digital Millennium Copyright Act (DMCA)⁸ and similar legislation, have effectively prevented the public disclosure of important security-related information.

In order to determine whether these kinds of license terms should be considered unenforceable where they impede security research or the disclosure of the results of that research, it is necessary to consider whether the public disclosure of security vulnerabilities improves or undermines cybersecurity. As discussed later in this part of the chapter, it is likely that the public disclosure of information about software security vulnerabilities improves cybersecurity, particularly if the disclosure is made pursuant to a “responsible disclosure” regime that gives a vendor time to fix the flaw.

Anti-Benchmarking Clauses

A benchmark test is a uniform test used to examine the performance of a software program in order to make meaningful comparisons between similar programs.⁹ Anti-benchmarking clauses are used by some software vendors to prevent or control the publication of performance reviews and comparisons by independent testers.

How Anti-Benchmarking Clauses Work For example, the licenses for Microsoft’s WGA Notification application, its SQL Server 2005 Express Edition, and its SQL XML 4.0 program include a clause that states that licensees may not disclose the results of any benchmark tests of the software to any third party without Microsoft’s prior authorization.¹⁰ Microsoft is not the only one who uses these terms. The VMWare Player End-User License Agreement goes further than prohibiting the disclosure of the test results and instead prohibits the tests themselves without VMWare’s prior consent.¹¹

An admittedly extreme example is provided by Retrocoder’s threat to sue for a breach of its anti-examination license term. In late 2005, Retrocoder threatened to sue Sunbelt Software, an anti-spyware company, because it had listed Retrocoder’s “SpyMon” software as spyware in its CounterSpy service.¹² CounterSpy informed its users when it detected SpyMon on their systems, allowing them to delete it if they wished. SpyMon was a surveillance program

that logs keystrokes and takes screenshots, and it was advertised as a tool to monitor the online activities of children, spouses, and employees.

Sunbelt received an email from Retrocoder stating, “[i]f you read the copyright agreement when you downloaded or ran our program you will see that Anti-spyware publishers/software houses are NOT allowed to download, run or examine the software in any way. By doing so you are breaking EU copyright law, this is a criminal offence. Please remove our program from your detection list or we will be forced to take action against you.”¹³

The license for SpyMon reputedly provided that anyone “who works for or has any relationship or link to an AntiSpy or AntiVirus software house or related company” was not permitted to use, disassemble, examine, or modify SpyMon, and further that anyone who produced a program that impeded the functioning of SpyMon would have to prove that they had not violated the restrictions.¹⁴

The enforceability of an anti-benchmarking clause contained in the license for security-related software was considered in *Spitzer v. Network Associates, Inc.*¹⁵ In that case, the New York Supreme Court considered an anti-benchmarking clause in a license for firewall software made by Network Associates. The dispute arose because Network World Fusion, an online magazine, published a comparison of six firewall programs, including Network Associates’ program. Network Associates objected to the publication of the results, in which its software performed poorly, citing the license clause that prohibited the publication of product reviews and benchmark tests without Network Associates’ prior consent.¹⁶

Then New York Attorney General Eliot Spitzer filed a suit against Network Associates in February 2002, arguing inter alia that the anti-benchmarking clause was an “invalid restrictive covenant,” which infringed upon the important public policy of free comment on products and product defects.¹⁷ The attorney general took the position that these clauses are illegal and invalid when they impose restrictions that exceed what is necessary to protect trade secrets, goodwill, or proprietary or confidential information. The attorney general also argued that free and open public discussion of software is essential to the public’s ability to make informed purchasing decisions, to ensure that defects become publicly known and to encourage the development of safe and efficient products. This, Spitzer argued, was particularly vital in the case of security software.¹⁸

Network Associates, on the other hand, justified the term on the ground that benchmark tests are often flawed and misleading, both inadvertently and

intentionally.¹⁹ In addition, it argued, benchmark tests offer opportunities for abuse and some testers make skewed comparisons by comparing an old version of one product with a newer version of a competing product. Network Associates referred to a general understanding in the industry that benchmark tests were flawed: “According to a well-known saying in the trade, ‘in the computer industry, there are three kinds of lies: lies, damn lies, and benchmarks.’”²⁰

Network Associates also argued that the publication, without notice to the manufacturer, of information about vulnerabilities in its software would expose users to security threats until the manufacturer could respond to fix the vulnerabilities: “[P]ublication of vulnerabilities in the company’s security software products, without notice, could adversely impact millions of people by alerting hackers to opportunities without giving Network Associates time to respond. Irresponsible reporting of security software vulnerabilities has, according to many in the computer field, already exposed millions of consumers to serious risks.”²¹

Unfortunately, the court did not rule on the ground that anti-benchmarking clauses are contrary to public policy, but on the narrow ground that the particular clause used by Network Associates was deceptive.²²

Anti-benchmarking clauses may harm cybersecurity by increasing the information costs facing purchasers who might wish to consider security in making their purchasing decisions. Software is a complex, rapidly changing product, and the average consumer is incapable of accurately assessing the respective merits of competing software programs. The information costs facing the average consumer are so high that the consumer is unlikely to find it worthwhile to become properly informed. Under such conditions, a reliable information intermediary is essential to ensuring that consumers are adequately informed so that the market may function properly. The suppression through anti-benchmarking clauses of information intermediaries (such as computing magazines that offer “consumer reports” on particular types of software) who might be able to produce this information more efficiently simply increases information costs for purchasers.

Anti-benchmarking clauses have their most obvious effect on cybersecurity when they are included in the licenses for security-related software such as firewalls, anti-spyware, or anti-virus programs, where the quality of the program is directly related to the security of the licensee’s computer. Comparative testing of security-related software would likely scrutinize the security-related attributes of security software, producing relevant performance information

for buyers who are generally unable to efficiently gather this information themselves. Furthermore, when independent benchmarks are prohibited, software vendors may be more apt to make exaggerated performance claims. Where purchasers cannot fully understand the mixture of price and quality on offer from various companies, the competitive market will not function properly—perhaps leading to a reduction in quality as companies compete on the basis of other attributes such as price.

Even in the case of software that does not play a security-related function, anti-benchmarking clauses may undermine cybersecurity. It is likely that the main focus of benchmark tests of non-security-focused software applications such as a media player or browser would be on their performance in their intended functions of playing audio or video files or surfing the Web. Nevertheless, some reviewers might have also incorporated security-related attributes into their testing, and anti-benchmark terms might suppress this along with the other testing.

Another way in which anti-benchmarking clauses could undermine cybersecurity whether or not they apply to security or non-security-related software is illustrated by the Sybase example, which is discussed in more detail later in this part of the chapter. Briefly, Sybase insisted that the public disclosure of a software security flaw discovered by another company would violate the license clause that prohibited the publication of benchmarks or performance tests without Sybase's permission. This example illustrates the fairly broad interpretation that licensors will attempt to make of anti-benchmarking clauses.

Should Anti-Benchmarking Clauses Be Enforced? Anti-benchmarking clauses are one instance of a broader category of “contracts of silence,” in which one party agrees to remain silent in exchange for some other benefit. Other examples are confidentiality agreements in the context of the settlement of legal disputes or nondisclosure agreements used in employment contracts or in the course of negotiations preceding the sale of a business. These contracts raise some common issues, but the policy balance on enforceability may vary.

Contracts of silence create an interesting clash between three types of freedom, each of which carries significant rhetorical weight in the United States and Canada, namely freedom of contract, freedom of speech, and the free market. The commitment to “freedom of contract” would suggest that voluntary contracts of silence should be enforceable. However, the values underlying free speech suggest that contracts of silence should perhaps not be enforceable, particularly when one considers that many free speech theories rely on the public

benefits of speech rather than the value to the speaker of being free to speak.²³ The free-market imperative cuts both for and against contracts of silence, depending upon the circumstances. The functioning of the free market may sometimes be helped by contracts of silence and sometimes not. While non-disclosure agreements facilitate negotiations for the sale of a business or the exploitation of trade secrets, anti-benchmarking clauses in software licenses appear to raise information costs in a market that already suffers from serious information problems, thereby undermining the ability of the free market to produce optimal results.

Software vendors raise business arguments to justify anti-benchmarking clauses. They complain that independent benchmark tests are poorly prepared,²⁴ and that they are sometimes tainted by deliberate manipulation by competitors.²⁵ A poor benchmark test result will affect sales and cause a vendor to incur costs in responding. Vendors may find it difficult to respond given that their objections are likely to be dismissed as self-interested. As a result, anti-benchmarking clauses have been used since the 1980s to suppress the publication of benchmark tests.²⁶

If it is usually true that independent benchmark tests are poorly prepared and biased, then the argument that the market and cybersecurity will be improved by protecting benchmark testing is weakened. However, it seems unreasonable to suppose that trustworthy information intermediaries could not provide such information if it is of interest to consumers. Indeed, trusted intermediaries such as the Consumers Union already offer some basic comparisons of security software.²⁷ Although more sophisticated comparisons of the efficacy of the programs would be helpful, well-reputed information intermediaries could, in theory, address this need.

Furthermore, software vendors' arguments that all benchmark testing must be suppressed because it is impossible to respond is also questionable. While it may be more effective, from the vendor perspective, to have a right of censorship, vendors do have other legal avenues to punish the publishers of false and misleading tests. They may use tort law, including the cause of action known variously as injurious falsehood, trade libel, disparagement of property, and slander of goods.

There is fairly broad support for the proposition that anti-benchmarking clauses contained in mass-market licenses should be unenforceable.²⁸ The Americans for Fair Electronic Commerce Transactions (AFFECT),²⁹ which was formed in 1999 in opposition to the Uniform Computer Information

Transactions Act (UCITA),³⁰ has published a set of “12 Principles for Fair Commerce in Software and Other Digital Products.” The tenth principle provides that “[l]awful users of a digital product are entitled to conduct and publish quantitative and qualitative comparisons and other research studies on product performance and features.”³¹

Section 105(c) of the 2002 version of UCITA also took the position that terms prohibiting an end-user licensee from making otherwise lawful comments about mass-market software in its final form are unenforceable.³²

The policy behind this subsection is this: if the person that owns or controls rights in the information decides that it is ready for general distribution to the public, the decision to place it in the general stream of commerce places it into an arena in which persons who use the product have a strong public interest in public discussion about it. This subsection recognizes that those public interests outweigh interests in enforcing the contract term in appropriate cases.³³

The restriction of the protections of §105(c) of UCITA to comments on final versions of software may be unfortunate in light of Microsoft’s roll-out of a test version of its Windows Genuine Advantage (WGA) Notification application.³⁴ This application was part of Microsoft’s anti-piracy program, known as Windows Genuine Advantage. The Notification application checks to ensure that the Windows program operating on the computer is genuine and will issue warnings if it is a pirated copy. The deployment of this pre-release version was controversial for a range of reasons. First, it was delivered to a random selection of users in many countries through the automatic update function under the misleading guise of a “high-priority update” even though it offered no immediate benefit to users. Second, it was a test version rather than a final version of the application (a fact disclosed in a license that few read).³⁵ Third, it could not be uninstalled even though it was a test version.³⁶ Fourth, it required users to accept a license that contained inappropriate and one-sided terms that placed the full risk of the pre-release software on the user even though it could not be uninstalled and there were no immediate benefits to installing it.³⁷ Fifth, it repeatedly transmitted user information to Microsoft.³⁸

In light of this evidence that test versions of software are being delivered to consumers in highly suspect ways, the limitation of §105(c) protection to public comments made about *final* versions of software seems inappropriate. Jean Braucher queries a different restriction in §105(c) of UCITA. She notes that §105(c) restricts its protection to software end users, so “distributors and

retailers are not protected, and magazines and developers who acquire products to test them and disseminate information might not be covered.”³⁹

In sum, the publication of benchmark tests of software is most likely to improve cybersecurity by improving market understanding of the efficacy of security-related software. To the extent that anti-benchmarking terms are used to suppress public disclosure of information about software security flaws (whether in security-related or other software), they may undermine cybersecurity.

Furthermore, vendor objections regarding biased information can be addressed without banning the tests altogether. As a result, clauses prohibiting comment on the software or comparison of the software with similar programs ought to be unenforceable. In this regard, the admittedly old case of *Neville v. Dominion of Canada News Co. Ltd.* [1915] KB 556 may be useful. In *Neville* the court considered an agreement under which a newspaper that purported to provide unbiased advice to Britons on buying land in Canada agreed not to comment on a particular vendor of Canadian land in exchange for the forgiveness of a debt. The court ruled that this was contrary to public policy.

Anti-Reverse-Engineering Clauses

Reverse engineering is the process of examining a product closely and working backward to discover how it was made.⁴⁰ It is a longstanding practice and has been generally legally accepted in the past, although legal challenges have accrued in different contexts, particularly since the 1970s.⁴¹

Reverse engineering may be conducted to learn about a product, to repair or modify a product, to develop compatible products and services, to develop new products, or to copy the product. Other uses in the software context are to find and fix security vulnerabilities and bugs, to evaluate the truth of vendors’ claims, or to detect infringement.⁴²

The reverse engineering of software involves the conversion of code from its machine-readable form into one that more closely resembles the original source code, which is human-readable.⁴³ In this process, incidental copying of the program might occur, and this raises the issue of whether reverse engineering infringes copyright.

How Anti-Reverse-Engineering Clauses Work The U.S. courts have usually held that the incidental copying that occurs during reverse engineering is a fair use if it is done to gain access to non-copyright-protected elements for a legitimate purpose (including producing non-infringing interoperable programs)

and there is no better way to gain access.⁴⁴ However, the right to make this fair use of a software program may be surrendered by contract. Recent U.S. cases make it clear that license terms purporting to prohibit reverse engineering will be enforceable.⁴⁵

These license clauses are being used to suppress information about software vulnerabilities. One example is provided by the case of Michael Lynn. In early 2005, Michael Lynn was employed by Internet Security Systems (ISS) and was asked by ISS to reverse engineer Cisco's router software to obtain more information about a flaw that Cisco had described only vaguely.⁴⁶ In doing this reverse engineering, Lynn found a much more serious flaw. Cisco was notified and it distributed a patch for the flaw.⁴⁷ Later that summer, ISS encouraged Lynn to present his research at a conference.⁴⁸ However, shortly before the presentation, ISS ordered Lynn to remove much of the technical content from his presentation, and threatened him with a lawsuit if he proceeded.⁴⁹ Instead, Lynn resigned and went ahead with the presentation. Cisco meanwhile pressured the conference organizers to suppress the distribution of Lynn's materials at the conference.⁵⁰ After the presentation, Cisco and ISS sought a restraining order against Lynn to prevent him from speaking further about the flaw.⁵¹ Cisco argued, among other things, that Lynn had illegally appropriated its intellectual property, which raised the question of the enforceability of the anti-reverse-engineering clause in the license agreement. In the end, the question was not answered because the parties reached a settlement.⁵²

Should Anti-Reverse-Engineering Clauses Be Enforced so as to Impede Security-Related Research? Anti-reverse-engineering clauses are likely primarily intended to protect the intellectual property in software by discouraging competitors from taking it apart and manufacturing competing products using the ideas in the software. However, these clauses are also deliberately used to suppress security-related research as discussed above in the Michael Lynn example. Even where the clauses are not deliberately used to suppress security-related research, their existence dissuades "white hat" research.⁵³

From the security perspective, the lack of clarity about whether anti-reverse-engineering clauses are enforceable against security researchers is probably harmful. The chilling effect on "white hat" researchers has been demonstrated to exist, at least in some cases. However, it seems most unlikely that they have much of an effect on researchers bent on the malicious use of the vulnerability information they discover. As a result, such clauses seem only to deter security research that will be communicated to the vendor or to the public. To the ex-

tent that the public disclosure of flaws may be harmful to the public interest, the appropriate solution is a good responsible disclosure system, rather than the foreclosure of research through anti-reverse-engineering provisions.

Reverse engineering for security-related research should not be tied to the more difficult question of whether all reverse engineering should be permissible and all anti-reverse-engineering clauses therefore unenforceable. Some forms of reverse engineering could be prohibited and others permitted. With respect to the concern for protecting intellectual property, Pamela Samuelson and Suzanne Scotchmer suggest that reverse engineering is generally competitively healthy as long as innovators are protected long enough to recoup their research and development costs.⁵⁴ They also emphasize the distinction between the act of reverse engineering, which is in itself unlikely to have market-destructive effects (and instead assists with the transfer of knowledge), and the use of the knowledge gained through reverse engineering, which may or may not have market-destructive effects. This is a helpful distinction as it focuses the attention on the range of possible uses for reverse engineering and helps to broaden the debate beyond the absolute positions of “ban all reverse engineering” or “permit all reverse engineering.”⁵⁵

Samuelson and Scotchmer write that, in addition to these absolute positions, the law has a number of other options, including (a) to regulate the means of reverse engineering where a means emerges that makes competitive copying too easy so that innovators cannot recoup their R&D costs, (b) to require that any products developed following reverse engineering display some “forward” innovation that takes the products past mere cloning, (c) to permit reverse engineering for some purposes but not others, (d) to regulate the tools used for reverse engineering, or (e) to restrict the dissemination of information gained by reverse engineering.⁵⁶

A serious danger with banning a means of reverse engineering or specific tools for reverse engineering is that these bans would prevent all reverse engineering, including reverse engineering for non-market-destructive ends. In particular, an absolute ban in the context of software would impede the detection and fixing of security flaws. This concern suggests that a “purpose-based” approach to reverse engineering is preferable. The approach of the courts appears to be purpose-based to some extent in its focus on a “legitimate reason” in determining when the copying incidental to reverse engineering will be treated as a fair use. The unfortunate consequence of the purpose-based approach is that it suggests that the default position is that reverse engineering of software

is impermissible.⁵⁷ This means that the status of a number of benign purposes will be uncertain until they are eventually expressly recognized as legitimate, which will chill those activities in the meantime.

UCITA declares anti-reverse-engineering terms to be invalid, but only to the extent that reverse engineering is conducted to achieve the interoperability of an independently created program, and where the program elements are not otherwise readily available. License clauses prohibiting reverse engineering for other purposes (including, presumably, examining software for flaws or to confirm a vendor's security-related claims) are valid unless they can be shown to be contrary to public policy under §105(b).⁵⁸ Arguably, reverse engineering for security-related research should receive more robust protection than this from anti-reverse-engineering clauses in software licenses.

AFFECT's approach in its "12 Principles" is to state that "[s]ellers marketing to the general public should not prohibit lawful study of a product, including taking apart the product."⁵⁹ The commentary emphasizes the importance of reverse engineering for adapting and repairing software, as well as for understanding their security features.

In order to promote cybersecurity, the law should recognize that reverse engineering in order to find security vulnerabilities is legal, notwithstanding any license term to the contrary. This recognition must be clear and predictable in order to overcome the concerns about liability that exist in the security research community. In order to make this palatable to the vendor community, it may be worthwhile to consider tying the protection of security-related reverse engineering to a carefully calibrated responsible vulnerability disclosure regime. Such a regime might require specified delays between the notification of the vendor, the distribution of a patch for the software flaw, and the public disclosure of the vulnerability.

License Terms That Restrict the Public Disclosure of Software Vulnerabilities

Software license terms have been used from time to time to restrict or prevent the disclosure of security flaws. As has been discussed above, both anti-benchmarking and anti-reverse-engineering terms have been used to threaten security researchers with liability for such disclosures.

Network Associates' submission in *Spitzer v. Network Associates* illustrates that vendors may have this purpose in mind in using anti-benchmarking clauses. One of the justifications that Network Associates advanced for these clauses was that they reduced the chances of "irresponsible" publication of in-

formation about software vulnerabilities.⁶⁰ As is discussed below, the proper regime for the disclosure of vulnerabilities in software is a problem that has garnered substantial attention in the IT world.⁶¹

Another example is provided by dispute, in which Next Generation Software Ltd. discovered security flaws in a Sybase product.⁶² Next Generation notified Sybase, which prepared a patch for the flaw. When Next Generation wanted to publish the details three months later, Sybase insisted that this would be a violation of the license, which prohibited the publication of benchmark or performance tests without Sybase's permission. Sybase's position was that it would be acceptable to disclose the existence of the flaw, but not to publish specific details.⁶³

Sybase's argument was presumably based on a desire to protect machines that were not yet patched (since some users are slow to download and install patches) or to minimize negative publicity. However, it is well known that once a patch has been released, attackers will quickly reverse-engineer it to discover the flaw and take advantage of unpatched computers. As a result, the suppression of the details using the anti-benchmarking clause would impede the development of general knowledge about software security while offering little security to the unpatched segments of the user community. Security researchers were dismayed by this novel use of anti-benchmarking clauses to suppress security research.⁶⁴

The Disclosure of Software Vulnerabilities and the Chilling of the "White Hat" Security Research Community The issue of whether, how, and when software vulnerabilities should be publicly disclosed is a controversial one.⁶⁵ This is not a new problem. In the mid-1800s, the same debate played out in the context of public discussions of the vulnerability of locks to lock-picking.⁶⁶ The arguments then (as now) were, on one hand, that the disclosure of vulnerabilities would simply assist "rogues," while, on the other hand, the "rogues" were experts who likely already know all about the vulnerabilities, so the suppression of information would merely leave the public ignorant and exposed to risk.⁶⁷

In the software context, it is known that the "rogues" continually comb mass-market software applications for security vulnerabilities, which can then be exploited or sold: "There is . . . an underground market for information on vulnerabilities. Cybercriminals pay top dollar for previously undisclosed flaws that they can then exploit to break into computer systems."⁶⁸

There is also a corps of independent security researchers who are motivated by curiosity, enjoyment of the challenge, a desire to improve software and

internet security, or sometimes the pursuit of fame (and consulting contracts). In the past, security researchers simply disclosed the vulnerabilities publicly when they discovered them.⁶⁹ This practice exposes users to a window of greatly increased vulnerability between the disclosure of the flaw and the distribution of a patch to fix the flaw. However, when researchers quietly notified software vendors of their discoveries rather than announcing them publicly, many found that the companies were rather unresponsive. As a result, the informal compromise that emerged was a regime of “responsible disclosure,” in which security researchers usually notify vendors ahead of public disclosure so that they may prepare patches.⁷⁰

The system of responsible disclosure is imperfect, it seems, as some security researchers have reported that software vendors can be sluggish about fixing software vulnerabilities after they are notified.⁷¹ It is true that preparing patches can take time, and vendors must test them carefully to avoid introducing new vulnerabilities. However, some researchers are suspicious that vendors drag their feet for reasons of self-interest while leaving their customers exposed to risk.

For example, in 2004, Paul Watson discovered a flaw that could be exploited in various networking products, including Cisco’s routers.⁷² Despite Cisco’s efforts to cancel his conference presentation, Watson presented his findings publicly when he became frustrated with Cisco’s nonresponsiveness. Cisco released a patch several days before the conference and also filed a patent application for its solution, leaving Watson suspicious that the delay was partly due to the preparation of the patent application.⁷³

eEye Digital Security responds to the problem of unreasonable delay by publicly disclosing the existence of a flaw along with the time that has elapsed since the vendor was notified, but waits to provide detailed information until a patch has been made available.⁷⁴ This practice has certain advantages. It notifies the public that a product is flawed, without providing too much detail. Potential purchasers who are aware of eEye’s list of flaws can factor this information into new purchase decisions. It also imposes some pressure on vendors to move swiftly, since a long delay will reflect badly on them and may generate some user dissatisfaction. One disadvantage, however, is that a delay in the broad dissemination of information about software security hinders the development of knowledge in an important area.

The optimal approach to vulnerability disclosure has become even more complex with the development of firms such as Tipping Point and iDefense, which offer payment to security researchers for an exclusive notification of the

flaws that they discover.⁷⁵ In this way, iDefense can market “advance knowledge” of flaws to its customer base.⁷⁶ This is controversial because the remainder of the user community remains exposed. One might argue that they are no worse off than before, but, as is the case with security measures that merely “move the problem” elsewhere, they may be somewhat worse off if attackers’ attention can be focused on a smaller population of vulnerable computers. This concern is likely unfounded for some attack types, particularly automated attacks. For example, a worm that circulates by exploiting a particular security vulnerability in software will be slowed by the reduction in the number of vulnerable computers. In this way, a reduction in the number of vulnerable computers protects the remainder to some extent. Furthermore, a reduction in the number of vulnerable computers improves the general level of cybersecurity, given that compromised computers pose risks to everyone (for example, as spam relays, vectors for the spread of malware, or attackers in denial-of-service attacks).

In any event, the practice of providing paying customers with advance notice of flaws is not new and has raised controversy before.⁷⁷ Another concern with the Tipping Point/iDefense model is that the incentive for such companies is to maintain the value of their products by lengthening as much as possible the delay until a flaw is actually fixed, even if a vendor is notified quickly.⁷⁸ Other security companies do not even notify the vendor.⁷⁹

Some security researchers instead seek payment from the software vendor in exchange for information about the flaw rather than selling it to a firm such as iDefense.⁸⁰ Although this feels unethical and perhaps even vaguely extortionate, security researchers are providing a useful security audit service for software vendors, and it seems reasonable that a software vendor would pay something for the information.⁸¹

A legitimate mechanism to purchase flaws might be preferable to the current underground market for flaws in which cybercriminals purchase previously unknown flaws to exploit.⁸² There has been some speculation about whether an auction system for the sale of security flaws might be a productive way to harness the efforts of security researchers.⁸³ In 2005 an anonymous vendor attempted to sell information on an unpatched flaw in Windows Excel on eBay.⁸⁴ The last bid before the auction was shut down by eBay was \$1,200.

However, instead of receiving encouragement for their research, security researchers who wish to improve security are exposed to a range of legal risks in addition to the threat of legal liability for breaching a software license term.

For example, Pascal Meunier, a CERIAS researcher, reports on the problems he encountered after a student approached him with information about a vulnerability in a website.⁸⁵ He informed the website, which was unfortunately hacked soon afterward. Meunier was visited by the police during the subsequent investigation. Feeling strongly that students do not realize the legal risks that they run in reporting vulnerabilities, and being confident that the student had not hacked the website, Meunier refused to identify the student. He was pressured by his employer and threatened by the police for this refusal. In the end the student identified himself. Meunier now recommends that students do not report vulnerabilities: “If you decide to report it against my advice, don’t tell or ask me anything about it. I’ve exhausted my limited pool of bravery—as other people would put it, I’ve experienced a chilling effect. Despite the possible benefits to the university and society at large, I’m intimidated by the possible consequences to my career, bank account and sanity.”⁸⁶

Meunier also points to the case of Eric McCarty, who was prosecuted as a result of disclosing a vulnerability. McCarty was charged with computer intrusion in April 2006 after he anonymously notified a reporter of a vulnerability in the University of Southern California’s Web page for online applications.⁸⁷ He sent the reporter the personal information of seven applicants as proof of the vulnerability. The journalist notified the school, which fixed the vulnerability. However, it also searched its server logs to find McCarty, who had not attempted to hide his tracks. Like Meunier, McCarty is no longer interested in notifying anyone of the security vulnerabilities he finds: “Keep [vulnerabilities] to yourself—being a good guy gets you prosecuted. I can say honestly that I am no longer interested in assisting anyone with their vulnerabilities.”⁸⁸

These examples show the legal dangers of conducting research into computer system vulnerability. As H. D. Moore puts it, “finding any vulnerability in a server online necessarily means that the researcher had exceeded authorization [so] the flaw finder has to rely on the mercy of the site when reporting.”⁸⁹ Unfortunately, the legal system seems to have succeeded in suppressing the voluntary efforts of “white hat” researchers who might notify the administrators of vulnerable servers. Meanwhile the profit-driven “black hat” researchers may find it worthwhile to continue as before.

While research into *software* vulnerabilities may not expose a researcher to the same kinds of charges as research into *server* vulnerabilities, there are still legal risks that chill security research.

For example, the French Loi pour la confiance dans l’économie numérique

introduced a new article 323-3-1 into the French Code Pénal, which provides that anyone who acts, without justification, to import, possess, or distribute any tool, program, or data developed for the purpose of or adapted to commit one of the offenses listed in articles 323-1 to 323-3 [that is, fraudulent access to a computer system, impairing the functioning of a computer system, and fraudulent interference with data in a computer system] will be liable to the same punishments as people convicted of those offenses.⁹⁰ The introduction of this provision in 2004 caused grave concern for some French security researchers, who worried whether their possession and distribution of vulnerability information would lead to problems under the new article.⁹¹

In the United States the Digital Millennium Copyright Act has already been used to impede the disclosure of security vulnerabilities. The act contains provisions criminalizing the circumvention of technological measures (that is, measures designed to control access to works protected under copyright laws), as well as providing for a civil cause of action.⁹² An Electronic Frontier Foundation paper on the effects of the DMCA describes how the DMCA has been used to suppress the disclosure of research relating to security vulnerabilities.⁹³

The lawsuit against 2600 magazine, threats against Professor Edward Felten's team of researchers, and prosecution of the Russian programmer Dmitry Sklyarov are among the most widely known examples of the DMCA being used to chill speech and research. Bowing to DMCA liability fears, online service providers and bulletin board operators have begun to censor discussions of copy-protection systems, programmers have removed computer security programs from their websites, and students, scientists and security experts have stopped publishing details of their research.⁹⁴

A fiasco over the Sony rootkit reveals the harmful consequences of the DMCA in this regard. Sony's rootkit was a technological protection measure intended to protect copyrighted music on CDs, but it also created a security vulnerability on users' computers. Ed Felten and Alex Halderman had been aware of the vulnerability for some time before it was finally disclosed by another researcher, Mark Russinovich.⁹⁵ Felten and Halderman had delayed disclosure while they consulted with lawyers about whether they would be liable under the DMCA for disclosing their research.⁹⁶ It is worthwhile in this discussion to also discuss the chilling of "white hat" researchers in order to tell the Sony rootkit story in some detail, as it illustrates a range of ways in which cybersecurity can be undermined.

The Sony rootkit story exploded on October 31, 2005, when Mark Russinovich revealed in his blog that he had traced a rootkit on his system to a Sony BMG music CD.⁹⁷ Rootkits, which are usually used to permit malicious code to remain hidden on infected computers, are “cloaking technologies that hide files, registry keys, and other system objects from diagnostic and security software.”⁹⁸ In this case, the rootkit was part of Sony’s copy protection software, known as Extended Copy Protection (XCP) and created by First4Internet. Although First4Internet downplayed the security risk presented by the rootkit, security researchers worried that the cloaking technology could be misused by virus writers.⁹⁹

Thomas Hesse, president of Sony BMG’s global digital business division, unwittingly explained why consumers cannot be expected to be effective in policing cybersecurity-reducing software vendor activity. He stated in an interview on NPR that “[m]ost people, I think, don’t even know what a rootkit is, so why should they care about it?”¹⁰⁰

Quickly, however, First4Internet offered to “allay any unnecessary concerns,” by issuing a patch that would uncloak the copy protection software, which would also stop virus writers from taking advantage of the cloaking technology.¹⁰¹ The concerns turned out to be well founded rather than unnecessary, as the first malware-exploiting XCP was detected on November 10. Naturally, people wanted to remove XCP, but it did not come with an uninstaller and was difficult to remove. Security researchers warned that attempts to uninstall it manually might disable the computer’s CD player.¹⁰² BMG informed users that the software could be uninstalled by contacting customer service.¹⁰³ Users were required to take multiple steps and to submit several forms containing unnecessary information before eventually being led to the uninstaller.¹⁰⁴ Ed Felten and Alex Halderman analyzed the uninstaller application and found that it also exposed users to a serious security vulnerability.¹⁰⁵ They described the consequences as severe: “It allows any web page you visit to download, install, and run any code it likes on your computer. Any web page can seize control of your computer; then it can do anything it likes. That’s about as serious as a security flaw can get.”¹⁰⁶

Meanwhile, security flaws were found in another copy protection program used by Sony, SunnComm’s MediaMax software.¹⁰⁷ Halderman suggested that it was difficult to be sure whether MediaMax’s security problems were as serious as XCP’s “since the license agreement specifically prohibits disassembling the software. However, it certainly causes unnecessary risk.”¹⁰⁸ MediaMax was also dif-

ficult to remove. Halderman later reported that if users are persistent, SunComm will eventually send an uninstaller for MediaMax, but that the uninstaller exposes users to a major security flaw that permits malicious attackers to take over a user's computer.¹⁰⁹ SunComm eventually released a patch to fix the flaw in the uninstaller.¹¹⁰ By the time the dust had settled, Sony had recalled millions of offending CDs, offered to replace the CDs, and been subject to multiple class-action lawsuits in several countries, as well as a lawsuit brought by the Texas attorney general and investigations by the FTC and other state attorneys general.¹¹¹

Bruce Schneier suggests that the real story behind the Sony rootkit debacle is the demonstration, at best, of incompetence among the computer security companies, and, at worst, of collusion between big media companies and the computer security companies.¹¹² He asks why none of the antivirus firms detected the rootkit, which had been around since mid-2004, and why they were so slow to respond once Russinovich publicized the rootkit:

What happens when the creators of malware collude with the very companies we hire to protect us from that malware? We users lose, that's what happens. A dangerous and damaging rootkit gets introduced into the wild, and half a million computers get infected before anyone does anything. Who are the security companies really working for? It's unlikely that this Sony rootkit is the only example of a media company using this technology. Which security company has engineers looking for the others who might be doing it? And what will they do if they find one? What will they do the next time some multinational company decides that owning your computers is a good idea? These questions are the real story, and we all deserve answers.¹¹³

This is an interesting and alarming suggestion. Support for Schneier's accusation is perhaps found in a remarkable statement by First4Internet on the day after Russinovich's blog entry. The CEO is reported to have stated: "The company's team has worked regularly with big antivirus companies to ensure the safety of its software, and *to make sure it is not picked up as a virus*"¹¹⁴ [emphasis added].

Returning to the subject of the chilling of "white hat" research, Alex Halderman and Ed Felten were aware of the problems with XCP software nearly a month before the news became public, but they delayed in disclosing the vulnerability in order to consult lawyers due to their concerns about liability under the DMCA.¹¹⁵ This story reveals the importance of ensuring that security research is clearly protected from liability. This is all the more essential if it is

true that antivirus and security companies cooperate with other major industry players to protect their risky software from detection.

At the same time that the Sony rootkit story was unfolding, EMI Music declared that it did not use rootkit technology.¹¹⁶ EMI also claimed that its copy protection software could be uninstalled with the standard uninstaller that came with its CDs. On January 4, 2006, the Electronic Frontier Foundation sent a letter to EMI Music asking the company to publicly declare that it would not assert claims under copyright law or its license agreement against computer security researchers who wished to investigate EMI's copy protection technologies.¹¹⁷ EMI responded by suggesting, among other things, that researchers had only to follow the procedure under §1201(g) of the DMCA and there would be no need to fear civil liability.¹¹⁸

Section 1201(g) of the DMCA permits the circumvention of technical protection measures for the purpose of "encryption research," although the researcher must first make a good-faith effort to obtain authorization from the rightsholder,¹¹⁹ and the circumvention must be necessary to the research.¹²⁰ However, various factors that are to be considered in determining whether the researcher qualifies for the exemption limit the scope of the exemption to "official" researchers,¹²¹ and limit how the information may be disseminated. In particular, one factor is whether the information was disseminated in a way calculated to advance knowledge or in a manner that facilitates infringement.¹²² The public disclosure of software vulnerabilities may both advance knowledge and facilitate infringement if the disclosure points to a weakness in the encryption system. This exemption therefore provides inadequate assurance to security researchers regarding their legal position.

Not only does §1201(g) not provide adequate coverage to security researchers for the dissemination of their discoveries, but it is questionable whether the flaws at issue in the Sony rootkit scenario fell within §1201(g). The flaws were unrelated to the robustness of an encryption algorithm. Instead, they had to do with the design of the software, which permitted an attacker to take advantage of the rootkit method of cloaking the existence of the copy protection system on a user's computer. Therefore the research in the Sony rootkit case may well have been more in the nature of "security testing." However, the DMCA exemption for "security testing" (§1201(j)) is even weaker than that provided for "encryption research."

Section 1201(j) permits the circumvention of technical protection measures to conduct "security testing," involving "accessing a computer, computer

system, or computer network,” but only with the authorization of the owner of that computer, system, or network.¹²³ The applicability of the exemption depends on “whether the information derived from the security testing was used or maintained in a manner that does not facilitate infringement.”¹²⁴ This exception is not realistically helpful to researchers looking for security holes in software or desiring to disclose their discoveries because (a) the wording appears to cover the testing of computer systems, in the manner of penetration testing, and not the reverse engineering of software to discover unknown software vulnerabilities; (b) it requires authorization, which is unlikely to come from software vendors; and (c) it appears to preclude public disclosure of security vulnerabilities even if a vendor refuses to do anything about it because disclosure might “facilitate infringement.”

Unfortunately, the DMCA’s chilling effect is not restricted to security research on software programs clearly related to protecting copyrighted works. It has also been wielded against security research on software programs that are not anti-copy-protection measures. In 2002, Hewlett-Packard threatened a security researcher from SnoSoft with a lawsuit under the DMCA after he posted a message to a security-related message board describing a flaw in HP’s Tru64 UNIX operating system.¹²⁵ Although HP soon abandoned the threat, it is troubling that the DMCA can be interpreted so broadly that it is invoked in relation to a security flaw in an operating system rather than a program more directly related to controlling access to copyright-protected works.¹²⁶

Canada is in the process of revising its Copyright Act,¹²⁷ in part to address the requirements of the 1996 WIPO (World Intellectual Property Organization) treaties. The previous government introduced its Bill C-60, An Act to amend the Copyright Act on June 20, 2005.¹²⁸ Bill C-60 introduces provisions prohibiting the circumvention of technological protection measures. The proposed measures provide a right of action against (1) a person who, for the purpose of infringing a copyright or moral rights, circumvents a technological protection measure;¹²⁹ (2) a person who offers or provides a service to circumvent a technological protection measure that the person knows or ought to know will result in the infringement of copyright or moral rights;¹³⁰ or (3) a person who distributes, exhibits, imports, etc., a work when the person knows or ought to know that the technological protection measure has been disabled or removed.¹³¹

The government has stated elsewhere that the new anti-circumvention provisions are not intended to affect the law already applicable to security testing or reverse engineering.¹³² Nevertheless, it seems possible to argue that the

disclosure or sale of vulnerability information is a provision of a service that a researcher ought to know will result in the infringement of copyright. Indeed, the Digital Security Coalition (an alliance of Canadian security technology companies) has sent a letter to the current ministers of Industry and Canadian Heritage warning of the harmful consequences for security and innovation of the proposed anti-circumvention provisions.¹³³ A reprieve was temporarily offered when Bill C-60 died on the Order Paper because a federal election was called in November 2005. However, the legislation was reintroduced by the present government as Bill C-61.¹³⁴

The foregoing illustrates the manner in which both license terms and legislation such as the DMCA have chilled security research. In light of the example of the Sony rootkit fiasco, and the possibility of collusion between media companies and security software companies, the importance of independent security research is clear. The chilling effect cannot be reversed simply by clearly declaring that anti-benchmarking and anti-reverse-engineering clauses are unenforceable with respect to security research because the DMCA will still be available to squelch security research. An amendment or a favorable judicial interpretation of the DMCA (if possible) is needed to give security researchers sufficient confidence to continue their work, particularly in relation to copy-protection software. The discussion thus far has assumed that the public disclosure of information about security vulnerabilities promotes rather than undermines cybersecurity. The following section explores this question in greater detail.

Should Restrictions on the Disclosure of Software Vulnerabilities Be Enforced?

There are a number of compelling arguments in favor of the public disclosure of software flaws. First, the market will be unable to properly generate the optimal balance of price and quality when a significant quality attribute remains hidden. Software (with the exception of open source software) is publicly available only in machine-readable form, having been compiled into that form from its initial source code (human readable) form. Software vendors are best placed to identify security flaws in their products because they have access to the source code and know their products best. Skilled researchers can do some reverse engineering to discover flaws, but the vast majority of users will have no way of detecting security flaws. Therefore, information regarding software vulnerabilities will remain largely hidden from the market unless public disclosure is permitted. Of course, the public disclosure of the full technical details of a flaw and the potential means for exploiting it may not be necessary

for the market to function adequately. However, a reasonable measure of disclosure is required in order for the market to evaluate properly the significance of the flaw, and to determine whether a particular software program tends to contain relatively more serious flaws than another.

Second, software vendors may not face sufficient pressure to fix flaws in their software unless the flaws can be publicly disclosed. Software licenses nearly always disclaim liability for harms, particularly consequential economic losses, and so software vendors face only a risk to reputation and goodwill if the flaws are exploited. As a result, it might be preferable to leave flaws unfixed in the hope that they will not be exploited, since the existence of a flaw will become known when a patch is issued to fix it—thereby bringing about some harm to reputation and goodwill. In other words, why provoke a certain harm by issuing a patch when one can continue in the hope that an uncertain harm (the exploitation of the flaw) will not come about? Of course, an exploited vulnerability is more costly to reputation and goodwill than the disclosure of a vulnerability that has been fixed. This is particularly true if it becomes known that the vendor knew about it, but presumably this cost is discounted by the probability that vulnerability will be exposed. In any event, all of this suggests that a software vendor is likely to delay fixing a flaw until a time that is convenient, keeping in mind the level of risk posed by the security flaw. Furthermore, security has, at least in the past, been an afterthought for many software vendors:

Companies want to get their products out to customers as quickly and cheaply as possible; thus they will deal with security quickly and cheaply if at all. If security interferes with the work of applications developers or other complementary businesses, companies will not make resolving the security issues a priority because having more complementary services means the product's value will increase and more people will adopt it.¹³⁵

Third, the general understanding of software security is enhanced by the public disclosure of information about software flaws.¹³⁶ Computer scientists can use this information to advance understanding of secure software engineering methods, for example. The long-run improvement of cybersecurity weighs in favor of the eventual disclosure of the technical details of software flaws, even if the disclosure is delayed.

The disadvantage associated with the public disclosure of software flaws is that it might assist attackers in their efforts. Peter Swire's work on whether security is enhanced by secrecy ("loose lips sink ships") or openness ("there is

no security through obscurity”) suggests that mass-market software benefits relatively little from secrecy since a large number of attacks is made, the attackers can learn from previous attacks, and attackers can communicate with each other.¹³⁷

Firewalls, mass-market software, and encryption are major topics for computer and network security. In each setting, there are typically high values for the number of attacks (N), learning by attackers (L), and communication among attackers (C). Secrecy is of relatively little use in settings with high N, L, and C—attackers will soon learn about the hidden tricks.¹³⁸

If it is true that attackers will eventually find the flaws and so secrecy provides relatively little benefit for security in mass-market software, then the countervailing benefits of disclosure would rise to the fore.¹³⁹ The risks associated with disclosure might even be somewhat mitigated through a system for delayed disclosure (where a vendor is notified before the public so that a patch can be developed and distributed), such as has arisen with the so-called “responsible disclosure” regimes, discussed above.

An analysis of proposals for the optimal design of a responsible disclosure system for software vulnerabilities is beyond the scope of this paper. It is possible that the optimal time delays between vendor notification and public disclosure of the flaw may vary because of factors such as (a) the seriousness of the flaw discovered (that is, does this flaw affect many or a few computers, can an exploit be developed quickly, is it a new type of flaw that will now be easy to find in many other software applications, and so forth); (b) the likelihood that the flaw has already been discovered by cybercriminals; (c) the time required to produce and distribute a patch for the flaw, and the efficacy of the patching system; (d) the existence of other incentives for a software vendor to fix the flaw quickly (such as invalidity of contractual exclusions of liability); and (e) whether disclosure of the general nature (if not the technical detail) of the flaw can be made without delay.

Given the foregoing conclusion that the suppression of the public disclosure of information about software vulnerabilities is likely to be harmful on balance to cybersecurity, it follows that license clauses that do just that will undermine cybersecurity. Such clauses may occasionally prevent some assistance from being given to cybercriminals, but this will come at the cost of the advancement of knowledge about software security and of market discipline on the security of software. Such clauses may dissuade security research-

ers with noncriminal motives, or cause them to make their findings known anonymously. To the extent that one of the motivations for this research is public recognition, the enforcement of license terms preventing the disclosure of software flaws would remove a key motivator of important research if researchers had to remain anonymous.

AFFECT's Principle III states that vendors must provide access to information about nontrivial defects in digital products such as "a flaw that prevents a spreadsheet from correctly calculating a certain type of formula or inclusion of spyware or a virus."¹⁴⁰ The justification for this provision is that the market will function better if customers are informed of these flaws so that they may stimulate competition on the basis of quality. This seems quite sensible with respect to non-security-related flaws.

It seems less likely that a vendor's public listing of security-related flaws would be helpful to cybersecurity on balance. Vendors (who have access to the source code of a program) are likely to be well ahead of both "black hat" and "white hat" external researchers in finding flaws, and so a vendor's list would likely assist attackers. If a list of security-related flaws must accompany new releases, all of the information might potentially be new to attackers. Perhaps AFFECT expects that a disclosure requirement of this sort would not produce a list because vendors would fix all known defects in order to avoid having to produce such a list. Indeed, Braucher points out that an advantage of the required disclosure of defects is that producers would face greater pressure to find and fix flaws before software is released.¹⁴¹

However, it is not clear that vendors would react in this way. Licenses already usually disclaim warranties and exclude liability in terms that would lead a licensee to expect that the software is full of defects and security flaws. One example among many is the license agreement for Skype, which provides that "the Skype software is provided 'as is,' with no warranties whatsoever . . . Skype further does not represent or warrant that the Skype software will always be . . . secure, accurate, error-free. . . ."¹⁴² Perhaps vendors will prefer to list known flaws in fairly general terms rather than to fix them (particularly if this entitles them to exclude liability for consequential damages resulting from those flaws)¹⁴³ and to take their chances on whether purchasers will read the list or refuse to buy on the basis of the list. The behavior of both vendors and purchasers in response to a requirement that there be a list of known defects in software may vary depending upon the nature of the software and the types of risks that the software creates.

AFFECT's Principle III also deals with the suppression of public disclosure of vulnerability reports from third parties. Comment (D) provides that "sellers may not restrict anyone, including other sellers, from disclosing what they know about the performance of products that are mass-marketed. Users must be allowed to make reports of defects and security breaches."¹⁴⁴ The principle also places an affirmative obligation on vendors to notify the public. It provides that sellers who become aware of any defects or security breaches that threaten customer computer security must notify all those who could potentially be affected (including customers and potential customers).¹⁴⁵ Sellers are, however, entitled to a reasonable amount of time to evaluate reports of defects before disclosing the details of the defect.¹⁴⁶ AFFECT's principles do not address the question of delay in order to prepare and distribute patches.

In summary, it seems likely that the public disclosure of detailed information about software security vulnerabilities is, in the long run, most conducive to improved cybersecurity for mass-market software products. The potential assistance to attackers that might be provided through this disclosure could be mitigated through an appropriately designed "responsible disclosure" system. Therefore, license terms that restrict or prohibit the disclosure of software security vulnerability information should be unenforceable, whether they are in the form of anti-benchmarking terms, anti-reverse-engineering terms, or some other more direct terminology. In addition, legislation, such as the DMCA, that also chills the disclosure of security vulnerability information must be amended or interpreted in a manner that permits responsible disclosure. As noted above in the context of anti-benchmarking clauses, protections for security research might be more palatable to software vendors if the protections were tied to a predictable and reasonable regime for the responsible disclosure of security flaws. Although a discussion of the attributes of such a regime is beyond the scope of this chapter, several precedents already exist upon which to build.¹⁴⁷

Risky Practices for Which Consent Is Obtained by License

Some software vendors engage in practices that create cybersecurity risks for licensees and for third parties, while seeking consent for those activities within licenses that usually go unread. This is somewhat different from the examples in the first part of this chapter, which deals with the suppression of security-related research or the dissemination of security-related information. In those

cases, the license terms themselves reduce cybersecurity by impeding research and public knowledge about software security. In this section, the source of the danger is the practice rather than the license term applicable to the practice. However, license terms that disclose the risky activities and exclude liability for the harms that may ensue support these activities and lend them legitimacy because the licensee has “consented.” One option short of regulating the questionable practices is to refuse to enforce clauses in which licensees “consent” to the practices or agree to the exclusions of liability.

An example of a cybersecurity-reducing practice is to make software programs extremely difficult to uninstall or to purport, through the license, to prohibit the removal of the program. A second example is the misuse of the automated software update system or the creation of an insecure automated update system. Third, I will consider practices that clearly expose third parties to a risk of harm—thus directly raising the problem of externalities. There are, unfortunately, many other examples, and this chapter does not attempt a comprehensive list.¹⁴⁸

Impeding the Removal of Software

Some software vendors deliberately resist the removal of their software from users’ computers (“uninstallation”). For example, certain “adware” programs are written deliberately to resist efforts to remove them.¹⁴⁹ Documents filed in the New York attorney general’s lawsuit against Direct Revenue indicate a deliberate practice of failing to include an uninstaller, or, when forced to include an uninstaller, providing one that is difficult to use.¹⁵⁰

It is not surprising that adware companies would seek to make their software difficult to uninstall given that most users would eventually want to uninstall it. However, adware is not the only type of software that causes this problem. Makers of other software and digital products, motivated by the desire to protect their intellectual property, are arguably undermining general cybersecurity by inhibiting the removal of their flawed copy protection measures.

The Sony rootkit fiasco, discussed in detail earlier, provides an excellent example of a problem that was greatly exacerbated by software removal problems. In that case, the copy protection software had an insecure design that exposed users’ computers to attack. In addition, it did not come with an uninstaller and was difficult to remove. Efforts to remove it manually created a risk of damage to the computer system.¹⁵¹ The process of obtaining an uninstaller from the company was cumbersome and privacy-invasive,¹⁵² and the uninstaller application itself contained a serious security flaw.¹⁵³

Another example, also discussed earlier, is Microsoft's roll-out of a test version of its Windows Genuine Advantage (WGA) Notification application.¹⁵⁴ Among the many reasons for controversy over this initiative are the facts that the software is a test version rather than a final version, and it cannot be uninstalled even though it is a test version and so presumably contains more flaws than the final version. The license places the full risk of harm caused by the test version of the software on the user even though it cannot be removed and there are no immediate benefits to installing it. Section 1 of the license provides that the licensee "will not be able to uninstall the software."¹⁵⁵

Since software vendors defend their omnipresent exclusion of liability terms on the ground that it is impossible to avoid software flaws, it seems highly unreasonable for them to deliberately impede the removal of their unavoidably flawed software from users' computers. This is perhaps even more unfair and unreasonable where liability is excluded for a test version that cannot be uninstalled, as with the Microsoft WGA Notification software.

AFFECT's "12 Principles" address this point in Principle VI, which provides that "[c]ustomers are entitled to control their own computer systems."¹⁵⁶ Comment (G) suggests that customers must be able to uninstall software.¹⁵⁷

In light of the frequent discovery of security flaws in mass-market software, the software must be easily uninstallable. Users may have to accept as a trade-off that the removal of an anti-piracy or copy-protection application will mean that they can no longer use the product in question. Whether or not products rejected for this reason should be returnable for a refund is a tricky question. It would not be appropriate for users to be able to use the product and then uninstall and return it when they no longer wish to use the music or software in question. However, where a significant security problem is discovered, users ought to be able to remove and return the affected products, notwithstanding the disclaimers of warranty contained in the licenses.

Abuse of the Software Update System

Automatic update systems are helpful in ensuring that security patches are sent out to vulnerable computers, since average home users will not bother to monitor a vendor's website for new patches.¹⁵⁸ In the aftermath of the Blaster worm epidemic in 2003, Microsoft began to explore automated patching to address the problem of how to ensure that security patches are quickly and widely deployed.¹⁵⁹ Microsoft's Windows Automatic Updates feature automatically monitors a user's computer and downloads and installs high-priority updates

as required.¹⁶⁰ Bruce Schneier, an expert in computer security, has endorsed this approach as an appropriate trade-off:

I have always been a fierce enemy of the Microsoft update feature, because I just don't like the idea of someone else—particularly Microsoft—controlling my system. . . . Now, I think it's great, because it gets the updates out to the non-technically savvy masses, and that's the majority of Internet users. Security is a trade-off, to be sure, but this is one trade-off that's worthwhile.¹⁶¹

If the current update system is the appropriate balance for ensuring general cybersecurity, practices that undermine public trust in the system should be avoided. In addition, the automatic update systems must be carefully designed to ensure that they themselves do not end up reducing security by introducing vulnerabilities.

One recent example of the abuse of an update system is again provided by the roll-out of the test version of Microsoft's WGA Notification system. Microsoft's Windows Update site indicates that "high priority" updates are "[c]ritical updates, security updates, service packs, and update rollups that should be installed as soon as they become available and before you install any other updates."¹⁶² Despite this, Microsoft delivered a "test" version of its anti-piracy program to users as a "high-priority" update. The fact that the supposedly "high-priority" update was a test version of a program rather than a final version was disclosed in the license, which few users read. It is not too strong to call this an abuse of the automatic update system, which users understand to be a means to deliver critical security-related fixes and not to test pre-release software that is of little immediate benefit to the user.¹⁶³ User suspicion of and resistance to the automatic update system might grow if the system's purpose is diluted in this way.

Another example of the misuse of the update system is provided by the practice of bundling security patches along with other software or license changes. In 2002, the Register reported that Microsoft's patch for security flaws in Windows Media Player came with a license provision that required users to consent to the automatic installation of digital rights management controls on their computers:¹⁶⁴

You agree that in order to protect the integrity of content and software protected by digital rights management ("Secure content"), Microsoft may provide security related updates to the OS Components that will be automatically downloaded onto your computer. These security related updates may disable your

ability to copy and/or play Secure content and use other software on your computer. If we provide such a security update, we will use reasonable efforts to post notices on a web site explaining the update.¹⁶⁵

Richard Forno argues that this practice should be impermissible as part of a patching system:

[S]ecurity and operational-related patches must not change the software license terms of the base system . . . Of course, users didn't have to accept the software license agreement that popped up when installing the patch, but doing so meant they didn't receive the needed security updates—something I equated in an article last year as a form of implied extortion by the Microsoft Mafia.¹⁶⁶

Apart from concerns about anti-competitive practices, there are also security implications. Although most users will unknowingly consent and apply the security patches, others may choose not to accept the update in order to avoid the license and the non-security-related software changes that are tied to the security patch. This would undermine efforts to ensure that vulnerabilities are patched.

AFFECT's Principle III, comment (E), addresses this practice, providing that "[s]ellers may not require customers to accept a change of initial terms in return for an update needed for product repair or protection."¹⁶⁷

Automatic update systems may also provide a point of vulnerability for malicious attackers. Ben Edelman describes the failure of a software maker to protect against attacks on its automated update system, which would enable an attacker to download malicious code to the vulnerable computer.¹⁶⁸

Whenever a software designer builds a program intended to update itself—by downloading and running updates it retrieves over the Web—the designer must consider the possibility of an attacker intercepting the update transmission. In particular, an attacker could send some bogus "update" that in fact causes the user's computer to perform operations not desired by the user and not intended by the designer of the initial software. This sort of vulnerability is well known among those who design self-updating software.¹⁶⁹

This problem exists for other automatic update systems, and designers must be careful to include protections against the vulnerability.¹⁷⁰

On balance, automatic update systems may be unavoidable to manage the flaws in mass-market software. However, the automatic systems should be employed strictly for security-related purposes. Any other changes that vendors

may wish to make should be presented to users separately from security updates, and in a forthright manner that does not make them appear to be security updates. Vendors should not require users to consent to modifications in the license in order to access a necessary security update. Finally, it might be worthwhile to consider limitations to the enforceability of clauses limiting liability where users fail to adopt industry-standard precautions to prevent malicious attack on an automatic update system.

Practices That Expose Third Parties to Risk

The two cybersecurity-reducing activities mentioned above, namely impeding the removal of software and misusing the automatic software patch system, expose the licensee to the risk that software security flaws on his or her computer will be exploited. However, a compromised computer may be as much, or more of a risk to third parties. Compromised computers are used to circulate spam, malware, and phishing emails and to launch denial of service attacks against third parties. If the compromise of the average user's home computer exposed the user to an intolerable level of risk, the user would presumably take steps to protect his or her computer or withdraw from the internet (at least through a home connection). However, users are less likely to do so in order to protect third parties.

Another form of this "negative externality" problem exists in the handling of credit card numbers. Canadian and American cardholders are fairly well protected from the risk of credit card fraud. For example, Mastercard states that cardholders have "zero liability" for unauthorized use of their cards as long as their accounts are in good standing, they exercise reasonable care to safeguard their cards, and they have not had more than two unauthorized events in the previous twelve months.¹⁷¹ In contrast, where a credit card transaction is disputed, the affected merchant will be subject to a chargeback unless it can show that the transaction was valid. This can be challenging for transactions where no signature was obtained (e.g., online transactions or telephone transactions).¹⁷²

Credit card fraud is a considerable problem. Information such as credit card and bank account information as well as other consumer information is sold online in underground markets.¹⁷³ The markets are described as huge, international, and structurally sophisticated, with buyers, sellers, intermediaries, and service providers.¹⁷⁴

Traders quickly earn titles, ratings, and reputations for the quality of the goods they deliver—quality that also determines prices. And a wealth of institutional

knowledge and shared wisdom is doled out to newcomers seeking entry into the market, like how to move payments and the best time of month to crack an account.¹⁷⁵

This fraud may harm or bankrupt online businesses. Flooz, an e-currency venture, was rumored to have been bankrupted in 2001, in part because of credit card fraud.¹⁷⁶ Flooz is said to have sold \$300,000 of its e-currency to a ring of credit card thieves over several months before being alerted by the FBI and the credit card processing company when the rightful owners of the stolen card numbers complained of Flooz transactions on their monthly statements.¹⁷⁷ The company's cash-flow situation deteriorated as the credit card processor withheld money from new purchases of Flooz currency to cover chargebacks for the fraudulent purchases.

Certain programs, "voluntarily" downloaded to users' computers pursuant to a license agreement, may increase the risk of credit card fraud. For example, Marketscore asks users to submit to detailed surveillance and reporting of their internet activities by downloading a piece of "researchware" in exchange for a rather vague promise of membership benefits.¹⁷⁸ The program is controversial as it decrypts secured transactions, reducing the security of information entered during purchases or online banking.¹⁷⁹ The company discloses this in its license agreement, noting that it will take "commercially viable efforts" to avoid collecting user IDs, passwords, and credit card numbers:

Once you install our application, it monitors all of the Internet behavior that occurs on the computer on which you install the application, including both your normal web browsing *and the activity that you undertake during secure sessions*, such as filling a shopping basket, completing an application form or checking your online accounts, *which may include personal financial or health information*. We make commercially viable efforts to develop automatic filters that would allow us to avoid collection of sensitive personally identifiable information such as UserID, password, and credit card numbers. Inadvertently, we may collect such sensitive information about our panelists; and when this happens, we will make commercially viable efforts to purge our database of such information. [emphasis added]

Assuming that an end user voluntarily installs this program after reading the license agreement, the transaction still fails to internalize the risk to third parties should the data such as the credit card information be compromised. Marketscore states that it takes various steps to secure the data.¹⁸⁰ However,

neither Marketscore nor the cardholder directly bears the costs should the safeguards fail, and they may thus fail to take optimal security measures.

The solution to credit card fraud is not likely to be to strip cardholders of protection for the fraudulent use of their cards. However, it is worth noting that where cardholders can pass along the cost of fraud to merchants or a credit card company, they may be less careful with respect to the protection of their card numbers. They may, therefore, be more willing to download these programs (assuming they read the licenses and understand the consequences) than if they bore the risks themselves. In these cases, a refusal to enforce license terms purporting to grant consent to such risky activities may be of some assistance. However, given that the harms are more likely to accrue to third parties and consumers may not be sufficiently motivated to complain, some other legal discouragement of such business methods may also be required.

Dealing with License Terms That Undermine Cybersecurity

The preceding two sections of this chapter have suggested that common license terms may be a part of the cybersecurity problem. The next question becomes what to do about it. The first issue is whether it is necessary to do anything at all. Some may argue that it is not necessary to intervene judicially or legislatively because the free market can be expected to produce the optimal license terms. In the alternative, it could be argued that there is a market failure because terms are not adequately disclosed to purchasers. The solution then would be to improve disclosure by requiring pre-transaction disclosure of terms and reducing incomprehensible legalese. While this might help, it is unlikely to solve the problem because (a) most end users do not read license agreements, and (2) even if they did read the license agreements (or an intermediary provided the information in a user-friendly manner), most end users might not reject the cybersecurity-reducing terms or practices.

The next section discusses the question of improved pre-contractual disclosure of license terms and why it is that this is unlikely to solve the problem. It then very briefly considers the contract law doctrines that permit courts to control the substance of undesirable software license terms. In the end, it appears that it would be best to create specific rules providing that certain cybersecurity reducing license terms are to be unenforceable. This approach avoids the inefficiency of judicial control of clearly harmful terms and also offers the

opportunity to create a self-enforcing “responsible disclosure” regime for software security vulnerabilities.

Improved Pre-Contractual Disclosure of Terms Will Not Solve the Problem

The topic of software contract formation has been controversial for years owing to the practice of delaying the presentation of the license terms until after purchase. This practice, known as “shrinkwrap” contracting, involved the sale to consumers of packaged software such that the consumer would be able to read the terms only after purchasing the software and opening the package or beginning to install the software.

Although the case law upholding the enforcement of shrinkwrap licenses depended on the fact that purchasers were able to return software for a refund if they objected to the terms,¹⁸¹ this was clearly highly inconvenient for consumers, even if vendors really intended that a refund be available as promised in the licenses. A recent lawsuit filed in California alleged that retailers and software vendors had colluded to sell software in a manner that prevented purchasers from seeing the license terms before purchase and from returning the software for a refund after purchase should they dislike the terms, even though the license agreements informed them they could do so.¹⁸² Far from being readily returnable, the claim argued that the retailers and software companies had agreed that refunds would be made only “if the consumer’s complaint reaches a pre-arranged level of outrage.”¹⁸³

The plaintiffs also complained that *online* sales were improper because the terms of the licenses were not made readily available to online purchasers.¹⁸⁴ A study of industry practices in 2003 revealed that even once internet use became widespread, most software companies failed to make license agreements easily available to potential purchasers.¹⁸⁵ Under the terms of the April 2004 settlement of the class action, Symantec, Adobe, and Microsoft agreed to make their license terms available on their websites and to place notices on their software packaging directing consumers to the websites to review the licenses before purchase.¹⁸⁶

Although the problems associated with delayed presentation of terms may be somewhat abated as a result of this settlement, other software vendors are not bound by the settlement. Furthermore, UCITA accepts delayed disclosure of license terms even in internet transactions, where it is a simple matter to disclose terms before purchase.¹⁸⁷ The Preliminary Draft No.2 of the ALI “Princi-

ples of the Law of Software Contracts” requires that mass-market license terms be reasonably accessible electronically before a transaction.¹⁸⁸

However, the focus on pre-transaction disclosure of terms likely will not be sufficient to address the problem of license terms that undermine cybersecurity or cybersecurity-reducing practices that are disclosed in licenses. This is because (1) most end users do not read license agreements and (2) even if they did read the license agreements, they might not reject the cybersecurity-reducing terms or practices because there are collective action and externality problems related to cybersecurity.

Most consumers do not read standard form contracts.¹⁸⁹ This seems quite rational given that (a) the consumer perceives that there is no room for negotiation, (b) the form is incomprehensible to most consumers, (c) the seller’s competitors usually use similar terms, (d) the remote risks described in the standard form are unlikely to come about, (e) the seller has a reputation to protect, and (f) the consumer expects the law will not enforce offensive terms in the form.¹⁹⁰ Under these conditions, “[t]he consumer, engaging in a rough but reasonable cost-benefit analysis of these factors, understands that the costs of reading, interpreting, and comparing standard terms outweigh any benefits of doing so and therefore chooses not to read the form carefully or even at all.”¹⁹¹

Although basic economic analysis of standard form contracts suggests that the market will generate only efficient terms,¹⁹² this reasoning breaks down if consumers do not read standard form contracts and so do not react appropriately to the terms:¹⁹³

Efficiency requires not only that buyers be aware of the content of form contracts, but also that they fully incorporate that information into their purchase decisions. Because buyers are boundedly rational rather than fully rational decision makers, they will infrequently satisfy this requirement. The consequence is that market pressure will not force sellers to provide efficient terms. In addition, under plausible assumptions, market pressure actually will force sellers to provide low-quality form terms, whether or not those terms are either socially efficient or optimal for buyers as a class.¹⁹⁴

The “informed minority” argument suggests that it does not matter if most purchasers do not read standard form contracts. According to this argument, sellers in a competitive market will be forced to provide efficient terms for the minority of purchasers who do read them.¹⁹⁵ Russell Korobkin suggests that this reasoning is incorrect because, if the efficient term is more costly to a seller,

the increase in prices needed to cater to the minority would drive away the majority of purchasers.¹⁹⁶ Furthermore, if a seller is able to identify the informed minority and offer them preferential terms, there is no need to offer the same terms to the majority, so that the informed minority's vigilance will not affect the terms offered to most purchasers.¹⁹⁷

Sellers may also face some pressure in the form of damage to their reputations if they use and enforce abusive terms.¹⁹⁸ The internet may assist in circulating information of this type.¹⁹⁹ Whether enough consumers read and act on this information is another question. In any event, the prevalence of unreasonable terms in software license agreements suggests that the market is only weakly able to police license terms.

Although improvements to disclosure should not be abandoned, it will be necessary to police the substantive content of terms in order effectively to address the ways in which software licensing contributes to the cybersecurity problem.

The second reason that improved disclosure of the terms in software licenses is unlikely to address the problem is that consumers might not reject the terms even if they did read them. For example, as discussed earlier, the terms that suppress security-related testing, reverse engineering, and the publication of security-related information are not of direct personal interest to the average end user, who is unlikely to be interested in researching them. Nevertheless, all end users would benefit if those who wish to do such research are able to. It seems likely, however, that very few purchasers would reject a desired software program in order to promote this somewhat remote collective interest.

Decision making about cybersecurity is also characterized by externalities. Put another way, an end user's decision to invest in cybersecurity by devoting attention and money to maintaining the security of his or her computer undoubtedly provides some direct benefit to that end user, but it also benefits the entire community of internet users. For example, various types of attacks can be launched from "botnets," which are networks of insecure computers that have been infected with "bot" software.²⁰⁰ Botnets are used for various purposes, including to circulate malware, to send spam (including phishing emails), and to launch denial-of-service attacks. Since these botnets are useful for cybercriminal purposes, bot software is often designed to be minimally disruptive to the computer owner in order to avoid detection and removal. In such cases, much of the cost of poor security is borne by the community rather than the end user. Under such conditions, one would expect inadequate attention to be

paid by end users to cybersecurity. After the spate of denial-of-service attacks against major websites in 2000, Ross Anderson noted that, “[w]hile individual computer users might be happy to spend \$100 on anti-virus software to protect themselves against attack, they are unlikely to spend even \$1 on software to prevent their machines being used to attack Amazon or Microsoft.”²⁰¹

Since most purchasers are unlikely to read software licenses and, even if they did, they would be unlikely to reject the license terms and practices that arguably undermine cybersecurity, it is not possible to rely on licensees to exert sufficient pressure through the market to discourage these terms. As a result, it is necessary to find some other mechanism to control such terms.

The Control of Software License Terms Using General Contract Law Doctrines

One of the possible means to address license terms that undermine cybersecurity is through the application of traditional contract law doctrines that enable the judicial scrutiny of the substance of contractual terms.

Unconscionability and Reasonable Expectations The doctrine of unconscionability, which is set out in the Restatement of the Law, Second, Contracts, §208²⁰² and in §2-302 of the UCC,²⁰³ seems unlikely to be of great assistance in addressing the terms that suppress security-related research or the public disclosure of software vulnerability information.²⁰⁴ The focus is on the unfair exploitation of one contracting party by the other, and the threshold for a finding of unconscionability is a high one. Contracts are invalidated only where they would “shock the conscience,”²⁰⁵ or result in “oppression and unfair surprise.”²⁰⁶ Clauses that suppress security-related research do not seem sufficiently oppressive to “shock the conscience,” particularly given that most licensees have no interest in conducting security-related research.

The doctrine of reasonable expectations, set out in §211(3) of the Restatement of the Law, Second, Contracts, is intended to ensure that the drafter of a standard form contract does not take advantage of the fact that consumers rarely read standard forms.²⁰⁷ Section 211(3) states that “[w]here the other party has reason to believe that the party manifesting such assent would not do so if he knew that the writing contained a particular term, the term is not part of the agreement.”²⁰⁸ A party will be considered to have reason to believe that the adhering party would have objected if “the term is bizarre or oppressive, . . . it eviscerates the non-standard terms explicitly agreed to, or . . . it eliminates the dominant purpose of the transaction.”²⁰⁹ Once again,

this doctrine seems unlikely to assist with terms that impede security-related research. In such cases, the licensor would be justified in believing that the licensee would not object, since most average purchasers are not interested in reverse engineering the software or conducting benchmark tests.

The doctrine according to which a court may refuse to enforce contracts that are contrary to public policy offers more promise in policing terms that undermine cybersecurity. However, whether courts will be willing to broaden the scope of judicially recognized public policies to include cybersecurity is uncertain.

The Unenforceability of Contracts That Are Contrary to Public Policy Common-law courts have long refused to enforce contracts considered injurious to the public.²¹⁰ The refusal is usually justified by the argument that a refusal to enforce contracts contrary to public policy will deter harmful contracts and activities and/or by the argument that public respect for the law will be undermined if courts lend assistance by enforcing contracts contrary to public policy.²¹¹

Where contracts are directly contrary to a statute,²¹² the situation is fairly straightforward, and courts will refuse to enforce the contracts.²¹³ The issue is more complicated where a contract seems contrary to the court's own perception of public policy.²¹⁴ Public policy invalidity of the second type is more controversial. The concern is that the unconstrained use of the doctrine will result in the arbitrary invalidation of contracts, thereby reducing the certainty and predictability of the law of contract, and resulting in decisions that fail to recognize the countervailing public policy favoring freedom of contract.²¹⁵

The judicial application of the public policy rule in contract law also runs into the general concern that decisions about public policy are better left to legislators than to the courts. The government, unlike the courts, is accountable through the democratic process to the public. In addition, it is said, the government is better equipped than the courts to undertake the complex factual investigations and interest balancing required for making sound public policy decisions.²¹⁶

As a result of concerns over the possibility of uncontrolled and capricious judicial use of the doctrine, there is sometimes a tendency in the Canadian context to say that the doctrine should be applied extremely cautiously, and that it might not be capable of expansion to encompass a broader range of public policies than are already represented in the precedents.²¹⁷ Nevertheless, not all Canadian courts take such a strictly conservative approach; nor does the Restatement of the Law (Second), Contracts, which notes that some of the

grounds of public policy are rooted in longstanding historical precedent but that “[s]ociety has, however, many other interests that are worthy of protection, and as society changes so do those interests.”²¹⁸ This seems appropriate given that the social consensus on important public policies and the values that should outweigh freedom of contract change over time.²¹⁹

Given the public policy declarations by the governments of both the United States²²⁰ and Canada²²¹ on the importance of cybersecurity, a reasonable argument can be made that contracts undermining cybersecurity may be contrary to public policy. This argument is perhaps strongest in relation to contracts impeding security research and the disclosure of software security vulnerabilities. Nevertheless, given judicial caution in recognizing new public policies, the success of such an argument is uncertain.

The Advisability of More Specific Rules to Govern Software Licensing

The common-law method of elaborating legal rules through repeated, heavily context-dependent judicial decisions has been criticized as an inefficient and ineffective way to address consumer protection. The low value of transactions, the ability of vendors to settle individual disputes to avoid unfavorable precedents, and the scope for a vendor to tweak its practices slightly to distinguish unfavorable precedents, led Arthur Leff to write that “[o]ne cannot think of a more expensive and frustrating course than to seek to regulate goods or ‘contract’ quality through repeated lawsuits against inventive ‘wrongdoers.’”²²² Leff suggested that it is far better to regulate clearly and directly than “merely to add to the glorious common law tradition of eventually coping.”²²³

Contracting is regulated fairly heavily in numerous sectors of the consumer economy already, including the retail insurance and airline transportation markets.²²⁴ It would, therefore, not be an aberration if specific rules were devised to govern software licensing. The difficulty, of course, is in designing an appropriate set of rules.

Korobkin provides a close analysis of market failure in relation to standard form contract terms. He recommends a blended approach of specific regulation and a refocusing of traditional contract law doctrine to address the problem. He notes that an approach which dictates the content of terms runs the risk of being poorly tailored for specific contexts. Attempts to provide more and more fine-grained rules and exceptions eventually become unwieldy.²²⁵ In addition, it is hard for regulation to anticipate all of the possible terms that could appear in a standard form and to address all of the possible problems that might

arise.²²⁶ Korobkin concludes that *ex ante* mandatory terms are therefore desirable where relatively simple rules can “insure that the mandated content will be efficient for a relatively large proportion of contracts.”²²⁷ He suggests that other cases should be addressed by the courts using an unconscionability doctrine that is properly oriented to focus on inefficiency in terms that are generally not policed by consumers.²²⁸

Several authors, writing in the context of software licensing, advocate the adoption of specific rules to address software licenses. Robert Oakley writes that “[t]he U.S. common law can continue to work within the framework of the unconscionability doctrine and other legal principles, but if it were possible to agree on a set of principles that were reasonable, it would promote certainty, commerce, and fairness by removing the current unknowns, and, in many cases, the need for and expense of litigation.”²²⁹ Braucher suggests that the general rules in the UCC and the common law can “supplement [the more specific principles proposed by AFFECT] and be used to address additional unfair practices and terms that either have not yet appeared or that have not yet been identified as problematic. But specific law reform can and should address known problems in mass-market digital product transactions.”²³⁰ Braucher recommends model legislation such as a Model End User Licensing Act based on a template such as the AFFECT principles.²³¹

As noted above, the existing contract law doctrines do, indeed, appear poorly adapted to dealing with the problem of license terms that undermine cybersecurity, with the possible exception of the public policy doctrine. This is not surprising given that the law applicable to mass-market software contracts is generally uncertain and inadequate, despite the economic importance of the industry.²³² Several efforts have been made and are being made to create rules, principles, or guidelines for software contracts.

The ALI’s project entitled “Principles of the Law of Software Contracts” is the latest in the history of the efforts to address problems in software transactions.²³³ The previous efforts have been highly controversial. The joint effort of the ALI and the National Conference of Commissioners on Uniform State Laws (NCCUSL) to produce a new Article 2B of the Uniform Commercial Code (to cover licenses for computer information) broke down in 1999 when the ALI withdrew from the project.²³⁴ The NCCUSL proceeded alone to produce the Uniform Computer Information Transactions Act (UCITA).²³⁵ The NCCUSL first approved UCITA in 2000, and this version was enacted in Maryland and Virginia.²³⁶ Nevertheless, the substantial opposition to UCITA resulted in its defeat in other jurisdictions, as

well as in the enactment of “bomb-shelter” legislation in several states to protect customers from choice-of-law or choice-of-forum clauses that would result in the application of UCITA.²³⁷ The NCCUSL produced the final and revised version of UCITA in 2002, but the American Bar Association declined to support it following a critical report by a high-level ABA working group.²³⁸

In addition to the efforts of traditional law reform bodies, such as the ALI and the NCCUSL, other groups have coalesced around the problem of software licensing. Americans for Fair Electronic Commerce Transactions (AFFECT) was formed in 1999 (as 4Cite) to oppose UCITA.²³⁹ AFFECT continues to oppose UCITA, but is also attempting to advance the debate by proposing a set of fair commerce principles for these transactions. Inspired in part by Professor Cem Kaner’s “Software Customer Bill of Rights,”²⁴⁰ it published its “12 Principles for Fair Commerce in Software and Other Digital Products” in 2004.²⁴¹ The more detailed technical version was completed in January 2005.²⁴² The 12 Principles include terms governing contract formation,²⁴³ minimum standards of quality,²⁴⁴ dispute resolution,²⁴⁵ and basic rights of the consumer in relation to the use of his or her computer, data, and the software.²⁴⁶

Other efforts to address the problem of rules for software licensing are also under way. Ed Foster, who has long been reporting on unfair terms in software licenses, has started a wiki project to create a model fair end-user license agreement (FEULA). He writes that it is intended to be “a short, simple license agreement that strikes a reasonable balance between the needs of software customers and software publishers.”²⁴⁷

Recommendations and Conclusions

Cybersecurity is an important public policy objective, and a lack of cybersecurity imposes heavy costs. The prevalence of software license terms that undermine cybersecurity, together with the reasons to believe that they are a product of market failure rather than a reflection of the optimal state, suggests that some steps ought to be taken to control harmful license terms.

Korobkin recommends that specific *ex ante* rules be used only in fairly clear cases, and that more complex context-dependent problems be left to *ex post* judicial control through more general contract doctrines.²⁴⁸ Pursuant to this recommendation, it seems advisable to address problems such as the suppression of security-related research, the practice of impeding uninstallation of software, and the misuse of the automatic update system, all of which create clear harms and for which a relatively discrete set of rules could be declared.

UCITA does not assist with the cybersecurity-related concerns raised in this chapter.²⁴⁹ AFFECT's 12 Principles would go a long way toward remedying the problem. AFFECT has clearly considered cybersecurity in the course of preparing its "12 Principles."

There is little incentive to fix a bug or security hole when license agreements protect a seller from legal recourse or criticism and deter would-be competitors from buying the product to see how it works and to improve it. The burden falls on individuals, businesses and governments, which continually struggle to maintain their systems' reliability and security, to prevent invasion of their private data, and to protect the nation's overall cyber-security—at the cost of billions each year.²⁵⁰

AFFECT's Principles properly address the need for software to be easily un-installable,²⁵¹ which is essential in light of the frequency with which security flaws are discovered in mass-market software. The Principles also address the misuse of the automatic update system,²⁵² which is advisable to preserve public trust and acceptance of an important cybersecurity-enhancing practice. Principle IX is also welcome in its clear affirmation of the right to reverse engineer software to understand security features,²⁵³ and Principle X makes it clear that licensees can conduct performance tests and publicly criticize software.²⁵⁴

AFFECT's Principles also address questions of liability for security flaws,²⁵⁵ and the enforceability of exclusions of liability for certain types of security flaw.²⁵⁶ Since this chapter has not addressed the issue of legal liability for flaws and the enforceability of disclaimers of implied warranties or exclusions of liability, no further comment will be made here. Nevertheless, some version of these provisions seems advisable. They clearly affect cybersecurity, but they will also likely be quite controversial.

This chapter suggests, however, that AFFECT's Principles may require adjustment in relation to the disclosure of software flaws, particularly for flaws that create security vulnerabilities. In particular, Principle III seems to require that vendors publicly disclose information about nontrivial defects in digital products,²⁵⁷ including security-related flaws ("inclusion of spyware or a virus"). This seems inadvisable given the serious risk that such a list would be of great assistance to cybercriminals because of vendors' superior and advance knowledge of their own products. It is not clear that software vendors would react to this requirement by fixing the flaws, rather than by merely disclosing their existence in general terms in the license.

In addition, AFFECT's Principle III also deals with the suppression through the license of public disclosure of vulnerability information. Comment (D) provides that there may be no license restrictions on the public disclosure of software vulnerability information.²⁵⁸ In my view, it would be preferable to tie the freedom to disclose vulnerabilities to a carefully designed "responsible disclosure" scheme. Such a scheme would reduce the possibility that software vulnerability disclosure would impose short-term reductions in cybersecurity. Furthermore, it seems that many independent security researchers are willing to live by responsible disclosure regimes that provide for a delay during which vendors can fix their software. As discussed above, a number voluntarily adhere to their own self-imposed responsible disclosure guidelines. If the freedom to disclose software vulnerabilities were tied to a carefully designed responsible disclosure system, software vendors might be more likely to accept the Principles, and perhaps the eventual enactment of legislation in accordance with the Principles.

10 Information Security, Law, and Data-Intensive Business Models

Data Control and Social Networking: Irreconcilable Ideas?

Lilian Edwards and Ian Brown

Giving the public details about oneself is a bourgeois temptation I have always resisted.

Gustave Flaubert

THE FUTURE of both law and technology will require reconciling users' desire to self-disclose information with their simultaneous desire that this information be protected. Security of personal information and user privacy are potentially irreconcilable with the conflicting set of user preferences regarding information sharing and the convenience of using technology to do so. Social networking sites (SNSs) provide the latest and perhaps most complicated case study to date of these technologies where consumers' desire for data security and control conflict with their desire to self-disclose. Although the law may provide some data control protections, aspects of the computer code itself provide equally important means of achieving a delicate balance between users' expectations of data security and privacy and their desire to share information.

The Rise of Social Networking

What are SNSs?

SNSs were the internet phenomenon of 2007 and show no sign of losing impetus. Sites like MySpace, Facebook, Orkut, LinkedIn, Bebo, and Club Penguin

have attracted students and seniors, adults and children, business users and entertainment seekers, both American and European, in ever increasing numbers. Social networking sites (or “services,” as that sometimes unreliable font of all wisdom Wikipedia, describes them)¹ can be characterized as *online social networks for communities of individuals who share activities and interests, or who are interested in exploring the activities and interests, and which necessitate the use of software*.² SNSs differ enormously in their intended audience, unique selling points, and interfaces, but all tend to share some points of similarity, such as

- “friends” or “buddy” lists;
- disclosure of personal information via pre-structured “user profiles,” including items such as name, nickname, address, email address, birth date, phone number, home city or town, school or college, pets, relatives, and the like;
- some form of intra-site messaging or “bulletin posting,” which encourages further disclosures of information by users to other users; a profit-making mechanism for the site owner, usually at least partly derived from advertisements served up to users when they view their own or other users’ profiles;
- governance by terms and conditions of the site user, or “end user license agreement” (EULA).

All of these common features, which enable and enhance social networking (or in the fourth and fifth examples, allow the site to survive financially and practically), can unfortunately also be seen in practice as sources of concern when we look at user privacy. Other features that are beginning to appear on some SNSs, and which also have serious privacy implications include:

- organization of users into groups or “networks” by some schema, such as country, region, town, college, school, color, sexuality;
- integration of the SNS in website form with mobile phone communications so, for example, an SNS member can be notified or made known to another SNS user when in the same locational area—using mobile phone cell or GPS technology;
- the allowing of access by site owner of third-party “apps” (applications) to the SNS. This brings into play issues of control of, and access to, the personal data of users by parties other than the SNS site owner, which as we shall see below can be disquieting;

- mining of personal data placed on SNS profiles together with non-explicit “traffic” data generated by users to produce profiled, context-sensitive advertising.

Finally, many, though not all, SNSs specifically target children and young persons as a key audience. Early social networking websites, for example, included Classmates.com (founded 1995), focusing on ties with former school-mates; and Facebook (founded 2004) originally built its audience by “capturing” entire school or undergraduate student years as a kind of digital class yearbook. In recent years sites aimed at a younger age group such as Bebo and Club Penguin have been big commercial successes. Given the perceived vulnerability of young people in the online environment and their general lack of life experience, this raises further concerns. Note, however, the UK statistics cited above, which demonstrate that even SNSs originally rooted in a youth demographic have the capacity to outgrow this stage and reach a wider audience.

How Prevalent Are SNSs?

According to the Pew internet and American Life Project, 55 percent of U.S. teenagers who use the internet have an SNS presence,³ while in Europe, 32 percent of 18–24-year-olds use an SNS at least monthly.⁴ Global SNS user figures are staggering for such a recent innovation; MySpace reports having 217 million users worldwide, competitors Bebo and Facebook claim 40 and 62 million global users respectively, and the “business user” SNS LinkedIn has 20 million global users.⁵ In addition to the current “big three” SNSs, MySpace, Facebook, and Bebo, SNSs exist for every social, cultural, racial, and ethnic niche: Jews, blacks, Asians, Swedes, football fans, environmentalists, photo-bloggers.

In the UK, which bears perhaps the greatest resemblance to U.S. internet culture in Europe, the SNS site Facebook has become both the market leader in SNS in 2007 and omnipresent in conversation and press headlines. Facebook grew exponentially in the UK in the period August 2006–September 2007, according to a major survey carried out in 2007 by analysts Human Control, increasing its audience capture by 1800 percent,⁶ overtaking MySpace to become the market leader, and reaching around 23 percent of the active internet user population in the UK. Over the same survey period, the internet “reach” itself increased by only 11 percent in the UK. Audience numbers rose by 20 percent per month throughout 2006–2007, although this had slowed to 15 percent

per month by September 2007. Facebook had 7.5 million unique users in the UK by September 2007, while MySpace had only 5.2 million users and Bebo (aimed at younger children) 2.7 million users.⁷ Based on number of unique users, Facebook was the thirteenth most popular website in the UK in 2007, beaten out by numerous other Web 2.0 sites such as YouTube, eBay, and Wikipedia. Based on the number of Web pages viewed however, Facebook was the third most popular site, with over 3 billion page views per year, beaten only by Google and eBay.

Contrary to popular belief (and unlike many other SNSs), Facebook is not used exclusively by undergraduate students and school kids. In fact, the age of the average Facebook user by September 2007 was almost 34, with most of the user growth coming from the 25–34-year-old age bracket. Even among people over 65, hardly the typical imagined users of SNSs, Facebook had an audience in September 2007 of 131,000 men and 49,000 women. Furthermore, like many SNSs and unlike many more traditional internet sites, Facebook does not have a male bias. Instead, it has a distinct gender skew, with 22 percent more females using it than males, the bias being greatest among young females in the 18–24 age group. These figures demonstrate provocatively the staggering and sudden rise in popularity of SNSs, the diversity of the age and gender groups engaging, and in particular the current victory over the UK market by one site, Facebook.

Social Network Sites and Personal Data Disclosed

A typical Facebook user profile frequently includes large amounts of personal, and even, in the terminology of the European Data Protection Directive (DPD),⁸ “sensitive” personal data.⁹ For example, one real Facebook profile revealed through self-disclosed information and network affiliations that a certain male member of the Communication Workers’ Union living in Illford, England, was a liberal Catholic in an open relationship with a woman named Jeanette and infected with the HIV virus. In this profile, therefore, we find sensitive information of several kinds—union affiliation; political and religious affiliation; interpersonal lifestyle information, including information naming another individual; and health information.

Privacy in the context of the information society is usually viewed as being about control by a living person over the processing of one’s “personal data,” as defined in the DPD.¹⁰ The DPD goes on to prescribe a regime based on eight principles for the processing of personal data, which include but also expands

on the familiar OECD Privacy Principles.¹¹ Key elements of the European DPD regime include that

- processing is to be fair and lawful, with consent of the data subject as the primary means of establishing that processing meets these conditions;
- processing is only to be undertaken for known and specified purposes;
- no more personal data are to be gathered than necessary and relevant to these purposes;
- data are to be kept accurately and if necessary updated;
- data are not to be held longer than necessary to fulfill these purposes;
- data are to be held securely;
- rights of data subjects—for example, to access and correct their data, and prevent its use for direct marketing, are to be respected;
- data are not to be exported without consent to countries outside the EU where privacy protection is not “adequate.”

“Sensitive personal data” is defined in the DPD as “personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, and data concerning health or sex life.”¹² The DPD states that particular conditions and safeguards must be observed when particularly “sensitive” personal data are processed.

Many Facebook profiles contain, or appear to contain, almost every category of data deemed especially “sensitive” by EU law. Facebook profiles typically reveal sexual details (“looking for man/woman/both”); religious details (“Jewish/atheist”); and political details (“very liberal”). Group memberships and events may also reveal significant information (such as member of “Gay Pride London 2008”; “attending ‘Vote for Obama’;” member “HIV Survivors Support New Jersey”). Empirical research suggests the view that this revelation of sensitive data is typical of user profiles. Ralph Gross and Alessandro Aquisti found in 2005 that, looking at a sample of 4,500 Facebook profiles of Carnegie Mellon students they had spidered, 80 percent contained an image of the user; 87 percent contained a date of birth; 39 percent listed a phone number; and over 50 percent listed a current residence. Turning to “sensitive data,” the majority of users in the study also listed sexual preferences (“Men”/“Women”), current relationship status, and political views.¹³

This simple example demonstrates both the potential of SNSs to disperse highly personal data, possibly to the detriment of the data subject, while at the

same time introducing the conundrum of whether traditional privacy legislation may over-regulate in a new era where disclosure, rather than secrecy, is becoming the norm. EU DPD law demands, for example, that a user give *explicit* consent to the processing of sensitive personal data, while in relation to “ordinary” personal data implied consent will suffice. Is it reasonable or practical to demand a higher standard of privacy protection in relation to one piece of information on a user SNS profile and not the rest of the profile? Arguably the DPD provides an exception that may negate the special rules on “sensitive data” in the SNS context, namely that “special treatment” is not required where “the data are manifestly made public by the data subject,”¹⁴ but this merely pushes the question one stage back: should a vulnerable young person, say, lose protection of sensitive data simply because social networking sites are by default public? Are these particular types of data really more “sensitive” in the eyes of the average SNS user? Certainly standard industry practice does not seem to show a difference in practice in relation to different types of data disclosed, and it is questionable how such distinctions would be implemented.

Below we examine a number of problems that have arisen in relation to privacy and personal data on SNSs through the lens of a number of widely covered recent incidents in the SNS world, and ask if these apparent or potential threats to personal privacy demand reconsideration of either or both the *detail* or the *application* of existing informational privacy laws to SNSs.

Case Study One: The Oxford Facebook Case and the Dangers of Default Privacy Settings

In July 2007, Oxford proctors in charge of university discipline at the ancient university used Facebook to find evidence of students breaking university disciplinary rules. Students, who, in post-exam hilarity, had held wild parties, sprayed each other with Champagne or shaving foam, or thrown flour bombs at each other, often posted photos of these incidents on Facebook. Proctors combed Facebook for evidence of such incidents and caught a number of students *in flagrante*. As a result, some students received disciplinary emails or more vigorous sanctions. The response from students was dismay and shock. The student union claimed that the incident was a “disgraceful” intrusion into the privacy of the students concerned. One caught perpetrator complained that she was “outraged”:

Alex Hill, 21, a math and philosophy student, received an e-mail stating that three of her photos provided evidence that she had engaged in “disorderly” conduct.

“I don’t know how the proctors got access to it,” the St Hugh’s College student said. “I thought my privacy settings were such that only students could see my pictures.

They cited three links to pictures on my Facebook profile where I’ve got shaving foam all over me. They must just do it randomly because it would take hours and hours to go through every profile. I’m outraged. It’s truly bizarre that they’re paying staff to sit and go through Facebook. It must be extremely time-consuming.”¹⁵

A number of points are worth making here. First, Ms Hill displays a common misperception that her posts on Facebook were “private” or at least restricted in access to her perceived “friends” group, namely fellow Oxford students. In fact, on Facebook, the default site setting is that profiles, including photos of events posted, are visible to everyone in the user’s default “network.” For Ms. Hill, an Oxford student with, one assumes, an *oxford.ac.uk* email address, her posts and photos would have been visible in their entirety to every member of the Oxford university network (unless she had deliberately altered the default settings—see further below). While, from press reports, Ms. Hill seems to have been aware that she belonged to a network and that this had disclosure implications, what she failed to anticipate is that not only students but also staff on the Oxford University payroll (including proctors) might have *oxford.ac.uk* email addresses, and thus also have access by default to her profile and photos.¹⁶

While one might argue that an Oxford student who failed to work out something as obvious as the possibility of surveillance when committing illegal acts deserved to get caught, the “network default” issue is an important one. The London Facebook Network has 2.1 million people in it as of January 2008: those who join that network in good, albeit ignorant, faith (perhaps because they want to see what events are on in their area, or want to track down a friend in the area) are disclosing their personal data by default to those millions of people, some of whom have every chance of being ID thieves, spammers, or worse. Furthermore, while university networks on Facebook are in theory “policed” by the need to have a relevant email address (such as an *ed.ac.uk* address to join the Edinburgh University network), nonuniversity networks such as London, Oxford, and Edinburgh have no such requirements; this writer might, for example, join the Portsmouth network to stalk a Portsmouth resident without having any connection to that city.¹⁷

Privacy defaults on SNSs can of course usually be altered by users, and Facebook, in fact, has a relatively sophisticated and granular set of privacy

controls.¹⁸ However, both anecdotal and survey evidence show that few users are aware that these controls can be “tweaked” (or even that they exist), and even fewer then take the time and energy to make these changes.¹⁹ Gross and Acquisti, for example, found that only 1.2 percent of Carnegie Mellon students in their survey changed their default settings to make their profile more private, and they concluded that “only a vanishingly small number of users change the (permissive) default privacy preferences.”²⁰ Default settings are not consistent across different SNSs, so there is little or no “learning from experience” as users move from today’s hot SNS to the next flavor of the month. Even within a single site such as Facebook, privacy defaults may not be consistent. For example, consider A, who is a member of two Facebook networks, Oxford University and London. A may alter his privacy defaults so that only his “friends” list and not every member of the Oxford University network has access to his biographical details, photos, and other information. However, possibly unknown to A, his choice will not have altered the settings for his London network, and so all 2.1 million London members will continue to have access to all of his personal data. Even a determined privacy-conscious user might struggle to control access to his data given such inconsistencies, let alone the inexperienced, time-poor, and disclosure-prone users of SNSs.

The fundamental issue here is that privacy on SNSs is primarily regulated not by law (whether it is EC data protection law or U.S. rules such as COPPA)²¹ or by informed user choice as the OECD principles might demand, but, as Lawrence Lessig famously put it, by code.²² Privacy rights in the examples above are determined by the default settings coded into the software, and they in their turn are determined by the writers of the SNS code. What incentive does the SNS have to code a “reasonable expectation” of privacy into its system as a default? There is no guarantee that the SNS has the privacy interests of its users as first priority when setting privacy defaults—indeed the converse is more likely to be true. As SNSs derive their income streams at least partly from data disclosed by users, their financial incentive is arguably to maximize disclosure and minimize privacy.²³

A second key point raised by the Oxford case is the recurring question of whether Facebook and similar SNSs are indeed a “private” space where the user has reasonable expectations of privacy, or a “public” space where such expectations do not or should not exist. Ms. Hill’s “outrage” at being stalked in an underhanded fashion by Oxford proctors seems to show an honest (if unreasonable?) belief that she was operating in a friendly private space. Should such attitudes be taken into account and reified by the law or by code?

Sonia Livingstone, researching attitudes of young persons in the UK to privacy on Facebook in 2006, found that young people had both a conflicted attitude to privacy and often were either ignorant or confused about how far they could alter privacy settings.²⁴ One of her respondents, Nina, complained, “they should really do something about making it more like private, because you can’t really set your profile to private.” Another respondent, Ellie, struggles with trying to leave her school area network when she moves away: “I probably can, but I’m not quite, I’m not so great at that, I haven’t learned all the tricks to it yet.”

Susan Barnes, working in the United States, notes that there is an apparent disconnect—which she calls the “privacy paradox”—between “the way users say they feel about the privacy settings of their blogs and how they react once they experience unanticipated consequences from a breach of privacy.”²⁵ She cites a student in one of her own surveys who explicitly reported her concern at revealing personal information online, but meanwhile had a Facebook page that nonetheless gave away her home address, phone numbers, and pictures of her young son. The internet abounds with such contradictory evidence.

Barnes’s conclusion is that “on the internet, the illusion of privacy creates boundary problems” with new users, and those engaged exclusively in recreational pursuits are most convinced by the illusion.²⁶ Students and young persons clearly wanted to keep information private from some persons, such as parents and teachers, but did not seem to realize that Facebook is a public space. Such pervasive assumptions seem to go beyond mere ignorance to something more rooted about perceptions of social networking and virtual community spaces, especially given that so many students of today are tech-savvy and (by definition?) well educated and familiar with information technology.

Privacy jurisprudence itself is conflicted about whether “privacy in public” exists and should be protected. The European Court of Human Rights, for example, has been in the process for some years of recognizing that privacy rights do exist even in public spaces, and even where celebrities, the archetypal “public property,” make themselves accessible to press attention in public—most noticeably in the celebrated ECHR case of *von Hannover*.²⁷ In the UK, the Press Complaints Commission has given spectacularly contradictory decisions concerning celebrity privacy in quasi-public spaces such as beaches.²⁸ On social networking sites, where the whole purpose for users is to network and to expose parts of themselves so as to engender trust and communication, the discourse is hopelessly confused. Trust and disclosure, arguably, depend on

users perceiving their surroundings as quasi-private or at least “gated,” as a “social club” of some kind. Yet Catherine Dwyer, Star Hiltz, and Katia Passerini found in 2007 that SNS users were prepared to disclose remarkable amounts of personal information on a number of SNS sites even if they had relatively little trust in fellow users.²⁹ This would seem to argue that a high level of disclosure by users does not imply a reasonable expectation of privacy.

A final obvious point raised by the Oxford case and the many, many similar cases, is that SNSs are simply a stalker’s—and a voyeur’s—charter.³⁰ Many groups have incentives to surveil SNS users for a variety of more or less dubious purposes. These range from surveillance for legitimate law or norm enforcement purposes (as in the Oxford case itself), to curious investigation by current or former friends, to less savory stalking by strangers or perhaps ex-partners, to collection of data without consent for economic exploitation by, *inter alia*, spammers, direct marketers, data miners, and identity thieves.³¹ It is extraordinarily difficult to measure or prescribe the quantity of privacy protection that users should expect or be able to demand as default or option, given this extensive range of possible watchers and data collectors, legitimate and illegitimate.

It should also not be forgotten that data disclosed on SNSs may persist for an unknown length of time. What if the harmless pranks of children today, which once would have vanished into faded memory but are now enshrined on an SNS, become part of a juvenile delinquent’s profile tomorrow, and a reason to be denied employment or admission to university in ten years’ time? One of the most worrying aspects of the SNS phenomenon is the widely acknowledged surge in their use by employers and other institutions as a means to screen applicants.³²

Reports in the UK have also suggested that while, in theory, data on Facebook can be deleted, Facebook does not guarantee this in its terms and conditions, and in practice profiles have a bad habit of persisting.³³ Even where the site cooperates in providing effective deletion mechanisms, it is more than likely that disclosed data may still be available via Google cache³⁴ or archiving sites such as the Way Back Machine.³⁵ Such concerns, yet again, do not seem to have communicated themselves to younger users. A study by the UK Information Commissioner’s Office (ICO) in 2007 found that almost 60 percent of UK 14–21-year-olds did not realize the data they were putting online could be permanently linked to them, and reactions were generally horrified when this was pointed out.³⁶ Just as users’ perception that SNSs are a safe and private space

is faulty, so apparently is their perception of the risk of long-term unintended consequences arising from their disclosures.

Case Study Two: The “Compare Me” Application and the Role of Third-Party Applications, Third-Party Tagging, and Loss of Data Control

One feature of Facebook that may have helped it become the SNS market leader in several countries has been the opening up of the site to applications written by third parties who have entered into licensing agreements—the so-called “apps.” Popular apps include, for example, Scrabulous—an obvious clone of Scrabble that is currently subject to threat of suit for trademark infringement by Mattel and Hasbro³⁷—which allows users of Facebook to play Scrabble online. Similarly apps have been written to allow users to send kisses, flowers, virtual fish, and virtual gifts to their friends list; to engage in tribal “warfare” games in which friends are either attacked or recruited to ranks of vampires, werewolves, and slayers; and to interface with other popular sites such as LifeJournal, Flickr, and Blogger. What all these apps have in common is that when the user attempts to use the application she is required to consent to a license which invariably requires the user to share her own personal data, and sometimes to share the personal data of friends.

By way of example, one third-party application on Facebook is called “You are Gay.” It is impossible to opt out of allowing this application to access all the data Facebook holds about you and to still gain access to the application. This data would include full real name, friends, and phone number, even though the only purpose of the application is to send a message to a specified other Facebook user saying “You Are Gay!” (too?). Almost all Facebook Apps are similar in demanding access to all the information the user has given to Facebook, and yet make little or no use of it for the purpose of the app itself.³⁸ This pattern is replicated throughout every Facebook app this writer has seen, and it must therefore be assumed it is the standard access license template offered by Facebook to app developers. The impression of choice for the user is therefore illusory: it is take the app *and* give away personal data (*all* personal data), or nothing.

Why is this problematic for privacy? Consider the “Compare Me” incident of September 2007. Compare Me is an app created by Ivko Maksimovic that allows a user to compare two friends on random questions, “everything from ‘who is more tech-savvy’ to ‘who would you rather sleep with.’”³⁹ As a result, anonymized rankings are produced in which a user might learn that he was third “hottest” in his group of friends but only the eighteenth “person they

would most like to go shopping with.” No details would be available about who the user had defeated or lost to in the various comparisons made, or who had voted for the user to win or lose. Naturally, such information if available could be highly embarrassing. The app claimed that:

Your friends cannot find out how you compared them except when it’s an innocuous compliment. For example, if someone loses a comparison, they will not know that they lost. If you rate compare someone on a dating question, they won’t know how you chose. There is no way for someone to look at the rank lists and see who said what about them.

However, despite this promise, a “premium” Compare Me service was then offered for a small payment, which allowed subscribers to find out some details about “voters” and who had been beaten or won in the various “Compare Me” challenges.⁴⁰ Despite publicity on various blogs about this breach of privacy (and promise), the app continued to be available on Facebook as of March 2009.

The example is trivial, but it illustrates vividly the difficulty of controlling personal data spread and enforcing privacy guarantees against third-party application writers. While an SNS by its nature encourages the disclosure of personal data, at least that information may be relatively safe if the SNS itself can be trusted and the user takes sensible safeguards, such as changing privacy defaults to hide sensitive parts of profiles from all comers. However once data have been divulged to third parties via an app, those data are beyond the control of both user and the SNS site itself. It is possible that the SNS may contractually require the third-party app developer to take reasonable security precautions and accord with local privacy laws—but the user will not usually see that contract or be party to it or have title to enforce it. Neither does the law in either Europe or the United States appear to demand that an SNS ask for such contractual assurances.

SNSs as currently constructed typically give the average user little or no chance to find out if an app is really a front for, or selling information to, third parties such as marketers, spammers, or stalkers. Obtaining information about app developers in advance is difficult and sometimes impossible. In many cases, full terms and conditions or a license agreement can be viewed (if at all) only after consent has been given and the app has been loaded—equivalent to locking the stable door after the personal data have bolted.

To make matters worse, many apps are “viral” in the sense that a user cannot sign up for them, or get results out of them, unless they pass the app on to ten

or fifteen other friends on the same SNS first. What this boils down to is that the price of entry is not only giving away your own details but also supplying the email addresses or other personal data of friends. Being viral, such apps spread rapidly. And being, on the whole, trivial applications, users rarely stop to think whether sharing data with unknown third parties is wise or in their best interest. All in all, it might be suggested that the easiest way to become an ID thief in the SNS world is to simply write a popular app, sit back, and gather all the personal information you want.⁴¹

In fact, it is not even necessary to write an app to collect data from strangers. Many users, as we have already discussed, leave their privacy defaults undisturbed and broadcast all their personal details to the world. Even those who restrict some or all of their data to “friends,” however, can fall prey to illicit surveillance and data collection. Above we mentioned the “illusion” that an SNS is a private or “friendly” space, not a “public” space. Another problem with this illusion is that “friendship” seems to be a far thinner construct on SNSs than in real life. Millions of people inhabit SNSs, and friends lists of hundreds or even thousands of people are not uncommon. Social competition and peer pressure seems to lead users, especially young people, to engage in competition to collect “friends”—“friend whoring” as it is sometimes called. In such an environment, it is not hard for a stranger to ask to become someone’s “friend” and have his or her request accepted, even if that person is completely unknown to the user in question. In one famous experiment, Sophos, the anti-virus company, created a frog character on Facebook who requested to become friends with 200 users.⁴² Forty-one percent of users who were approached agreed to befriend the frog, thereby divulging in most cases data such as email address, date of birth, phone number, current address, and education or occupation.⁴³

Loss of control of personal data to third parties is a pervasive theme on SNSs. On Facebook, photographs and “tagging” present a particular problem. Photographs can be “tagged” with the names of the Facebook users who appear in them, and this tagging can be done not only by the data subject—the person in the photograph—but by any other Facebook user. It is quite possible that the students caught in the Oxford Facebook case (discussed above) had not been so foolish as to tag themselves in photos depicting illegal acts, but that “friends” had done it for them. Photo-tagging is seen as one of the “killer app” features of Facebook, and there is no community norm discouraging the tagging of other people’s photos. Again, it is possible on Facebook to amend the code defaults so that tagging cannot be done by third parties, but this option is buried in the

privacy section and almost certainly entirely ignored by most users. We will return to the issue of the setting of privacy defaults below.

Photographs, and photos used as icons (characteristic pictures that head up the user's profile), are of particular importance in a privacy context because they can act as an index to connect a user profile of A on one site to A's activities on another site. For example, a user might have the same photograph of herself on two websites, Live Journal and Facebook. Live Journal is a blogging site where pseudonyms are used and privacy is on the whole prized and respected. In contrast, Facebook is a site whose contractual terms and code both attempt to enforce the use of real names. It is not hard to imagine how a photo tagged with a name can be used as a "key" or unique identifier to link anonymized personal data to real world data, with predictable privacy-invasion consequences. The ENISA Report on security issues for online social networks recognized "face recognition issues" as one of the key problems for SNSs.⁴⁴ Face recognition software has improved so much over the past decade that both law enforcement agencies and more dubious entities can often conduct automated correlation of user pictures across different sites. According to ENISA, Facebook had a database of around 1.7 billion user photos as of May 2007, and was growing by more than 60 million per week. In work by Gross and Aquisti in 2007 and 2005, it was shown that more than 60 percent of the images on Facebook were good enough for direct identification of users using commercial face recognition software.⁴⁵ Re-identification—the connection of a user via his photo to other data anonymized but bearing the same image—was therefore eminently possible. In a world of ubiquitous CCTV surveillance and post 9/11 paranoia, the privacy consequences of this boggle the imagination.

A final threat related to loss of control over data is the threat to security. It is well known that apps can be used to introduce malware such as spyware and adware onto users' desktops. One recent example was the "Secret Crush" app, which ostensibly allowed users to find out of which of their friends "had the hots for them" but in fact was a conduit for adware.⁴⁶ Facebook disabled the application for violation of its terms of service, but only after around 4 percent of Facebook users had installed it.⁴⁷

Case Study Three: The Facebook Beacon, Data Collection, and Targeted Ads

Facebook is a free service to users. It appears to make its money primarily via third-party advertising served to its users. Since Facebook's value has been put at some \$15 billion,⁴⁸ it is clear that these advertisements must provide a

valuable income stream. (Some additional revenue is accrued via extra services offered by Facebook, merchandising, sale of anonymized aggregate personal data, and allowing of access to the site to third-party app developers, but these are probably not the main revenue generators.)

Facebook's privacy policy governs its self-imposed rules on collection and disclosure of users' personal data.⁴⁹ Facebook's policy, as of February 2008, said: "We do not provide contact information to third party marketers without your permission. We share your information with third parties only in limited circumstances where we believe such sharing is 1) reasonably necessary to offer the service, 2) legally required or, 3) permitted by you." This leaves open the question of when exactly Facebook "believes" that you wish to share your information. However, in practice, Facebook, while allowing third-party advertisers access to their site and to users, does not appear to date to be selling user information on in a non-anonymized form.⁵⁰

In late 2007, Facebook announced that it had formed a partnership with certain third-party retailers in an enterprise called "Facebook Beacon." Facebook took information about users' activities on these partner businesses and published the details on Facebook for everyone to see. So, for example, some users found a line on their profiles saying "X went to Amazon and bought *The Story of O*" (say)—something they might not want everyone to know, and certainly, in many cases, an embarrassing surprise. Some users were horrified at connections being made between their private purchasing habits and the "public" world of their SNS profile. Many users complained; 50,000 signed a petition asking Facebook to "stop invading my privacy." Facebook succumbed to user pressure in December 2007 and changed the system so that users had to explicitly "opt in" to having their details published by the Beacon system.⁵¹

Was Facebook doing anything illicit here? According to both their own terms and conditions, and European data protection law, arguably they were in the right even before adopting "opt-in." Facebook had already apparently gained tacit user consent to collection of both explicit user personal data and user traffic data on its own site, via the blanket assertion that "By using or accessing Facebook, you are accepting the practices described in this Privacy Policy." These practices include:

"When you register with Facebook, you provide us with certain personal information, such as your name, your email address, your telephone number, your address, your gender, schools attended and any other personal or preference information that you provide to us. . . . When you enter Facebook, we collect

your browser type and IP address. This information is gathered for all Facebook visitors. In addition, we store certain information from your browser using “cookies.”

The policy of course only covers data revealed to Facebook, not to the third-party retailers. However, it is likely those third parties had very similar policies in place.

Yet Facebook Beacon had apparently, again, violated the “reasonable expectation” of privacy of users. In DPD terms, although consent had been given to the collection of data, for what *purposes* had that consent been given? DPD (as the OECD principles do) rests on the notion of notice and choice: users are given notice not only as to what data is being collected but also how it is to be processed, and it is this whole package to which they give consent. Would users who had given consent, say on both Facebook and Amazon, have expected a result to be explicit revelations on their profile about what they had been buying for the world to see?

Furthermore, even if legal consent *had* been obtained from users to any and every purpose or use, can such “consent” truly be regarded as informed and freely given, as the European DPD requires?⁵² Consent, as we noted above, is meant to be a gatekeeping condition signifying agreement to terms and conditions. But here, consent is the price of access to Facebook itself.

It is well known that on many internet sites, including SNSs, consent to terms and conditions is obtained via an entry page tick box, which may often be already ticked. The EC Article 29 Data Protection Working Party has already strongly criticized such practices in its report in 2002: “using pre-ticked boxes fails to fulfil the condition that consent must be a clear and unambiguous indication of wishes.”⁵³ Yet having to proactively tick a box is not much better. How many young people are likely to turn down the opportunity of entry to Facebook because of fears about a privacy policy they are unlikely to have read or understand? Research has showed repeatedly that small print online is rarely read and even more rarely understood. And as with employment contracts, such terms and policies are take-it-or-leave-it: never negotiable. Regardless of these legal quibbles, however, Facebook, in the end, caved and instituted “opt in,” not because it was threatened with legal action, but because Beacon was a public relations disaster, and users were prepared to leave the site if the worst excesses of Beacon were not curbed.

Beacon is, however, only the beginning of the story for imaginative use of personal data disclosed online via SNSs. Both MySpace and Facebook have

announced plans to use the large amount of personal data disclosed on their sites, possibly combined with other personal databases, to allow advertisers to serve finely targeted ads to their users.⁵⁴ So, for example, a user who describes himself as male, single, living in London, and 25 might find himself served with ads for local dating agencies rather than baby diapers. The idea of targeted context-sensitive ads is not new: indeed it has long been the basis of Google's successful AdWords program where ads are served up alongside and matched to the search term the user entered. A similar protocol has been adopted, with rather more privacy-activist resistance, on Google's Gmail.⁵⁵ SNSs, however, give advertisers unprecedented access to personal data, often highly sensitive, in a context where that data has been made visible for a quite different purpose than seeking advertised services—unlike on Google. In European and OECD terms, the data were disclosed and thus made available for collection for one purpose (networking) and have now been used for another (ads). Businesspeople might argue that Facebook and others are merely adopting the obvious route to make money from the service they offer for free. According to the Center for Digital Democracy and the U.S. Public Interest Research Group, however, this "sheer betrayal of trust, as youth-driven communities are effectively sold to the highest advertising bidders, threatens to undermine the shared culture of the internet."⁵⁶

Striking an academic balance, again, the main problem here seems to be the illusory quality of the consent collected by Facebook. Going back to the concept of "reasonable expectations of privacy," a user may well expect when he signs up for a free service like Facebook that he will have to receive ads of some kind to make it worthwhile for the site owner. (A similar expectation might apply to Gmail.) However he almost certainly does not fully understand or expect his personal data to be collected, mined, combined, and sold to third parties to produce user profile data that may then be retained and distributed nearly indefinitely, and used to serve him with publicly visible advertisements that he finds intrusive of his privacy. Interestingly, the U.S. Federal Trade Commission (FTC) has backed a tightening of the use of personal information about user behavior to produce targeted ads in guidelines proposed in January 2008. They suggest that "every web site where data is collected for behavioral advertising should provide a clear, consumer friendly and prominent statement that data is being collected to provide ads targeted to the consumer, and give consumers the ability to choose whether or not to have their information collected for such purposes."⁵⁷ If implemented, these guidelines might mean that, in practice, if not in theory, U.S. consumer law becomes more protective of the privacy of users on

SNSs than currently implemented EC DP law. As we have noted throughout, however, notice is of little value if users do not have a real marketplace of choices where there is an alternative to consenting to such disclosure for such purposes (or if regulation does not impose limits on the consequences of “choice”).

The FTC proposals also suggest that where particularly “sensitive data” are collected for use in “behavioral advertising,” such as medical details, then “explicit consent” should be required from the user. As noted above, this is in line with the letter of current EC DP law, but in practice, little or no distinction seems to be drawn between “ordinary” and “sensitive” personal data when consent is sought in the SNS world. (The definition of what constitutes sensitive data has not yet been settled—the FTC proposals contemplate children’s data being “sensitive,” which is not one of the current EC categories of sensitive data.)⁵⁸ Explicit “opt-in” consent was implemented by Facebook to deal with the Facebook Beacon problem, but when similar concerns were raised some months earlier about the opening up of Facebook profiles to Google and other search engine spiders, Facebook chose only to implement an “opt-out” regime.⁵⁹ In general, the level of actual or potential public dissatisfaction seems to be the determining factor in the type of consent obtained by an SNS site in relation to collecting or disclosing particular data, as opposed to any legally driven taxonomy of the sensitivity of the particular information collected.⁶⁰

Data Control Issues on SNSs and Possible Solutions

The examples described above illustrate that major problems exist in reconciling reasonable user expectations of data security and privacy with the “disclosure by design” paradigm concerning personal data on SNSs. Example 1 demonstrated that users tend to misperceive SNSs as a private rather than public space, leading to unfortunate and unintended disclosures of personal and sometimes sensitive data. Users are also often misled about “reasonable expectations of privacy” on an SNS by the way the code has been written and defaults set. This makes SNSs a paradise for stalkers, ID thieves, and marketers, just as much as law enforcement officials. Example 2 described how even users who choose to disclose data carefully on SNSs can lose control of it and find it misused by third parties. Third-party “apps” and photographs in particular are almost wholly not under the control of users. Finally, example 3 showed how the advertising model of “behavioral advertising” that is likely to be adopted on SNSs in the future is also worryingly out of the control of users. Users may be asked to give individual consent to the collection of data on individual sites, but need not be given an

opportunity to allow or veto the processing of the digital dossiers of primary and secondary data that are generated, both from explicit revealed information and from traffic data collected on SNS and other sites. The ENISA report on security names the aggregation of digital dossiers, and secondary (traffic) data collection, as the two main privacy related threats on SNSs today.⁶¹

Examples 2 and 3 also illustrate that, underlying the obvious problems of privacy and disclosure on SNSs, governance is a more subtle issue. SNSs are governed, like private spaces, primarily by contract in the form of EULAs, terms and conditions, or privacy policies. They are not regulated as public spaces, by public regulation, with the public interest in mind. When we turn to *privacy* issues on SNSs, a policy choice presents itself starkly. If privacy is viewed as an aggregate social benefit, as the likes of Priscilla Regan⁶² and Colin Bennett and Charles Raab⁶³ assert, then a case for public regulation of SNSs to preserve societal privacy, even where individuals do not take proactive steps themselves, can surely be made. On the other hand, if privacy is viewed purely as an individualistic right, for solely that individual's benefit, then it can arguably be legitimately left to the individual to assert and protect that right. A midway "consumer protection" camp might suggest that although privacy is primarily a matter for individual enforcement, some users are so ignorant or vulnerable that some public protective measures should be extended. Here it is of considerable relevance that SNSs are so often aimed at children and inexperienced young persons. This approach appears to be the one currently being pursued by the UK Information Commissioner, which has produced guidance on the use of SNSs targeted at young users only.⁶⁴

As matters stand, the real-world governance of SNSs by contract leaves the matter firmly in the latter camp. Individuals are left to give a formal indication of consent to privacy policies that are pre-dictated by the SNS and that can, in general, also be changed by the SNS whenever it pleases. As Bruce Schneier notes:

Facebook can change the rules whenever it wants. Its Privacy Policy is 2,800 words long and ends with a notice that it can change at any time. How many members ever read that policy, let alone read it regularly and check for changes? . . . [Facebook] can sell the data to advertisers, marketers and data brokers. It can allow the police to search its databases upon request. It can add new features that change who can access that personal data, and how.⁶⁵

This writer would stake her place in the first camp and agree with Regan that "if privacy became less important to one individual in one particular context,

or even to several individuals in several contexts, it would still be important as a value because it serves crucial functions beyond those that it performs for a particular individual. Even if the individual interests in privacy became less compelling, social interests in privacy might remain.⁶⁶

Thus the debate about whether privacy should be publicly rather than privately regulated on SNSs can be located in the same discursive space as similar debates around other privacy-invasive techniques to which formalistic “consent” is usually given, such as employee surveillance and data profiling and mining in the private sector, using devices such as credit card records, click-stream data, and RFID (radio frequency identification) chips. In the commercial sector, consumers often “voluntarily” trade privacy for convenience or for extras such as loyalty points, air miles, bargains, and faster delivery times. Such consent is however rarely fully informed and often not freely given, as in the context of employee surveillance.

In Europe, data protection laws are explicitly founded on an individualistic concept of privacy as a constitutive human right.⁶⁷ Privacy is thus protected primarily by this notion of individual consent to processing of data.⁶⁸ But on SNSs the notion of consent fails as a gatekeeper protecting the privacy of users. Formal consent is given when a user signs up for Facebook, but with no vestige of choice or ability to negotiate conditions. The situation is even worse in example 2: as we saw, a user signing up for a Facebook “app” may not even have seen the terms and conditions before being required to say yes. Finally, the consent given by most or many SNS users, especially young and inexperienced persons—such as the student in example 1—is almost always based on a misapprehension of risks. It is in human nature to want jam today—fun and frivolity—over jam tomorrow—safety and security in some murky future where relationships, job opportunities, and promotions may be pursued. Much sociological and criminological literature has indicated that, universally, consumer perceptions of future versus current risks are fundamentally flawed.⁶⁹ And it seems wrong that a one-time consent given today may prejudice that user for an indefinite future time, as is likely given the persistence of data on the internet.

The law is used to dealing with consent as a faulty risk management process in the context of consumer law. In consumer contracts terms are in the main imposed by the party with power (the business) on the disempowered party (the consumer) regardless of whether there is an apparent formal consent given to those conditions by the weaker party. Such inequality of bargaining power

is typically observed in standard form or “adhesion” contracts. Most jurisdictions have thus developed legal means by which contractual terms prejudicial to consumers imposed on them without true, informed, or free consent can be declared void or unenforceable or otherwise mitigated. In Europe, the primary means for this is the EC Unfair Terms Directive 1993,⁷⁰ and in the UK, the Unfair Contract Terms Act 1976 as amended and the Unfair Terms in Consumer Contract Regulations 1999.⁷¹ In the United States, such protection is found in both common law and statute depending on the state in question, but terms in online consumer contracts have in the past been declared void or voidable on common-law grounds such as unconscionability.⁷² Means thus do exist to challenge unreasonable standard terms in SNS contracts. However, it seems unlikely that a user would have reason to challenge such terms until after damage had been done by misuse of personal data, and even then it might be extremely hard to find causation between the misuse and the damage caused.

Control over SNS terms and conditions in order to protect user privacy, would, it is suggested, be far better exercised proactively by model contracts for SNSs, or industry or co-regulatory codes of conduct, than retrospectively by litigation. In the United States, Facebook is unusual among the major SNSs in being signatory to TrustE, the industry privacy seal program. This means in principle that Facebook’s privacy policy is subject to third-party review. However as EPIC, the Electronic Privacy Information Center, notes in its briefing on SNSs and privacy,⁷³ review by TrustE has not been satisfactory in the past, with members involved in well-publicized privacy scandals, and “TrustE has even been described as untrustworthy by certain commentators.”

In the UK a number of bodies—including the ICO and the government-sponsored Get Safe Online campaign⁷⁴—have been active in promoting the idea of codes of conduct for SNSs; and the Home Office has reportedly engaged in talks with industry leaders such as Bebo about a more generalized code. Similar activity can be found in Australia and Canada.⁷⁵ However, in all these jurisdictions more effort seems to have gone toward advising users how to act wisely on SNSs (an educational perspective), rather than in persuading SNSs to adopt rigorous, clear, consistent, and non-oppressive terms in both their written documents and, importantly, in their code.

As noted in the introduction, the second strand of governance on SNSs—and arguably the most important form—is what the SNS software or code, in the sense used by Lessig, allows the user to do.⁷⁶ In example 1 above (the Oxford case), for example, we saw that the default code settings in Facebook allow

anyone in a user's "network" to see the personal details of any other user in this network, sometimes with counterintuitive privacy-invading consequences. In example 2, the code relating to apps forces users to give third-party software providers access to all the personal data Facebook holds even where this is clearly unnecessary for functionality (how much information is needed to send a virtual bunch of flowers?). Similarly the code allows third-party users by default the right to identify by tags photos of users on Facebook. Finally and significantly, in example 3 we saw how Facebook Beacon was originally introduced as a default choice and was later adjusted by code, after public outcry, to provide "opt-in" functionality.

Adjusting code is a far more effective privacy protection mechanism than adjusting the text of contractual privacy policies, for the very obvious reason that conditions imposed by code cannot be "breached" as such (code can of course be hacked, but doing so is likely to be beyond the competence of most). Code is also a far more efficient way to regulate norms consistently in a transnational environment than law, even privately ordered law such as contract. The same Facebook code can run in the UK and the United States enforcing the same privacy norms. By contrast, privacy policies and terms and conditions may need adjustment to reflect individual national laws.

Is there an argument then for suggesting that codes of conduct should in the main prescribe code solutions rather than, as at present, mainly seek to modify contractual terms and/or user behavior? The idea that software can adjust and regulate human and industry behavior has of course been prevalent in internet law circles since it was popularized by Lessig in 1999.⁷⁷ The particular influence of defaults in software is now also beginning to be recognized in legal scholarship. Jay Kesan and Rajiv Shah have done extensive work in this area; they report on the extensive power defaults and how they can be used and manipulated as a policy tool. "First, defaults provide users with agency. Users have a choice in the matter: They can go with the default option or choose another setting. Second, a default guides a user by providing a recommendation." And later "Defaults are important not only in affecting a person's actions, but also in shaping norms and creating culture."⁷⁸ Kesan and Shah report also that defaults can disempower users: "[D]efault settings will not be seen as defaults but as unchangeable. After all, if people don't know about defaults, they will assume that any alternative settings are impossible or unreasonable. The influence on people's perceptions of their control over software configurations is a core concern with software regulation."⁷⁹

Do defaults empower or disempower online users of SNSs? In the consumer environment, it is an acknowledged fact that consumers as a population, especially in the online world, have a tendency toward inertia. Put simply, many will not know that settings other than the default exist; many more will never try to find out, whether through ignorance, fear, or simple lack of time or energy or imagination. Thus in the world of online spam, opt-out has proven to be useless as a means to reduce the amount of spam, and opt-in has accordingly been adopted by the EU,⁸⁰ though not the United States, as the legal default. In the SNS environment, anti-privacy pro-data-collection software defaults may not only disempower users who do not know or care that these defaults can be changed, but also reify or reinforce a norm of less-than-adequate privacy protection on SNSs. Given the tendencies already noted above on SNSs to “disclose now, worry about it later,” this is a disturbing conclusion.

By contrast, a voluntary or state-imposed code that required certain standards in default setting would produce a contrary influence: reinforcing a norm of adequate privacy protection. In all the examples given above, some thought about the effect of defaults could have produced a more privacy-protective result that was nonetheless compatible with the primary social-networking focus of the site. In all these cases however, the income generation model of SNSs—disclosing as much information as possible for collection either by the SNS itself or by third-party partners—suggested a different model for the setting of defaults. It is thus apparent that some form of public regulation—whether by co-regulatory “soft law” codes or by the threat of mandatory legislation—would probably be necessary to persuade the SNS industry to move toward privacy-protective defaults. Nor, it should be stressed, is it impossible to imagine an SNS with privacy-protective defaults and a successful business model. Some already exist—often serving specialized privacy-conscious niches, such as SNSs for gay people, or certain religious groups—where privacy in relation to “outsiders” is as important as networking within the social group.⁸¹

Given the industry profit drivers toward setting defaults at “maximum disclosure” and the privacy drivers toward setting them at “minimum disclosure,” how should a code be drafted so as to reconcile these two interests? A third interest is of course that of the users themselves: what do they want? Why, to network and make social relationships! Kesan and Shah suggest that one approach to determining defaults is to go with the “would have wanted” standard: what would the user and the SNS have agreed to if negotiation costs had been zero and so an arm’s length rather than a standard form agreement

had been negotiated? The trouble here is that users are likely to make unwise choices about their privacy in the SNS environment. They are not fully informed;⁸² nor are they in a good position to make risk assessments balancing social advantage against privacy risks—especially the young and vulnerable. Furthermore, many users do not have the technical knowledge or ability to change defaults they might have agreed to as a starting point, but only on the basis that they could later change their minds. As a result, the “would have wanted” standard does not seem appropriate to SNS privacy defaults, at least without substantial amendment.⁸³

Beyond specifically pushing the code defaults already discussed in examples 1–3 toward a more privacy-protective default setting, a number of general types of rules for software defaults in SNS sites might be worth debating.

Automatic data expiration. Viktor Mayer-Schoenberger points out that in the non-digital world data naturally dissipate over time.⁸⁴ On the internet, however, personal data persist, are retained, combined, disseminated, and often become inaccurate. Could personal data profiles on SNSs be set to expire by default after six months or a year? Users could be warned by email and opt to retain their profile if they wished. This would address some of the problems of persistence of embarrassing personal data on the internet years after its hasty disclosure.

A general rule that privacy settings be set at the most privacy-friendly setting when a profile is first set up. At first glance, this seems unreasonable. A Facebook profile at its most privacy-friendly setting is not visible to anyone except its creator, and eventually, to any users added as “friends” by the creator. Clearly this is not a desirable start state for social networking. However, such an initial state would inform all users that privacy settings use them before they moved on to networking. It is unlikely, however, to be an option the SNS industry, or even users themselves, would favor. This option might be more palatable, however, if allied to a start-up “install” routine, in which users are prompted to pick the privacy settings most appropriate to their needs. Since most software comes with such installation routines, this is a familiar exercise for the user. It would provide an easy and business-compatible way, however, to also give some version of privacy “opt-in” rather than the current norm of obscure and hard-to-understand privacy settings of which most users either have no knowledge or lack the impetus to find out how to use.

A general rule that personal data in profiles is “owned” by the user and cannot be manipulated by the SNS or third-party users without their explicit consent. This would have the effect of giving users clear and explicit control over their “tagging” or identification by their photos, either on one SNS or across different sites, as discussed in example 2. It would also prevent the creation of, for example, the Facebook “NewsFeed,” which has also been the subject of privacy-activist and user criticism,⁸⁵ without explicit user consent.

Code to allow portability and interoperability. Such code would allow any user on any SNS to move to another SNS with all of his or her data (and remove those data permanently from the old site). Why would such code be privacy-promoting? As the ENISA report points out, because, at present, SNS interoperability is almost zero, there is a very high overhead on users shifting to a new site.⁸⁶ As a result, users will put up with a bad deal rather than make the effort to replicate all their personal data and “friends” connections elsewhere. Effectively, lack of portability of data and interoperability between SNSs empowers the site owner and disempowers the user. Furthermore, because personal data have to be resubmitted every time a user decides to engage with a new software application providing social services (for example, a photo blogging site, an instant messaging site, or a calendar application), users have a strong tendency to make the “home” SNS site their “data warehouse” and use its functionality for all their needs. As a result, all personal data are placed, increasingly, in one basket. Facebook has facilitated this tendency further with its extensive reliance on third-party apps to make its site continuously fresh and appealingly novel. Finally, when personal information is warehoused in one place, it is more vulnerable both to attacks by malicious hackers and “data grabs” by the government or litigators using subpoenas or equivalent. Although the technology may not be sophisticated enough, regulatory drivers toward portability and interoperability in SNS code would thus be likely to both empower the user and reduce their privacy-invasion and security risks.

Last Thoughts

It is always possible that rather than rushing to generate industry compliance with “soft law” that mandates software defaults, or even considering legislation of a more traditional variety, we should be doing nothing at all. This is not because the problem is trivial—the above amply demonstrates it is not—but for a number of other reasons. First, it is becoming accepted wisdom that where

technology appears to create social problems in the “web 2.0 society,” legislating in haste often leads to getting it wrong and repenting at leisure.⁸⁷ Second, it is quite plausible that this is a blip problem. The youth of today who are currently enthusiastically giving away their personal data on the internet will shortly grow into the young-adult generation of tomorrow who are well versed in how to manipulate the internet and may have no difficulty deciding when and where to use privacy defaults and similar controls. (This writer has her doubts, revolving around the general historical prevalence of consumer inertia and lack of information as to risks—but it is possible.) Certainly this appears to be the hopeful attitude many privacy commissioners and governments are taking, given the welter of educational advice appearing in various jurisdictions.

Finally, it is possible that the future these young social networkers will grow into will be one where privacy is simply no longer prized. The SNS phenomenon in itself, as noted above, shows a clear shift of values from prizing privacy to prizing disclosure and visibility in the social online space. (This is not merely an online phenomenon; observe the rise of the “famous for five minutes” generation, who will reveal anything from their sexuality to their unhappy childhood on shows like *Jerry Springer* and *Big Brother* to achieve a soupcon of celebrity.) We have already noted above, however, that commentators like Regan argue persuasively that even if privacy is not individually valued, it may still be of value to society as a whole and therefore need protection.

But even if privacy is no longer valued, surely privacy harms will still result from disclosure? Perhaps not in all cases. Anecdotal conversations with young people often reveal a fatalistic attitude, along the lines of “well by the time I’m looking for a job/promotion/partner, there will be so much data out there, that either everyone will have something embarrassing on their record, or else it will be impossible to sort through all the material on the internet to check me out.” Another version of this is that in time we will turn into a more forgiving, sympathetic society; if the eternal memory of Google remembers everyone’s faults equally, we will have to, in turn, employers and lovers, colleagues and referees, forgive each other’s sins for fear of being equally castigated. Time will tell if this sanguinity comes to pass. Some privacy harms, it seems, will persist. ID thieves, cyber stalkers, and civil litigants looking for evidence are probably not going to go away. Given this sad truth, a serious look at how we should regulate social networks to seek some compatibility between the human urge to be gregarious and the human need (and right) to be private seems urgently needed.

Conclusion

Andrea M. Matwyszyn

OVER THE PAST quarter-century our social relationship to information exchange has been fundamentally altered, and a key component of this transformation has been an increase in information collection by corporate entities. The current widespread corporate information security inadequacies that are the subject of this book are a symptom of this transformation—a “growing pain” of change. As companies struggle to embrace their new information technology-dependent personas, four lessons are clear for both organizations and regulators attempting to understand information security.

First, information security requires a focus on humans, not merely technology. Second, information security dynamics are inherently emergent in nature; only a process-based approach with constant monitoring and reevaluation can succeed. Third, information security is situated simultaneously across multiple business and social contexts. As such, fixing an information security deficit successfully requires understanding how the information at issue affects multiple overlapping business and social uses. Finally, corporate best practices are emerging too slowly, and many corporations are simply ignoring information security concerns. Corporations must recognize that corporate codes of information security conduct and capital investments in information security are not an optional luxury; they are a rudimentary necessity for every business. A proactive corporate and legal approach to information security is the only approach that can succeed.

Information Security Requires a Focus on Humans, Not Merely Technology

The biggest challenges in information security frequently involve humans more than they involve technology. Humans, perhaps unlike technology, can demonstrate extreme levels of variation in skill and do not always follow logical rules in conduct. They can be irrational actors, driven by perception and emotion as much as by objective reality. As such, humans must be studied in the information security context, both as attackers and as consumers. By contrast, the actual technologies that are used in data collection should be viewed merely as tools; they are secondary to the motives of the humans who use them.

Pincus, Blankinship, and Ostwald argued that understanding information security means studying not only technology, but also people in an interdisciplinary manner, and that the social aspects of information security are equally important, and perhaps more so, than the mathematical components. As such, they argued that information security should be analyzed as a social science.

Slaughter-Defoe and Wang instructed us that development and technology proficiency, as well as knowledge about data protection, do not always map onto chronological age. The child data protection problems left unsolved by COPPA necessitate sensitivity to children's development. Similarly, sensitivity to parental limitations is needed. Empowering parents to better protect their children's information can mitigate child data security problems in a more successful manner than the current legal paradigm.

Edwards and Brown discussed the desire of users to share information about themselves for purposes of social networking, while simultaneously maintaining control over their information. Businesses may view these two consumer desires as inherently contradictory. Nevertheless, the information security and privacy expectations of consumers in part drive their user behaviors, and when a company violates consumers' expectations, the results include loss of users, risk of suit, and bad publicity.

Information Security Dynamics Are Emergent

The only constant in information security is constant evolution. Humans and information security exist in an emergent social context.¹ This social context—including technology itself—changes in frequently unpredictable ways.

Both computer code and law impose a top-down order that restricts certain outcomes and information security strategies.² However, equally potent

restrictions come from the bottom-up forces that impact information security.³ These bottom-up forces are the focus of much of this book. The outcomes of strategic interactions among hackers, businesses, information security professionals, researchers, existing information practices, and consumers generate their own type of regulation, an “organizational code.”⁴ Structures of order arise spontaneously from these interactions. Global patterns develop from the aggregation of individual information security behaviors, patterns that cannot be forecast through simply understanding or controlling the behavior of one particular actor in the system. This organizational code fundamentally alters information security best practices and outcomes,⁵ and paying attention to it is essential to understanding and predicting future information security problems.

Zetter introduced us to the norms of information security reporting and their evolution. News about security is gathered and emerges in not entirely foreseeable ways. Just as the consequences of security breaches are not fully predictable, neither are the methods through which information about them reaches the public.

Vetter presented changing dynamics in the area of cryptographic patenting. As new patterns of patenting emerge, businesses should consider multiple strategies for intellectual property related to information security. Certain cryptographic patenting behaviors, when aggregated, generate inefficiencies that require cooperative solutions.

Chandler highlighted the evolution of contract terms that relate to information security. As certain information security behaviors become undesirable, prohibitions on these behaviors begin to appear as contractual provisions. Because many contracts are not analyzed by courts or seen by anyone other than the parties, these changing legal drafting norms present an emergent source of restrictions on information security conduct that may not be immediately transparent.

Information Security Is Situated Across Multiple Contexts Simultaneously

Corporate and individual identity and behavior are influenced by multiple layers of context. The same corporation or individual in two different social contexts will arrive at two different outcomes and, potentially, two different information security strategies. These multiple simultaneous contexts must be considered in information security decisions and policy making.

In the current information security landscape on the macro level, international, federal, and state regulation as well as criminal elements exert pressure on companies in their information security decisions. On the meso level, information security standards are increasingly driven by a collectively generated sense of best business practices. On the individual level, internal management concerns regarding corporate culture and employee loyalty are implicated.

Howard and Erickson presented data regarding the big-picture context of corporate vulnerability in the United States. Though individual companies may not deem their breaches to be noteworthy, when aggregate dynamics are demonstrated, a large-scale problem of corporate data vulnerability is evident. This context makes it more difficult for companies conscious of information security concerns to successfully protect their own data; their business partners may expose them to information security risks.

Hoffman and Podgurski explained the multiple operative contexts of personally identifiable health information. It is the intersection of these multiple contexts that makes health difficult to secure. They set forth the regulatory approaches currently in use under HIPAA and their shortfalls as a result of these multiple overlapping contexts.

Paya discussed the inherently self-contradictory nature of financial information as both secret and shared. Particularly with regard to credit card numbers and Social Security numbers, divergent social and business dynamics result in two types of financial data that present fundamentally different information security challenges. While industry self-regulation may provide a workable paradigm for credit card data, the broader social uses of Social Security numbers mean that another layer of context complicates their security.

Finally, Rowe introduced the risks that can arise from ignoring internal threats as one of the multiple contexts of information security. Companies frequently look for threats to their information security externally, neglecting to mitigate and prevent damage done by malicious insiders. The internal context of information security is equal in importance to external contexts.

Corporate Codes of Information Security Conduct and Building a Corporate Culture of Information Security

Currently, information security culture wars are being waged within many companies. Proponents of more rigorous information security practices and ethical data handling are facing off with decision makers who believe information security is not really a problem, despite much evidence to the contrary.

Although the best regulatory and common-law approaches to information security will be debated by courts and lawmakers for years to come, what is incontrovertible is that information security concerns can no longer be ignored by companies. Best information security practices mandate that companies proactively seek to preserve the confidentiality and integrity of their information assets, and aggregate improvements in corporate information security do appear to be happening. The problem is that the pace is unacceptably slow.⁶ The first step toward faster improvement is recognizing that a widespread problem of corporate data vulnerability exists. The second step involves individual level corporate improvement. Companies should conduct regular assessments of their information security adequacy.

The way to analyze the adequacy of a company's security practices is to look at the company's "transitive closure."⁷ Transitive closure involves the entire group of internal and external individuals whose information security practices can compromise the security of a company's data. In other words, it is an end-to-end analysis of the chain of internal and external information possession and sharing. A comprehensive corporate analysis of information security starts with an information flow map of the entity's internal and external data sharing.

On the basis of internal information risks revealed by this map, upper-level management should assess the possible damage from a failure at any point in internal information flow control and craft a corporate code of information security conduct. This code should designate key individuals responsible for security risk management, establish clear lines of communication for reporting internal and external security breaches and third-party evaluations of security adequacy, and create sanctions for failure to comply. The existence of corporate codes of conduct or corporate policy statements that are enforced regularly are likely to encourage ethical employee behavior.⁸ Company codes that are enforced regularly and clearly stipulate standards for information security conduct send a message to employees to take data care into consideration.

The more difficult and long-term component of a successful internal corporate approach to information security requires neutralizing the internal information security deniers inside an organization and generating a self-sustaining internal corporate culture that values and prioritizes information security. A culture of security is one that demonstrates due care in information security, not only with corporate sensitive information but also with

consumer information. Practices that reflect a culture of security include the following:

- Data should be destroyed when it is no longer needed and stored in ways that minimize risk of compromise.
- All employees should sign confidentiality agreements and consider prudent data handling as a key component of their jobs.
- A company's own history of previous data breaches should be known to all employees to prevent repeating mistakes.
- Clear channels should exist for reporting problems, especially confidential reporting of insider attacks.
- Information technology and security staff should be adequately qualified and trained.
- Key individuals should be designated to investigate reports of security breaches and incident response.
- Capital investment in security measures must be adequate in light of emerging information security threats known to information security professionals.
- External auditors should be used to "penetration test" and otherwise assess information security adequacy. Their recommendations for information security improvements should be followed.

The creation of a proactive corporate information risk culture is half the picture. The second half of the picture is the creation of industry and economy-wide information security consciousness, where threats to information security are assessed by prospective business partners in advance of embarking on business relationships and new projects. Therefore, business partners should vet each other with data security concerns in mind.

The transitivity of information risk is always present in business relationships, and the entire path of transfer of the data and the attendant risks must be included in any effective information risk calculus.⁹ This means that accurately assessing corporate information risk for each company requires not only looking internally to employee information access and externally to a company's neighborhood of immediate partners. It also means looking to the partners of those partners and beyond. The transitive closure of a company in the context of information security encompasses both the added information risk from a company's trusted partners and the risks from the partners of

those partners and onward, following the chain of possession of the data end to end. In other words, even if a company's immediate business partners maintain strong security in connection with shared data, one unwise outsourcing or sharing decision anywhere in the chain of data custody by the partners of the company's partners can destroy information security for all holders of the data. The consequences of a data breach are felt by all custodians of the information, and the harm occurs regardless of whether the initial data holder ever directly chose the vulnerable company as a business partner. Indirect sharing is enough to cause harm. For this reason, advocating for strong industry-wide and economy-wide information security practices is in the self-interest of each individual company.

In Closing

The contributors to this book believe that information security issues will challenge companies and society for years to come. Each of us has called for more thoughtful approaches to the ways that companies leverage, share, and store information. The problems of information security we have introduced have no easy solutions, and the questions we have raised in this book are indeed difficult ones. Information security will continue to be an inherently messy, human-driven, and evolving area for corporate and social policy in the coming decade. What is clear, however, is that the need for corporations and policy makers to better address information vulnerability is pressing. Time is increasingly of the essence.

Notes

Introduction

1. (Jewellap, 2007).
2. ("TJX Agrees to Class-Action Settlement," 2007).
3. (Kerber, 2007).
4. (Gaudin, 2007).
5. (Vamosi, 2007).
6. Class-action lawsuits were filed both by consumers and by several bank associations in an attempt to recover the costs of reissuing credit card numbers compromised in the breach. (Gaudin, 2007).
7. (Ou, 2007).
8. (Pereira, 2007).
9. (Jewellap, 2007).
10. (Gartner, 2006).
11. (PGP, 2007).
12. (Fox, 2000).
13. ("More Businesses Are Buying over the Internet," 2004). For a discussion of the consequences of technological adoption and the values embodied therein, see, for example, (M. Rogers, 2003), discussing the consequences of innovations, examining the value implications of different innovations, and arguing that technologies need to be critically evaluated from utilitarian and moral perspectives before being adopted.
14. H.R. Rep. No. 106-74, pt. 3, at 106-7 (1999). As a result of the explosion of information available via electronic services such as the internet, as well as the expansion of financial institutions through affiliations and other means as they seek to provide more and better products to consumers, the privacy of personal financial information has become an increasing concern of consumers.
15. (Winn and Wrathall, 2000).

16. For example, most law firms use document management systems to centralize work product. For a discussion of document management software, see Kennedy and Gelagin, 2003. This use of information technology facilitates knowledge management, the sharing of institutional intellectual resources such as form contracts, and control over access to certain information.

17. These attempts to centralize built in high dependencies between systems. (Labs, 2006).

18. In the context of manufacturing, this meant connecting up “islands of automation” into a single communication network.

19. (Fraudenheim, 2003).

20. (Sandeem, 2003). As a consequence of this transformation, numerous state corporate statutes have been amended to allow for email notice, virtual shareholder meetings, and internet proxy voting. (Derrick and Faught 2003; Pozen, 2003).

21. (Barabasi, 2002).

22. Databases with financial data and social security numbers became targets of choice because of their usefulness in identity theft.

23. For example, some professional spammer employees earn salaries in excess of \$100,000 per year while professional spammer entity owners earn millions of dollars per year. (“Comments of Simple Nomad,” 2003).

24. (Chapman, 2007).

25. Phishing attacks are becoming increasingly sophisticated. (Desai, 2004).

26. (Federal Trade Commission, 2004). The FTC estimates that U.S. corporations lost as much as \$48 billion to identity theft alone between September 2002 and September 2003. (MailFrontier, n.d.; Federal Trade Commission, 2003).

27. (“Good News,” 2004; Webb, 2004; Gartner, 2004).

28. In particular, phishing attacks usually infringe the trademarks of the spoofed entity as well as the look-and-feel of the entity’s website.

29. (“Phishing Alert,” n.d.; Valetk, 2004).

30. Spoofing is defined as sending a message to make it appear as if it is arriving from someone else. (“Spoofing,” n.d.).

31. One entity whose email is spoofed frequently is Citibank. For statistics on phishing see (Antiphishing Working Group, n.d.) For additional discussion of phishing, see (Federal Trade Commission, “Phishing Alert”; Valetk, 2004).

32. The term “phishing” is derived from the idea that internet con artists use email lures to “fish” for passwords and other personally identifiable data from the sea of internet users. The letters “ph” are a frequent replacement for “f” in hacker language, and most likely reflect an act of verbal homage to the original form of hacking, called “phreaking,” a term coined by the first hacker, John Draper, known as “Cap’n Crunch.” By 1996, hacked accounts had come to be known as “phish,” and by 1997 phish were used as currency by hackers in exchange for items such as hacking software. (Anti-Phishing Working Group, n.d.).

33. Even a highly technology-savvy consumer may have difficulty distinguishing between a phishing email and a legitimate commercial communication from an entity

with whom the consumer has a preexisting relationship. (MailFrontier Phishing IQ Test II, n.d.). Even the author of this article misidentified one of the items in this quiz as fraudulent when in fact it was legitimate.

34. Monster chose not to notify the affected consumers until ten days after the discovery of the security problem, and a public relations maelstrom erupted. ("Monster.com Admits Keeping Data Breach Under Wraps," 2007).

35. (Chapman, 2007).

36. (Hidalgo, 2007).

37. Zombie drones are security compromised machines that can be controlled remotely without the user's knowledge for sending spam or other malicious purposes. ("Primer: Zombie Drone," 2004; Testimony of Thomas M. Dailey, 2004).

38. For example, one Polish spam group uses more than 450,000 compromised systems, "most of them home computers running Windows high-speed connections" all over the world. (Ciphertrust, n.d.). Powerful economic incentives exist for information criminality. The black market in security-compromised machines is an international market. Recent arrests in Germany and elsewhere have provided useful information into the international market in zombie drones. (Leyden, 2004). The market in compromised machines is big international business: the price of these botNets (doSNets) was roughly \$500 for 10,000 hosts during summer 2004 when the MyDoom and Blaster (the RPC exploit worm) first appeared on the scene. Nonexclusive access to compromised PCs sells for about five to ten cents each per minute (in early 2009). The greatest incidence of zombies is not in the United States, but in the European Union (EU) (26.16 percent). The United States is second in incidence (19.08 percent), and China is third (14.56 percent). (CipherTrust, n.d.; "Rise of Zombie PCs," 2005).

39. Comments of Vint Cerf, in (Weber, 2007).

40. (Menn, 2004). This trend is concerning particularly because numerous U.S. federal agencies, including the Department of Homeland Security, have repeatedly failed cybersecurity review by the Government Accountability Office. (McCullagh, 2005). According to FBI sources, the Eastern European mafia views sending out emails as its "9 to 5 job." (Comments of Supervisory Special Agent Thomas X. Grasso, Jr., Federal Bureau of Investigation, Fighting Organized Cyber Crime—War Stories and Trends, at DefCon 2006, Las Vegas, August 3, 2006).

41. (Espiner, 2008).

42. Mosaic was developed by Marc Andersen and Eric Bina, two University of Illinois graduate students, in 1993. Immediately following the launch of Mosaic, use of the World Wide Web increased. (Cassidy, 2002).

43. ("EU Data Directive," 1995). The EU Data Directive sets forth specific minimum standards of care in processing, handling, and storing "personal data" relating to an identified natural person and mandates that consent must be "unambiguously given" by the subject of the data collection. The subject must be informed of the identity of the "controller" of the collected information and the purposes and use of collection, along with such additional disclosures as required to provide full and fair disclosure of information practices of the collector. The subject must retain the ability to access the

collected personal data in order to correct or remove information. Member states of the European Union are required to enact legislation in order to codify the minimum standards of data protection articulated in the Data Directive and to provide recourse to individual subjects through judicial remedies and rights to compensation for violations of the Data Directive and corollary member-level statutes. The Data Directive provides a “floor” of protection and does not restrict EU members from providing higher levels of data protection to their citizens. For example, the United Kingdom Data Protection Act of 1998, which supersedes the previously enacted Act of 1984, was passed as the United Kingdom’s enactment of the Data Directive. (Baker & MacKenzie, n.d.). The 1998 act embodies principles that cover both facts and opinions about individuals and calls into question the intentions of the data controller toward the individual, with some permitted exceptions. Imposed obligations include obligations to (1) process data fairly and lawfully; (2) collect data only for specified, disclosed and lawful purposes; (3) collect data in an adequate, relevant, and not excessive manner in relation to the purposes of the collection; (4) keep accurate and updated information where necessary; (5) retain data no longer than necessary for the purposes for which it is processed; (6) process in accordance with data subjects’ rights; (7) keep collected data secure with appropriate safeguards, including both technological and physical security measures; (8) prevent transfer to a country outside the European Union unless the country ensures an adequate level of protection for subject data. The Data Protection Act of 1998 further provides individual data subjects with rights that include rights (1) to be informed by a data controller whether the data controller processes and shares any of the data; (2) to require the data controller to stop or not begin processing for, among other reasons, direct marketing purposes or if processing is likely to cause harm; (3) to require the controller to correct or erase inaccurate data; and (4) to obtain compensation for damages related to data collection and processing. Pursuant to amendments to the 1998 act, U.S. companies conducting business in the United Kingdom are subject to the act. Transfers of UK employee, customer, and subscriber information to the United States is regulated as if such data were processed in the UK, both in digital and in manual form. (“Data Protection Act,” 1998). The European Union has provided standard contractual clauses to assist entities in adequately protecting subject information under the Data Directive and are available from the (International Chamber of Commerce, n.d.).

44. (“EU Data Directive,” 1995, 1995 Article 32, § 1), mandating compliance by the Member States within three years from a state’s date of adoption.

45. The Internet Archive’s Wayback Machine catalogues old versions of websites. For example, Microsoft’s MSN site dates back to at least October 22, 1996. (Internet Archive, n.d.).

46. (“EU Data Directive,” 1995, Article 17).

47. This stance was aggressive by U.S. standards, but certainly not by EU standards. In the European Union, the conception of an individual right to privacy differs from that in the United States. Consequently, citizens and regulators approach questions of privacy from a fundamentally different conceptual framework. The EU approach may be characterized as one that begins from a presumption in favor of citizen privacy in

commercial transactions, whereas the U.S. approach might be characterized as beginning from a presumption against citizen privacy in commercial transactions. Though privacy guarantees in the United States and the European Union are slowly converging in favor of a regulatory approach closer to the position of the European Union, this movement is slow. (Salbu, 2002).

48. This statement does not include criminal statutes such as the Electronic Communications Privacy Act, 18 U.S.C. § 2701 (2000), which was passed in 1986.

49. 15 U.S.C. §§ 6501-6506; 16 C.F.R. § 312.

50. (Health Insurance Portability & Accountability Act of 1996; U.S. Department of Labor, Fact Sheet, n.d.). The Health Insurance Portability & Accountability Act (HIPAA) was passed and signed into law in 1996 to provide a framework for, among other things, minimum levels of data care and security with regard to the collection, storage, and sharing of personally identifiable health information. For a discussion of HIPAA, see (Johnston and Roper, 2001; Swire and Steinfeld, 2002). Specifically, HIPAA requires that entities “covered” by HIPAA, that are handling personally identifiable health information, provide notice of privacy practices and ensure the privacy and security of the information. 45 C.F.R. § 164.520 (2004). Covered entities include health care providers, health information clearinghouses, and health plans. 45 C.F.R. § 160.103 (2004). To clarify these requirements, HIPAA’s administrative simplification rules were passed and can be divided into three segments—privacy rules, which took effect in April 2003; transaction rules, which took effect October 2003; and security rules, which became effective for enforcement purposes on April 21, 2005. 45 C.F.R. § 160.308 (2004). In particular, the HIPAA privacy rules require that a chief privacy officer have responsibility for privacy within each organization. 45 C.F.R. §§ 164.502(e), 164.504(e) (2004). Under § 164.530, entities are required to designate a privacy official who is responsible for the development and implementation of the policies and procedures of the entity and a contact person or office responsible for receiving complaints. Health Insurance Reform: Security Standards, 45 C.F.R. § 164.530(a) (2004), available at <http://aspe.hhs.gov/admsimp/final/PvcTxt01.htm>. The transaction rules set standards for electronic transactions in health data, and the final security rules, meanwhile, mandate that covered entities implement administrative, physical, and technical safeguards. 45 C.F.R. pts. 160, 162, 164; (Price Waterhouse Coopers, n.d.). The HIPAA rules also mandate disclosure of practices to consumers and require that contracts with third-party providers include an information security warranty on the part of the provider to maintain the integrity, confidentiality, and availability of health data they receive. Health Insurance Reform: Security Standards, 68 Fed. Reg. 8359 (Feb. 20, 2003) (codified at 45 C.F.R. pts. 160, 162, 164 (2004)), available at <http://www.cms.hhs.gov/SecurityStandard/Downloads/securityfinalrule.pdf>.

HIPAA enforcement to date has been weak, adopting a focus on voluntary compliance. At a Department of Health and Human Services (HHS) conference on the HIPAA privacy rule, then Office of Civil Rights Director Richard Campanelli stated that HHS will not be aggressive in punishing health care organizations that violate HIPAA. Campanelli stated that voluntary compliance is the most effective way to implement data security and recommended that the public complain to the covered entity about privacy

breaches. (“Phoenix Health Care HIPPA Advisory HIPPA Alert,” n.d.). Meanwhile, privacy breaches of health records are becoming frequent. For example, an automated probe of a computer at Indiana University’s Center for Sleep Disorders in November 2003 compromised the data for as many as 7,000 patients. (*Idem*). Similarly, about 1.4 million files containing the personal data of patients may have been stolen from the University of California, Berkeley, during a 2004 security breach. (Benson, 2004). Also, incidents have been reported where domestic entities have outsourced work with patient data to entities in other countries and received threats of publishing the patient data on the Web unless the domestic entity paid a “ransom” to prevent disclosure of patient records. (Price Waterhouse Coopers, n. 142). That said, the first criminal prosecution under HIPAA was settled in August 2004 in an egregious case of patient information theft by an insider who used patient data to obtain credit cards. (U.S. Department of Justice, 2004). This spirit of federal nonenforcement continues, with few enforcement actions and prosecutions brought to date. Two defendants were convicted in connection with criminal theft of identity information from the Cleveland Clinic for purposes of identity theft and in violation of HIPAA. (U.S. Department of Justice, 2007).

51. 15 U.S.C. §§ 6801-6809 (2004). Financial information security and privacy was addressed by the Gramm-Leach-Bliley Act (GLBA), also known as the Financial Modernization Act of 1999. 15 U.S.C. §§ 6801-6809 (2004). GLBA governs the data handling of “financial institutions” broadly defined. The term “financial institutions” as used by GLBA refers to entities that offer financial products or services to individuals, such as loans, financial or investment advice, or insurance, including non-bank mortgage lenders, loan brokers, some financial or investment advisers, tax preparers, real estate settlement services providers, and debt collectors. (Federal Trade Commission, “In Brief”). It requires that financial institutions provide notice of privacy practices and exercise care in data handling, including granting consumers the opportunity to opt out of data sharing and prohibiting the use of consumer financial information in ways not authorized by the consumer. *Alternative Forms of Privacy Notices Under the Gramm-Leach-Bliley Act*, 68 Fed. Reg. 75164 (proposed Dec. 30, 2003) (to be codified at 16 C.F.R. pt. 313), available at <http://www.ftc.gov/os/2003/12/031223anprfinalglbnotices.pdf>. GLBA also imposes an obligation on financial institutions to enter into contracts with commercial partners with whom they share data, pursuant to an exemption under the act. These contracts must prohibit the partners’ use of customer information for any purpose other than that of the initial disclosure of information. 16 C.F.R. § 313.13 (2004), available at <http://www.ftc.gov/os/2000/05/65fr33645.pdf>. More than ten federal and state agencies are authorized to enforce provisions of GLBA, and several entities have been prosecuted for violations of GLBA. One such company was Superior Mortgage Corp., a lender with forty branch offices in ten states and multiple websites. The FTC stated that the company “fail[ed] to provide reasonable security for sensitive customer data and falsely claim[ed] that it encrypted data submitted online.” Specifically, the FTC complaint alleged that the company violated the GLBA Safeguards Rule because it did not assess risks to its customer information in a timely manner; did not use appropriate password policies to limit access to company systems and documents containing sensi-

tive customer information; failed to encrypt or otherwise protect sensitive customer information before emailing it; and failed to verify that its service providers were providing appropriate security. The FTC's encryption argument is noteworthy—although the company encrypted sensitive personal information when it was collected, once the information was received at the website, it was decrypted and emailed in clear, readable text. The FTC deemed these to be deceptive acts and violations of the FTC act. The settlement, among other provisions, requires the company to establish data security procedures subject to independent third-party auditor review for ten years and prohibits misrepresenting the extent to which the company maintains and protects the privacy, confidentiality, or security of consumers' personal information. (In the Matter of Superior Mortgage Corporation, n.d.).

The FTC attempted and failed to extend the reach of GLBA to attorneys. GLBA security obligations are in addition to those that many GLBA "financial institutions" already have under the Fair Credit Reporting Act. The FTC has also attempted to expand the reach of GLBA to businesses not generally considered to be "financial institutions." The FTC attempted and failed to extend the reach of GLBA to attorneys. *American Bar Association v. Federal Trade Commission*, No. 02cv00810, No. 02cv01883 (D.C. Cir. 2005) GLBA security obligations are in addition to those that many GLBA "financial institutions" already have under the Fair Credit Reporting Act.

52. (Children's Online Privacy Protection Act of 2000). Children's Online Privacy Protection Rule, 16 CFR Part 312 (1999). The Children's Online Privacy Protection Act (COPPA) became effective in April 2000. For a discussion of COPPA, see (Bernstein 2005; Matwyshyn 2005; Palmer and Sofio, 2006; Peek, 2006; Stuart 2006). Commentators have observed that COPPA was a reaction to the failure of self-regulation, particularly subsequent to the Kids.com advisory letter in which the FTC set forth standards for privacy policies on websites targeting children. For a discussion of the Kids.com FTC letter, see (Aftab, 2004). COPPA requires that websites targeting children under the age of 13 provide notice of privacy practices and obtain verifiable parental consent before collecting data from the child (COPPA, 15 U.S.C. § 6502(b)(1)(a)(i)–(ii)). The statute also empowers the Federal Trade Commission to promulgate additional regulations to require the operator of a website subject to COPPA to establish and maintain reasonable procedures "to protect the confidentiality, security, and integrity of personal information collected from children" (15 U.S.C. § 6502(b)(1)(D)). In addition, commentary to the promulgated regulations states that the appropriate security measures for protecting children's data include, without limitation or proscription, "using secure web servers and firewalls; deleting personal information once it is no longer being used; limiting employee access to data and providing those employees with data-handling training; and carefully screening the third parties to whom such information is disclosed" (Children's Online Privacy Protection Rule, 1999). Unfortunately, however, this articulation of the technology specifications is suboptimal. For example, the implementing regulations instruct companies to use "secure servers," but servers cannot be inherently "secure" or "vulnerable." Securing a server is an ongoing process. Perhaps better phraseology would be to have required companies to take all steps identified by a leading security

research firm as the fundamental exercise of care in attempting to secure a server on an ongoing basis. COPPA leaves much discretion in data security to the individual website operator and creates no external reporting mechanism to monitor internal security improvements of website operators subject to COPPA. However, the cost of encryption was deemed to be potentially prohibitive and left to the discretion of entities, as was the suggested use of contractual provisions requiring minimum standards of data care from third parties granted access to the collected children's data.

Specifically, COPPA stipulates that before collecting data from a child under 13 a website "operator" must obtain "verifiable parental consent." Operator is broadly defined under the COPPA statute and implementing regulations. They encompass anyone who meaningfully handles children's data. 15 U.S.C. §§ 6501–6506 (1998); Children's Online Privacy Protection Rule, 16 C.F.R. § 312.2 (2005). Verifiable parental consent was ideally constructed as a process involving, e.g., faxing parents' signatures to each website permitted to collect a child's data. 15 U.S.C. §§ 6501–6506 (1998); Children's Online Privacy Protection Rule, 16 C.F.R. § 312.5 (2005). This process allows for easy circumvention as no independent means of authenticating the parental signature exists. The preferred medium for this verifiable parental consent is receipt of a fax from the parent. An email exception was originally crafted as an interim measure to be phased out over time. Because faxing was cumbersome, email verification of parental consent was subsequently permitted. 15 U.S.C. §§ 6501–6506 (1998); Children's Online Privacy Protection Rule, 16 C.F.R. § 312.5 (2005). Though this exception was originally intended to be phased out, because email verification is susceptible to even easier child circumvention than fax verification, it has persisted. The email exception evolved into a "sliding scale approach," which is still applied by the FTC in COPPA inquiries. ("FTC Decides to Retain COPPA Rule," 2006). Depending on the character of the data collection and the intended use, the FTC's analysis varies. For example, the need to obtain verifiable parental consent does not pertain equally to all collection of data on children; for example, a website that collects data for a one-time use and does not permanently connect the child with the information does not necessitate the same degree of consent verifiability. (15 U.S.C. § 6501–6506, 1998; Children's Online Privacy Protection rule, 16 CFR Part 312, 2005). In particular, one of the COPPA exceptions provides for one-time collection, provided the information is subsequently destroyed. (15 U.S.C. §§ 6501–6506. Children's Online Privacy Protection Rule, 16 CFR Part 312). In practice, companies frequently learned how to live within the exceptions to the extent possible to avoid compliance. In addition, a safe-harbor program allows third-party certificate authorities can attest to the compliance of websites with COPPA. (Federal Trade Commission, "Children's Privacy Initiatives"). Independent third parties such as the Children's Advertising Review Unit of the Better Business Bureau can review and warrant entities' compliance with COPPA. (Federal Trade Commission, 2006d).

The FTC is empowered to institute regulatory prosecutions against entities violating COPPA. These prosecutions result in fines and consent decrees. Amounts of fines have varied, with \$1 million recently levied against Xanga.com, a social networking website, and \$130,000 against Imbee.com. (*United States v. Xanga.com, Inc.*). On

September 7, 2006, the FTC and Xanga.com settled the regulatory action. Xanga.com acknowledged that it failed to notify parents and obtain consent before collecting, using, and disclosing the information of users it knew to be younger than 13. Despite the user agreement's statement that children under 13 could not join, children could register using a birth date showing they were younger than 13. After Xanga.com allegedly knew of the age requirement, the company failed to put in place measures to prevent collection of younger children's personal information. Xanga.com also failed to notify the children's parents of the company's information practices or provide parents with access to and control over the information collected on their children. (*United States v. Xanga.com, Inc.*; *United States v. Industrious Kid, Inc. and Jeanette Symons*). Prior prosecutions have been relatively few in number, and previous fines have not exceeded \$500,000. (*United States v. Bonzi Software, Inc.*; *United States v. UMG Recordings, Inc.*; *United States v. Hershey Foods Corp.*; *United States v. Mrs. Fields Famous Brands, Inc.*; *United States v. The Ohio Art Co.*; *United States v. Pop Corn Co.*; *United States v. Lisa Frank, Inc.*; *United States v. Looksmart, Ltd.*; *United States v. Monarch Servs.*; *United States v. Bigmailbox.Com, Inc., et al.*). According to the FTC website, only thirteen entities have been prosecuted since COPPA's passage. (Federal Trade Commission, "COPPA Enforcement").

During the first eight years of its existence, COPPA has received mixed reviews. The deterrent effect of prosecutions appears to have been limited. A large number of websites that are governed by COPPA appear to be noncompliant and are willingly to risk prosecution rather than invest effort in an attempt to comply with COPPA. Several studies have found that compliance is generally under 60 percent, and even websites that attempt compliance are frequently easily circumvented in their age verification process. (Turow 2001; Newsletter 2000). Two studies of COPPA compliance by the University of Pennsylvania's Annenberg Public Policy Center and by the Center for Media Education reported that although most of the sites they reviewed had privacy policies and limit the information collected from children, these privacy statements did not include required disclosures and used language that was difficult to understand.

Businesses have complained that the cost of COPPA compliance associated with monitoring usage, drafting privacy policies, and obtaining proof of parental consent runs as much as \$200,000 per year by some estimates. (Charny, 2000; Wolinsky, 2000). For example, some websites removed highly interactive elements from their sites shortly after COPPA's passage, alleging that compliance costs rendered certain lines of business unsustainable. In some cases, companies have deemed the costs of compliance prohibitive and simply ceased operations. (Wolinsky, 2000). Perhaps most problematic is that, practically speaking, COPPA protects only the data of children who wish to have their data protected. For children who simply wish content access, in many instances immediate workarounds are readily available. Often the child merely needs to log in again and provide a false birth date to gain access to the material to which they had earlier been denied access. (Newsletter, 2000).

53. A complete list of complaints is available on the Federal Trade Commission website. (Federal Trade Commission, "COPPA Enforcement"). The Federal Trade

Commission has deemed the reach of its powers to prevent unfairness and deception under Section 5 of the Federal Trade Commission Act to include issues of information security promises made to consumers. 15 U.S.C. 45 (2004). As such, it has investigated and entered into consent decrees with approximately twenty-five companies related to their information security conduct. Although one consent decree included a \$10 million fine and a \$5 million obligation to redress consumer harms arising from the security breach at issue, most FTC consent decrees involve no monetary fine. They do, however, usually require a company to build an internal information security structure. ChoicePoint, Inc. was fined \$10 million by the Federal Trade Commission and required to provide \$5 million in consumer redress. The FTC alleged that at least 800 incidents of identity theft were tied to the ChoicePoint data breach (Federal Trade Commission, 2006a). The FTC has filed complaints against approximately twenty companies in connection with inadequate security practices since 1999. These companies have included Eli Lilly and Company, Microsoft Corp., Guess.com, Inc., Tower Records, Petco, and TJX Companies, Inc. A complete list of complaints is available on the Federal Trade Commission website. (Federal Trade Commission, "COPPA Enforcement").

For example, the FTC settled charges with DSW Shoe Warehouse. (Federal Trade Commission, 2006b). The FTC complaint alleged that the company engaged in unfair practices because it "created unnecessary risks to sensitive information by storing it in multiple files when it no longer had a business need to keep the information; failed to use readily available security measures to limit access to its computer networks through wireless access points on the networks; stored the information in unencrypted files that could be easily accessed using a commonly known user ID and password; failed to limit sufficiently the ability of computers on one in-store network to connect to computers on other in-store and corporate networks; and failed to employ sufficient measures to detect unauthorized access." The consent decree with DSW provided for no fine but required "the designation of an employee or employees to coordinate and be accountable for the information security program." It also required "the identification of material internal and external risks to the security, confidentiality, and integrity of personal information that could result in the unauthorized disclosure, misuse, loss, alteration, destruction, or other compromise of such information, and assessment of the sufficiency of any safeguards in place to control these risks . . . [through] assessments and reports . . . from a qualified, objective, independent third-party professional, using procedures and standards generally accepted in the profession." This requirement further stated that "[a]t a minimum, this risk assessment should include consideration of risks in each area of relevant operation, including, but not limited to: (1) employee training and management; (2) information systems, including network and software design, information processing, storage, transmission, and disposal; and (3) prevention, detection, and response to attacks, intrusions, or other system failures." DSW will file these reports regarding adequacy of internal safeguard with the FTC on a biennial basis for the next twenty years. (Federal Trade Commission, 2006b). This type of consent decree is the typical result in situations where the FTC files a complaint against a company, and, in 2008,

a similar consent decree was reached with TJX Companies, Inc. (Federal Trade Commission, 2008).

54. The newest and, arguably, most effective statutes to date that have sought to directly address issues of information security are state data breach notification statutes. For a discussion of state data breach notification statutes see (P. M. Schwartz, 2007). At this writing in 2009, approximately forty states have data security breach notification statutes on their books. For a list of state data breach notification statutes see (National Conference of State Legislatures, n.d.). Generally speaking, these notification statutes compel entities that have suffered data breaches to provide written notice to the consumers whose data have been affected. These state statutes vary in their definition of what constitutes a breach warranting notice, leaving discretion in some cases to the entity itself to determine whether the breach triggers the statute.

In fact, significant variation exists across data breach notification statutes in several areas. The types of data statutorily covered are not homogeneous. For example, California only recently added health data to its statutory definition of data that, if breached, triggers a disclosure obligation. (Gage, 2008). The definition of a breach also differs from one statute to the next, leaving room for discretion in some cases to the breached entity to determine whether notice is appropriate. Some statutes provide blanket encryption exemptions; in other words, if the breached data were encrypted at the time of compromise, no notice obligation is triggered. Definitions of encryption that qualifies, where they exist, vary. Statutory time frames for reporting a security breach vary from state to state; some allow ten days or longer to report a breach from the time of discovery of a breach. (NJ P.L.1997, Sect. 3, as amended, 1997). The discovery of a breach may occur months or years after the initial communication with a consumer that collected the breached sensitive data.

For example, UCLA suffered data breaches of applicants' files for at least the ten years before 2006. (Keizer, 2006). Finally, data breach notification statutes vary on who must give notice. Most of the statutes cover only for-profit entities, and there have been few prosecutions to date. For example, the first prosecution under the New York data breach law occurred in April 2007. CS Stars, a Chicago claims management company, waited more than six weeks to notify 540,000 consumers after discovering that a computer containing personnel records was missing. A settlement was reached with a \$60,000 fine against the company. ("Violating NY Data Breach Law," 2007).

The legislative intent driving data breach notification statutes is to prevent identity theft and generate a modicum of external accountability for data care. By requiring breached entities to notify consumers that their data have been compromised, legislatures have aimed to mitigate the effects of identity theft. Potential victims who check their credit reports zealously may be able to detect some instances of identity theft early. For a discussion of steps to mitigate identity theft see (Federal Trade Commission, "Identity Theft"). Although consumer notices do not solve the underlying security problem that resulted in the breach, some research indicates that consumers pay attention to data breach notifications and increasingly view information holders as having an obligation of data stewardship to them. (Greenberg, 2007). Simultaneously, however,

consumers feel powerless to protect themselves against data mishandling and may begin to suffer from “notification fatigue” as numerous security notices describing past breaches arrive. For a discussion of the possibility of national data breach notification legislation see (Gross, 2006).

55. (McGraw and Viega, n.d.).

56. For example, it is estimated by the Federal Trade Commission that U.S. corporations lost approximately \$48 billion to identity theft alone between September 2002 and September 2003. (MailFrontier, n.d.); (FTC Releases Survey,” 2003).

57. (“Massachusetts, Connecticut Bankers Associations,” 2007).

58. (Gaudin, 2007).

59. For example, Acxiom Corporation derives revenue principally from selling aggregated information. If this information were stolen and became available cheaply on the information black market, it is highly unlikely that Acxiom would be able to maintain the value of this intangible asset at previous levels.

60. It can be argued that any data leak is demonstrative of inadequate measures to keep the information secret, thereby putting it outside the scope of trade secret protection of most states’ trade secret statutes. Trade secret statutes vary from state to state, but most define a “trade secret” as information that an entity has used due care to protect from disclosure. If it can be demonstrated that an entity’s information security practices were suboptimal during any point in the lifetime of the information, it can frequently be successfully argued that the information in question is no longer a trade secret. (Soma, Black, and Smith, 1996).

61. (Wright, n.d.). In the tax context, entities frequently argue that they should be allowed to amortize the value of their customer lists. *Charles Schwab Corp. v. Comm’r*, 2004 U.S. Tax Ct. LEXIS 10 (T.C. Mar. 9, 2004).

62. In the biggest incidence of identity theft known to date, a help-desk worker at Teledata Communications, Inc., which provides credit reports on consumers to lenders, is estimated to have stolen 30,000 consumers’ credit reports, which he shared with around twenty compatriots who leveraged the data to cause significant financial damage to the consumers in question. He was paid approximately \$30 per credit report, or a total of \$900,000. (Neumeister, 2004; Reuters, 2004).

63. At least 81,000 viruses are known to be in existence today, poised to generate even more staggering losses. (Epatko, n.d.). The Blaster worm losses alone are approaching \$10 million. (Federal Bureau of Investigation, n.d.).

64. (Claburn, 2007a).

65. One of the newest brand-building techniques is for each entity to make its own corporate cyborg/avatar to provide a friendly face to internet visitors. (Vhost Sitepal, n.d.).

66. (McWilliams, 2002b).

67. (Fichera and Wenninger, 2004).

68. (Berinato, 2007).

69. (Berinato, 2007).

70. (Berinato, 2007).

71. (Berinato, 2007).
72. (Berinato, 2007).
73. (Schwartz, 2003).
74. (Sullivan, 2006).
75. (United States Attorney, Southern District of New York, 2004).
76. (United States Attorney, Southern District of New York, 2004).
77. ("New Weakness in 802.11 WEP" 2001).
78. (Greenemeier, 2007).

Chapter 1

1. A patch is a correction to a problem in a program.
2. A virus is code that attaches itself to other programs, which then make additional copies of the code. ("Virus," n.d.).
3. A Trojan is malicious code that disguises itself as another program. ("Trojan," n.d.).
4. A rootkit is type of Trojan that allows access to a computer at the most basic "root" level. ("Rootkit," n.d.).
5. Spyware is software that sends information about a user's internet activities to a remote party. ("Spyware," n.d.).
6. Spam is email that is not requested, frequently commercial in nature. ("Spam," n.d.).
7. Phishing is a type of email scam that attempts to trick the user into revealing credentials useful for identity theft. ("Phishing," n.d.).
8. Security engineering addresses the interdisciplinary field of ensuring security in both real space and computer applications. For a discussion of security engineering, see (Anderson, 2001).
9. ("Computer Science," n.d.).
10. ("Diversity of Computer Science," n.d.).
11. (Denning, 2003).
12. (Denning, 2003).
13. (Pincus, 2005).
14. A device driver is a program that links a peripheral device with an operating system. ("Device Driver," n.d.).
15. Attackers have different goals: to make the user provide a specific piece of information (e.g., one that is of economic value or just useful in conducting the actual attack); to make the user change the configuration of the system (e.g., disable the fire-wall or change DNS settings); to make the user perform seemingly non-security-related actions (e.g., connect with a specific website); to make the user *not* take any action in response to events (e.g., train a user to ignore alerts about attack attempts).
16. (Camp and Anderson, n.d.).
17. For an extensive list of papers, see ("Information Security Economics," Annotated Bibliography, n.d.).
18. (Sheyner et al., 2002).

19. (M. Rogers, 2003).
20. (Odlyzko, 2007).
21. (Werlinger and Botta, 2007).
22. (Thomas, 2002).
23. (Symposium on Usable Privacy and Security, n.d.).
24. (Kephart and Chess, 1993).
25. (Staniford, Paxson, and Weaver, 2002).
26. (Thomas, 2003).
27. (Hargittai, 2007).
28. ("Estonia Hit by Moscow Cyber War," 2007).
29. (Davis, 2007).
30. (Brelsford, 2003).
31. (Office of New York State Attorney General Andrew Cuomo, 2003; T. Bishop, 2004; Krebs, 2007a; Macmillan, 2006).
32. (Whitten and Tygar 1999).
33. A dictionary attack is an attack where possible decryption keys and passwords are tried until the correct key or password is found. ("Dictionary Attack," n.d.).
34. (Saltzer and Schroeder, 1974).
35. (Whitten and Tygar, 1999).
36. The list of topics from the call for papers for the March 2007 special issue on Usable Security and Privacy of *IEEE Technology in Society* included areas such as usability analyses of specific technologies, design for usability in security and privacy, risk models of end users, human factor analysis in security, and trust-building systems for online interactions. ("Call for Papers," n.d.).
37. (Conti, Ahamad, and Stasko, 2005).
38. (Anti-Phishing Working Group, n.d.).
39. (Wu, Miller, and Garfinkel, 2006; Schechter et al., 2007).
40. (Jagatic et al., 2005).
41. For a discussion of standpoint theories, see (Harding, 2003).
42. In other words, it may be worthwhile to reexamine standard human computer interaction (HCI) precepts. For a discussion of standard HCI see ("Standards and Guidelines," n.d.).
43. (Cook, Render, and Woods, 2000; Cook and Woods, 1994).
44. (Hollnagel, 1983).
45. (Rasmussen, 1983).
46. (Hollnagel, Woods, and Leveson, 2006, 6).
47. For a discussion of the causes of software vulnerabilities, see (Podgurski, n.d.).
48. (Butler, 2000).
49. (Pincus, 2004).
50. (Phillips, 2001).
51. (Schneier, 2001).
52. (Butler and Fischbeck, 2001).
53. (Butler, 2002).

54. (Li et al., 2006).
55. The term “days of risk” was first used in Forrester Research’s 2004 report. (Koetzle, 2004).
56. (Ford, 2007).
57. (Ford, Thompson, and Casteron, 2005).
58. (Beattie et al., 2002).
59. Apple, Firefox, and Microsoft all provide automated patch download services; Microsoft Windows Update also includes an option to install the patches automatically. (Windows Update, n.d.).
60. (Altiris, n.d.).
61. (Novell, n.d.).
62. (AutoPatcher, n.d.) Microsoft’s recent interactions with AutoPatcher (requesting that AutoPatcher stop redistribution of Windows patches) cited concerns about a malicious spoofed update being distributed through AutoPatcher. This is an excellent example of the organizational, branding, and economic aspects of computer security.
63. (Howard, Pincus, and Wing, 2003).
64. (Granick, 2006a).
65. A bot herder or zombie network operator is the person in control of a large number of compromised machines that can be used to send spam, carry out distributed denial-of-service attacks, or otherwise inflict damage. (“Bot Herder Pleads Guilty To Hospital Hack,” 2006).
66. (Guidelines for Security Vulnerability Reporting and Response,” 2004).
67. An exploit is an attack that takes advantage of a security vulnerability. (“Exploit,” n.d.).
68. For the history and context of these discussions, see (Schneier, 2001a).
69. Originally, the term “o-day” was used only in the context of exploit codes. At the time, publishing information about vulnerability without details (but also without informing the vendor earlier) was considered by many as a reasonable alternative to the “responsible disclosure” protocol, and o-day exploits were regarded as the public enemy, because the vendor was learning about the problem from a public source and there was a fully functional attack code outside. Later attaching an exploit code became not so relevant, since in order to prove the vulnerability was real, some level of detail was required, and it was usually the same level of detail needed for skilled researchers to develop a working exploit code.
70. (Granick, 2005b).
71. (Thomas, 2003).
72. (Sterling, 1993).
73. (*Defcon*, n.d.).
74. (*Blackhat*, n.d.).
75. (RSA Security Inc., n.d.).
76. (*CanSecWest*, n.d.).
77. (*Hackinthebox*, n.d.).
78. (*Xcon*, n.d.).

79. ("Ph Neutral," n.d.).
80. (*BlueHat*, n.d.).
81. (Arrison, 2004).
82. (Carr, 2006).
83. (Schneier, 2007).
84. (Lindstrom, 2005).

Chapter 2

1. (Sullivan, 2006).
2. ("U.S. Says Personal Data on Millions of Veterans Stolen," 2006; Bosworth, 2006).
3. (Vijayan, 2007).
4. (Bosworth, 2007).
5. (Howard, Carr, and Milstein, 2005).
6. (P. N. Howard, 2002, 2006).
7. (Milne and Culnan, 2004; Fox, 2000).
8. (Nissenbaum, 2004).
9. *Universal City Studios, Inc. v. Reimerdes*, 111 F.Supp.2d 294, 320 (S.D.N.Y. 2000).
10. (Cavazos and Morin, 1996); see also (Zook, 2003). Publishers and republishers of offline defamatory statements can be held liable because it is expected that they possess considerable editorial control over their own published content. However, when publication moves into an online setting, the distribution of liability becomes less clear. Not all internet publishers maintain strict editorial control, and some media outlets function more like "conduits" through which news is automatically updated. Other websites allow users to generate content, with limited moderation provided by the system administrator. In both of these cases, it becomes more difficult to assign responsibility for defamatory material. The decentralized nature of computer networks poses other challenges for regulators. In cases involving obscenity, lawmakers in the United States have employed a method known as the "community standards test" to determine whether published material can be considered obscene. Material is deemed to lie outside the protections afforded by the First Amendment when it is found to be offensive to the norms and standards of the community in which it is located. While this method has functioned adequately in offline settings, it is less effective when individuals from diverse communities can transmit information to one another, often across state and national boundaries.

Early applications of the community standards test to online publishers proved unworkable. In the case of *United States v. Thomas*, 74 F.3d 701 (6th Cir., 1996) a website operator located in California was tried and convicted in Tennessee for violating the obscenity laws in the jurisdiction where the material was accessed, rather than where the material was stored. This case is often cited as evidence that current legislation is anachronistic and lags behind the requirements of communication technologies that bypass traditional jurisdictional boundaries.

11. Faced with an overwhelming number of users, along with the relative anonymity provided by computer-mediated communication, prosecutors in the United States have

tended to focus efforts on website operators rather than on end users. The jurisdictional challenges posed by computer networks continue to hamper their efforts in this regard, however, since offending websites can be operated offshore in areas with less stringent regulation. The United States has pursued this strategy in regard to online gambling, with limited success. Charges brought by New York State against twenty-two online gambling websites in 1999 yielded only one arrest, when the operator visited the United States on vacation. (Wilson, 2003).

12. For a discussion of the history of the CFAA see, e.g., (*North Texas Preventive Imaging, L.L.C. v. Eisenberg*, 1996).

13. In practice, the monetary felony threshold has proved somewhat meaningless, since the value of computer code compromised during intrusion is often quoted well in excess of \$5,000. In the case of *United States v. Mitnick*, Sun Microsystems claimed \$80 million in damages related to the cost of research and development of the source code that Mitnick copied during his intrusion. (*United States v. Mitnick*, 1998).

14. (Skibell, 2003).

15. Skibell argues that not all computer crime is committed by self-interested or malicious criminals. (Skibell, 2002). Criminals who use hacker techniques to access private data are rarely members of hacker communities, and they are often less sophisticated in their hacker skill set.

16. Other computer hackers appear to be motivated by codes of conduct inside their community. According to Jordan and Taylor, these legitimate computer hackers are motivated by a variety of concerns that make comparisons with other types of criminal behavior problematic. (Jordan and Taylor, 1998). These scholars argue that hacker projects are shaped by an ethical framework formed by a strong sense of imagined community. Many hackers are interested in the intellectual challenge and the sense of mastery provided by computer networks, rather than monetary rewards that could be gained from accessing sensitive information. They seek to differentiate themselves from other computer criminals who use computer networks for destructive, rather than creative, purposes. Furthermore, in recent years the core hacker community has been somewhat successful at contesting the malicious meaning attached to the term "hacker." While the press often continues to report hackers as those responsible for most forms of computer crime, some hackers have worked hard to distance themselves from the sensationalist definition used by the news media.

17. Many hackers divide their community into "white hat" and "black hat" constituencies to help distinguish those who use their computer skills with malicious intent from those who do not. The term "cracker," which now denotes an individual who destroys rather than improves computer systems, indicates a deliberate rhetorical strategy on the part of some hackers to create a nuanced understanding of the different aspects of the computer hacking community, particularly among scholars interested in computer subcultures. (Jordan and Taylor, 2004; Thomas, 2002). In contrast, "gray hats" are those who publicly expose security flaws, without concern for whether the act of exposure allows administrators to patch the flaw or allows others to exploit the flaw. Moreover, mainstream computer security experts have co-opted the term "blue hat" to

further distinguish the community of skilled computer users who hack in the service, and often employment, of Microsoft.

18. In our survey, some incidents involving U.S.-based organizations or U.S. citizens were reportedly carried out by individuals working outside the United States. For example, the 2001 theft of customer account information from Bloomberg Financial was carried out by a Kazak citizen named Oleg Zevov, who threatened to expose the information unless the company paid him \$250,000.

19. California Civil Code 1798.29.

20. This sentiment is supported by the California Department of Consumer Affairs, which maintains a website devoted to online privacy protection. The agency has also distributed a flyer listing the “top 10 tips for identity theft prevention.” This list enjoins consumers to take active steps to avoid becoming victims of electronic fraud by shredding personal documents, installing up-to-date computer virus and firewall software, and becoming vigilant about which sites they visit and how they use their credit cards. Consumers are also urged to take a more proactive role in monitoring their personal credit rating, in order to detect potential fraud. The Department of Consumer Affairs recommends that individuals apply for free credit reports at least three times per year in order to prevent misuse of their electronic identity.

21. (Burchell, 1996; Peck and Tickell, 2002).

22. There are interesting advantages and disadvantages to using printed news sources to construct the history of computer hacking and breached private records. As stated above, the mainstream media often equate hackers with any crime involving a computer and use the misnomer “hacker” without a nuanced understanding of the history of more legitimate computer hacking. We continue to use the term in this analysis because it is the most commonly used term in media reports where an intruder was deemed responsible for compromised data. Although criminal records would certainly provide details about the prevalence of malicious intrusions, such records are extremely difficult to collect nationwide. Moreover, a survey of incidents composed through criminal records would significantly *oversample* incidents in which an individual hacker was at fault and significantly *undersample* incidents in which an organization was culpable but not deemed criminally negligent. Over time, journalists would not have discovered all incidents, and even though current California law requires that a person whose data have been compromised be so informed, such a breach is not necessarily noted in news archives. However, journalists do their best to report the facts, and in the absence of a public agency that might maintain comprehensive incident records on privacy violations, news accounts provide the most comprehensive resource available.

23. The records lost by the Acxiom Corporation consisted of credit card numbers, purchasing histories, and marital status of individuals.

24. We believe it is more likely that computer equipment is stolen for personal use or resale value than for the data that thieves suspect is on the hard drives of the equipment they steal.

25. This single case is illustrative of the challenge of compiling and comparing incidents of compromised personal records. For example, the Acxiom incident involved an

employee of Snipermail.com, who removed 8.2 gigabytes of personal data in 137 separate incidents between April 2002 and August 2003. To be consistent with our sampling, we record this as a single incident occurring in 2004 because the news coverage and his arrest did not occur until 2004. Acxiom, the company that was entrusted with personal records, and even justice officials commenting on the case, describe the culprit as a hacker. However, there was actually a client relationship between the two firms, and Snipermail.com staff legitimately had the correct password to upload data to Acxiom servers. Someone at the Snipermail.com firm guessed that the same password might also be used to download data, though they were not legitimately allowed to do so. Some might argue that this is an example of a poor security choice by Acxiom, not an example of an ingenious technical exploitation by a rogue outsider with a hacker's skills. However, the majority of cases we label as "insider abuse" involve employees. The culprit in this case did legitimately have some insider information about Acxiom's security. To be conservative, and since we are interested in how the news media frame issues of data security, we code this incident as involving data stolen by a hacker because that was the language used in news coverage; we do not code it as insider abuse because the culprit was not an employee.

26. (Hall et al., 1978; Critcher 2003).

27. (Mnookin and Kornhauser, 1979; Rose, 1999).

Chapter 3

1. (National Conference of State Legislatures, n.d.).
2. An intrusion detection system is software that monitors for attacks. ("Intrusion Detection Systems," n.d.).
3. A firewall blocks access to certain traffic onto a network. ("Firewall," n.d.).
4. For example, Monster.com was aware that hackers using stolen credentials were harvesting data from the Monster jobseeker database. These stolen credentials were then used, among other things, to send messages that contained a malicious attachment. Monster chose not to notify the affected consumers until ten days after the discovery of the security problem. ("Monster.com Admits Keeping Data Breach Under Wraps," 2007).
5. Data covered by data breach notification laws varies from state to state. For example, California only recently included health data explicitly within a data breach notification statute. (Gage, 2008).
6. (Zetter, 2005g).
7. (Zetter, 2005e).
8. (Zetter, 2007f).
9. (Zetter, 2007d). IRC is a protocol for instant messaging where users join "channels" and all users of the channel see the users' messages.
10. (Zetter, 2006b; 2007e).
11. (Zetter, 2005g).
12. (Zetter, 2006a).
13. (Zetter, 2007a).

14. (Zetter, 2003).
15. (Zetter, 2005c).
16. (Zetter, 2006c).
17. (Zetter, 2007c).
18. (Zetter, 2006b).
19. (Zetter, 2007b).
20. (Zetter, 2005a).
21. (Zetter, 2005f).

Chapter 4

1. 35 U.S.C. § 271(a) (2000).
2. In U.S. patent law, there are two types of indirect liability: inducement and contributory liability. 35 U.S.C. §§ 271(b)–(c) (2000).
3. They usually have the help of an attorney or agent specially licensed by the PTO to file applications. Sometimes this attorney helps the inventor assess beforehand the potential patentability of the technology.
4. The odd structure and style of a patent claim owes its origin at least in part to the PTO's regulations. For example, among several requirements, the PTO insists that the claim be the object of a sentence, begin with a capital letter, end with a period, and use line indentation to enumerate elements of the claim. (*Manual of Patent Examining Procedure*, § 608.01(m) [hereinafter MPEP]).
5. At the PTO, technically skilled employees called “examiners” review the inventor's application, placing particular emphasis on the claims. The PTO examiner determines whether the application satisfies five criteria for patentability. These criteria are legal tests. Some of them have multiple subtests. There is typically some back-and-forth between the inventor's attorney and the PTO examiner. This discussion is usually an argument about whether the application meets some disputed tests within the five criteria. Patents that are issued but later determined to be invalid impose social costs; thus the examiner is charged with scrutinizing the application. The back-and-forth discussion sometimes prompts the inventor to amend the claim language, typically to claim a narrower scope for the invention and thus increase the chances that the PTO will issue the patent. If the applicant eventually convinces the examiner that one or more claims are valid, the patent can issue. It is commonly thought in the patent community that patent examiners spend between ten and thirty hours on a patent application. The variation is due to differences in technology areas and examiner experience. Recent empirical work supports this estimate. See (King, 2003), estimating, for a variety of technologies, a range of 15.7 to 27.5 mean hours for a PTO examiner to dispose of an application. Thus the degree of examiner scrutiny is inherently bounded by what can be accomplished within this period of time.
6. (Barney, 2002), noting that of all patents issued in 1986, only 42.5 percent were maintained past the twelfth year, and noting that the abandonment rate varied depending on the technology.
7. Some of the other commonly given justifications for the patent system include that: (i) the patent system stimulates investment to support the commercialization of

inventions; and (ii) the patent systems of the world facilitate the beneficial exchange of goods, services, and information among nations by protecting rights of foreign nationals. (Merges, Menell, and Lemley, 2003).

8. This legal test once included the now-defunct business methods exception from statutory subject matter. The exception worked as follows: although processes are subject matter the statute declares patentable if the other requirements are met, the business methods exception excluded methods of conducting business from statutory subject matter even though such methods fit within the statute's word "process."

9. 35 U.S.C. § 101 (2000).

10. The courts have emphasized the broad statutory language. The logic is that because Congress used broad words in the statute, courts should be wary of creating exceptions or limitations for statutory subject matter. The Supreme Court has made famous a statement in the legislative history of the federal statute—that the patent system could "include anything under the sun that is made by man." (*Diamond v. Chakrabarty*, 1980), holding that living organisms are not per se unpatentable.

11. (*Diamond v. Diehr*, 1981).

12. The utility requirement is most easily illustrated with some counterexamples. The PTO regularly rejects patent applications for perpetual motion machines because they lack utility. Also in this category are claims for inventions that produce power using so-called cold fusion. The PTO rejects these applications because recognized science disproves the possibility of usefulness for these devices.

But patent protection is available for devices that merely amuse, such as a mechanical toy that honks and twitches. Further, a patent is useful and meets the utility requirement if its purpose is for one product to imitate another, such as a process for putting spots on cigars because spotted tobacco is perceived as having higher quality, or a drink-dispensing machine that seems (by demonstrating colored water swirling in a clear tank) to contain the beverage, such as orange juice, mixed and ready to dispense, but actually mixes the user's drink as the machine pours it into the cup (U.S. Pat. No. 5,575,405). (*Juicy Whip, Inc. v. Orange Bang, Inc.*, 2002).

13. Consider an example based on the hypothetical claim from above. The claim's two primary components are (i) the "message transfer protocol relay," and (ii) policy managers for source/destination, content, and viruses. Assume that an article is prior art because it discusses firewall technology, and that it was published before the date of invention for the hypothetical claim. If the article described the protocol relay and the policy managers along with the other details in the hypothetical claim, the article will anticipate the claim. In that case, the claim is invalid. The PTO may not discover the article when it examines the patent. The inventor may also be unaware of the article. Regardless, anytime during the patent's enforcement life the article can be asserted as a defense to invalidate the claim(s) it anticipates. To change the example, if the article disclosed the protocol relay, but only disclosed policy managers for source/destination and content, then the article would not anticipate and thus invalidate the hypothetical claim. It does not anticipate because it does not disclose all the elements claimed. The claim describes a system with policy managers for three items: source/destination,

content, and viruses. The prior art article described a system with only two of the three policy managers. The reference must disclose all that the claim describes—i.e., all claim elements—to invalidate the claim by anticipation. The example illustrates a prior art reference anticipating and thus invalidating the hypothetical firewall claim, but other types of references could anticipate the claim. The claim's elements might be disclosed in the background section of an earlier patent, even if that patent did not claim the firewall. Non-printed references can render the claim invalid for lack of novelty. For example, someone may have built and operated the claimed firewall in the United States before the inventor developed her firewall. The United States patent law implements prior art based on geography. For example, potentially invalidating uses of a technology in another country are not considered prior art under the U.S. system. That same use, however, if described in an article published in a foreign jurisdiction, regardless of the language of publication, will count as prior art with the potential to invalidate claim(s). This shows that independent invention does not save patent validity.

14. Consider this example: the inventor of the hypothetical firewall claim operates firewalls for third parties for many years, doing a brisk business, but keeps the firewalls' internal operation secret. The firewalls so operated are covered by the hypothetical claim. Eventually, after ten years, the inventor files for a patent. Without the statutory bar the inventor would effectively enjoy control over the technology for thirty years, ten more than the patent system's term of twenty years. Thus the statutory bars support the primary policy goals of the novelty criteria: reserving patent protection for truly new, noncommercialized technology. The system expects commercialization of the newly discovered and newly patented technology, but expects such control and leverage to derive from the patent right.

15. Consider an example based on the hypothetical claim from above. The claim's two primary components are (i) the "message transfer protocol relay," and (ii) policy managers for message source or destination, content, and viruses. Assume two prior art references. The first, a patent by Jones, discloses the message transfer protocol relay and a policy manager for determining which messages can travel from sources to destinations. The second is an article by Smith that describes policy managers for filtering messages by content and by the presence of viruses. Put Smith and Jones together and you have all the claimed elements. The question is whether it would be obvious to combine Smith and Jones.

16. Some have even proposed that facilitating the option to credibly publish information is an important role for the patent system. (Long, 2002).

17. Consider an example based on the hypothetical claim from above. The claim recites a firewall. The disclosure before this claim need only mention that the firewall is implemented using some readily available computer technology. Assume that the disclosure describes a firewall created in software running on an Intel Pentium computer. This raises the question: would the disclosure need to provide the software source code? The answer is no. The patent disclosure need only provide an algorithmic description of the code's flow and sequence, unless something very particular is claimed that requires a specific programming language mechanism. Thus patents claiming functionality imple-

mented in software, as described in the disclosure, usually do not provide much or any of the source code. This does not invalidate the patent under the enablement test as long as a programmer of ordinary skill in the relevant technology could figure it out: can she make and use the claimed method or process without undue experimentation? Determining whether experimentation is “undue” is tricky. The law handles this with a multi-factor test, but precision is hard to achieve.

18. (Allison, 2004), arguing, among other points, “that the easiest way to discover the characteristics of valuable patents is to study litigated patents.”

19. (Nelson, 2001, at B1), noting that for its new product, Cottonelle Fresh Rollwipes, Kimberly-Clark is “guarding the roll and its plastic dispenser with about 30 patents.”

20. (*State St. Bank & Trust Co. v. Signature Fin. Group, Inc.*, 1998). The patent at issue in *State Street* claimed a computer system that calculated asset values for a particular configuration of entities sharing participation in pooled mutual funds. (*AT&T v. Excel Communications*, 1999), extending the holding of *State Street* to a pure process claim for a long-distance messaging technique to facilitate charge billing.

21. Companies use information and computing resources to implement valuable business processes. Automation is pervasive in developed-country enterprises. Software implements and controls the automation. The software requires a secure and stable information technology environment to function. Thus a company’s software and information technology resources are among its most important operational assets. As with any valuable asset, it makes sense to implement measures to protect these assets.

22. (National Research Council, 2000; Ferguson and Schneier, n.d.), acknowledging the promise of cryptography but arguing that the industry has been unable to convert “the mathematical promise of cryptographic security into a reality of security.”

23. (*PGP History*, n.d.).

24. The hypothetical patent claim gives the count of patents classified in three classes.

25. Enterprises have numerous techniques with which to protect and secure both their information and their computing infrastructure. Physical security and personnel training are important techniques. But equally important are (i) network and computer access and control security for both users and autonomous entrants, (ii) software application security, and (iii) data protection and management. These techniques intimately involve many types of software, including operating systems, network middleware such as internet applications, databases and the innumerable applications that rely on them, and user productivity applications. All of these techniques, through the software, might apply cryptographic methods.

26. The National Research Council’s Computer Science and Telecommunications Board characterized cryptographic capabilities as follows: “Cryptography can help to ensure the integrity of data (i.e., that data retrieved or received are identical to data originally stored or sent), to authenticate specific parties (i.e., that the purported sender or author of a message is indeed its real sender or author), to facilitate nonrepudiation, and to preserve the confidentiality of information that may have come improperly into the possession of unauthorized parties.” (Dam and Lin, n.d.).

27. Although the U.S. patent system is nondiscriminatory in its major features, there are some exceptions. Special handling applies to biotechnology and drug patents, but these features are beyond the present discussion. Business method patents implemented with information technology are treated slightly differently. Because of concerns about the quality of such patents as their quantity exploded in the late 1990s and early 2000s, the PTO implemented more stringent review processes. The extra stringency was not legal but administrative. Among other measures, the PTO implemented additional examiner review to try to prevent invalid business method patents from issuing. ("March 2000 Director Initiatives").

28. (Mann, 2005), noting based on an earlier article by Professor Mann that certain information technology areas "had markedly higher rates, including graphics and digital imaging, expert systems and natural language, multimedia, and security."

29. Before 1975, there was in essence no patenting of modern cryptography. During the three decades thereafter, each successive five-year period has seen at least double-digit (and sometimes triple-digit) percentage increases for patents classified to cryptography. See Table 4-1.

30. (Moy, 2002).

31. (Graham and Mowery, 2003; Allison and Tiller, 2003).

32. Embedded technology refers to a technology that is inserted into another technology. See, e.g., ("Embedded," n.d.).

33. Corporate procurement agreements often require that a developer indemnify the corporate user against patent infringement for the product or technology supplied.

34. (National Research Council, 2000). This exceedingly brief sketch only scratches the surface in describing cryptography. This chapter, however, will not go much deeper. There are other, better references available for delving into the technology.

35. (Ferguson and Schneier, n.d.).

36. (Commercial Encryption Export Controls," n.d.).

37. (Froomkin, 1996).

38. (National Institute of Standards and Technology, n.d.).

39. (Wayner, n.d.).

40. Saying that the recipient's public key is on the internet, or that the recipient has previously sent the sender the recipient's public key, exposes another problem: verifying that the recipient is who she says she is and that the public key is hers. Cryptography is also used against this problem to implement a "digital signature." This technique essentially inverts the public/private key system described in the main text. To generate the digital signature, one cryptographically processes a signature-private-key against some information about the recipient, including her public key. There is then a signature-public-key that is used to verify that the information originated from whoever had the signature-private-key. For full effectiveness, however, the digital signature system requires a trusted third party to verify the recipient's digitally signed information. These authorities for the internet are called Certificate Authorities (CA). There can be a hierarchy or chain of CAs so that they can cross-verify each other. The CA issues a "certificate" that is "a computer-based record which: (1) identifies the CA issuing it, (2) names,

identifies, or describes an attribute of the subscriber, (3) contains the subscriber's public key, and (4) is digitally signed by the CA issuing it." (Froomkin, 1996).

41. (U.S. Patent No. 4,200,770).

42. (Internet Engineering Task Force (IETF), n.d.; "Open Group, Public Key Infrastructure," n.d.).

43. (U.S. Patent No. 4,218,582).

44. (U.S. Patent No. 4,405,822).

45. (RSA Security Inc., n.d.).

46. (U.S. Patent No. 3,962,539).

47. (National Institute of Standards and Technology, 2001; Froomkin, 1995, discussing how DES became the U.S. government standard and the controversy surrounding its selection).

48. (Department of Commerce National Institute of Standards and Technology, n.d.).

49. (Froomkin, 1995, 895–96), discussing how, in the early 1990s, the U.S. federal government's selected digital signature standard (DSS) was ignored by vendors until the government was able to make a royalty-free license available for the patents that covered the DSS.

50. (Froomkin, 1995, 734–38).

51. (*RSA Data Security, Inc. v. Cylink Corporation*, 1996).

52. (RSA Security, n.d.).

53. (*Schlaefly v. Public Key Partners*, 1997). In this case, an RSA-related company asserted its patent against another entity selling digital signature technology. The case went in RSA's favor, resulting in a determination that the defendant entity should no longer sell the technology.

54. (Radlo, 1996).

55. (RSA Laboratories, n.d.), listing RSA's description of the cryptography patents that had or have influence on the technology).

56. The data in the table were obtained using the U.S. PTO's public advanced search interface, which limits the query text length, and which prohibits a combined query to get a true total.

57. This conclusion is based on a search and review of U.S. federal court cases that were reported but not necessarily precedential, and contained terminology related to cryptography.

58. The search text is: ccl/380\$ and ttl/key\$ and ttl/manage\$. The search conducted on April 18, 2005, in the U.S. PTO database returned seventy-two results. One example is U.S. Pat. No. 6,738,905, entitled "Conditional access via secure logging with simplified key management." The patent relates to encrypting content for distribution, with likely applications in entertainment delivery.

59. (Radlo, 1996, 10).

60. (Shapiro, 2001).

61. Patent pool licensing varies in different industries and for different technologies, so this chapter is not the place to enumerate the possibilities. It suffices to note that pooling sometimes clears patents from blocking the path of product deployment, but

may create problems, including the incentive for developers and suppliers to acquire patents in a race to gain leverage and influence within the pool. (Meurer 2002; Carlson 1999: "Patent pools are private contractual agreements whereby rival patentees transfer their rights into a common holding company for the purpose of jointly licensing their patent portfolios.")

One well-known patent pool sometimes associated with data encryption is the DVD pool. (DVD 6C Licensing Agency: Patent Catalogue, n.d.) This patent pool, however, does not directly cover the well-known Content Scrambling System (CSS), a relatively weak cryptographic approach used by the entertainment industry to inhibit DVD copying. (Openlaw DVD/DeCSS Forum," n.d.).

62. (Lemley, 2002), describing "standard-setting organization intellectual property rules as private ordering in the shadow of patent law," and noting that in "many industries IP owners regularly cross-license huge stacks of patents on a royalty-free basis. These patents are used defensively rather than offensively; their primary economic value is as a sort of trading card that reduces the risk that their owner will be held up by other patent owners."

63. ("What Is the Trusted Computing Group?" n.d.); (Goodwin, 2002).

64. ("Trusted Computing Group Backgrounder," 2005).

65. ("Trusted Computing Group Backgrounder," 2005, 5).

66. Besides the IEEE, the Internet Engineering Task Force (IETF) is an important standard-setting organization for cryptography. ("Overview of the IETF," n.d.). The IETF manages the Public Key Infrastructure standard. ("Public Key Infrastructure," n.d.).

67. ("Public Key Infrastructure," n.d.).

68. ("Public Key Infrastructure," n.d.).

69. ("Advanced Encryption Standard Algorithm Validation List," n.d.).

70. (Vetter, 2004).

71. The United States PTO initiated an effort in early 2006 to systematically make open source software available as searchable prior art for its examiners. (Markoff, 2006).

72. (Lohr, 2005). The article reported IBM's approach as follows: "[IBM] announced in January [2005] that it would make 500 patents—mainly for software code that manages electronic commerce, storage, image processing, data handling and Internet communications—freely available to others. And it pledged that more such moves would follow. [In April 2005], the company said that all of its future patent contributions to the largest standards group for electronic commerce on the Web, the Organization for the Advancement of Structured Information Standards, would be free."

73. ("OASIS Committees by Category: Security," n.d.).

74. (Nelson, 2001), describing how a paper manufacturer used about thirty patents to cover a new, wet toilet paper roll and its dispenser.

75. (Certicom Overview Brochure, n.d.): "Since 1985, Certicom has been building an extensive portfolio of over 300 patents and patents pending covering key techniques critical to the design of cryptographic systems both in software and hardware."

76. (Mann, 2005, 996–97, n.180): "The only stable equilibrium response of IBM is to

obtain a sufficiently large portfolio of patents to induce Microsoft to enter into a formal or informal cross-licensing arrangement under which neither side will sue the other for patent infringement.”

Chapter 5

1. (2005 FBI Computer Crime Survey, n.d.).
 2. (2005 FBI Computer Crime Survey, n.d.): “Companies reported a \$1,985,000 loss due to proprietary information theft in 2005.”
 3. (Hearnden, 1989), reflecting on a data compilation table that finds 80 percent of computer crimes are committed by employees.
 4. Uniform Trade Secrets Act § 1, 14 U.L.A. 437 (1990).
 5. (Epstein, 2005, Sect.1.02 at 1–4). The Restatement (Third) of Unfair Competition now also governs trade secrets, and its rules apply to actions under both the UTSA and the Restatement of Torts. (Restatement of the Law (Third) of Unfair Competition, 1995, Sect. 39, Reporter’s Note).
 6. (Epstein 2005, Sect.1.02 at 1–4).
 7. (*McFarland v. Brier*, 1998).
 8. UTSA § 2(a), 14 U.L.A. 449 (1990).
 9. A negative trade secret is the knowledge of what not to do or what doesn’t work, a lesson learned from a certain process or research and development effort that failed. (Pooley, 1997, Sect.4.02[3]).
 10. (UTSA § 1, defining misappropriation; Milgrim, 1997, Sect.1.01[2]), discussing the UTSA.
 11. The UTSA defines “misappropriation” as:
 - (i) acquisition of a trade secret of another by a person who knows or has reason to know that the trade secret was acquired by improper means; or
 - (ii) disclosure or use of a trade secret of another without express or implied consent by a person who:
 - (A) used improper means to acquire knowledge of the trade secret; or
 - (B) at the time of disclosure or use, knew, or had reason to know, that his knowledge of the trade secret was:
 - (I) derived from, or through, a person who had utilized improper means to acquire it;
 - (II) acquired under circumstances giving rise to a duty to maintain its secrecy or limit its use; or,
 - (III) derived from, or through, a person who owed a duty to the person seeking relief to maintain its secrecy or limit its use; or
 - (C) before a material change of his position knew or had reason to know that it was a trade secret and that knowledge of it had been acquired by accident or mistake.
- Uniform Trade Secrets Act § 2(a), 14 U.L.A. 449.
12. Uniform Trade Secrets Act § 1 (1985).

13. Uniform Trade Secrets Act § 1, 14 U.L.A. 449.
14. (Rowe, 2007).
15. (*Lockridge v. Tweco Products, Inc.*, 1972).
16. (Rowe, 2005; *E. I. DuPont de Nemours Powder Co. v. Masland*, 1917): “defendant [employee] stood in confidential relations with the [former employer].”
17. (*BIEC Intern, Inc. v. Global Steel Servs. Ltd.*, 1992; *Flotec, Inc. v. Southern Research, Inc.*, 1998).
18. (*Air Prods. & Chem., Inc. v. Johnson*, 1982: “[A]n ex-employer can reasonably rely upon the obligation of its employees not to disclose trade secrets about which they obtained knowledge while working in a confidential relationship with that employer.” (*L. M. Rabinowitz Co. v. Dasher*, 1948): “It is implied in every contract of employment that the employee will hold sacred any trade secrets or other confidential information which he acquires in the course of his employment.”
19. (*Churchill Communications Corp. v. Demyanovich*, 1987): even in the absence of a restrictive covenant an employee’s use of an employer’s trade secrets can be enjoined since it violates a fiduciary duty owed to the employer; (*Rubner v. Gursky*, 1940): fiduciary duty not to disclose implied in all employment contacts.
20. (Restatement of the Law (Second) of Agency, 1958, Sect. 387): “Unless otherwise agreed, an agent is subject to a duty to his principal to act solely for the benefit of the principal in all matters connected with his agency”; (*Royal Carbo Corp. v. Flameguard, Inc.*, 1996): duty of loyalty breached where employee surreptitiously organized competing entity and utilized former employer’s customer lists; (Pedowitz et al., 1995): providing a comprehensive state-by-state survey.
21. (Sheinfeld and Chow, 1999).
22. (“Computer and Internet Use at Work in 2003,” n.d.).
23. (Stone, 2001).
24. (Aaron and Finkin, 1999).
25. (Aaron and Finkin, 1999, 541): “It has been widely reported that large corporations no longer offer their employees implicit contracts for lifetime employment.
26. (Aaron and Finkin, 1999, 540; Mischel, Bernstein, and Schmitt, 1999).
27. (Aaron and Finkin, 1999, 548).
28. (Rowe, 2005).
29. (Turnley and Feldman, 1999).
30. (Savage, Moreau, and Lamb 2006, 209, n.133): “From 2000 to 2003, only five of twenty-six prosecutions for violations of the [Economic Espionage Act] involved outsiders.”
31. (Rowe, 2007).
32. (Mills, 1997).
33. (Fitzpatrick, 2003).
34. (Fitzpatrick, 2003).
35. (Mills, 1997).
36. (*U.S. v. Martin*, 2000, 7, 8, 10).
37. (*U.S. v. Yang*, 2002).

38. (Reisner, 1998).
39. (*U.S. v. Yang*, 2002).
40. (Rowe, 2007).
41. (*Religious Technology Center v. Lerma*, 1995, 1364).
42. The Religious Technology Center is a nonprofit corporation formed by the Church of Scientology to protect its religious course materials. (*Religious Technology Center v. Netcom*, 1995).
43. (*Religious Technology Center v. Netcom*, 1995, 1368).
44. (*Religious Technology Center v. Netcom*, 1995, 1239, 1256–57).
45. (*Ford Motor Co. v. Lane*, 1999, 747, 748, 750, 753).
46. (Electronic Monitoring & Surveillance Survey, n.d.): “Computer monitoring takes various forms, with 36% of employers tracking content, keystrokes and time spent at the keyboard. Another 50% store and review employees’ computer files. Companies also keep an eye on e-mail, with 55% retaining and reviewing messages.”
47. (“Addressing the New Hazards,” 1991).
48. (Aaron and Finkin, 1999).
49. (Electronic Monitoring & Surveillance Survey, 2005).
50. (*People v. Pribich*, 1994), a California case involving a telecommuting employee.

Chapter 6

1. (Institute of Medicine, 2003).
2. (Bobb et al., 2004).
3. (Garde et al., 2007), discussing the importance of interoperability.
4. 45 C.F.R. §§ 164.302–164.318 (2007).
5. (“Continued Progress,” 2007).
6. (Jha et al., 2006).
7. (Brown, 2007).
8. (“Privacy and Consumer Profiling,” n.d.; Medical Marketing Service, n.d.; Medical Maladies Ailments, n.d.).
9. (Cleveland Clinic, n.d.).
10. (Health Status Internet Assessments, n.d.).
11. (U.S. National Institutes of Health, n.d.).
12. (“Exposed Online,” 2001).
13. (Freudenheim, 2007).
14. (Statement of Aetna CEO and President, n.d.).
15. (Anderson, 1996), citing need to safeguard computerized patient records to protect hospitals 1993.
16. (Garfinkel and Shelat, 2003).
17. (Solove, 2004; Wheeler, 2006).
18. (Terry, 2005).
19. (Report of the Board of Trustees, n.d.).
20. (Hoffman, 2003), discussing the Americans with Disabilities Act’s scope of coverage and its definition of “disability.”

21. (Anderson, 1996, 5), reporting that after a computer was stolen from a general medical practice in Britain, two prominent women received letters from blackmailers who threatened to publicize the fact that the women had had abortions.

22. ("Medical Identity Theft," n.d.).

23. (Bishop et al., 2005).

24. (Harris Interactive Inc., 2005).

25. (Day, 2007).

26. For a comprehensive web-based resource concerning state laws see (*Health Privacy Project*, n.d.).

27. Ariz. Rev. Stat. §§ 12-2293, 20-2101 (2007); Colo. Rev. Stat. Ann. § 25-1-802(1)(a) (2007); Fla Stat. Ann. §§ 456.057 (2007).

28. Ariz. Rev. Stat. § 12-2292 (2007); Fla. Stat. Ann. §§ 381.026, 456.057, 395.3025, 627.4195 (2007); 410 Ill. Comp. Stat. 50/3(a) and (d) (2007).

29. Ala. Code §§ 27-21A-25, 22-56-4(b)(7), 22-11A-14, 22-11A-22 (2007), restricting disclosure by HMOs and disclosures relating to mental health and sexually transmitted diseases; Del. Code Ann. Tit. 16 §§ 204, 1121(6), 1121(19), 2220 (2007), governing rest homes, nursing homes, alcoholism treatment facilities, and data concerning birth defects.

30. N.H. Laws § 328 (2007); Vt. Laws No. 80 Sec. 17 (2007).

31. (*IMS Health v. Rowe*, 2007; *IMS Health v. Sorrell*, 2007; *IMS Health Inc. v. Ayotte*, 2007).

32. (*Diaz v. Oakland Tribune*, 1983), in which the jury found defendant liable for publicizing the fact that plaintiff had gender corrective surgery. Award was overturned based on erroneous jury instructions.

33. (*Satterfield v. Lockheed Missiles and Space Co. S.C.*, 1985), stating that "[c]ommunication to a single individual or to a small group of people" will not support liability under a theory of (public disclosure of private facts, which requires publicity rather than publication to a small group of people; (*Beard v. Akzona, Inc.*, 1981), emphasizing that publication to a small number of people will not create liability; (*Tollefson v. Price*, 1967), stating that public disclosure occurs only when the information is communicated to the public generally or to a large number of people; (*Vogel v. W. T. Grant Co.*), 1974, explaining that the tort is established only if disclosure is made to the public at large or the information is certain to become public knowledge; (*Swin-ton Creek Nursery v. Edisto Farm Credit S.C.*), 1999, stating that "publicity, as opposed to mere publication, is what is required to give rise to a cause of action for this branch of invasion of privacy."

34. (*Horne v. Patton*, 1973).

35. (Keeton et al., 1984).

36. 5 U.S.C. § 552a (2000).

37. 5 U.S.C. § 552 (2000).

38. 42 U.S.C. § 12112(d) (2000).

39. 20 U.S.C. § 1232g (2000).

40. 15 U.S.C. § 1681a(f) (2000). The term "consumer reporting agency" is defined as "any person which, for monetary fees, dues, or on a cooperative nonprofit basis, regu-

larly engages in whole or in part in the practice of assembling or evaluating consumer credit information or other information on consumers for the purpose of furnishing consumer reports to third parties, and which uses any means or facility of interstate commerce for the purpose of preparing or furnishing consumer reports.”

41. 15 U.S.C. §§ 1681b(g); 15 U.S.C. §§ 1681c(a)(6) (2000).
42. 42 U.S.C. §§ 1320d-1320d-8 (2000).
43. 45 C.F.R. 160.103 (2007).
44. 45 C.F.R. § 164.524 (a)–(b) (2007).
45. 45 C.F.R. § 164.520 (2007).
46. 45 C.F.R. §§ 164.502 & 164.512 (2007).
47. 45 C.F.R. § 164.504(e)(2) (2007).
48. 45 C.F.R. § 164.306(a) (2007).
49. 45 C.F.R. § 164.308 (2007).
50. 45 C.F.R. § 164.310 (2007).
51. 45 C.F.R. § 164.312 (2007).
52. 45 C.F.R. § 160.306 (2007).
53. 45 C.F.R. § 160.308 (2007).
54. 45 C.F.R. § 160.508 (2007); 42 U.S.C. 1320d-5 (2000).
55. 42 U.S.C. § 1320d-6 (2000).
56. (“Health Information Technology,” 2007).
57. (“Review of the Personal Health Record (PHR) Service Provider Market,” 2007).
58. 45 C.F.R. § 160.102(a) (2007).
59. (Hustead and Goldman, 2002; Dolgin, 2001; Rothstein and Hoffman, 1999).
60. 45 C.F.R. § 164.526(a) (2007).
61. (*Acara v. Banks*, 2006): “Congress did not intend for private enforcement of HIPAA.”
62. 45 C.F.R. §§ 160.300–160.552 (2007); 42 U.S.C. § 1320d-6 (2000).
63. (“Compliance and Enforcement: Privacy Rule,” n.d.).
64. (“Compliance and Enforcement: Numbers at a Glance,” n.d.; “Compliance and Enforcement: Privacy Rule,” n.d.).
65. (Baldas, 2007).
66. (U.S. Healthcare Industry HIPAA Compliance Survey Results, 2006).
67. 45 C.F.R. § 164.306(b)(1) (2007).
68. 45 C.F.R. § 164.312(e)(2)(ii) (2007).
69. (Sobel, 2007).
70. (Rothstein and Talbott, 2007).
71. For more detailed discussions of our recommendation, see (Hoffman and Podgurski, 2007a, 2007b).
72. 42 U.S.C. § 1320d-1(a) (2000).
73. 45 C.F.R. § 160.103 (2007).
74. 45 C.F.R. § 164.524(c)(4) (2007).
75. (“Compliance and Enforcement: Privacy Rule,” n.d.).

76. 45 C.F.R. § 164.306(a) (2007).
77. (Stonebumer et al., 2002).
78. (Carnegie Mellon Software Engineering Institute, n.d.).

Chapter 7

1. Here data breaches are defined as events where sensitive information associated with private citizens is obtained by unauthorized parties with intent to commit fraud.
2. It should be pointed out that there is a lot of uncertainty in the number due to the difference between records that could have been accessed by an unauthorized person and the number that were actually taken, which frequently cannot be determined.
3. Privacy Rights Clearinghouse, a privacy advocacy group, maintains a chronology of data breaches dating back to January 2005, in the wake of widely publicized incidents at ChoicePoint and earlier at Acxiom. (Mohammed, 2006; Poulsen, 2003).
4. For example, CardSystems Solutions was in violation of the Payment Card Industry (PCI) security standards around the time it experienced a breach affecting 40 million records. (Zetter, 2005b).
5. (Spradlin, 2005).
6. For our purposes the expression “payment instrument” includes any meta-data associated with the method of payment. A credit card will have an expiration date, subscriber name, associated billing address, and a CVV (card validation value) field printed on the back. Similarly a bank account number is not meaningful without either the name of the financial institution or, more conveniently, the nine-digit routing number in the United States or the SWIFT code for international transfers.
7. (“Experian National Score Index,” n.d.).
8. CVV2 stands “Card Verification Value 2,” also known as Card Security Code 2. This is a three- or four-digit number that is printed (not embossed) on the card and which is not included in the information encoded on the magnetic stripe. Merchants are not allowed to store the CVV2 field. (Visa, n.d.).
9. In other words, instead of relying on “what you have” as a way of authentication, the merchant relies on “what you know”—pure abstract information such as the sequence of digits printed on the card, plus auxiliary information about the card holder such as the billing address.
10. (Social Security Administration, n.d.).
11. (Darlin, 2007).
12. (Garfinkel, 1995).
13. These approaches suffer from the problem that multiple individuals may share the same name and some people may not have a driver’s license. As such they cannot guarantee unique disambiguation and coverage for all persons, unlike SSNs.
14. (Fair Credit Billing Act, n.d.).
15. (Electronic Funds Transfer Act, n.d.).
16. (Berner and Carter, 2005).
17. (Perez, 2005; Keizer, 2006a).
18. (Isaacson, 2004).

19. In information security, authentication is the process of establishing the identity of an actor and authorization is the process of verifying whether the actor is permitted to carry out a particular action, such as accessing a resource. (Anderson, 2001b).

20. In contrast, recovering from an integrity violation, which is authorized tampering with or destruction of data, is significantly easier: the original state of the system can be restored from backups.

21. (PCI Security Standards Council, 2006, sections 3.6 and 8.5.9).

22. "A system's attack surface is a measure of the number of different ways an adversary could attempt to target a system and inflict damage. While a higher attack surface does not necessarily imply lower security, it does mean that there are more places where an implementation error or oversight can lead to a security breach, and all else being equal, statistically higher risk. This is independent of whether such defects exist." (Howard, Pincus, and Wing, 2003).

23. Balance-carrying cards are distinct from charge cards, which require the balance to be paid in full at the end of each billing cycle.

24. (Hansell, 2001).

25. (Holman, 2008).

26. (Hirst and Litan, 2004).

27. (Gobioff et al., 1996). As the authors point out, the challenge of adequately capturing user consent is not limited to magnetic stripe cards, but also applies to smart cards.

28. Whether that assumption is plausible depends on the application. In an ecosystem with a small number of carefully vetted participants, it may be a reasonable trade-off. When there are many merchants in the picture with varying levels of sophistication and security posture—exactly the situation with the current payment card networks and financial services—it becomes a matter of probability that at least one merchant will experience a security breach at some point. In fact, the risk of a security breach is not confined to the merchant. Typically merchants use payment processors to carry out the actual funds transfer, who in turn employ other intermediaries. Similarly merchants may outsource operation of their IT systems to a third party that leases servers at a co-location center operated by a different entity. That entity may in turn have contracted with a private firm to provide physical security for the premises. The net result is that once disclosed by the consumer to any one endpoint, the information percolates through the system and becomes dependent on the security practices of many actors.

29. (Greenemeier, 2007b).

30. (Gaudin, 2007a; Kerber, 2007b).

31. One study from 2007 places this cost at between \$90 and \$305 per exposed record. (Evers, 2007).

32. (Gaudin, 2007c).

33. (Matwyshyn, 2005).

34. Security-through-obscurity refers to a discredited design approach that relies on hiding details about a system's design in order to improve security by concealing existing weaknesses and making it more difficult for others to discover them.

35. Some banks are introducing notification systems designed to alert the customer of suspicious charges by email or phone. For example, Chase has promoted its mobile alerts system, designed to send SMS messages to customer phones. (JP Morgan Chase, n.d.).

36. More recently, the bureaus have started offering credit monitoring services aimed at the consumer market. (Lankford, 2008).

37. (Fair Credit Reporting Act, n.d.).

38. (Mayer, 2005).

39. In fact, several instances of fraud involving SSNs for deceased individuals have been reported in the press. (Kirchheimer, 2007).

40. (Krebs, 2007b).

41. (Social Security Administration, 2007).

42. Success here is measured by the extent of consumer adoption and the profitability of the credit card business. ("Credit-Card Wars," 2008).

43. There are profiling and tracking issues associated with massive databases indexed by SSN, but these can be decoupled from the new account fraud risks.

44. Incremental solutions such as requiring date of birth or mother's maiden name *in addition to the SSN* simply create additional targets for informational criminals, placing even greater amounts of personal information at risk for the dubious objective of shoring up a fundamentally weak protocol.

45. ("Common Access Cards," n.d.).

46. According to the Electronic Privacy Information Center (EPIC) website, the opposition includes the Association for Computing Machinery, American Library Association, National Governors Association, National Council of State Legislatures, and American Immigration Lawyers Association. (EPIC, n.d.).

47. For example, refer to the homepage for the Belgium eID program. (Belgium eID Program, n.d.).

48. (Singel, 2008).

49. (Brodkin, 2007).

50. (California SB 1386, 2002).

Chapter 8

The authors are grateful to the editor of this book for substantial editorial work on this chapter.

1. (Calvert, Jordan, and Cocking, 2002).

2. (Hempel and Lehman, 2005).

3. ("Teens and Technology," 2005).

4. The internet is potentially a much more powerful means than traditional media of reaching and collecting data about children. Sales to children can mean big business in the long run; businesses that use the internet successfully to promote direct sales can develop lifelong brand loyalty among children. They also collect personal information from children for the purpose of profile analysis to better target their consumers. For example, the popular teen website MySpace.com, which was purchased by News

Corp. in July 2005 for \$580 million (*Economist*, 2006) has close to 60 million registered users. The site attracts all kinds of advertisements targeted at teens from music to body spray. The site hits ranked number 15 on the entire U.S. internet in October 2005, according to the Nielson/NetRatings. In the same month, about 20 million members logged on to MySpace, which accounts for 10 percent of all advertisements viewed on-line in the month. Monthly advertising revenue generated from the site was estimated at \$13 million. One advertiser that pursues teenage consumers is the retailer Target. It sponsored a group called “Klipfliplin” on MySpace.com that featured 15-year-old professional snow- and skateboarder Shaun White. Users who joined the group could watch a video clip of him (with a Target logo on his helmet) discussing his exploits, or they could click on the “Shop” button. As of October 2005, more than 31,000 users had joined the group (Hempel and Lehman, 2005).

5. This concern is even greater for socioeconomically disadvantaged children. Existing data indicate that the resiliencies of children are most challenged by the effects of chronic poverty, particularly in a cultural context like that of the United States that values wealth and consumerism.

6. (Greenfield, 1984; Singer and Singer, 2001).

7. (Children’s Online Privacy Protection Act of 1998).

8. (“Protecting Teens Online,” 2005).

9. (Children’s Online Privacy Protection Act of 1998). COPPA as a commercial sector privacy law deals with the informational security aspects of internet protection. There have also been multiple other legislative efforts to protect children in cyberspace. Related legislation includes the Communications Decency Act of 1996 (CDA). CDA regulates the provider sites, allowing users to sue providers that knowingly send or display over the internet “indecent” materials in a manner that is available to a person under 18 years of age. The Child Online Protection Act (COPA) 47 U.S.C. 231 protects children under 17 from inappropriate content. It requires websites to restrict access to materials that are “harmful to minors.” Violations are subject to criminal convictions and heavy civil fines. However, neither act was implemented because of its undue infringement of free speech. Basically there is no way to restrict minors’ access without also barring adult access. With the large and ever-growing number of websites maintained from every corner of the world, it is virtually impossible to censor from the provider side. Alternative considerations for protecting children from harmful online materials include: (a) targeting specific materials, and (b) limiting children’s access by filtering and zoning. (Nist, 2004). Recently the internet advertisement business became concerned about the controversial reputation of the popular teen website MySpace.com. MySpace.com was founded by Tom Anderson and Chris DeWolfe in October 2003 as a free Web space for independent musicians to promote their music. It has grown into a multifunctional social networking platform. Registered users can create profiles of themselves, upload pictures, blog, add other online IDs as virtual “friends,” and chat and join groups. Its slogan is “A Place for Friends.” However, MySpace.com has been in the news repeatedly since also becoming a resource for sexual predators seeking teenage victims. (Stafford, 2006). According to Parry Aftab, a Fort Lee, New Jersey, privacy lawyer who founded

WiredSafety.org to help keep kids safe from cyber-criminals, every year the nation's law enforcement officials have an estimated 6,000 cases involving teens victimized as a result of online activity ("Protecting Your Kids from Cyber-Predators," 2005). Among the convicted predators are ex-Disney executive Patrick Naughton (Dotinga, 2000) and Department of Homeland Security deputy press secretary Brian J. Doyle (Meserve, 2006).

According to *Wired.com*, in February 2006, Attorney General Richard Blumenthal of Connecticut announced a criminal investigation into the practice of MySpace after several underage girls in one part of the state were fondled or had consensual sex with adult men they met through the site. All the men involved had lied about their age on MySpace. Blumenthal called MySpace "a parent's worst nightmare" ("Scenes from the MySpace Backlash," 2006).

MySpace is not the only problem site. In 2005, nearly one-third of online teens (30 percent) said they had talked about meeting someone whom they have only met through the internet. One in four (27 percent) said they had talked online about sex with someone they never met in person. And nearly one in five (19 percent) reported knowing a friend who had been harassed or asked about sex online by a stranger. (Hempel and Lehman, 2005).

Nearly one in eight online teens (12 percent) had learned that someone they were communicating with online was an adult pretending to be younger. In comments quoted in *Business Week*, a parent expressed worry about the sexual content posted on social networking websites:

Facebook, xanga are tell all for teens but that is not always good. As I surf thru the sites with a false name listed and age, I learn where you live, what school you go to, and where you hang out. Good for me as a parent. Not good for predators etc. looking for a new conquest. Almost every my space site has someone as a friend it ms who is soliciting sex. Be it through pictures, name or site links. Ages are lied about by the girls. Older men hint about meeting up. I have . . . girls setting up meetings with people they have never met. Yeah some have met up and commented they met their husband. Well once you have a daughter or son and they hit 13 etc. are you gonna let them do that? Freedom of speech is fine but these sites have gone awry of the purpose. If they have one. So as a parent I say you will not let your child go free on these sites. (Hempel and Lehman, 2005).

Contrary to what most parents seem to think, most younger readers tended to believe they are responsible enough to go on these social networking websites. A 17-year-old high school student said:

After reading the comments posted before me, I have pretty much come to the conclusion that every single one of you are right in your own way. I am a 17-year-old high school student who uses MySpace frequently. I'd say 97 percent of the people on my friends list are people I actually know from school. The other 3% are either bands, family, or friends [whom I've met before] who live in Michigan. Sometimes after logging on, I think maybe I am wasting time! Maybe it's just some stupid trend or fad that will go away in the next couple of months, who knows? But all the same, it's a fun way to communicate with people. I certainly do not consider myself to be

an idiot-child who uses the internet to “hook up with hot guys”, I use it to simply talk with my friends. Why would I want to get caught up in something as dangerous as that, and run the risk of communicating with some sort of creepy, drugged out, online stalker? Though that’s what some kids do, it’s not all of us! Thanks.

Another teen spoke to all the upset parents:

Parents: You are never going get us off MySpace, no matter how hard you try. Nobody will stop me from using it, even if you do block it at school. Teens do what they want, and parents trying to stop them only makes them more rebellious. Please stop being all: “Oh my God my child is talking to a child molester.” We’re not stupid, although a very small percent is.

Despite these reassurances, the case of Justin Berry is enough to frighten almost any parent and/or child advocate. At this writing, Justin Berry is a 19-year-old young man. When he was 13, he set up a webcam on his computer. One day while he was online, a man offered him \$50 to take off his shirt. It seemed harmless to Justin at the time, and \$50 was a lot of money for a 13-year-old. So he did. Little did Justin know that was the first step toward becoming a self-made internet porn star. Over the next five years, with the help of his father, Justin developed an online child pornography business. He wanted to get out but could not. Finally in June of 2005, with the help of *New York Times* reporter Kurt Eichenwald, Justin left the business. On April 4, 2006, Justin Berry testified before Congress on the sexual exploitation of children over the internet. He wanted his story to inform people about the evils of child predators and hoped to help law enforcement combat this evil. He also provided law enforcement a list of 1,500 men who registered on his website.

Justin’s story is an extreme example of how criminals can use the internet and how vulnerable children are in the digital age. Justin especially mentioned the potential danger of webcams and instant-messaging in his testimony:

Webcams and instant-messaging give predators power over children. The predators become part of that child’s life. Whatever warnings the child may have heard about meeting strangers, these people are no longer strangers. They have every advantage. It is the standard seduction of child predators multiplied on a geometric scale. (Berry, 2006).

10. (“Frequently Asked Questions,” 2006).

11. According to MySpace, some 22 percent of its registered users are under 18, and the websites forbid minors younger than 13 years of age from joining. This restriction results from COPPA. MySpace also provides protections for those who are 14 and 15 by setting their profiles as private; only friends have access to private profiles. MySpace profiles and flags members likely to be under 14 and deletes thousands of profiles. Their safety tips page reads: “If you are under 14, go away!” However, in light of the purpose of the site, child users under 13 quickly recognize that to participate fully in the space they need only lie about their age because no independent verification method exists.

12. (Armstrong and Casement, 2000).

13. (“Protecting Your Kids from Cyber-Predators,” 2005). Some parents may also

feel reluctant to restrict access to the internet. When the child is online in his or her own room, parental monitoring could be construed in some families as a form of breaching the child's privacy.

14. (Piaget, 1926; Flavell, 1963; Flavell and Ross, 1981).

15. They are observed to execute this with such regularity and efficiency that attachment theorists like the late Mary Ainsworth and colleagues argued that internalized biological mapping for species-specific survival is linked to the proximity-seeking behaviors of infants and toddlers (Ainsworth, Bell, and Stayton, 1974; Ainsworth et al., 1978). Similarly, the "reunion" behaviors that are observable when children are reunited with cherished caregivers, usually parents, are thought indicative of biologically encoded survival mechanisms. By age 3.5, however, children are observed to no longer simply adjust their behavior after parental actions; rather, without any verbal exchanges or commentary, they are seen to *anticipate* parental moves, and to adjust their behaviors accordingly. We in the child development field recognize such actions as evidence of the child's increased capacity for decentering.

16. Preschool and kindergarten teachers devote many minutes during the day to fostering interdependence, mutual responsibility, respect, and sharing among the class members. Young children are known to be especially intolerant of peers who seem to be self-centered—that is, who act as if they alone count. Importantly, in the child development field, young children who have not yet "decentered" are not considered selfish. Rather, their behaviors are understood to be age-related and are expected to wane with time, biological maturation, and social inputs.

17. The "me too" initiative takes on new meaning in such contexts.

18. Teachers are very cognizant of the utility of schoolchildren's tendencies toward social comparison. In classroom management, they rely heavily on children's strong preferences to be as academically, socially, personally, and even physically competent as their peers. In cultures like our own, observable differences (such as age and sex) even become the basis of social control in classrooms and schools. Well before early adolescence, parents dread and bemoan the phrase, "But [so-and-so] can do it, why can't I?"

19. Amy Jordan, a colleague of the first author at the University of Pennsylvania, provides the following commentary in an April 2006 special issue of the *Archives of Pediatrics and Adolescent Medicine*:

The research presented in this special issue . . . clearly illustrates that the media have a disturbing potential to negatively impact many aspects of children's healthy development, including weight status . . . sexual initiation . . . aggressive feelings and beliefs . . . and social isolation. . . . Such evidence offers increasing support for the American Academy of Pediatrics' recommendation that children over the age of two spend no more than two hours per day with screen media, preferably educational screen media. . . . We are clearly becoming more creative and sophisticated in how we study the problem, and more nuanced in the ways we think about audiences. Despite these advances, those who work in this field must continue to grapple with difficult issues. First, there is no gold standard for a measure of media exposure that is thoroughly tested and widely accepted. . . . A second important challenge

facing the field is the changing landscape of the media environment. . . . Finally, for decades we have known that excessive media use and exposure to problematic content is detrimental to children's healthy development. Despite this fact, we have been slow to develop interventions that are evaluated and replicated across a variety of settings." (Jordan, 2006, 446–48).

Jordan points out that the authors of journal articles differ in how they measure exposure to TV. Therefore, mixed or conflicting research findings could be attributed to measurement procedures (e.g., defining TV viewing as "reported hours per day" versus "hours that child is awake while the TV is turned on"). She reports that the rise of hundreds of TV channels and niche programming makes content analyses of "snapshots" a superficial approach to understanding precisely what children might be learning from the TV viewing that they do. Finally, she reports that interventions are likely to have little impact so long as parents, pediatricians, and schoolteachers believe that they can have no effect on children's TV exposure.

20. (Jordan, 2004), 103. As a senior research investigator with the Annenberg Public Policy Center, Jordan has spent the past ten years attempting to both understand and affect the broadcasting industry relative to children's programming.

21. (Jordan, 2004).

22. (Jordan, 2004), 103.

23. (Jordan, 2004).

24. Following the introduction of television, probably the most important technological breakthrough has been the development of information technology. Indeed, information technology is perhaps the single most important development of the twentieth century. In the early 1980s, Alvin Toffler anticipated that information and communication technology would dramatically change the world. (Toffler, 1981). Since then, computers, especially with the help of the World Wide Web, have brought radical social changes greater than any previous technological revolution. ("A Decade of Adoption," 2005):

A decade [after browsers came into popular use], the Internet has reached into—and, in some cases, reshaped—just about every important realm of modern life. It has changed the way we inform ourselves, amuse ourselves, care for ourselves, educate ourselves, work, shop, bank, pray and stay in touch (Kline, 2004).

Researchers and educators are conflicted about the evolutionary change the internet promised. On the one hand, it is believed to be associated with a greater degree of freedom and democracy for all citizens. On the other, it has posed new challenges for the safety and protection of vulnerable youth.

25. Because of the interactivity and connectedness of the internet, learning online is more student-centered and autonomous than classroom learning. Students are able to access information and assistance through the internet, as well as create Web content themselves. On the internet, students have control over what they learn and how they learn it. Knowledge is constructed without top-down control by mass media and teachers and textbooks (think about how Web logs or "blogs" have changed our way of getting the news). The new generation of children, much more fluent in technology

than their parents will ever be, are making their own culture in the virtual space. Quite literally, they are the masters of the “Republic of the Internet.”

Nonetheless, much more work is needed to better utilize the internet as a learning tool in classrooms, including teacher training, curriculum development, student assessment, and enhancing school reform efforts. A number of studies have suggested that learning through the internet can enhance students’ verbal skills, creativity, motivation, metacognition, and other specific subject matters (Roschelle et al., 2000; Kline, 2004).

26. (Teens and Technology,” 2005).

27. (Kline and Botterill, 2001).

28. While youngsters enjoy the excitement, the convenience, and the freedom the internet has brought, their extensive use of it has raised issues such as copyright piracy, privacy, pedophilia, pornography, racism, hate speech, gambling, and stalking (Berry, 2006). Therefore, many believe there is an urgent need to regulate the internet to protect children and youth from the growing possibilities of being victimized. Ironically then, the individual’s freedom in virtual space has to be regulated to ensure that the majority can enjoy its benefits.

29. Philadelphia District Attorney Lynne Abraham pointed out the cruel reality: “Online info-sharing capacities are so tremendous that it is virtually impossible to keep information about ourselves private.” (Ta, 2006). An individual’s personal information is quite accessible to anyone who wants it badly enough. Thus a total stranger can know as much as or even more about an individual than the person himself or herself.

29. In their book *The Right to Privacy* (1995), Alderman and Kennedy dedicated one chapter to “informational privacy.” Even though the chapter was published more than a decade ago, its contents are still relevant to contemporary American society. Alderman and Kennedy state:

Perhaps the scariest threat to privacy comes in the area known as “informational privacy.” Information about all of us is now collected not only by the old standbys, the IRS and FBI, but also by the MTB, MIB, NCOA, and NCIC, as well as credit bureaus, credit unions, and credit card companies. We now have cellular phones, which are different from cordless phones, which are different from what we used to think of as phones. We worry about e-mail, voice mail, and junk mail. And something with the perky name Clipper Chip—developed specifically to allow governmental eavesdropping on coded electronic communications—is apparently the biggest threat of all. (Alderman and Kennedy, 1995, 223).

30. (“Protecting Teens Online,” 2005).

31. (Polly Klaas Foundation, 2005).

32. (“Teen Content Creators and Consumers,” 2005).

33. (Armstrong and Casement, 2000).

34. (Erikson, 1968).

35. (Calvert, Jordan, and Cocking, 2002).

36. Harry Potter has become so popular among children that he alone generated worldwide sales of 250 million books. The first three Harry Potter movies earned almost £1 billion at the global box office. The fourth movie again was a hit, and a number of

others may well follow. DVDs and videos have generated sales of about £430 million. There are more than 400 items of Harry Potter merchandise on the market. The brand valuation is estimated at £2.2 billion. (Simmons, 2005). When “cool” characters in the media become part of real-life culture, the products that are associated with them generate huge profits.

37. (“Protecting Teens Online,” 2005).

38. For example, filters frequently fail to distinguish between indecent material and information materials, e.g., by filtering out everything containing the word “breast,” including “breast cancer.”

39. (“Protecting Teens Online,” 2005).

40. (Kline and Botterill, 2001).

41. (“Protecting Teens Online,” 2005).

42. By itself, social comparison is an essentially disinterested process that facilitates cultural transmission; it is very likely also a biologically encoded process that ensures an appreciation for effective inter-individual dependence. We think that at this juncture in American history children’s vulnerability to electronic media is precisely because twenty-first-century tools are considerably less subject to ongoing and intuitive adult intervention and regulation. In fact, parents are challenged to keep pace with the sheer mechanics, to say nothing of the ideations and values expressed, of these digital media.

43. (Hempel and Lehman, 2005).

44. (Hempel and Lehman, 2005).

45. Another presently immature technology is “zoning.” By assigning separate domains and screening age online, zoning can keep children away from adult content websites, hence permitting consensual and voluntary self-regulation. However, currently there is no satisfactory technique for specifying internet users’ age online. In addition, identifying adult-content websites with a separate domain, such as .XXX, would only make these sites easier to locate. Appropriate legislation thus awaits further technological advances and breakthroughs. See also (Solove, 2004).

46. (Rubin and Lenard, 2002).

47. (Burbules and Carllister, 2000). Solove argues that future privacy law should focus on people’s relationships with bureaucracies. (Solove, 2004).

48. Awareness is increasing. A 2008 conference sponsored by Princeton University’s Woodrow Wilson School of Public and International Affairs, together with the Educational Research Section, the Future of Children, and the Princeton Program in Teacher Preparation addressed “Students and Electronic Media: Teaching in the Technological Age.” And the topic of a spring 2008 special issue of *The Future of Children* was “Children and Electronic Media,” edited by Jeanne Brooks-Gunn and Elisabeth Hirschborn Donahue.

Chapter 9

1. (American Law Institute, 2005).

2. (National Conference of Commissioners on Uniform State Laws, 2002).

3. (American Law Institute, 2005).

4. (Varian, 2000). Varian notes that “[s]ecurity researchers have tended to focus on the hard issues of cryptography and system design. By contrast, the soft issues revolving around the use of computers by ordinary people and the creation of incentives to avoid fraud and abuse have been relatively neglected. That needs to be rectified.” See also the useful resources at (Anderson, n.d.).

5. In past work, I have explored the way in which tort law could be applied to promote cybersecurity. (Chandler 2003–2004; Chandler, 2006a, 2006b).

6. Other incentives may still exist, such as the protection of business reputation and goodwill.

7. See, e.g., the Ontario Consumer Protection Act, 2002, S.O. 2002, c.30, Appendix, § 9, which creates an implied warranty that services will be of a “reasonably acceptable quality” and provides that both the implied warranty for services and the implied warranties and conditions under the Ontario sale of goods legislation are non-waivable in consumer agreements.

8. 17 U.S.C. § 1201.

9. (Simons, 1996).

10. The license terms for the SQL Server 2005 Express and the SQL XML 4.0 are available for download on Microsoft’s website: “Microsoft Software License Terms—Microsoft SQL XML 4.0” http://download.microsoft.com/documents/useterms/SQLXML_4.0_English_79850836-b3ba-4195-b8d2-b72b573b1270.pdf, “Microsoft Software License Terms—Microsoft SQL Server E2005 Express Edition,” http://download.microsoft.com/documents/useterms/SQL%20Server%20Express_2005_English_b432ae7e-417a-4847-b779-34d6dea77163.pdf. The license for the WGA Notification application is not available on Microsoft’s site, but can be accessed at Ed Foster’s Gripe-wiki, “Microsoft Pre-Release Software License Terms—Windows Genuine Advantage Validation Tool,” http://www.gripegwiki.com/index.php/Microsoft_Windows_Genuine_Advantage_Validation_Tool.

11. (End User Agreement for VMWare Player, n.d.).

12. (Evers, 2005g).

13. (Eckelberry, 2005).

14. (Eckelberry, 2005). It appears that SpyMon is no longer available. The SpyMon website (www.spymon.com/) states that SpyMon has been withdrawn from the market.

15. (*Spitzer v. Network Associates*, 2003).

16. (*Spitzer v. Network Associates*, 2003, 467).

17. (Spitzer, 2002; “Memorandum of Law,” n.d.).

18. (“Memorandum of Law,” 11, 12–13): “Such disclosure is particularly vital in the case of security software like VirusScan and Gauntlet, on which consumers and businesses rely to protect computers from viruses, hackers, and cyber-terrorists.”

19. (Respondent Network Associates’ Memorandum of Law, n.d.).

20. (Respondent Network Associates’ Memorandum of Law, n.d., 6).

21. (Respondent Network Associates’ Memorandum of Law, n.d., 2).

22. (*Spitzer v. Network Associates*, 2003, 470).

23. The “marketplace of ideas” theory of John Stuart Mill justifies free speech by its

greater likelihood of generating “the truth.” Mill wrote that “the peculiar evil of silencing the expression of an opinion is that it is robbing the human race, posterity as well as the existing generation—those who dissent from the opinion, still more than those who hold it. If the opinion is right, they are deprived of the opportunity of exchanging error for truth; if wrong, they lose, what is almost as great a benefit, the clearer perception and livelier impression of truth produced by its collision with error.” (Mill, 1974). Alexander Meiklejohn’s “democratic self-governance” argument defends free speech as essential to collective self-governance. (Meiklejohn, 1965). Further evidence of this thinking is found in Justice Brennan’s statements in (*Board of Education v. Pico*, 1982) where he wrote that the ability to receive information and ideas is “an inherent corollary of the rights of free speech and press” because “the right to receive ideas is a necessary predicate to the recipient’s meaningful exercise of his own rights of speech, press and political freedom.”

24. (Delio, 2002), quoting Network Associates’ general counsel, Kent Roberts: “Our past experience is that reviewers will sometimes have out-of-date versions of products, which is especially critical with our products because they’re updated monthly if not sooner.”

25. (Becker, 2003), quoting Mercury analyst Dean McCarron as stating that the manipulation of benchmark testing is common in the PC industry.

26. (Simons, 1996, 169; E. Foster, 2002).

27. *Consumer Reports* offers basic comparisons of the features of anti-virus, anti-spam, and anti-spyware programs dated September 2005 at <http://www.consumerreports.org/cro/electronics-computers/index.htm>.

28. (Oakley, 2005, 1097): “Terms in non-negotiated licenses that purport to limit these free-speech-related rights should be unenforceable as against an important public policy.”

29. (AFFECT, n.d.).

30. (Uniform Computer Information Transactions Act, 2002).

31. (“12 Principles for Fair Commerce,” 2005, Principle X).

32. (Uniform Computer Information Transactions Act, 2002, § 105(c)).

33. (Uniform Computer Information Transactions Act, 2002, § 105, cmt. 4).

34. (Evers, 2006a, 2006b).

35. (Evers, 2006a).

36. (Evers, 2006b).

37. (“Microsoft Anti-Piracy Program,” 2006).

38. The frequency with which the WGA Notification application checks in with Microsoft was changed to every two weeks. (Evers, 2006c).

39. (Braucher, 2006).

40. (Samuelson and Scotchmer, 2002), noting the definition from *Kewanee Oil Co.* (*Kewanee Oil Co. v. Bicron Corp.* 1974, 476): Reverse engineering is the process of “starting with the known product and working backward to divine the process which aided in its development or manufacture.”

41. (Samuelson and Scotchmer, 2002, 1577): “Reverse engineering has a long history as an accepted practice. . . . Lawyers and economists have endorsed reverse engineering

as an appropriate way to obtain such information, even if the intention is to make a product that will draw customers away from the maker of the reverse-engineered product. Given this acceptance, it may be surprising that reverse engineering has been under siege in the past few decades.”

42. (Samuelson and Scotchmer 2002, 1614; Oakley, 2005, 1095 and 1098).

43. (Sookman, 2006).

44. (Samuelson and Scotchmer, 2002, 1608–13; Loren, 2004; *Sega Enterprises, Ltd. v. Accolade, Inc.*, 1992; *Sony Entertainment Inc. v. Connectix Corp.*, 2000).

45. (*Bowers v. Baystate Technologies Inc.*, 2003; *Davidson & Assocs. v. Jung*, 2005).

46. (Zetter, 2005c).

47. (Evers, 2005q).

48. (Zetter, 2005h).

49. (Bank, 2005; Garza, 2005; Zetter, 2005i).

50. (Bank, 2005).

51. (Zetter, 2005i).

52. (Jennifer Granick represented Lynn during the settlement negotiations and summarizes the legal thinking in her blog posting, which is reproduced in (Granick, 2005a).

53. (“White Hat,” 2006): “A white hat hacker, also rendered as ethical hacker, is, in the realm of information technology, a person who is ethically opposed to the abuse of computer systems.”

54. (Samuelson and Scotchmer, 2002, 1651): “[R]everse engineering has generally been a competitively healthy way for second comers to get access to and discern the know-how embedded in an innovator’s product. If reverse engineering is costly and takes time, as is usually the case, innovators will generally be protected long enough to recoup R&D expenses. More affirmatively, the threat of reverse engineering promotes competition in developing new products, constrains market power, and induces licensing that enables innovators to recoup R&D costs.”

55. (Samuelson and Scotchmer, 2002, 1651).

56. (Samuelson and Scotchmer, 2002, 1651).

57. (Samuelson and Scotchmer, 2002, 1657).

58. (Uniform Computer Information Transactions Act, 2002, § 118(c)).

59. (“12 Principles for Fair Commerce,” Principle IX, cmt. A).

60. (Respondent Network Associates’ Memorandum of Law, n.d., 2), stating that “irresponsible reporting of security software vulnerabilities has, according to many in the computer field, already exposed millions of consumers to serious risks.”

61. (Lemos, 2002).

62. (Fisher, 2005).

63. (Fisher, 2005), quoting the company’s statement: “Sybase does not object to publication of the existence of issues discovered in its products. However, the company does not believe that publication of highly specific details relating to issues is in the best interest of its customers. Sybase requires any third-party disclosure of issues discovered in Sybase products be done in accordance with the terms of the applicable Sybase product license.”

64. (Fisher, 2005).
65. Articles in the legal literature include: (Granick, 2005b; Swire, 2006; Swire, 2004; Preston and Lofton, 2002).
66. (Blaze, 2003), referring to (Hobbs, 1853).
67. (Blaze, 2003); (Lemos, 2005a), quoting software security researcher David Aitel: "We don't feel that we are finding things that are unknown to everyone else," he said. "I am not special because I can run a debugger. Others can find—and use—these flaws."
68. (Evers, 2005d).
69. (Evers and Reardon, 2005): "In the past, many hackers and security researchers outed glitches without giving much thought to the impact the disclosures would have on Internet users."
70. Various different policies and guidelines have been created. For example, version 2 of the "Guidelines for Security Vulnerability Reporting and Response" was released in 2004 by the Organization for Internet Safety (a group of security companies and software vendors) and is available at <http://www.oisafety.org/index.html>. See also the list of vulnerability disclosure guidelines hosted at the website of the University of Oulu, Finland ("Vulnerability Disclosure Publications and Discussion Tracking, 2006).
71. (Evers, 2005e), reporting a German security researcher's complaint that Oracle had still not fixed serious flaws two years after he notified the company. This view is described as a "myth" by Oracle's chief security officer: "There's a myth about security researchers that goes like this: Vendors are made up of indifferent slugs who wouldn't fix security vulnerabilities quickly—if at all—if it weren't for noble security researchers using the threat of public disclosure to force them to act." Mary Ann Davidson maintains that preparing fixes takes time, and that software vendors do not need the threat of public disclosure to move as quickly as possible on preparing fixes. (Davidson 2005). See also (Evers and Reardon, 2005; Lemos, 2005a).
72. (Evers and Reardon, 2005).
73. Cisco indicated that it would not charge royalties for use of the patent.(Reardon, 2004). See also (Evers and Reardon, 2005).
74. (eEye Digital Security, n.d.): "In the effort to track the responsiveness of the vendors involved, eEye produces an advisory timeline, the details of which can be viewed below. eEye expects the vendor to provide remediation for these flaws within 60 days of notification. After 60 days, these flaws are considered 'Overdue.' As a service to the network security community, eEye provides general information about these discoveries, including vendor, description and affected applications and operating systems. Once the flaws have been rectified, eEye will provide a detailed advisory for it."
75. (Evers, 2005c; Lemos, 2006b).
76. ("Verisign iDefense Services," n.d.; "Zero Day Initiative," n.d.).
77. (Lemos, 2003).
78. For example, the iDefense website states that "[c]ontributors provide iDefense exclusively with advance notice about the vulnerability or exploit code. If the vendor has not been previously contacted, iDefense will work with contributors to determine the

appropriate process. After an agreed-upon amount of time has passed, contributors are free to distribute the submitted information to a public forum and/or contact the affected vendors themselves, assuming they have not already requested iDefense to do so.” However, at least one researcher wonders whether iDefense will really work diligently to fix the flaw. (Evers, 2005c). Tipping Point’s Zero Day Initiative states, “3Com will make every effort to work with vendors to ensure they understand the technical details and severity of a reported security flaw. If a product vendor is unable to, or chooses not to, patch a particular security flaw, 3Com will offer to work with that vendor to publicly disclose the flaw with some effective workarounds. In no cases will an acquired vulnerability be ‘kept quiet’ because a product vendor does not wish to address it.” (Tipping Point, n.d.).

79. (Lemos, 2005a).

80. (Davidson, 2005).

81. (Evers and Reardon, 2005): “‘Security researchers provide a valuable service to our customers in helping us to secure our products,’ said Stephen Toulouse, a program manager in Microsoft’s security group.”

82. (Evers, 2005c). (Granick 2005b), reporting in Part II of her article that participants at a Stanford conference on Cybersecurity, Research and Disclosure “know researchers who are paid to find network vulnerabilities for exploitation by spammers.”

83. (Lemos, 2005b): “Turning to auctions to maximize a security researcher’s profits and fairly value security research is not a new idea, Hoglund said. Two years ago, he had reserved the domain ‘zerobay.com’ and intended to create an auction site, but worries over liability caused him to scuttle the plan a few days before the site went live, he said.”

84. (Lemos, 2005b).

85. (Meunier, 2006).

86. (Meunier, 2006).

87. (Granick, 2006b); (Lemos, 2006a).

88. (Lemos, 2006a).

89. (Lemos, 2006a).

90. Loi pour la confiance dans l’économie numérique, n 2004–575 du 21 juin, 2004, art. 46 I, *Journal Officiel* du 22 juin 2004. The text contains the author’s amateur translation of the French Code Pénal, art. 323-3-1. The original provides: “Le fait, sans motif légitime, d’importer, de détenir, d’offrir, de céder ou de mettre à disposition un équipement, un instrument, un programme informatique ou toute donnée conçus ou spécialement adaptés pour commettre une ou plusieurs des infractions prévues par les articles 323-1 à 323-3 est puni des peines prévues respectivement pour l’infraction elle-même ou pour l’infraction la plus sévèrement réprimée.”

91. (K-Otik Staff, 2004).

92. 17 U.S.C. § 1201, 1203, 1204.

93. (EFF, 2006).

94. (Russinovich, 2005).

95. (Submission by Ed Felten and J. Alex Halderman to the U.S. Copyright Office, 2005).

96. (Rusinovich, 2005).
97. (Rusinovich, 2005).
98. (Borland, 2005c).
99. (Schneier, 2005).
100. (Borland, 2005d).
101. (Borland, 2005a).
102. (Borland, 2005c).
103. (Felten, 2005b).
104. (Felten, 2005a; Halderman and Felten, 2005).
105. (Halderman and Felten, 2005).
106. (Halderman, 2005b).
107. (Halderman, 2005b).
108. (Halderman, 2005b): "If you visit the SunnComm uninstaller Web page, you are prompted to accept a small software component—an ActiveX control called AxWebRemoveCtrl created by SunnComm. This control has a design flaw that allows any website to cause it to download and execute code from an arbitrary URL. If you've used the SunnComm uninstaller, the vulnerable AxWebRemoveCtrl component is still on your computer, and if you later visit an evil website, the site can use the flawed control to silently download, install, and run any software code it likes on your computer. The evil site could use this ability to cause severe damage, such as adding your PC to a botnet or erasing your hard disk."
109. (Borland, 2005b).
110. (Broache, 2006). See also Mark Lyon's Sonysuit.com website for a listing of various legal actions brought against Sony BMG, <http://sonysuit.com/>.
111. (Schneier, 2005).
112. (Schneier, 2005).
113. (Schneier, 2005).
114. (Borland, 2005c).
115. (Submission by Ed Felten and J. Alex Halderman to the U.S. Copyright Office, 2005).
116. (Marson, 2005).
117. (Lohmann, 2006).
118. (McMullan, 2006).
119. 17 U.S.C. § 1201(g)(2)(C).
120. 17 U.S.C. § 1201(g)(2)(B).
121. 17 U.S.C. § 1201(g)(3)(B). One of the factors to be considered is "whether the person is engaged in a legitimate course of study, is employed, or is appropriately trained or experienced, in the field of encryption technology."
122. 17 U.S.C. § 1201(g)(3)(A). Another factor to be considered is "whether it was disseminated in a manner reasonably calculated to advance the state of knowledge or development of encryption technology, versus whether it was disseminated in a manner that facilitates infringement under this title or a violation of applicable law other than this section, including a violation of privacy or breach of security."

123. 17 U.S.C. § 1201(j).
124. 17 U.S.C. § 1201(3).
125. (Rasch, 2002; McWilliams, 2002a).
126. (McCullagh, 2002).
127. *Copyright Act*, 1985.
128. Bill C-60, *An Act to Amend the Copyright Act*, 2004–2005.
129. Bill C-60, *An Act to Amend the Copyright Act*, 2004–2005, § 27, containing the proposed § 34.02(1).
130. Bill C-60, *An Act to Amend the Copyright Act*, 2004–2005, § 27, containing the proposed § 34.02(2).
131. Bill C-60, *An Act to Amend the Copyright Act*, 2004–2005, § 27, containing the proposed § 34.02(3).
132. Government of Canada, “Copyright Reform Process: Frequently Asked Questions” <http://strategis.ic.gc.ca/epic/internet/incrp-prda.nsf/en/rp01146e.html>: “The protections for TMs [technological protection measures] contained in this bill will apply consistently with the application of copyright. That is, the circumvention of a TM applied to copyrighted material will only be illegal if it is carried out with the objective of infringing copyright. Legitimate access, as authorized by the *Copyright Act*, will not be altered. These measures will not affect what may already be done for the purposes of security testing or reverse engineering.”
133. (Letter from the Digital Security Coalition to the Canadian Ministers of Industry and Canadian Heritage, 2006).
134. (Nowak, 2008).
135. (Granick, 2005b, Part V).
136. (Granick, 2005, Part III(1)).
137. (Swire, 2004).
138. (Swire, 2004, 186).
139. Granick takes this position: “In the context of computers, secrecy is unlikely to benefit security more than openness does, and may harm it. This is because there is no practical difference between security tools and attack tools, because the economics of attack are such that vulnerabilities do not remain secret for long, and because defenders find vulnerability information at least as useful as attackers do.” (Granick, 2005b, Part IV).
140. (“12 Principles for Fair Commerce in Software,” 2005, Principle III).
141. (Foster, 2006).
142. (Skype, n.d.).
143. (Braucher, 2006, 12). Braucher suggests that compliance with the defect disclosure principle would be encouraged if sellers were held liable for the consequential damages caused should they decide not to disclose known flaws that pose significant risks of causing foreseeable harm.
144. (“12 Principles for Fair Commerce in Software,” 2005, Principle III, cmt. D).
145. (“12 Principles for Fair Commerce in Software,” 2005, Principle III, cmt. B).
146. (“12 Principles for Fair Commerce in Software,” 2005, Principle III, cmt. C).

147. See the list of vulnerability disclosure guidelines collected at the website of the University of Oulu, Finland (“Vulnerability Disclosure Publications,” 2006).

148. Other examples include the deliberate inclusion in software of “backdoors,” software that surreptitiously communicates with a remote third party, or software that obtains users’ “consent” to disable or remove other programs (including security programs). For example some “adware” programs obtain user “consent” to remove or disable anti-spyware software. (Cave, 2002; Edelman, 2005).

149. (Adware, 2005): “Adware or advertising-supported software is any software package which automatically plays, displays, or downloads advertising material to a computer after the software is installed on it or while the application is being used.”

150. (W. Davis, 2006).

151. (Borland, 2005c).

152. (Felten, 2005b).

153. (Felten, 2005a; Halderman and Felten, 2005).

154. See endnotes 33 to 39 and associated text.

155. See endnotes 33 to 39 and associated text.

156. (“12 Principles for Fair Commerce in Software,” 2005, Principle VI).

157. (“12 Principles for Fair Commerce in Software,” 2005, Principle VI, cmt. G): “Customers must be able to uninstall or otherwise remove the product.”

158. (Larkin, 2006).

159. (Krebs, 2003).

160. End users are encouraged to permit automatic updates to both download and install the updates on a regular schedule. Those with administrator privileges may opt to receive notifications only or to control the installation of the downloaded updates.

161. (Schneier).

162. (Windows Update FAQ, n.d.).

163. (Evers, 2006a).

164. (Greene, 2002; Forno, 2002; Orlowski, 2002).

165. (Greene, 2002).

166. (Forno, 2003).

167. (“12 Principles for Fair Commerce in Software,” 2005, Principle VI; Principle III, cmt. E).

168. (Edelman, 2004).

169. (Edelman, 2004).

170. For further information about one class of attacks, see (Evers, 2005b), discussing DNS cache poisoning and “pharming.” See also (Zoller, 2006).

171. Mastercard provides that American and Canadian cardholders are not liable for unauthorized use of their cards as long as they meet certain conditions. The U.S. website is at www.mastercard.com/us/personal/en/cardholderservices/zeroliability.html and the Canadian website is at www.mastercard.com/canada/education/zero/index.html.

172. See, e.g., the section of the Visa website devoted to “Operations and Risk Management” for “Small Business and Merchants.” Visa states that the major challenge facing the “card-not-present merchant” is fraud: “When a card is not present—

with no face-to-face contact, no tangible payment card to inspect for security features, and no physical signature on a sales draft to check against the card signature—your fraud risk rises. You could end up with lost revenue, higher operational costs, and potentially even [lose] your ability to accept payment cards.” <http://www.usa.visa.com/business/?it=gbl/ISmall%20Businesses%20%26%20Merchants>.

173. (Zeller, 2005).

174. (Zeller, 2005).

175. (Zeller, 2005).

176. (Naraine, 2001).

177. (Naraine 2001).

178. Marketscore distinguishes its software from spyware or adware, describing it as “researchware.” See (*Marketscore*, n.d.).

179. (Roberts, 2004): “Experts like Edelman concede that ComScore discloses what the Marketscore program does prior to installation. However, he and others say the program circumvents other organizations’ website security by acting as a “man in the middle” that intercepts, decrypts, tracks and analyzes users’ behavior.”

180. (“Privacy and User License Agreement,” n.d.).

181. (“Privacy and User License Agreement,” n.d.).

182. (*ProCD Inc. v. Zeidenberg* 1996; *Paterson Ross and Santan Management Ltd. v. Alumni Computer Group Ltd.* [2000] M. J. No. 630 (Man. Q.B.) (refusing to follow *North American Systemshops Ltd. v. King* [1989] A.J. No. 512 (Alta. Q.B))).

183. (Amended Complaint, *Baker and Johnson v. Microsoft Corp. et al.*, 2003).

184. (Amended Complaint, *Baker and Johnson v. Microsoft Corp. et al.*, 2003, 4, 6–7).

185. (Braucher, 2000), noting the author’s finding that 87.5 percent of the 100 largest personal computer software companies did not make pre-transaction disclosure of their terms. (Rodriguez, n.d.): “None of the 43 major software companies studies] seemed interested in making licensing terms readily available to consumers prior to software purchase.”

186. (E. Foster, 2004).

187. (Braucher, 2006, 7; Braucher, 2004), noting that “[d]uring the UCITA drafting process, software producers fought hard against advance disclosure of terms. They were reduced to arguing that it would be too hard to put their terms on their websites. Lawyers for the Business Software Alliance, funded by Microsoft, worried aloud about the poor small software producers who might not even have websites. An exception for those without websites could have been designed, of course. The independent developers in attendance found this show pretty hysterical.”

188. (American Law Institute 2005, § 2.01 and 2.02).

189. (Hillman and Rachlinski, 2002; Korobkin 2003). PC Pitstop ran an experiment in which it included a clause in its EULA promising a financial reward to anyone who read the clause and contacted the company. It took four months and over 3,000 downloads before someone contacted the company for the reward. (Magid, n.d.).

190. These factors are summarized by (Hillman and Rachlinski, 2002, 435–36).

191. (Hillman and Rachlinski, 2002, 436).

192. (Korobkin 2003, 1208–16): “Standard economic reasoning suggests that form contract terms provided by sellers should be socially efficient. Less obviously, economic reasoning also leads to the conclusion that those terms will be beneficial to buyers as a class, in the sense that buyers would prefer the price/term combination offered by sellers to any other economically feasible price/term combination. These conclusions are valid whether all, some or no buyers shop multiple sellers for the best combination of product attributes and whether the market is competitive or dominated by a monopolist seller.” (Korobkin 2003, 1216).

193. (Korobkin, 2003). Part II discusses the insight that consumers are “boundedly rational” rather than “fully rational” in their behavior.

194. (Korobkin, 2003, 1217–18).

195. (Korobkin 2003, n.128; Braucher, 2006, 9): “Even a small number of customers shopping over terms can introduce some weak market policing,” citing (Schwartz and Wilde, 1983).

196. (Korobkin, 2003, 1237).

197. (Hillman and Rachlinski, 2002, 442–43).

198. (Hillman and Rachlinski, 2002, 442).

199. For example, Ed Foster is building a library of license agreements on his Grip-eWiki (http://www.gripewiki.com/index.php/EULA_Library): “The Grip-eWiki’s EULA library is a place to find, read, post, and discuss the terms of all manner of end user license agreements.” Ed Foster’s Grip-eWiki also collects postings by users about computer products and online services in a useful and organized form.

200. Braucher, 2006, 14: “In general, mass-market terms that restrict testing, comment, and study only directly affect a small fraction of customers and thus are unlikely to be driven out by market forces, but these activities should be preserved because of their indirect benefit to customers, as part of a culture of competition and innovation.”

201. For further discussion of “bots” and “botnets” see (Chandler, 2006b).

202. (*Restatement of the Law (Second), Contracts*, 1981 § 208): “If a contract or term thereof is unconscionable at the time the contract is made a court may refuse to enforce the contract, or may enforce the remainder of the contract without the unconscionable term, or may so limit the application of any unconscionable term as to avoid any unconscionable result.”

203. Uniform Commercial Code, § 2-302(1): “If the court as a matter of law finds the contract or any clause of the contract to have been unconscionable at the time it was made the court may refuse to enforce the contract, or it may enforce the remainder of the contract without the unconscionable clause, or it may so limit the application of any unconscionable clause as to avoid any unconscionable result.”

204. (Oakley 2005, 1064): “Although unconscionability is an available doctrine and is occasionally used, in fact the number of cases in which it has actually been found is relatively small. Moreover, it is an open question whether the issues raised in information contracts, for instance a denial of fair use, would shock the conscience, even though it is a fundamental principle of copyright law. As a consequence, where a

contract of adhesion is involved . . . unconscionability may just be too high of a standard to do the job.” See also (Loren, 2004, 509–10).

205. (Oakley, 2005, 1056).

206. UCC, § 2-302, comment 1.

207. *Restatement of the Law (Second), Contracts*, 1981, § 211, cmt. F).

208. *Restatement of the Law (Second), Contracts*, 1981, § 211(3)).

209. *Restatement of the Law (Second), Contracts*, 1981, § 211, cmt. F).

210. (Fridman, 1999; Gellhorn, 1935).

211. (Gellhorn, 1935, 684); *Restatement of the Law (Second), Contracts* (1981), chap. 8, “Unenforceability on Grounds of Public Policy,” introductory note.

212. These situations are described in the Canadian context as instances of “statutory illegality.” Section 178(1) of the *Restatement of the Law (Second), Contracts* provides that “[a] promise or other term of an agreement is unenforceable on grounds of public policy if legislation provides that it is unenforceable or the interest in its enforcement is clearly outweighed in the circumstances by a public policy against the enforcement of such terms.”

213. (Waddams, 1999).

214. Canadian contract law would describe these situations as cases of “common law illegality.” They are also covered in the *Restatement of the Law (Second), Contracts*, 1981, § 178(1).

215. (Gellhorn, 1935, 695).

216. (Gellhorn, 1935, 685; Fridman, 1999, 392); *Restatement of the Law (Second), Contracts*, § 179, cmt. B: “The declaration of public policy has now become largely the province of legislators rather than judges. This is in part because legislators are supported by facilities for factual investigations and can be more responsive to the general public.”

217. Waddams notes that the lists of “established” public policy grounds vary from author to author, with one suggesting nine and another twenty-two (Waddams, 1999, 403). Fridman recognizes the following: contracts to commit illegal acts (i.e., crimes or torts), contracts that interfere with the administration of justice (e.g., to stifle a prosecution), contracts injurious to the state (e.g., trading in public office), contracts that involve or encourage immorality, certain contracts affecting marriage, and contracts in restraint of trade (Fridman, 1999, 392–393).

218. *Restatement of the Law (Second), Contracts*, § 179, cmt. B.

219. (Waddams, 1999, 401–2): “An evolving society must, however, have changing values, and the law fails in its service to society if it cannot also evolve.”

220. (United States, 2003).

221. (Canada, 2004), announcing a commitment to develop a “National Cybersecurity Strategy.”

222. (Leff, 1969–1970).

223. (Leff, 1969–1970, 357).

224. In addition to general consumer protection legislation, which makes certain rights non-waivable (e.g., the Ontario Consumer Protection Act, 2002, S.O. 2002, c. 30, Appendix), sector-specific legislation applies to certain types of contracts. See the discussion in (Korobkin, 2003, 1247–48).

225. (Korobkin, 2003, 1250).
226. (Korobkin, 2003, 1251).
227. (Korobkin, 2003, 1251–52).
228. (Korobkin, 2003, 1278–79).
229. (Oakley, 2005, 1071).
230. (Braucher, 2006, 20).
231. (Braucher, 2006, 20–22).
232. (National Conference of Commissioners on Uniform State Laws, 2002, 1): “The law of software transactions is in disarray . . . Yet, because of its burgeoning importance, perhaps no other commercial subject matter is in greater need of harmonization and clarification.” (See also Braucher, 2006, 2).
233. (National Conference of Commissioners on Uniform State Laws, 2002, 1).
234. (Braucher, 2006, 6), writing that the ALI withdrew because of Article 2B’s “amorphous scope, complex and unclear drafting, overreaching into issues best left to intellectual property law, and a failure to require pre-transaction presentation of terms even in Internet transactions.”
235. (Braucher, 2006, 6).
236. (Braucher, 2006, 6).
237. (Braucher, 2006, 6).
238. (Braucher, 2006, 6–7). The ABA report is available at <http://www.abanet.org/leadership/ucita.pdf>.
239. (AFFECT, n.d.).
240. (Braucher, 2006, 7), referring to (Kaner, 2003).
241. AFFECT maintains an educational campaign website at <http://www.fairterms.org/>.
242. (Braucher, 2006, 8).
243. (“12 Principles for Fair Commerce in Software,” 2005): “Principle 1: Customers are entitled to readily find, review, and understand proposed terms when they shop”; “Principle 2: Customers are entitled to actively accept proposed terms before they make the deal.”
244. (“12 Principles for Fair Commerce in Software,” 2005): “Principle 3: Customers are entitled to information about all known, nontrivial defects in a product before committing to the Deal”; “Principle 4: Customers are entitled to a refund when the product is not of reasonable quality.”
245. (“12 Principles for Fair Commerce in Software,” 2005): “Principle 5: Customers are entitled to have their disputes settled in a local, convenient venue.”
246. (“12 Principles for Fair Commerce in Software,” 2005): “Principle 6: Customers are entitled to control their own computer systems”; “Principle 7: Customers are entitled to control their own data”; “Principle 8: Customers are entitled to fair use, including library or classroom use, of digital products to the extent permitted by federal copyright law”; “Principle 9: Customers are entitled to study how a product works”; “Principle 10: Customers are entitled to express opinions about products and report their experiences with them”; “Principle 11: Customers are entitled to the free use of public domain

information”; “Principle 12: Customers are entitled to transfer products as long as they do not retain access to them.”

247. (“FEULA,” n.d.).

248. (Korobkin, 2003).

249. UCITA has been criticized for leaving the control of license clauses to the doctrines of unconscionability and a weakened version of the doctrine of contracts contrary to public policy. Braucher points out that UCITA provides that a court may refuse to enforce a contract against a “fundamental” public policy, while the Restatement does not use the word “fundamental.” (Braucher, 2006, 7).

250. (“12 Principles for Fair Commerce in Software,” 2005, 3).

251. (“12 Principles for Fair Commerce in Software,” 2005, Principle VI, cmt. G, 6): “Customers must be able to uninstall or otherwise remove the product.”

252. (“12 Principles for Fair Commerce in Software,” 2005, Principle II, cmt. E).

253. (“12 Principles for Fair Commerce in Software,” 2005, Principle IX, 7).

254. (“12 Principles for Fair Commerce in Software,” 2005, Principle X, 8).

255. (“12 Principles for Fair Commerce in Software,” 2005, Principle VI, 5): “Sellers must take reasonable steps to ensure a product is free of viruses, spyware, and other malicious code or security problems that will compromise computer systems.”

256. (“12 Principles for Fair Commerce in Software,” 2005, Principle VI, cmt. D, 6): “If a product contains a virus or other harmful code, language limiting otherwise valid claims under applicable law for resulting damage should be ineffective.” Principle VI, cmt. C, p. 6: “Customers are entitled to adequate remedies in cases where sellers have not taken reasonable steps to secure the product from third-party interference.”

257. (“12 Principles for Fair Commerce in Software,” 2005, Principle III).

258. (“12 Principles for Fair Commerce in Software,” 2005, Principle III, cmt. D).

Chapter 10

1. (“Social Networking Service,” 2008).

2. (“Social Networking Sites,” n.d.).

3. (Lenhart and Madden, 2007).

4. (Livingstone, 2007).

5. (*LinkedIn*, 2008).

6. All figures about Facebook in this paragraph are taken from Broughton and Pople, 2007, based on Nielsen Net Ratings survey panel of approximately 40,000 persons in the UK only; survey released at *Poke 1.0*, London (Broughton and Pople, 2007).

7. (Livingstone, 2007).

8. (“EU Data Directive,” 1995).

9. Personal data refers to “any information relating to an identified or identifiable natural person (“data subject”)” where an identifiable person is “one who can be identified, directly or indirectly, in particular by reference to an identification number or to one or more factors specific to his physical, physiological, mental, economic, cultural or social identity.” (“EU Data Directive,” 1995, Article 2(a)).

10. (“EU Data Directive,” 1995, Article 2(a)).

11. "OECD Guidelines," n.d.).
12. ("EU Data Directive," 1995, Article 8).
13. (Gross and Acquisti, 2005).
14. ("EU Data Directive," 1995, Article 8(2)(e)).
15. (P. Foster, 2007).
16. Another "lurking" set of persons with access to a university "network" on Facebook are those who once had legitimate university email addresses but have since moved on. The writer of this chapter, now at Southampton University, is still a member in good faith of the Edinburgh University network on Facebook, on the basis of a now expired email address acquired from her former employers.
17. Although Facebook does restrict a user from belonging to more than one geographic network at a time. This would not, one imagines, deter the determined stalker.
18. By "granular" I mean that user X can choose, for example, to disclose his friends list to everyone, his picture and biographical details only to friends, and his email address to nobody. Compare the SNS Live Journal where a user can only choose to display the whole of a post or none of it certain groups of "friends."
19. This is true in part because of the approved social value of "openness" and its perceived advantages on SNSs—see further below.
20. (Gross and Acquisti, 2005).
21. COPPA refers to the Children's Online Privacy Protection Act of 2000, 15 U.S.C. §§ 6501-6506 (2000). Children's Online Privacy Protection Rule, 16 CFR Part 312 (2006). For a discussion of COPPA, see, for example, (Bernstein, 2005; Matwyshyn, 2005; Palmer and Sofio, 2006; Peek, 2006; Stuart, 2006).
22. (Lessig, 2000).
23. (Arthur, 2007).
24. (Livingstone, 2007).
25. (Barnes, 2006, 9), citing (Viegas, 2005).
26. (Barnes, 2006).
27. *Von Hannover v. Germany*, no. 59320/00, 2004-VI ECHR 294, available at www.echr.coe.int/eng.
28. Interestingly, following a number of complaints, the PCC commissioned a report into whether use by newspapers of information found on SNSs is abusive of privacy and should be a breach of the PCC Code. (Greenslade, 2008). In this context, the PCC may be viewed as being ahead of the courts.
29. (Dwyer, Hiltz, and Passerini, 2007).
30. The first UK prosecution for harassment explicitly involving Facebook was initiated in March 2008. (Williams, 2008).
31. (Ward, 2008).
32. (Shepard and Shariatmadari, 2008).
33. (Skinner, 2008), reporting a UK information commissioner's investigation in January 2008 into the persistence of Facebook profiles even after users tried to delete them.
34. Facebook profiles were originally not made available to Google spiders. However, Facebook took a decision to make profiles available to Google and other search

engines in September 2007. Users were given an opportunity to opt out of (rather than to opt *in* to) having their profiles indexed. See discussion in this writer's blog, (Edwards, 2007).

35. (Internet Archive, n.d.).

36. (UK Information Commissioner, 2007). One respondent to the survey (female, age 14) replied, "Initial thoughts—who cares? Subsequent thoughts—omg!"

37. ("Facebook Asked to Pull Scrabulous," 2008).

38. (Felt and Evans, n.d.). In October 2007, the authors performed a systematic review of the top 150 applications on Facebook: 8.7 percent needed no data at all to work; 82 percent used public data (e.g., name, list of friends), and only 9.3 percent needed access to private-by-default data (e.g., birth date). They concluded: "Since *all* of the applications are given full access to private data, this means that 90.7% of applications are being given more privileges than they need."

39. (R. Hoffman, 2007a).

40. (R. Hoffman, 2007b).

41. (McAfee Inc., 2007).

42. In a nice touch, the frog was named Freddi Staur, an anagram of "ID Fraudster."

43. (*Sophos*, 2007).

44. (European Network and Information Security Agency, 2007).

45. (Gross and Acquisti, 2005).

46. (Leyden, 2008).

47. (Leyden, 2008).

48. (Lauria, 2007).

49. (*Facebook*, 2008).

50. Anonymized aggregate data clearly can be sold according to the policy: "Facebook may use information in your profile without identifying you as an individual to third parties. We do this for purposes such as aggregating how many people in a network like a band or movie and personalizing advertisements and promotions so that we can provide you Facebook. We believe this benefits you. You can know more about the world around you and, where there are advertisements, they're more likely to be interesting to you. For example, if you put a favorite movie in your profile, we might serve you an advertisement highlighting a screening of a similar one in your town. But we don't tell the movie company who you are."

51. (*Facebook*, 2008). "Facebook Beacon is a means of sharing actions you have taken on third-party sites, such as when you make a purchase or post a review, with your friends on Facebook. In order to provide you as a Facebook user with clear disclosure of the activity information being collected on third-party sites and potentially shared with your friends on Facebook, we collect certain information from that site and present it to you after you have completed an action on that site. You have the choice to have Facebook discard that information, or to share it with your friends."

52. ("EU Data Directive," 1995, Article 2).

53. (Article 29 Working Party, n.d.).

54. (Claburn, 2007b).

55. (*Google*, 2008).
56. (*Google*, 2008).
57. (Federal Trade Commission, 2007).
58. ("EU Data Directive," 1995, Article 2).
59. (Cartwright, 2007).
60. (Wong, 2007), calling for a reconsideration of how "sensitive data" are categorized and regulated, especially in the context of the internet.
61. (European Network and Information Security Agency, 2007).
62. (Regan, 1995).
63. (Bennett and Raab, 2007).
64. (UK Information Commissioner, 2007).
65. (Schneier, 2006).
66. (Regan, 1995), 66.
67. ("EU Data Directive," 1995 Article 1).
68. It is true that in fact the DPD does not favor consent over other practices that justify processing of data, such as the "legitimate interests pursued by the controller" ("EU Data Directive," 1995, Article 7). However both the recitals and surrounding documentation, and the use of "explicit" consent as the main criterion for processing of *sensitive* personal data, indicate the conceptual if not legal primacy of consent. ("EU Data Directive," 1995 Recital 33).
69. (Apgar, 2006; Rauhofer, n.d.).
70. ("Directive on Unfair Terms in Consumer Contracts," 1993).
71. ("Unfair Terms in Consumer Contracts Regulations," 1999).
72. (*Marc Bragg v. Linden Research, Inc. and Philip Rosendale*, 2007).
73. (Electronic Privacy Information Center, n.d.).
74. (*Get Safe Online*, n.d.).
75. (Ramadge, 2008).
76. (Lessig, 1999).
77. (Burk, 2005; Reidenberg, 1998).
78. (Kesan and Shah, 2006, 596).
79. (Kesan and Shah, 2006, 596–97).
80. ("Directive on Privacy and Electronic Communications," 2002).
81. In the UK, Bebo, a leading SNS for young children, individually and manually vets the user profiles of every one of its young user base, to provide privacy and safety guarantees.
82. (Kesan and Shah, 2006).
83. Kesan and Shah themselves acknowledge cases when this is so. (Kesan and Shah, 2006).
84. (Mayer-Schoenberger, 2007).
85. (Schneier, 2006).
86. (European Network and Information Security Agency, 2007).
87. (Reed, 2007).

Conclusion

1. (Johnson, 2001).
2. For example, limitations built into computer code include digital rights management, and limitations imposed by law, include prohibitions on unauthorized access to computer systems. However, this is only one part of the dynamic portrait of information security today.
3. At least one noted legal scholar has highlighted the importance of considering bottom-up norms and legal emergence. (Radin, 2002). However, most scholarly work on internet regulation to date has focused on top-down governance. (Benkler, 2002; Lemley, 2003; Lessig, 2000; Samuelson, 2000; Zittrain, 2003). Various applications of complex systems theory to other legal contexts exist. (Post and Johnson, 1998), argued that legal theory would be enriched by paying attention to algorithms derived from the study of complex systems in contexts such as competitive federalism and the “patching” algorithm. See also (Beecher-Monas and Garcia-Rill, 2003; Brenner, 2004; Chen, 2004; Crawford, 2003; Creo, 2004; Emison, 1996; Farber, 2003; Geu, 1998; Goldberg, 2002; Hughes, 2004; Lewin, 1998; Martin, 1999; McClean, 2001–2002; Miller, 2000; Ruhl and Salzman, 2003; Ruhl, 1999; Ruhl, 1996; Salzman, Ruhl, and Song, 2002).
4. Organizational code differs from computer code as a method of regulation. Whereas computer code regulates on the individual level through stealthy imposition of the value of a creator, organizational code regulates on the person-society border and is inherently socio-behavioral in nature, arising out of aggregate behaviors.
5. For example, organizational code includes the behavioral, strategic, and legal responses of companies after the discovery of a serious vulnerability, the role of information security professionals’ and hackers’ behavioral norms in shaping the comparative power and strategies of actors within the system, and evolving information security contracting norms. In terms borrowed from Eric Raymond, organizational code can be said to be order developing through a babbling “bazaar” that permits norms to percolate to widespread acceptance, while legal code and, frequently, computer code develop order through a “cathedral” style where norms are hierarchically imposed. (Raymond, n.d.).
6. One company where the forces of security appear to be winning the information security culture war is, perhaps surprisingly, the Microsoft Corporation. Despite years of suboptimal security practices that resulted in lost customers and an FTC investigation related to children’s data security, a culture of security through process appears to be taking hold. Microsoft has called for national privacy legislation that is more aggressive than laws currently in place, a request supported by previously adversarial privacy groups. (Krebs, 2005).
7. (Ford and Richardson, 1994).
8. Transitive closure refers to all points reachable from a particular point in a network, directly or indirectly, whose behavior affects the behavior and risk profile of the initial point. (Kozma, n.d.).
9. HIPAA and GLBA attempt to recognize this transitivity of risk by requiring that entities that share statutorily protected data contractually impose data care obligations

onto their immediate trusted business partners. Thus stronger information security practices will presumably be transferred to the immediate business partners of entities subject to HIPAA and GLBA, the “neighborhood” of an entity. In other words, the entire neighborhood of HIPAA- and GLBA-compliant entities adopts a stronger focus on information security. However, neither statute contemplates transitive closure.

Bibliography

- Aaron, Benjamin, and Matthew Finkin. "The Law of Employee Loyalty in the United States." *Comparative Labor Law & Policy Journal* 20 (1999): 321, 339.
- Acara v. Banks*. No. 06-30356 (5th Circuit Court, November 13, 2006).
- "Addressing the New Hazards of the High Technology Workplace." *Harvard Law Review* 104 (1991): 1898, 1903.
- "A Decade of Adoption: How the Internet Has Woven Itself into American Life." *Pew Internet and American Life Project*. January 25, 2005. http://www.pewinternet.org/pdfs/Internet_Status_2005.pdf.
- "Advanced Encryption Standard Algorithm Validation List." <http://csrc.nist.gov/cryptval/aes/aesval.html> (accessed April 16, 2005).
- "Adware." *Wikipedia*. June 29, 2005. <http://en.wikipedia.org/wiki/Adware>.
- AFFECT*. <http://www.ucita.com/who.html>.
- Aftab, Parry. "How COPPA Came About." *Information Week*, January 19, 2004. <http://www.informationweek.com/story/showArticle.jhtml?articleID=17300888>.
- Ainsworth, Mary D. S., Silvia M. Bell, and Donelda J. Stayton. "Infant-Mother Attachment and Social Development." In *The Integration of a Child into a Social World*, edited by Martin P. M. Richards. Cambridge: Cambridge University Press, 1974.
- Ainsworth, Mary D. S., M. Biehar, E. Waters, and E. Wall. *Patterns of Attachment*. Hillsdale, NJ: Erlbaum, 1978.
- Air Prods. & Chem., Inc. v. Johnson*. 296 Pa. Super. 405, 417, 442 A.2d 1114, 1120 (1982).
- Alderman, Ellen, and Caroline Kennedy. *The Right to Privacy*. New York: Alfred A. Knopf, 1995.
- Allison, John R. "Valuable Patents." *Georgetown Law Journal* 92 (2004): 435, 437.
- Allison, John R., and Emerson H. Tiller. "Internet Business Method Patents." In *Patents in the Knowledge-Based Economy*, edited by Wesley M. Cohen and Stephen A. Merrill. Washington, DC: National Research Council of the National Academies, 2003.

- Altiris. *Patch Management Solutions*. <http://www.altiris.com/Products/PatchManagementSolution.aspx> (accessed March 10, 2008).
- Amended Complaint, Baker and Johnson v. Microsoft Corp. et al.*, No. CV 030612 (California Superior Court, May 1, 2003).
- American Bar Association v. Federal Trade Commission*, No. 02cv00810, No. 02cv01883 (D.C. Cir. 2005).
- American Law Institute. "Principles of the Law of Software Contracts." Preliminary Draft No. 2, 2005.
- Anderson, Ross J. *Security in Clinical Information Systems*. London: British Medical Association, 1996.
- . "Economics and Security Resource Page." <http://www.cl.cam.ac.uk/rja14/econsec.html>.
- . "Why Information Security Is Hard—An Economic Perspective." In *Proceedings of the 17th Annual Computer Security Applications Conference (ACSAC '01)*, December 10–14, 2001a, New Orleans, LA.
- . *Security Engineering: A Guide to Building Dependable Distributed Systems*. Hoboken, NJ: John Wiley & Sons, 2001b.
- Anti-Phishing Working Group*. <http://www.antiphishing.org/> (accessed March 10, 2008).
- Apgar, David. *Risk Intelligence*. Cambridge, MA: Harvard Business School Press, 2006.
- Armstrong, Alison, and Charles Casement. *The Child and the Machine: How Computers Put Our Children's Education at Risk*. Beltsville, MD: Robins Lane Press, 2000.
- Arrison, Sonia. "Canning Spam: An Economic Solution to Unwanted Email." San Francisco: Pacific Research Institute, 2004.
- Arthur, Charles. *Do Social Network Sites Genuinely Care About Privacy?* September 13, 2007. <http://www.guardian.co.uk/technology/2007/sep/13/guardianweeklytechnologysection.news1>.
- Article 29 Working Party. "Working Document on a Common Interpretation of Article 26(1) of Directive 95/46/EC of 24 October 1995." Working Party on the Protection of Individuals with Regard to the Processing of Personal Data, Set Up by Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995, WP 114, 2002. http://ec.europa.eu/justice_home/fsj/privacy/docs/wpdocs/2005/wp114_en.pdf (accessed January 20, 2008).
- AT&T v. Excel Communications*. 172 F. 3d 1352, 1353–4, 1360–61 (Fed. Cir., 1999).
- AutoPatcher. <http://autopatcher.com/> (accessed March 10, 2008).
- Baker & MacKenzie. *European Union Directive: Country by Country Comparison Table*. <http://www.bmck.com/ecommerce/directivecomp6.htm> (accessed August 12, 2002).
- Baldas, Tresa. "Hospitals Fear Claims over Medical Records." *National Law Journal* 29 (May 2007): 4.
- Bank, David. "Cisco Tries to Squelch Claim About a Flaw in Its Internet Routers." *WSJ.com*, July 28, 2005. http://online.wsj.com/public/article/SB112251394301198260-22gDRmLtWgPF5vKgFn1qYJBjaGo_20050827.html?mod=blogs.
- Barabasi, Alberto Laszlo. *Linked*. New York: Plume, 2002.

- Barnes, Susan. "A Privacy Paradox: Social Networking in the U.S." *First Monday* 11 (2006).
- Barney, Jonathan A. "A Study of Patent Mortality Rates: Using Statistical Survival Analysis to Rate and Value Patent Assets." *American Intellectual Property Law Association Quarterly Journal* 30 (2002): 317, 325, 331.
- Barry, A., T. Osbourne, and N. Rose, eds., *Foucault and Political Reason: Liberalism, Neo-liberalism, and Rationalities of Government*. Chicago: University of Chicago Press, 1996.
- Beard v. Akzona, Inc.* 517 F. Supp. 128, 132 (E.D. Tenn., 1981).
- Beattie, Steve, Seth Arnold, Crispian Cowan, Perry Wagle, and Chris Wright. "Timing the Application of Security Patches for Optimal Uptime." *Lisa Systems Administration Conference Proceedings*. 2002. <http://citeseer.ist.psu.edu/beattie02timing.html>.
- Becker, David. "Nvidia Accused of Fudging Tests." *CNET News.com*, May 23, 2003. <http://news.com.com/2100-1046-1009574.html>.
- Beecher-Monas, Erica, and Edgar Garcia-Rill. "Danger at the Edge of Chaos: Predicting Violent Behavior in a Post-Daubert World." *Cardozo Law Review* 24 (2003): 1848.
- Belgium eID Program. <http://eid.belgium.be/fr/navigation/12000/index.html> (accessed March 2008).
- Benkler, Yochai. "Intellectual Property and the Organization of Information Production." *International Revenue Law and Economics* 22 (2002): 81.
- Bennett, Colin, and Charles Raab. *The Governance of Privacy*. Cambridge, MA: MIT Press, 2007.
- Benson, Clea. "Computer Data on Home Care Breached." *Sacramento Bee*, October 20, 2004. <http://www.sacbee.com/content/news/medical/story/11152364p-12068658c.html>.
- Berinato, Scott. "The Global State of Information Security." *CIO Magazine*, August 28, 2007. <http://www.cio.com/article/133600>.
- Berner, Robert, and Adrienne Carter. "The Truth About Credit-Card Fraud." *Business Week*, June 21, 2005. http://www.businessweek.com/technology/content/jun2005/tc20050621_3238_tc024.htm.
- Bernstein, Gaia. "When New Technologies Are Still New: Windows of Opportunity for Privacy Protection." *Villanova Law Review* 51 (2005): 921.
- Berry, Justin. "What Parents, Kids and Congress Need to Know About Child Predators." Statement Before the U.S. House of Representatives Committee on Energy and Commerce. Hearing on Sexual Exploitation of Children over the Internet. 2006.
- BIEC Intern., Inc. v. Global Steel Servs., Ltd.*, 791 F. Supp. 489, 548 (E.D. Pa. 1992).
- Bill C-60, *An Act to Amend the Copyright Act*, First Session, Thirty-eighth Parliament, 53-54 Elizabeth II, 2004-2005. http://www.parl.gc.ca/38/1/parlbus/chambus/house/bills/government/C-60/C-60_1/C-60_cover-E.html.
- Bishop, Lynne "Sam," et al. *National Consumer Health Privacy Survey 2005*. California Health Care Foundation, 2005.
- Bishop, Todd. "Microsoft, Amazon.com File Anti-Spam Lawsuit." *Seattle Post-Intelligencer*, September 29, 2004.
- Blackhat*. <http://www.blackhat.com> (accessed March 10, 2008).

- Blaze, Matt. *Is It Harmful to Discuss Security Vulnerabilities?* January 2003. <http://www.crypto.com/hobbs.html>.
- BlueHat. Microsoft Corporation. <http://www.microsoft.com/technet/security/bluehat/default.msp> (accessed March 10, 2008).
- Board of Education v. Pico*. 457 U.S. 853 (1982).
- Bobb, Anne, et al. "The Epidemiology of Prescribing Errors: The Potential Impact of Computerized Prescriber Order Entry." *Archives of Internal Medicine* 164 (2004): 785.
- Borland, John. "Bots for Sony CD Software Spotted Online." *CNET News.com*, November 10, 2005a. http://news.com.com/Bots+for+Sony+CD+software+spotted+online/2100-1029_3-5944643.html.
- . "Patch Issued for Sony CD Uninstaller." *CNET News.com*, November 21, 2005b. http://news.com.com/Patch+issued+for+Sony+CD+uninstaller/2110-1002_3-5965819.html.
- . "Sony CD Protection Sparks Security Concerns." *CNET News.com*, November 1, 2005c. http://news.com.com/2100-7355_3-5926657.html.
- . "Sony to Patch Copy-Protected CD." *CNET News.com*, November 2, 2005d. http://news.com.com/Sony+to+patch+copy-protected+CD/2100-7355_3-5928608.html.
- Bosworth, Martin H. "Bot Herder Pleads Guilty to Hospital Hack." *Security Focus*, April 8, 2006a. <http://www.securityfocus.com/brief/204>.
- . "Census Bureau Admits to Data Breach as ID Theft Levels Climb." *Consumer-affairs.com*, March 8, 2007. http://www.consumeraffairs.com/news04/2007/03/census_breach.html.
- . "VA Loses Data on 26 Million Veterans." *Consumeraffairs.com*, May 22, 2006b. http://www.consumeraffairs.com/news04/2006/05/va_laptop.html.
- Bowers v. Baystate Technologies Inc.* 320 F.3d 1317, 1323 (Federal Circuit Court, 2003).
- Braucher, Jean. "Amended Article 2 and the Decision to Trust the Courts: The Case Against Enforcing Delayed Mass-Market Terms, Especially for Software." *Wisconsin Law Review*, 2004: 753, 767.
- . "Delayed Disclosure in Consumer E-Commerce as an Unfair and Deceptive Practice." *Wayne Law Review* 46 (2000): 1805, 1806–07.
- . "New Basics: 12 Principles for Fair Commerce in Mass-Market Software and Other Digital Products, Arizona Legal Studies Discussion Paper No. 06-05." *Social Science Research Network*. January 2006. <http://ssrn.com/abstract=730907>.
- Brelsford, James. "California Raises the Bar on Data Security and Privacy." *FindLaw*, September 30, 2003. <http://library.findlaw.com/2003/Sep/30/133060.html>.
- Brenner, Susan W. "Toward a Criminal Law for Cyberspace: Distributed Security." *Boston University Journal of Science and Technology* 10 (2004): 1.
- Broache, Anne. "Sony Rootkit Settlement Gets Final Nod." *CNET News.com*, May 22, 2006. http://news.com.com/Sony+rootkit+settlement+gets+final+nod/2100-1030_3-6075370.html.

- Brodtkin, Jon. "ChoicePoint Details Data Breach Lessons." *PCWorld*, June 11, 2007. <http://www.pcworld.com/article/id,132795-page,1/article.html>.
- Broughton, Tom, and Heather Pople. "The Facebook Faceoff: A Survey by Human Capital." *Scribd*, November 15, 2007. <http://www.scribd.com/doc/513941/The-Facebook-Faceoff-An-Empirical-Analysis-by-Human-Capital>.
- Brown, Bob. "The Number of Online Personal Health Records Is Growing, but Is the Data in These Records Adequately Protected?" *Journal of Health Care Compliance* 9 (2007): 35.
- Burbules, Nicholas C., and T. A. Carllister. *Watch It: The Risks and Promises of Information Technologies for Education*. Boulder, CO: Westview Press, 2000.
- Burchell, Graham. "Liberal Government and Techniques of the Self." In *Foucault and Political Reason: Liberalism, Neoliberalism, and Rationalities of Government*, edited by A. Barry, T. Osbourne, and N. Rose, Chicago: University of Chicago Press, 1996.
- Burk, Dan L. "Legal and Technical Standards in Digital Rights Management Technology." *Fordham Law Review* 74 (2005): 537.
- Butler, Shawn A. "Security Attribute Evaluation Method: A Cost-Benefit Approach." International Conference on Software Engineering. 2002.
- . "Software Design: Why It Is Hard to Do Empirical Research, Workshop on Using Multidisciplinary Approaches in Empirical Software Engineering Research." *International Conference on Software Engineering Proceedings*. 2000. <http://www.cs.cmu.edu/afs/cs/project/vit/pdf/secure.butler.pdf>.
- Butler, Shawn, and Paul Fischbeck. "Multi-Attribute Risk Assessment." *Technical Report CMU-CS-01-169*. 2001. <http://citeseer.ist.psu.edu/618238.html>.
- California SB 1386. September 25, 2002. http://info.sen.ca.gov/pub/01-02/bill/sen/sb_1351-1400/sb_1386_bill_20020926_chaptered.html.
- "Call for Papers." *IEEE Technology in Society*. <http://www.ljean.com/specialIssue.html> (accessed April 19, 2006).
- Calvert, Sandra, Amy B. Jordan, and Rodney R. Cocking. *Children in the Digital Age: Influences of Electronic Media on Development*. New York: Praeger Publishers, 2002.
- Camp, Jean, and Ross Anderson. "Economics and Security Resource Page." <http://www.cl.cam.ac.uk/rja14/econsec.html> (accessed March 10, 2008).
- Canada. "Securing an Open Society: Canada's National Security Policy." 2004. http://www.pco-bcp.gc.ca/default.asp?Page=Publications&Language=E&doc=NatSecurnat/natsecurnat_e.htm.
- CanSecWest*. <http://cansecwest.com/> (accessed March 10, 2008).
- Carlson, Steven C. "Patent Pools and the Antitrust Dilemma." *Yale Journal* 16 (1999): 359, 367–69.
- Carnegie Mellon Software Engineering Institute, CERT Coordination Center. <http://www.cert.org> (accessed December 11, 2007).
- Carr, Nicholas. "The Net's Killer App." *RoughType*, February 4, 2006. http://www.rough-type.com/archives/2006/02/killer_app.php.
- Cartwright, Freeth. "Let's Not Forget the Real Facebook Privacy Issues Amongst All This

- Talk About Facebook Public Profiles." *IMPACT*, September 5, 2007. <http://impact.freethcartwright.com/2007/09/lets-not-forget.html>.
- Cassidy, John. *Dot.Con*. New York: HarperCollins, 2002.
- Cavazos, E. A., and D. Morin. "A New Legal Paradigm from Cyberspace? The Effect of the Information Age on the Law." *Technology in Society* (1996): 357.
- Cave, Damien. "Spyware v. Anti-Spyware." *Salon.com*, April 26, 2002. http://dir.salon.com/story/tech/feature/2002/04/26/anti_spyware/index.html.
- Certicom Overview Brochure. "Certicom: Securing Innovation." http://www.intel.com/netcomms/events/ctia/Certicom_overview.pdf (accessed April 18, 2005).
- Chandler, Jennifer A. "Improving Software Security: A Discussion of Liability for Unreasonably Insecure Software." In *Securing Privacy in the Internet Age*. Palo Alto, CA: Stanford University Press, 2006a.
- . "Liability for Botnet Attacks." *Canadian Journal of Law and Technology* 5, no. 1 (2006b): 13.
- . "Security in Cyberspace: Combatting Distributed Denial of Service Attacks." *University of Ottawa Law and Technology Journal* 1 (2003–2004): 231.
- Chapman, Matt. "Monster.com Suffers Job Lot of Data Theft." *vnunet.com*, August 21, 2007. <http://www.itweek.co.uk/vnunet/news/2197133/monster-suffers-job-lot-theft>.
- Charny, Ben. "The Cost of COPPA: Kids' Site Stops Talking." *ZDNet*, September 12, 2000. http://news.zdnet.com/2100-9595_22-523848.html.
- Chen, Jim. "Webs of Life: Biodiversity Conservation as a Species of Information Policy." *Iowa Law Review* 89 (2004): 495.
- Children's Online Privacy Protection Act of 1998. <http://www.ftc.gov/ogc/coppa1.htm>.
- Children's Online Privacy Protection Act of 2000. 15 U.S.C. §§ 6501–6506. 2000.
- Children's Online Privacy Protection Rule. 16 CFR Part 312. November 3, 1999. <http://www.ftc.gov/os/1999/10/64fr59888.pdf> (accessed February 22, 2007).
- Churchill Communications Corp. v. Demyanovich*, 668 F. Supp. 207, 211 (E.D. N.Y. 1987).
- CipherTrust. "Zombie Statistics." <http://www.ciphertrust.com/resources/statistics/zombie.php> (accessed August 28, 2006).
- Claburn, Thomas. "The Cost of Data Loss Rises." *Information Week*, November 28, 2007a. <http://www.informationweek.com/management/showArticle.jhtml?articleID=204204152>.
- . "Facebook and MySpace Monetize Friendship with Targeted Ads." November 7, 2007b. <http://www.itnews.com.au/News/64502,facebook-and-myspace-monetize-friendship-with-targeted-ads.aspx>.
- "Class Definitions, Class 380, at 380 1." United States Patent and Trademark Office. <http://www.uspto.gov/go/classification/uspc380/defs380.pdf> (accessed April 18, 2005).
- "Class Definitions, Class 705, at 705 1." United States Patent and Trademark Office. <http://www.uspto.gov/go/classification/uspc705/defs705.pdf> (accessed April 18, 2005).
- "Class Definitions, Class 713, at 713 1." United States Patent and Trademark Office. <http://www.uspto.gov/go/classification/uspc713/defs713.pdf> (accessed April 18, 2005).
- Cleveland Clinic. <https://www.clevelandclinic.org/contact/form.asp> (accessed December 11, 2007).

- Cohen, Wesley M., and Stephen A. Merrill, eds. *Patents in the Knowledge-Based Economy*. Washington, DC: National Research Council of the National Academies, 2003.
- "Comments of Simple Nomad." Stanford University, Cybersecurity, Research and Disclosure Conference. 2003.
- "Commercial Encryption Export Controls, U.S. Dept. of Commerce, Bureau of Industry and Security." <http://www.bxa.doc.gov/encryption/default.htm> (accessed April 15, 2005).
- "Common Access Cards." *Department of Defense*. <http://www.cac.mil/> (accessed March 2008).
- "Compliance and Enforcement: Numbers at a Glance." United States Department of Health and Human Services. <http://www.hhs.gov/ocr/privacy/enforcement/numbersglance1107.html>.
- "Compliance and Enforcement: Privacy Rule Enforcement Highlights." United States Department of Health & Human Services. <http://www.hhs.gov/ocr/privacy/enforcement/12312007.html>.
- "Computer and Internet Use at Work in 2003." United States Department of Labor. <http://www.bls.gov/news.release/ciuaw.nro.htm> (accessed August 21, 2006).
- "Computer Science." Wikipedia. http://en.wikipedia.org/wiki/Computer_science (accessed April 19, 2006).
- Conti, Gregory, Mustaque Ahamad, and John Stasko. "Attacking Information Visualization System Usability Overloading and Deceiving the Human." Symposium on Usable Privacy and Security Proc. 2005. http://cups.cs.cmu.edu/soups/2005/2005_proceedings.
- "Continued Progress: Hospital Use of Information Technology." American Hospital Association. January 14, 2007. <http://www.aha.org/aha/content/2007/pdf/070227-continuedprogress.pdf>.
- Cook, Richard, and David Woods. "Operating at the Sharp End: The Complexity of Human Error." In *Human Error in Medicine*, edited by Marilyn Sue Bogner. Hillsdale, NJ: Lawrence Erlbaum, 1994.
- Cook, Richard, Martha Render, and David Woods. "Gaps in the Continuity of Care and Progress on Patient Safety." *British Medical Journal* 320, no. 791 (2000).
- Copyright Act*, R.S.C. 1985, c.C-42. <http://laws.justice.gc.ca/en/C-42/index.html>.
- "Council Directive 95/46/EC of 24 October 1995 on the Protection of Individuals with Regard to the Processing of Personal Data and on the Free Movement of Such Data, 1995 O.J. (L 281) 38." October 24, 1995.
- Crawford, Susan P. "The Biology of the Broadcast Flag." *Hastings Communication and Entertainment Law Journal* 25 (2003): 603.
- "Credit-Card Wars." *Wall Street Journal*, March 29, 2008. http://online.wsj.com/article/SB120674915149073307.html?mod=googlenews_wsj.
- Creo, Robert A. "Mediation 2004: The Art and the Artist." *Penn State Law Review* 108 (2004): 1017.
- Critcher, Chas. *Moral Panics and the Media*. Maidenhead, Berkshire, UK: Open University Press, 2003.

- Dam, Kenneth W., and Herbert S. Lin, eds. *Cryptography's Role in Securing the Information Society*. Washington, DC: National Academies Press. <http://www.nap.edu/readingroom/books/crisis/C.txt> (accessed April 15, 2005).
- Darlin, Damon. "Think Your Social Security Number Is Secure? Think Again." *New York Times*, February 24, 2007. <http://www.nytimes.com/2007/02/24/business/24money.html?hp>.
- "Data Protection Act." 1998. <http://www.hms0.gov.uk/acts/acts1998/80029—c.htm#17>.
- Davidson & Assocs. v. Jung*. 422 F.3d 630 (8th Circuit Court, 2005).
- Davidson, Mary Ann. "When Security Researchers Become the Problem." *CNET News.com*, July 27, 2005. http://news.com.com/When+security+researchers+become+the+problem/2010-1071_3-5807074.html?tag=nl.
- Davis, Joshua. "Hackers Take Down the Most Wired Country in Europe." *Wired.com*, August 21, 2007. http://www.wired.com/politics/security/magazine/15-09/ff_estonia.
- Davis, Wendy. "Documents Detail Direct Revenue Strategies." *OnlineMedia Daily*, April 13, 2006. <http://publications.mediapost.com/index.cfm?fuseaction=Articles.san&s=42172&Nid=19774&p=28323>.
- Day, Jeff. "Poll Finds Concern over Improper Disclosure of Personal Health Data May Affect Research." *Medical Research Law and Policy* 6 (2007): 533.
- DefCon*. <http://www.defcon.org> (accessed March 10, 2008).
- Delio, Michelle. "New York Says No-No to NA." *Wired News*, February 7, 2002. www.wired.com/news/print/0,1294,50299,00.html.
- Denning, Peter. "Computer Science: The Discipline." In *Encyclopedia of Computer Science*, edited by Anthony Ralston, Edwin Reilly and David Hemmendinger. Hoboken, NJ: Wiley, 2003.
- Department of Commerce National Institute of Standards and Technology, Announcing Draft Federal Information Processing Standard (FIPS) 46-3, Data Encryption Standard (DES), and Request for Comments. <http://csrc.nist.gov/cryptval/> (accessed April 15, 2005).
- Derrick, Gary W., and Irving L. Fought. "New Developments in Oklahoma Business Entity Law." *Oklahoma Law Review* 56 (2003): 259, 263–65.
- Desai, Vikram. "Phishing—Who's Taking the Bait Now?" *CNet*, November 23, 2004. <http://news.com.com/Phishing+who's+taking+the+bait+now/2010-7349-5463346.html>.
- "Device Driver." *ZDNet*. <http://dictionary.zdnet.com/index.php?d=driver> (accessed March 10, 2008).
- Diamond v. Chakrabarty*. 447 U.S. 303, 308–09, 318 (1980).
- Diamond v. Diehr*. 450 U.S. 175 (1981).
- Diaz v. Oakland Tribune*. 139 (Cal. App. 3d 126, 1983).
- "Dictionary Attack." *ZDNet*. <http://dictionary.zdnet.com/definition/Dictionary+Attack.html> (accessed March 10, 2008).
- "Directive on Privacy and Electronic Communications." *Directive 2002/58/EC of the European Parliament and the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector*.

- July 12, 2002. http://mineco.fgov.be/internet_observatory/pdf/legislation/directive_2002_58_en.pdf.
- "Directive on Unfair Terms in Consumer Contracts." *Council Directive 93/13/EEC of 5 April 1993 on unfair terms in consumer contracts*, L 095 , 21/04/1993 P. 0029 - 0034. April 5, 1993. <http://eur-lex.europa.eu/LexUriServ/LexUriServ.do?uri=CELEX:31993L0013:EN:HTML>.
- "Diversity of Computer Science." *Wikipedia*. http://en.wikipedia.org/wiki/Diversity_of_computer_science (accessed April 19, 2006).
- Dolgin, Janet L. "Personhood, Discrimination, and the New Genetics." *Brooklyn Law Review* 66 (2001): 755, 764.
- Dotinga, R. *APBNEWS*, August 10, 2000. <http://www.abpnews.com/newscenter/breakingnews/2000/08/10naughton0810&uscore;01.html>.
- DVD 6C Licensing Agency: Patent Catalogue. <http://www.dvd6cla.com/catalogue.html> (accessed April 19, 2005).
- Dwyer, Catherine, Star Roxanne Hiltz, and Katia Passerini. "Trust and Privacy Concern Within Social Networking Sites: A Comparison of Facebook and MySpace." *Proceedings of the 13th Americas Conference on Information Systems*. 2007. <http://csis.pace.edu/dwyer/research/DwyerAMCIS2007.pdf>.
- The Economist*. "Murdoch's Space." April 1, 2006.
- E. I. DuPont de Nemours Powder Co. v. Masland*, 244 U.S. 100, 102 (1917).
- Eckelberry, Alex. "Trying to Use EULAs and Copyright Law to Block Spyware Research." *Sunbelt Blog*, November 8, 2005. http://sunbeltblog.blogspot.com/2005/11/trying-to-use-eulas-and-copyright-law_08.html.
- Edelman, Ben. "Direct Revenue Deletes Competitors from Users' Disks." February 8, 2005. <http://www.benedelman.org/news/120704-1.html>.
- . "WhenU Security Hole Allows Execution of Arbitrary Software." June 2, 2004. <http://www.benedelman.org/spyware/whenu-security/>.
- Edwards, Lilian. "Facebook and Privacy Returns." *PANGLOSS*, September 5, 2007. <http://blogscript.blogspot.com/2007/09/facebook-and-privacy-returns.html>.
- eEye Digital Security. "Upcoming Advisories." <http://www.eeye.com/html/research/upcoming/index.html> (accessed January 3, 2007).
- Electronic Frontier Foundation (EFF). "Unintended Consequences: Seven Years Under the DMCA." April 2006. http://www.eff.org/IP/DMCA/unintended_consequences.php.
- Electronic Funds Transfer Act. 15 U.S.C. 1693b.
- Electronic Monitoring & Surveillance Survey: Many Companies Monitoring, Recording, Videotaping—and Firing—Employees. 2005. <http://www.amanet.org/press/amanews/emso5.htm> (accessed August 29, 2006).
- "Embedded." *ZDNet*. <http://dictionary.zdnet.com/definition/embedded.html> (accessed January 3, 2007).
- Emison, Gerald Andrews. "The Potential for Unconventional Progress: Complex Adaptive Systems and Environmental Quality Policy." *Duke Environmental Law and Policy Forum* 7 (1996): 167.

- End User Agreement for VMWare Player. <http://www.vmware.com/download/eula/player.html>.
- Epatko, Larisa. "Cyber Attacks Target Computer Vulnerabilities." *PBS Online Newshour*. http://www.pbs.org/newshour/science/computer_worms/intro.html (accessed November 26, 2004).
- Electronic Privacy Information Center (EPIC). "National ID Cards and REAL ID Act." <http://epic.org/privacy/id-cards/> (accessed March 2008).
- . "Social Networking Privacy." <http://epic.org/privacy/socialnet/default.html> (accessed March 20, 2008).
- Epstein, Michael A. *Epstein on Intellectual Property*. 4th ed. London: Kluwer Law, 2005.
- Erikson, Erik H. *Identity: Youth and Crisis*. New York: Norton, 1968.
- Espiner, Tom. "CIA: Cyberattacks Caused Multicity Blackout." *CNET News*, January 22, 2008. http://www.news.com/2100-7349_3-6227090.html.
- "Estonia Hit by 'Moscow Cyber War.'" *BBC News*, May 17, 2007. <http://news.bbc.co.uk/2/hi/europe/6665145.stm>.
- "EU Data Directive." Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data. October 24, 1995. http://ec.europa.eu/justice_home/fsj/privacy/law/index_en.htm (accessed March 20, 2008).
- European Network and Information Security Agency. "Provider Security Measures." 2007. http://enisa.europa.eu/doc/pdf/deliverables/enisa_security_spam_part2.pdf (accessed February 1, 2008).
- Evers, Joris. "Cisco Hits Back at Flaw Researcher." *CNET News.com*, July 27, 2005a. http://news.com.com/Cisco+hits+back+at+flaw+researcher/2100-1002_3-5807551.html.
- . "DNS Servers—An Internet Achilles Heel." *CNET News.com*, August 3, 2005b. http://news.com.com/DNS+servers—an+Internet+Achilles+heel/2100-7349_3-5816061.html.
- . "iDefense Ups the Bidding for Bugs." *CNET News.com*, July 26, 2005c. http://news.com.com/iDefense+ups+the+bidding+for+bugs/2100-7350_3-5806059.html?tag=nl.
- . "Microsoft Draws Fire for Its Stealth Test Program." *CNET News.com*, June 13, 2006a. http://news.com.com/Microsoft+draws+fire+for+stealth+test+program/2100-1029_3-6083204.html.
- . "Microsoft Piracy Check Comes Calling." *CNET News.com*, April 24, 2006b. http://news.com.com/Microsoft+piracy+check+comes+calling/2100-1016_3-6064555.html?tag=nl.
- . "Microsoft to Ease Up on Piracy Check-Ins." *CNET News.com*, June 9, 2006c. http://news.com.com/Microsoft+to+ease+up+on+piracy+check-ins/2100-7348_3-6082334.html.
- . "Offering a Bounty for Security Bugs." *CNET News.com*, July 24, 2005d. http://news.com.com/Offering+a+bounty+for+security+bugs/2100-7350_3-5802411.html.
- . "Oracle Dragging Heels on Unfixed Flaws, Researcher Says." *CNET News.com*,

- July 19, 2005e. http://news.com.com/Oracle+dragging+heels+on+unfixed+flaws%2C+researcher+says/2100-1002_3-5795533.html?tag=nl.
- . “Spyware Spat Makes Small Print a Big Issue.” *CNET News.com*, November 10, 2005f. http://news.com.com/2100-1029_3-5944208.html.
- . “What’s the Cost of a Data Breach?” *CNET News*, April 13, 2007. http://www.news.com/8301-10784_3-6176074-7.html.
- Evers, Joris, and Marguerite Reardon. “Bug Hunters, Software Firms in Uneasy Alliance.” *CNET News.com*, September 6, 2005. http://news.com.com/Bug+hunters%2C+software+firms+in+uneasy+alliance/2100-1002_3-5846019.html?tag=st.prev.
- “Experian National Score Index.” *Experian*. <http://www.nationalscoreindex.com/USS-core.aspx> (accessed March 2008).
- “Exploit.” *ZDNet*. <http://dictionary.zdnet.com/index.php?d=exploit> (accessed March 10, 2008).
- “Exposed Online: Why the New Federal Health Privacy Regulation Doesn’t Offer Much Protection to Internet Users.” *Pew Internet and American Life Project*. November 18, 2001. http://www.pewinternet.org/pdfs/PIP_HPP_HealthPriv_report.pdf.
- “Facebook Asked to Pull Scrabulous.” *BBC News*, January 16, 2008. <http://news.bbc.co.uk/2/low/technology/7191264.stm>.
- Facebook. “Facebook Policy.” February 14, 2008. <http://www.facebook.com/policy.php>.
- Fair Credit Billing Act. 15 U.S.C. 1601. <http://www.ftc.gov/os/statutes/fcb/fcb.pdf>.
- Fair Credit Reporting Act. 15 USC 1681. <http://www.ftc.gov/os/statutes/031224fcra.pdf>.
- Farber, Daniel A. “Probabilities Behaving Badly: Complexity Theory and Environmental Uncertainty.” *University of California at Davis Law Review* 37 (2003): 145.
- Federal Bureau of Investigation (FBI). “U.S. Dept. of Justice Operation Cybersweep.” <http://www.fbi.gov/cyber/cysweep/cysweep1.htm> (accessed November 26, 2004).
- Federal Trade Commission. “Children’s Privacy Initiatives.” http://www.ftc.gov/privacy/privacyinitiatives/childrens_shp.html (accessed January 6, 2008).
- . “ChoicePoint Settles Data Security Breach Charges; to Pay \$10 Million in Civil Penalties, \$5 Million for Consumer Redress.” January 26, 2006a. <http://www.ftc.gov/opa/2006/01/choicepoint.shtm>.
- . “COPPA Enforcement.” http://www.ftc.gov/privacy/privacyinitiatives/childrens_enf.html (accessed March 10, 2008).
- . “FTC Releases Survey of Identity Theft in U.S. 27.3 Million Victims in Past 5 Years, Billions in Losses for Businesses and Consumers.” September 3, 2003. <http://www.ftc.gov/opa/2003/09/idtheft.htm>.
- . “FTC Staff Proposes Online Behavioral Advertising Privacy Principles.” December 20, 2007. <http://www.ftc.gov/opa/2007/12/principles.shtm>.
- . “Identity Theft: Immediate Steps.” http://www.consumer.gov/idtheft/con_steps.htm (accessed January 15, 2008).
- . “Identity Theft Survey Report.” September 2004. <http://www.ftc.gov/os/2003/09/synovatereport.pdf>.
- . “In Brief: The Financial Privacy Requirements of the Gramm-Leach-Bliley Act.”

- <http://www.ftc.gov/bcp/online/pubs/buspubs/glbshort.pdf> (accessed February 6, 2006).
- . “In the Matter of DSW, Inc. File No 052 3096, Complaint.” March 7, 2006b. <http://www.ftc.gov/os/caselist/0523096/0523096c4157DSWComplaint.pdf> (accessed March 4, 2007).
- . “In the Matter of DSW, Inc. File No. 052 3096, Agreement containing consent decree.” March 14, 2006c. <http://www.ftc.gov/os/caselist/0523096/051201agree0523096.pdf>.
- . “In the Matter of TJX Companies, Inc., File no. 072 3055, Agreement containing consent order.” March 27, 2008. <http://www.ftc.gov/os/caselist/0723055/080327agreement.pdf>.
- . “Letter of FTC to CARU.” January 21, 2006d. <http://www.ftc.gov/os/2001/02/caruletter.pdf>.
- . “Phishing Alert.” <http://www.ftc.gov/bcp/online/pubs/alerts/phishingalrt.htm>.
- . “Unfairness and Deception Cases.” http://www.ftc.gov/privacy/privacyinitiatives/promises_enf.html (accessed March 29, 2008).
- Felt, Adrienne, and David Evans. “Privacy Protection for Social Networking APIs.” <http://www.cs.virginia.edu/felt/privacy/> (accessed March 20, 2008).
- Felten, Ed. “Don’t Use Sony’s Web-Based XCP Uninstaller.” *Freedom to Tinker Blog*, November 14, 2005a. <http://www.freedom-to-tinker.com/?p=926>.
- . “Sony BMG ‘Protection’ Is Spyware.” *Freedom to Tinker Blog*, November 10, 2005b. <http://www.freedom-to-tinker.com/?p=923>.
- Ferguson, Niels, and Bruce Schneier. “Practical Cryptography Preface.” <http://www.macfergus.com/pc/preface.html> (accessed April 18, 2005).
- “FEULA.” *GripeWiki*. <http://www.gripewiki.com/index.php/FEULA>.
- Fichera, Richard, and Stephan Wenninger. “Islands Of Automation Are Dead—Long Live Islands Of Automation.” August 13, 2004. <http://www.forrester.com/Research/Document/Excerpt/0,7211,35206,00.html>.
- “Firewall.” *PCMag.com*. http://www.pcmag.com/encyclopedia_term/0,2542,t=firewall&i=43218,00.asp (accessed February 28, 2008).
- Fisher, Dennis. “Sybase Demands for Silence Raise Outcry.” *eWeek.com*, March 28, 2005. <http://www.eweek.com/article2/0,1895,1780178,00.asp>.
- Fitzpatrick, William. “Uncovering Trade Secrets: The Legal and Ethical Conundrum of Creative Competitive Intelligence.” *SAM Advanced Management Journal* 28 (2003): 3.
- Flavell, John. *The Developmental Psychology of Jean Piaget*. New York: Van Nostrand Reinhold, 1963.
- Flavell, John, and Lee Ross. *Social Cognitive Development*. Cambridge: Cambridge University Press, 1981.
- Flotec, Inc. v. Southern Research, Inc.* 16 F.Supp. 2d 992 (S.D. Ind. 1998).
- Ford Motor Co. v. Lane.* 67 F. Supp. 2d 745 (E.D. Mich. 1999).
- Ford, Richard. “Open v. Closed.” *5ACM Queue*. 2007. <http://www.acmqueue.com/modules.php?name=Content&pa=showpage&pid=453>.
- Ford, Richard, Herbert Thompson, and Fabian Casteron. “Role Comparison Report:

- Web Server Role." March 2005. http://www.securityinnovation.com/pdf/windows_linux_final_study.pdf.
- Ford, Robert C., and Woodrow D. Richardson. "Ethical Decision Making: A Review of the Empirical Literature." *Journal of Business Ethics* 13 (1994): 205.
- Forno, Richard F. "Microsoft Makes an Offer You Can't Refuse." June 30, 2002. <http://www.infowarrior.org/articles/2002-09.html>.
- . "Patch Management Isn't the Only Needed Change." June 8, 2003. <http://lists.jammed.com/ISN/2003/06/0034.html>.
- Foster, Ed. "A Censorship Test Case." *InfoWorld*, March 1, 2002. www.infoworld.com/article/02/03/01/0203040pfoster_1.html.
- . "A Fatal Blow to Shrinkwrap Licensing?" *The Gripe Line Weblog*, December 12, 2004. <http://weblog.infoworld.com/foster/2004/12/21.html>.
- Foster, Patrick. "Caught on Camera—and Found on Facebook." *Times Online*, July 17, 2007. http://technology.timesonline.co.uk/tol/news/tech_and_web/the_web/article2087306.ece.
- Fox, Susannah. "Trust and Privacy Online: Why Americans Want to Rewrite the Rules." *Pew Internet and American Life Project*. 2000. <http://www.pewinternet.org/reports/toc.asp?Report=19>.
- Frauenheim, Ed. "Report: E-mail Volume Grows Rapidly." *CNET*, October 2, 2003. http://news.com.com/2110-1032-5085956.html?tag=3Dnefd_hed.
- "Frequently Asked Questions About the Children's Online Privacy Protection Rule." Federal Trade Commission (FTC). <http://www.ftc.gov/privacy/coppafaqs.htm> (accessed April 21, 2006).
- Freudenheim, Milt. "Medical Data on Empire Blue Cross Members May Be Lost." *New York Times*, March 14, 2007: C2.
- Fridman, G. H. L. *The Law of Contract in Canada*. 4th ed. Scarborough: Carswell, 1999.
- Froomkin, A. Michael. "The Essential Role of Trusted Third Parties in Electronic Commerce." *University of Oregon Law Review* (1996): 49.
- . "The Metaphor Is the Key: Cryptography, the Clipper Chip, and the Constitution." *University of Pennsylvania Law Review* (1995): 709.
- . "It Came from Planet Clipper." *University of Chicago Legal Forum* (1996): 15.
- "FTC Decides to Retain COPPA Rule with No Change After Review of Comments." *Computer Technology Law Report* 7 (2006): 127.
- "FTC Releases Survey of Identity Theft in U.S. 27.3 Million Victims in Past 5 Years, Billions in Losses for Businesses and Consumers." Federal Trade Commission. September 3, 2003. <http://www.ftc.gov/opa/2003/09/idtheft.htm>.
- Gage, Deborah. "California Data-Breach Law Now Covers Medical Information." *San Francisco Chronicle*, January 4, 2008. <http://www.sfgate.com/cgi-bin/article.cgi?f=/c/a/2008/01/04/BUR6U9000.DTL>.
- Garde, Sebastian, et al. "Towards Semantic Interoperability for Electronic Health Records: Domain Knowledge Governance for open EHR Archetypes." *Methods of Information in Medicine* 46 (2007): 332, 340–41.

- Garfinkel, Simson. "Risks of Social Security Numbers." *Communications of the ACM* 38, no. 10 (October 1995): 146.
- Garfinkel, Simson L., and Abhi Shelat. "Remembrance of Data Passed: A Study of Disk Sanitization Practices." 1 *IEEE Security & Privacy* (2003). <http://www.computer.org/security/v1n1/garfinkel.htm> (accessed December 11, 2007).
- Gartner, Inc. "Gartner Says Rash of Personal Data Thefts Shows Social Security Numbers Can No Longer Be Sole Proof of Identity for Enterprises." June 5, 2006. http://www.gartner.com/press_releases/asset_153141_11.html.
- . "Gartner Study Finds Significant Increase in E-Mail Phishing Attacks: Cost to U.S. Banks and Credit Card Issuers Estimated at \$1.2 Billion in 2003." May 6, 2004. http://www.gartner.com/5_about/press_releases/asset_71087.
- Garza, Victor R. "Security Researcher Causes Furor by Releasing Flaw in Cisco Systems IOS." *SearchSecurity.com*, July 28, 2005. http://searchsecurity.techtarget.com/originalContent/0,289142,sid14_gci1111389,00.html?track=NL-358&ad=523843.
- Gaudin, Sharon. "Banks Hit T.J. Maxx Owner with Class-Action Lawsuit." *Information Week*, April 25, 2007a. <http://www.informationweek.com/news/showArticle.jhtml?articleID=199201456>.
- . "Estimates Put T.J. Maxx Security Fiasco at \$4.5 Billion." *Information Week*, May 2, 2007b. <http://www.informationweek.com/news/showArticle.jhtml?articleID=199203277>.
- . "Three of Four Say They Will Stop Shopping at Stores That Suffer Data Breaches." *Information Week*, April 12, 2007c. http://www.informationweek.com/software/showArticle.jhtml?articleID=199000563&cid=RSSfeed_TechWeb.
- Gellhorn, Walter. "Contracts and Public Policy." *Columbia Law Review* 35 (1935): 679. *Get Safe Online*. <http://www.getsafeonline.org/> (accessed March 20, 2008).
- Geu, Thomas Earl. "Chaos, Complexity, and Coevolution: The Web of Law, Management Theory, and Law Related Services at the Millennium." *Tennessee Law Review* 66 (1998): 137.
- Gobioff, Howard, Sean Smith, J. D. Tygar, and Bennet Yee. "Smart Cards in Hostile Environments." *Proceedings of the 2nd USENIX Workshop on Elec. Commerce*. 1996. 23–28.
- Goldberg, Daniel S. "And the Walls Came Tumbling Down: How Classical Scientific Fallacies Undermine the Validity of Textualism and Originalism." *Houston Law Review* 39 (2002): 463.
- "Good News: 'Phishing' Scams Net Only \$500 Million." *CNET*, September 29, 2004. http://news.com.com/Good+news+Phishing+scams+net+ionly+500+million/2100-1029_3-5388757.html.
- Goodwin, Bill. "Trusted Computing Could Lead to More Supplier Lock-in." *ComputerWeekly.com*, November 14, 2002. <http://www.computerweekly.com/Articles/2002/11/14/190933/trusted-computing-could-lead-to-more-supplier-lock-in.htm> (accessed February 13, 2009).
- Google. "Ads in Gmail." March 20, 2008. <http://mail.google.com/support/bin/answer.py?hl=en&answer=6603>.

- Graham, Stuart J. H., and David C. Mowery. "Intellectual Property Protection in the U.S. Software Industry." In *Patents in the Knowledge-Based Economy*, edited by Wesley M. Cohen and Stephen A. Merrill. Washington, DC: National Academies Press, 2003.
- Gramm-Leach-Bliley Financial Services Modernization Act of 1999, 15 U.S.C. §§ 6801-6809 (2004).
- Granick, Jennifer. "Bug Bounties Exterminate Holes." *Wired News*, April 12, 2006a. <http://www.wired.com/politics/law/commentary/circuitcourt/2006/04/70644>.
- . "An Insider's View of Ciscogate." *Wired.com*, August 5, 2005a. http://www.wired.com/news/technology/0,68435-1.html?tw=wn_story_page_next1.
- . "The Price of Restricting Vulnerability Publications." *International Journal of Communication Law and Policy* 9 (2005b): 10.
- . "Spot a Bug, Go to Jail." *Wired.com*, May 10, 2006b. <http://www.wired.com/news/columns/circuitcourt/0,70857-0.html>.
- Greenberg, Andy. "If Security Is Expensive, Try Getting Hacked." *Forbes.com*, November 28, 2007. http://www.forbes.com/home/technology/2007/11/27/data-privacy-hacking-tech-security-cx_ag_1128databreach.html.
- Greene, Thomas C. "MS Security Patch EULA Gives Billg Admin Privileges on Your Box." *The Register*, June 20, 2002. <http://www.theregister.co.uk/content/4/25956.html>.
- Greenemeier, Larry. "T.J. Maxx Data Theft Likely Due to Wireless 'Wardriving.'" *InformationWeek*, May 9, 2007a. <http://www.informationweek.com/news/showArticle.jhtml?articleID=199500385>.
- . "T.J. Maxx Parent Company Data Theft Is the Worst Ever." *InformationWeek*, March 29, 2007b. <http://www.informationweek.com/news/showArticle.jhtml?articleID=198701100>.
- Greenfield, Patricia. *Mind and Media: The Effects of Television, Video Games, and Computers*. Cambridge, MA: Harvard University Press, 1984.
- Greenslade, Roy. "PCC Faces Up to Facebook Intrusions." *Guardian UK*, February 28, 2008. http://blogs.guardian.co.uk/greenslade/2008/02/pcc_faces_up_to_facebook_intru.html.
- Gross, Grant. "Analysis: US Data Breach Notification Law Unlikely This Year." *IDG News Service*, May 8, 2006. <http://www.macworld.com/article/50709/2006/05/databreach.html>.
- Gross, Ralph, and Alessandro Acquisti. "Information Revelation and Privacy in Online Social Networks (the Facebook Case)." ACM Workshop on Privacy in the Electronic Society, WPES '05. November 7, 2005. <http://www.heinz.cmu.edu/acquisti/papers/privacy-facebook-gross-acquisti.pdf>.
- "Guidelines for Security Vulnerability Reporting and Response, Version 2.0." September 1, 2004. <http://www.oisafety.org/guidelines/secresp.html>.
- HackintheBox*. <http://www.hackingthebox.org> (accessed March 10, 2008).
- Halderman, J. Alex. "Not Again! Uninstaller for Other Sony DRM Also Opens Huge Security Hole." *Freedom to Tinker Blog*, November 17, 2005a. <http://www.freedom-to-tinker.com/?p=931>.

- . "Sony Shipping Spyware from Suncomm Too." *Freedom to Tinker Blog*, November 12, 2005b. <http://www.freedom-to-tinker.com/?p=925>.
- Halderman, J. Alex, and Ed Felten. "Sony's Web-Based Uninstaller Opens a Big Security Hole; Sony to Recall Discs." *Freedom to Tinker Blog*. November 15, 2005. <http://www.freedom-to-tinker.com/?p=927>.
- Hall, Stuart, Charles Critcher, Tony Jefferson, John Clarke, and Brian Robert. *Policing the Crisis: Mugging, the State, and Law and Order*. London: Palgrave Macmillan, 1978.
- Hansell, Saul. "Credit Card Chips with Little to Do." *New York Times*, August 12, 2001. <http://query.nytimes.com/gst/fullpage.html?res=9F00E5D6103FF931A2575BC0A9679C8B63>.
- Harding, Sandra, ed. *The Feminist Standpoint Theory Reader: Intellectual and Political Controversies*. New York: Routledge, 2003.
- Hargittai, Eszter. "Whose Space? Differences Among Users and Non-Users of Social Network Sites." *Journal of Computer-Mediated Communication* 13 (2007). <http://jcmc.indiana.edu/vol13/issue1/hargittai.html>.
- Harris Interactive Inc. "How the Public Sees Health Records and an EMR Program." Lions Aravind Institute of Community Ophthalmology. February 2005. <http://laico.org/v2020resource/files/Healthtopline.pdf> (accessed December 11, 2007).
- "Health Information Technology: Early Efforts Initiated but Comprehensive Privacy Approach Needed for National Strategy." Government Accountability Office. January 2007. <http://www.gao.gov/new.items/do7238.pdf> (accessed December 11, 2007).
- Health Insurance Portability & Accountability Act of 1996 (HIPAA). Pub. L. No. 104-191, 110 Stat. 1936 (1996). 104th Congress. Washington, DC: GPO, 1996.
- Health Privacy Project*. http://www.healthprivacy.org/info-url_nocat2304/info-url_nocat_list.htm (accessed December 11, 2007).
- Health Status Internet Assessments. <http://www.healthstatus.com/assessments.html> (accessed December 11, 2007).
- Hearnden, Keith. "Computer Criminals Are Human, Too." In *Computers in the Human Context*, edited by Tom Forester. Cambridge, MA: MIT Press, 1989.
- Hempel, Jesse, and Paula Lehman. "The MySpace Generation." *Business Week*, December 12, 2005. http://www.businessweek.com/magazine/content/05_50/b3963001.htm.
- Hidalgo, Amado. "A Monster Trojan." Symantec. August 17, 2007. http://www.symantec.com/enterprise/security_response/weblog/2007/08/a_monster_trojan.html.
- Hillman, Robert A., and Jeffrey J. Rachlinski. "Standard-Form Contracting in the Electronic Age." *New York University Law Review* 77 (2002): 429, 435–36.
- Hirst, Clare, and Avivah Litan. "Target's Move Highlights Smart Cards' Struggle in U.S. Market." Gartner. March 8, 2004. http://www.gartner.com/DisplayDocument?doc_cd=119996.
- Hobbs, A. C. *Locks and Safes: The Construction of Locks*. London: Virtue & Co., 1853.
- Hoffman, Rae. "Compare Me Facebook App Pulls a Bait and Switch?" *Sugarrae*. July 9, 2007a. <http://www.sugarrae.com/compare-people-facebook-app-pulls-a-bait-and-switch/>.

- . “More on the Compare Me Premium Service.” *Sugarrae*. November 9, 2007b. <http://www.sugarrae.com/more-on-the-compare-people-premium-service/>.
- Hoffman, Sharona. “Corrective Justice and Title I of the ADA.” *American University Law Review* 52 (2003): 1213.
- Hoffman, Sharona, and Andy Podgurski. “In Sickness, Health, and Cyberspace: Protecting the Security of Electronic Private Health Information.” *Boston College Law Review* 48 (2007a): 331.
- . “Securing the HIPAA Security Rule.” *Journal of Internet Law* 10 (February 2007b): 1.
- Hollnagel, Erik. “Human Error.” NATO Conference on Human Error. 1983. http://www.ida.liu.se/erihio/Bellagio_Mhtm.
- Hollnagel, Erik, David Woods, and Nancy Leveson. *Resilience Engineering*. Aldershot, UK: Ashgate Publishing, 2006.
- Holman, Pablos. “How to Hack RFID-Enabled Credit Cards for \$8.” *Boingboing TV*, March 19, 2008. <http://tv.boingboing.net/2008/03/19/how-to-hack-an-rfide.html>.
- Horne v. Patton*. 287 (So.2d 824, Ala. 1973).
- Howard, Michael, Jon Pincus, and Jeannette M. Wing. “Measuring Relative Attack Surfaces.” *Proceedings of Workshop on Advanced Developments in Software and Systems Security*. Taipei, 2003.
- Howard, Philip N. “Network Ethnography and the Hypermedia Organization New Media, New Organizations, New Methods.” *New Media and Society* (2002): 550.
- . *New Media Campaigns and the Managed Citizen*. Cambridge: Cambridge University Press, 2006.
- Howard, Philip N., John Carr, and Tema J. Milstein. “Digital Technology and the Market for Political Surveillance.” *Surveillance and Society* 3 (2005): 1.
- Hughes, Scott H. “Understanding Conflict in a Postmodern World.” *Marquette Law Review* 87 (2004): 681.
- Hustead, Joanne L., and Janlori Goldman. “The Genetics Revolution: Conflicts, Challenges and Conundra.” *American Journal of Law and Medicine* 28 (2002): 285, 288.
- IMS Health Inc. v. Ayotte*. No. 06-cv-00280-PB (District of New Hampshire, 2007).
- IMS Health v. Rowe*. No. 1:07-cv-00127-JAW (District of Maine, August 29, 2007).
- IMS Health v. Sorrell*. No. 2:07-cv-00188-wks (District of Vermont, August 29, 2007).
- “Information Security Economics.” Annotated Bibliography. <http://infoecon.net/workshop/bibliography.php> (accessed September 20, 2007).
- “In the Matter of Superior Mortgage Corporation, File No. 052 3136.” Federal Trade Commission. <http://www.ftc.gov/os/caselist/0523136/0523136.htm> (accessed December 20, 2005).
- Institute of Medicine. *Key Capabilities of an Electronic Health Record System*. Washington, DC: National Academies Press, 2003.
- International Chamber of Commerce. http://www.iccwbo.org/home/statements_rules/statements/2001/contractual_clauses_for_transfer.asp.
- Internet Archive. <http://www.archive.org> (accessed March 4, 2008).

- "Internet Engineering Task Force (IETF), Public Key Infrastructure (X.509) (pkix)." <http://www.ietf.org/html.charters/pkix-charter.html> (accessed April 15, 2005).
- "Intrusion Detection Systems." *PCMag.com*. http://www.pcmag.com/encyclopedia_term/0,2542,t=IDS&i=44731,00.asp (accessed February 28, 2008).
- Isaacson, Walter. *Benjamin Franklin: An American Life*. New York: Simon and Schuster, 2004.
- Jagatic, Tom, Nathaniel Johnson, Markus Jakobsson, and Filippo Menczer. "Social Phishing." *Communications of the ACM*, 2005.
- Jewellap, Mark. "Record Number of Data Breaches in 2007." MSNBC, December 30, 2007. <http://www.msnbc.msn.com/id/22420774/>.
- Jha, Ashish K., et al. "How Common Are Electronic Health Records in the United States? A Summary of the Evidence." *Health Affairs* (2006): 496.
- Johnson, Steven. *Emergence: The Connected Lives of Ants, Brains, Cities and Software*. New York: Scribner, 2001.
- Johnston, Mary Beth, and Leighton Roper. "HIPAA Becomes Reality: Compliance with New Privacy, Security and Electronic Transmission Standards." *West Virginia Law Review* (2001): 103.
- Jordan, Amy B. "Exploring the Impact of Media on Children: The Challenges That Remain." *Archives of Pediatrics & Adolescent Medicine* (April 2006): 446–48.
- . "The Three-Hour Rule and Educational Television for Children." *Popular Communication*, no. 105 (2004).
- Jordan, Tim, and Paul Taylor. *Hacktivism and Cyberwars: Rebels with a Cause?* New York: Routledge, 2004.
- . "A Sociology of Hackers." *Sociological Review* (1998): 757.
- JP Morgan Chase. "What Matters." <http://www.chasewhatmatters.com> (accessed March 2008).
- Juicy Whip, Inc. v. Orange Bang, Inc.* 292 F.3D 728 (Fed. Cir., 2002).
- Kaner, Cem. "Software Customer Bill of Rights." August 27, 2003. <http://blackbox.cs.fit.edu/blog/kaner/archives/000124.html>.
- Katz, James E., and Ronald E. Rice. *Social Consequences of Internet Use—Access, Involvement and Interaction*. Cambridge, MA: MIT Press, 2002.
- Keeton, W. Page, et al. *Prosser and Keeton on the Law of Torts*. 5th ed. Eagan, MN: West, 1984.
- Keizer, Gregg. "Consumer Security Fears Cost E-Commerce \$2 Billion." *Information Week*, November 27, 2006a. <http://www.informationweek.com/news/showArticle.jhtml?articleID=196513328>.
- . "UCLA Admits Massive Data Hack." *Information Week*, December 12, 2006b. <http://www.informationweek.com/security/showArticle.jhtml?articleID=196603485>.
- Kennedy, Dennis, and John Gelagin. "Want to Save 16 Minutes Every Day?" *Findlaw*, February 2003. http://practice.findlaw.com/archives/worldbeat_0203.html.
- Kephart, Jeffrey O., and David M. Chess. "Computers and Epidemiology." *IEEE Spectrum*. May 1993.

- Kerber, Ross. "Analysts: TJX Case May Cost over \$1b." *Boston Globe*, April 12, 2007a. http://www.boston.com/business/personalfinance/articles/2007/04/12/analysts_tjx_case_may_cost_over_1b/?page=2.
- . "TJX, Banks Reach Settlement in Data Breach." *Boston Globe*, December 18, 2007b. http://www.boston.com/business/articles/2007/12/18/tjx_banks_reach_settlement_in_data_breach/.
- Kesan, Jay, and Rajiv Shah. "Establishing Software Defaults: Perspectives from Law, Computer Science and Behavioral Economics." *Notre Dame Law Review* 82 (2006): 583.
- Kewanee Oil Co. v. Bicron Corp.* 416 U.S. 470, 1974.
- King, John L. "Patent Examination Procedures and Patent Quality." In *Patents in the Knowledge-Based Economy*, edited by Wesley M. Cohen and Stephen A. Merrill. Washington, DC: National Academies Press, 2003.
- Kirchheimer, Sid. "Grave Robbery: Stop Identity Theft of the Dead." MSNBC. May 10, 2007. <http://www.msnbc.msn.com/id/18495531/page/2/>.
- Kline, Stephen. "Learners, Spectators, or Gamers? An Investigation of the Impact of Digital Media in the Media-Saturated Household." In *Toys, Games, and Media*, edited by Jeffrey Goldstein, David Buckingham, and Gilles Brougere. Mahwah, NJ: Lawrence Erlbaum, 2004.
- Kline, Stephen, and Jackie Botterill. "Media Use Audit for BC Teens: Key Findings." *Kym Stewart*. May 2001. <http://www.kymstewart.com/assets/documents/research-pg/secondschool.pdf>.
- Koetzle, Laura. "Is Linux More Secure Than Windows?" Forrester Research. March 19, 2004. <http://download.microsoft.com/download/9/c/7/9c793b76-9eec-4081-98ef-f1doebff9d/LinuxWindowsSecurity.pdf> (accessed March 10, 2008).
- Korobkin, Russell. "Bounded Rationality, Standard Form Contracts, and Unconscionability." *University of Chicago Law Review* 70 (2003): 1203, 1217.
- K-Otik Staff. "Full-Disclosure Is Now ILLEGAL in France! Vulnerabilities, Technical Details, Exploits." *Security Focus Bugtraq*, April 8, 2004. <http://www.securityfocus.com/archive/1/359969/30/0/threaded>.
- Kozma, Robert. "Why Transitive Closure Is Important." http://www.msci.memphis.edu/kozmar/web-t_alg_n11-2.ppt.
- Krebs, Brian. "Major Anti-Spam Lawsuit Filed in Virginia." *Washington Post*, April 26, 2007a. <http://www.washingtonpost.com/wp-dyn/content/article/2007/04/25/AR2007042503098.html>.
- . "Microsoft Calls for National Privacy Law." *Washington Post*, November 3, 2005. http://blog.washingtonpost.com/securityfix/2005/11/microsoft_calls_for_national_p_1.html.
- . "Microsoft Weighs Automatic Security Updates as a Default." *Washington Post.com*, August 19, 2003. <http://www.washingtonpost.com/ac2/wp-dyn/A11579-2003Aug18>.
- . "Second Credit Bureau Offers File Freeze." *Washington Post*, October 4, 2007b.

- http://blog.washingtonpost.com/securityfix/2007/10/second_big_three_credit_bureau.html.
- L. M. Rabinowitz Co. v. Dasher*, 82 N.Y.S.2d 431, 435 (Sup. Court. N.Y. County) 1948.
- Labs, Wayne. "Machine Control: Still Islands of Automation?" *Food Engineering*, January 10, 2006. http://www.foodengineeringmag.com/CDA/Articles/Feature_Article/fd8b90115c2f8010VgnVCM100000f932a8co.
- Lankford, Kimberly. "Do-It-Yourself ID Protection." *Kiplinger's Personal Finance*, March 23, 2008. <http://www.washingtonpost.com/wp-dyn/content/article/2008/03/21/AR2008032103824.html>.
- Larkin, Eric. "The Battle for Your Computer." *Today@PC World*, May 4, 2006. <http://blogs.pcworld.com/staffblog/archives/001991.html>.
- Lauria, Peter. "MySpace Loves Facebook Value." *New York Post*, October 26, 2007. http://www.nypost.com/seven/10262007/business/myspace_love_facebook_value.htm.
- Leff, Arthur Allen. "Unconscionability and the Crowd—Consumers and the Common Law Tradition." *University of Pittsburgh Law Review* 31 (1969–1970): 349, 356.
- Lemley, Mark A. "Intellectual Property Rights and Standard Setting Organizations." *California Law Review* 90 (2002): 1889.
- . "Place and Cyberspace." *California Law Review* 91 (2003): 521.
- Lemos, Robert. "Breach Case Could Curtail Web Flaw Finders." *Security Focus*, April 26, 2006a. <http://www.securityfocus.com/news/11389>.
- . "Flaw Finders Go Their Own Way." *CNET News.com*, January 26, 2005a. http://news.com.com/Flaw+finders+go+their+own+way/2100-1002_3-5550430.html?tag=nl.
- . "Groups Argue over Merits of Flaw Bounties." *Security Focus*, April 5, 2006b. <http://www.securityfocus.com/news/11386>.
- . "Researchers: Flaw Auctions Would Improve Security." *Security Focus*, December 15, 2005b. <http://www.securityfocus.com/news/11364>.
- . "Security clearinghouse under the gun." *CNET News.com*, January 29, 2003. http://news.com.com/Security+clearinghouse+under+the+gun/2100-1001_3-982663.html?tag=nl.
- . "Software Security Group Launches." *CNET News.com*, September 26, 2002. <http://news.com.com/2100-1001-959836.html>.
- Lenhart, Amanda, and Mary Madden. "Teens Privacy and Online Social Networks." *Pew Internet and American Life Project*. January 7, 2007. http://www.pewinternet.org/pdfs/PIP_Teens_Privacy_SNS_Report_Final.pdf.
- Lessig, Lawrence. *Code and Other Laws of Cyberspace*. New York: Basic Books, 1999.
- . "Cyberspace and Privacy: A New Legal Paradigm? Foreword." *Stanford Law Review* 52 (2000): 987.
- Letter from the Digital Security Coalition to the Canadian Ministers of Industry and Canadian Heritage. June 22, 2006. http://www.digitalsecurity.ca/DSC_LT_Conervative_Ministers_re_balanced_copyright_-_22_June_06.pdf.
- Lewin, Jeff L. "The Genesis and Evolution of Legal Uncertainty and 'Reasonable Medical Certainty.'" *Maryland Law Review* 57 (1998): 380.

- Leyden, John. "Facebook Blocks Secret Crush over Adware Row." *The Register*, January 8, 2008. http://www.theregister.co.uk/2008/01/08/facebook_blocks_secret_crush/.
- . "Hatbot Arrest Throws Open Trade in Zombie PCs." *The Register*, May 12, 2004. http://www.theregister.co.uk/2004/05/12/phatbot_zombie_trade/.
- Li, Paul Luo, James Herbsleb, Mary Shaw, and Brian Robinson. "Experiences and Results from Initiating Field Defect Prediction and Product Test Prioritization Efforts at ABB Inc." *International Conference on Software Engineering Proceedings*, 2006, 413.
- Lindstrom, Pete. "To Sue Is Human, to Err Denied." *Computerworld*, November 2, 2005. <http://www.computerworld.com/securitytopics/security/story/0,10801,105869,00.html>.
- LinkedIn. "About LinkedIn." March 20, 2008. http://www.linkedin.com/static?key=company_info.
- Livingstone, Sonia. "Taking Risky Opportunities in Youthful Content Creation." *Scribd*, November 15, 2007. <http://www.scribd.com/doc/513946/sonia-livingstone-social-networking-presentation-Poke-sy>.
- Lockridge v. Tweco Products, Inc.*, 209 Kan. 389, 393 (1972).
- Lohmann, Fred von. "Letter to Alain Levy and David Munns." *EFF*, January 4, 2006. <http://www.eff.org/IP/DRM/emi.pdf>.
- Lohr, Steve. "I.B.M. Hopes to Profit by Making Patents Available Free." *New York Times*, April 11, 2005.
- Long, Clarisa. "Patent Signals." *University of Chicago Law Review* 69 (2002): 625.
- Loren, Lydia Pallas. "Slaying the Leather-Winged Demons in the Night: Reforming Copyright Owner Contracting with Clickwrap Misuse." *Ohio Northern University Law Review* 30 (2004): 495, 502.
- Macmillan, Robert. "Lawsuit Threatens Spamhaus with Shutdown." *Infoworld*, October 17, 2006. http://www.infoworld.com/article/06/10/17/HNspamhauslawsuit_1.html.
- Magid, Larry. "It Pays to Read License Agreements." *PC Pitstop.com*. <http://www.pcpitstop.com/spycheck/eula.asp>.
- MailFrontier Phishing IQ Test II*. <http://survey.mailfrontier.com/survey/quiztest.html> (accessed November 26, 2004).
- MailFrontier. "Threat Stats." <http://www.mailfrontier.com/threats/stats.html> (accessed November 3, 2005).
- Mann, Ronald J. "Do Patents Facilitate Financing in the Software Industry?" *Texas Law Review* (2005): 961.
- Manual of Patent Examining Procedure* 8th ed. (rev. 2, May 2004). Washington, DC: U.S. Patent and Trademark Office. <http://www.uspto.gov/web/offices/pac/mppep/index.html> (accessed April 15, 2005).
- Marc Bragg v. Linden Research, Inc. and Philip Rosendale*. NO. 06-4925 (Eastern District of Pennsylvania, 2007).
- "March 2000 Director Initiatives, U.S. PTO: Patents: Guidance, Tools & Manuals: Patent Business Methods." <http://www.uspto.gov/web/menu/pbmethod> (accessed April 15, 2005).
- Marketscore*. <http://www.marketscore.com/Researchware.aspx>.

- Markoff, John. "U.S. Office Joins an Effort to Improve Software Patents." *New York Times*, January 10, 2006.
- Marson, Ingrid. "EMI: We Don't Use Rootkits." *CNET News.com*, November 7, 2005. http://news.com.com/EMI+We+dont+use+rootkits/2100-1029_3-5937108.html.
- Martin, Patricia A. "Bioethics and the Whole Pluralism, Consensus, and the Transmutation of Bioethical Methods into Gold." *Journal of Law, Medicine and Ethics* 27 (1999): 316.
- "Massachusetts, Connecticut Bankers Associations and the Maine Association of Community Banks and Individual Banks File Class Action Lawsuit Against TJX Companies Inc." Massachusetts Bankers Association. April 24, 2007. <https://www.massbankers.org/pdfs/DataBreachSuitNR5.pdf>.
- Matwyshyn, Andrea M. "Material Vulnerabilities: Data Privacy, Corporate Information Security and Securities Regulation." *Berkeley Business Law Journal* 3 (2005): 129.
- Mayer, Caroline E. "'Virtual card' offers online security blanket." *Washington Post*, October 1, 2005. <http://www.washingtonpost.com/wp-dyn/content/article/2005/09/30/AR2005093001679.html>.
- Mayer-Schoenberger, Viktor. "Useful Void: The Art of Forgetting in the Age of Ubiquitous Computing, KSG Working Paper No. RWP07-022." 2007. <http://ssrn.com/abstract=976541>.
- McAfee, Inc. "McAfee Virtual Criminology Report 2007." 2007. http://www.mcafee.com/us/research/criminology_report/default.html.
- McClean, Thomas R. "Application of Administrative Law to Health Care Reform: The Real Politik of Crossing the Quality Chasm." *Journal of Law and Health* 16 (2001-2002): 65.
- McCullagh, Declan. "Homeland Security Flunks Cybersecurity Prep Test." *CNet News*, May 26, 2005. http://news.zdnet.com/2100-1009_22-5722227.html.
- . "Security Warning Draws DMCA Threat." *CNET News.com*, July 30, 2002. <http://news.com.com/2100-1023-947325.html>.
- McFarland v. Brier*, 1998 WL 269223 at *3 (R.I. Super., 1998).
- McGraw, Gary, and John Viega. "The Chain Is Only as Strong as Its Weakest Link." *IBM Developer Works*. <http://www-106.ibm.com/developerworks/linux/library/s-link.html> (accessed November 30, 2004).
- McMullan, Alasdair J. "Letter to Fred Von Lohmann." *EFF*. January 26, 2006. http://www.eff.org/IP/DRM/EMI_response.pdf.
- McWilliams, Brian. "HP Exploit Suit Threat Has Holes." *Wired.com*, August 2, 2002a. <http://www.wired.com/news/technology/0,1282,54297,00.html>.
- . "Name Your Own Price on PayPal." *Wired News*, April 19, 2002b. http://www.wired.com/news/business/0,1367,51977,00.html?tw=wn_story_related.
- "Medical Identity Theft: The Information Crime That Can Kill You." World Privacy Forum. http://www.worldprivacyforum.org/pdf/wpf_medicalidtheft2006.pdf (accessed May 3, 2006).
- "Medical Maladies Ailments." *Hippo Direct*. http://www.hippodirect.com/ListSubjectsN_1.asp?lSubject=37 (accessed December 11, 2007).

- Medical Marketing Service. <http://www.mmslists.com> (accessed December 11, 2007).
- Meiklejohn, Alexander. *Political Freedom*. New York: Oxford University Press, 1965.
- "Memorandum of Law in Support of Petition of Attorney General, *Spitzer v. Network Associates, Inc.* dba McAfee Software." *Find Law*. <http://news.findlaw.com/hdocs/docs/cyberlaw/nyntwrkasso20702mol.pdf>.
- Menn, Joseph. "Deleting Online Extortion." *LA Times*, October 25, 2004. http://www.josephmenn.com/other_delete_online_extortion.php.
- Merges, Robert P., Peter S. Menell, and Mark A. Lemley. *Intellectual Property in the New Technological Age*. 3rd ed. New York: Aspen Publishers, 2003.
- Meserve, Jeanne. "Homeland Security Official Arrested in Child Sex Sting." *CNN.com*, April 5, 2006. <http://www.cnn.com/2006/LAW/04/04/homeland.arrest/index.html>.
- Meunier, Pascal. "Reporting Vulnerabilities Is for the Brave." *CERIAS weblogs*, May 22, 2006. <http://www.cerias.purdue.edu/weblogs/pmeunier/policies-law/post-38/>.
- Meurer, Michael J. "Business Method Patents and Patent Floods." *Washington University Journal of Law and Policy* (2002): 309, 324–26.
- "Microsoft Anti-Piracy Program Has Hard-Edged EULA." *Infoworld*, Ed Foster's Gripelog, April 28, 2006. <http://www.gripe2ed.com/scoop/story/2006/4/28/0851/56993>.
- Microsoft Corporation. *Windows Update*. <http://windowsupdate.microsoft.com/> (accessed March 10, 2008).
- Milgrim, Roger M. *Milgrim on Trade Secrets*. New York: Matthew Bender, 1997.
- Mill, John Stuart. *On Liberty*. London: Penguin Books, 1974.
- Miller, Jeffrey G. "Evolutionary Statutory Interpretation: Mr. Justice Scalia Meets Darwin." *Pace Law Review* 20 (2000): 409.
- Mills, Mike. "Testing the Limits on Trade Secrets; Kodak Lawsuit Is Likely to Have Broad Impact on Use of Confidential Data." *Washington Post*, December 9, 1997.
- Milne, George R., and Mary J. Culnan. "Strategies for Reducing Online Privacy Risks: Why Consumers Read (or Don't Read) Online Privacy Notices." *Journal of Interactive Marketing* (2004): 15.
- Mischel, Lawrence, Jared Bernstein, and John Schmitt. *The State of Working America 1998–1999*. Washington, DC: Economic Policy Institute, 1999.
- Mnookin, Robert, and Lewis Kornhauser. "Bargaining in the Shadow of the Law." *Yale Law Journal* (1979): 950.
- Mohammed, Arshad. "Record Fine for Data Breach." *Washington Post*, January 27, 2006. http://www.washingtonpost.com/wp-dyn/content/article/2006/01/26/AR2006012600917_pf.html.
- "Monster.com Admits Keeping Data Breach Under Wraps." Fox News, August 24, 2007. <http://www.foxnews.com/story/0,2933,294471,00.htm>.
- "More Businesses Are Buying over the Internet." *National Statistics (UK)*, November 3, 2004. <http://www.statistics.gov.uk/pdffdir/e-com1104.pdf>.
- Moy, R. Carl. "Subjecting Rembrandt to the Rule of Law: Rule-Based Solutions for Determining the Patentability of Business Methods." *William Mitchell Law Review* (2002): 1047, 1050, 1071–72.

- Naraine, Ryan. "Flood to File Bankruptcy: Victim of Credit Card Fraud." *Internet News.com*, August 27, 2001. www.internetnews.com/ec-news/pring.php/873321.
- National Conference of Commissioners on Uniform State Laws. "Uniform Computer Information Transactions Act." 2002. <http://www.law.upenn.edu/bll/archives/ulc/ucita/ucita200.htm>.
- National Conference of State Legislatures. "Security Breach Notification Laws." <http://www.ncsl.org/programs/lis/cip/priv/breachlaws.htm> (accessed January 15, 2008).
- National Institute of Standards and Technology. "Commerce Secretary Announces New Standard for Global Information Security." December 4, 2001. http://www.nist.gov/public_affairs/releases/go111.htm (accessed April 15, 2005).
- . Computer Security Division: Computer Security Resource Center (CSRC). <http://csrc.nist.gov> (accessed April 15, 2005).
- National Research Council. "The Digital Dilemma: Intellectual Property in the Information Age, app. E—[Cryptography] Technologies for Intellectual Property Protection." 2000. http://www.nap.edu/html/digital_dilemma/appE.html (accessed April 15, 2005).
- Nelson, Emily. "Toilet-Paper War Heats Up with New, Wet Roll." *Wall Street Journal*, January 2001.
- Neumeister, Larry. "Guilty Plea in Huge ID Theft Case." CBS News, September 14, 2004. <http://www.cbsnews.com/stories/2004/09/15/tech/main643714.shtml>.
- "New Weakness in 802.11 WEP." *Slashdot*, July 27, 2001. <http://developers.slashdot.org/article.pl?sid=01/07/27/1734259&tid=93>.
- Newsletter. *NetFamily News*, April 21, 2000. <http://www.netfamilynews.org/nl000421.html>.
- Nissenbaum, Helen. "Hackers and the Contested Ontology of Cyberspace." *New Media and Society* (2004): 195.
- Nist, T. A. "Finding the Right Approach: A Constitutional Alternative for Shielding Kids from Harmful Materials Online." *Ohio State Law Journal* 45, no. 451 (2004).
- NJ P.L.1997, Sect. 3, as amended. 1997. http://www.njleg.state.nj.us/2004/Bills/A3500/4001_R1.PDF.
- North Texas Preventive Imaging, L.L.C. v. Eisenberg*, 1996 U.S. Dist. LEXIS 19990 (C.D. Cal. Aug. 19, 1996). <http://www.tomwbell.com/NetLaw/Chog/NorthTexas.html>.
- Nowak, P. "Copyright Law Could Result in Police State: Critics." CBC News, June 12, 2008. <http://www.cbc.ca/technology/story/2008/06/12/tech-copyright.html>.
- Novell. "Patch Management." <http://www.novell.com/products/zenworks/patchmanagement/> (accessed March 10, 2008).
- Oakley, Robert L. "Fairness in Electronic Contracting: Minimum Standards for Non-Negotiated Contracts." *Houston Law Review* 42 (2005): 1041–97.
- "OASIS Committees by Category: Security." http://www.oasis-open.org/committees/tc_cat.php?cat=security (accessed April 20, 2005).
- Odlyzko, Andrew M. "Economics, Psychology, and Sociology of Security." In *Financial Cryptography: 7th International Conference*, edited by R. N. Wright. Springer, 2007.
- "OECD Guidelines on the Protection of Privacy and Transborder Flows of Personal

- Data." Organization for Economic Cooperation and Development. http://www.oecd.org/document/18/0,2340,es_2649_34255_1815186_1_1_1_1,00.html (accessed March 20, 2008).
- Office of New York State Attorney General Andrew Cuomo. *State Lawsuit Attacks Spammers' Fraudulent Emails*. December 18, 2003. http://www.oag.state.ny.us/press/2003/dec/dec18b_03.html.
- "The Open Group, Public Key Infrastructure." <http://www.opengroup.org/public/tech/security/pki> (accessed April 15, 2005).
- The Openlaw DVD/DeCSS Forum. Frequently Asked Questions (FAQ) List, § 2.11.2. <http://cyber.law.harvard.edu/openlaw/DVD/dvd-discuss-faq.html> (accessed April 19, 2005).
- Orlowski, Andrew. "Microsoft EULA Asks for Root Rights—Again." *The Register*, August 2, 2002. <http://www.theregister.co.uk/content/4/26517.html>.
- Ou, George. "Retailers Haven't Learned from TJX." *ZDNet*, May 10, 2007. <http://blogs.zdnet.com/Ou/?p=487>.
- "Overview of the IETF." <http://www.ietf.org/overview.html> (accessed April 19, 2005).
- Palmer, Edward L., and Lisa Sofio. "Food and Beverage Marketing to Children in School." *Loyola Los Angeles Law Review* 39 (2006): 33.
- "Patch." *ZDNet*. <http://dictionary.zdnet.com/definition/Patch.html> (accessed March 10, 2008).
- PCI Security Standards Council. "PCI Data Security Standards." September 2006. https://www.pcisecuritystandards.org/tech/pci_dss.htm (accessed March 2008).
- Peck, Jamie, and Adam Tickell. "Neoliberalizing Space." *Anitpode* (2002): 380.
- Pedowitz, Arnold H., et al., eds. *Employee Duty of Loyalty*. Washington, DC: BNA Books, 1995.
- Peek, Marcy E. "Information Privacy and Corporate Power: Towards a Re-Imagination of Information Privacy." *Seton Hall Law Review* 37 (2006): 127.
- People v. Pribich*. 21 Cal. App. 4th 1844 (27 Cal. Rptr. 2d 113, 1994).
- Pereira, Joseph. "How Credit-Card Data Went out the Wireless Door." *Wall Street Journal*, May 4, 2007. http://online.wsj.com/article_email/article_print/SB117824446226991797-lMyQjAxMDE3NzA4NDIwNDQoWj.html.
- Perez, Juan Carlos. "Security Concerns to Stunt E-commerce Growth." *InfoWorld*, June 24, 2005. http://www.infoworld.com/article/05/06/24/HNsecurityconcerns_1.html.
- PGP History*. <http://www.pgp.com/company/history.html>.
- PGP. "2007 Annual Study: U.S. Cost of a Data Breach." November 2007. http://www.pgp.com/downloads/research_reports/ (accessed March 10, 2008).
- Phillips, Bill. *Complete Book of Locks and Locksmithing* 190. McGraw-Hill Professional, 2001.
- "Phishing." *ZDNet*. <http://dictionary.zdnet.com/index.php?d=phishing> (accessed March 10, 2008).
- "Ph Neutral." <http://ph-neutral.darklab.org/> (accessed March 10, 2008).
- "Phoenix Health Care HIPPA Advisory HIPPA Alert." <http://www.hipaadvisory.com/alert/vol4/number2.htm> (accessed February 6, 2006).

- Piaget, Jean. *Language and Thought of the Child*. Translated by Paul Kegan. New York: Routledge, 1926.
- Pincus, Jonathan D. "Computer Science Is Really a Social Science." *Microsoft Research*. January 2005. <http://research.microsoft.com/users/jpincus/cs%20socsci.html>.
- Podgurski, Andy. "Designing and Implementing Security Software." www.eecs.case.edu/courses/eecs444/notes/SecureCoding.ppt.
- . "Graceless Degradation, Measurement, and Other Challenges in Security and Privacy." *International Conference on Software Engineering Proceedings*. 2004.
- Polly Klaas Foundation. "New Survey Data on Youth Internet Behavior and Experiences Reveals Risks Teend and Tweens Take Online." December 21, 2005. <http://www.pollyklaas.org/media/new-survey-data-reveals-risks.html>.
- Pooley, James. *Trade Secrets*. New York: Law Journal Seminars Press, 1997.
- Post, David G., and David R. Johnson. "Chaos Prevailing on Every Continent: Toward a New Theory of Decentralized Decision-making in Complex Systems." *Chicago-Kent Law Review* 73 (1998): 1055.
- Poulsen, Kevin. "Chats Led to Acxiom Hacker Bust." *SecurityFocus*, December 19, 2003. <http://www.securityfocus.com/news/7697>.
- . "Scenes from the MySpace Backlash." *Wired*, February 27, 2006. <http://www.wired.com/news/politics/0,70254-0.html>.
- Pozen, Robert C. "Institutional Perspectives on Shareholder Nominations of Corporation Directors." *Business Lawyer* 59 (2003): 95.
- Preston, Ethan, and John Lofton. "Computer Security Publications: Information Economics, Shifting Liability and the First Amendment." *Whittier Law Review* 24 (2002): 71.
- Price Waterhouse Coopers. *How HIPAA and Security Intersect: Reporting on Request*. <http://www.pwcglobal.com/extweb/manissue.nsf/DocID/67B8EB4D694ACCo685256DE8007EC9F6> (accessed November 30, 2004).
- "Primer: Zombie Drone." *Washington Post*, February 1, 2004. <http://www.washingtonpost.com/wp-dyn/articles/A304-2004Jan31.html>.
- "Privacy and Consumer Profiling." *Electronic Privacy Information Center*. <http://www.epic.org/privacy/profiling> (accessed December 11, 2007).
- "Privacy and User License Agreement." *Marketscore*. <http://www.marketscore.com/Privacy.aspx>.
- ProCD Inc. v. Zeidenberg*. 86 F.3d 1447 (7th Circuit Court, 1996).
- "Protecting Teens Online." *Pew Internet and American Life Project*. March 17, 2005. http://www.pewinternet.org/PPF/r/166/report_display.asp.
- "Protecting Your Kids from Cyber-Predators." *Business Week*, December 12, 2005. http://www.businessweek.com/magazine/content/05_05/b3963915.htm.
- "Public Key Infrastructure (X.509) (pkix)." <http://www.ietf.org/html.charters/pkix-charter.html> (accessed April 19, 2005).
- Radin, Margaret Jane. "Online Standardization and the Integration of Text and Machine." *Fordham Law Review* 70 (2002): 1125, 1135–37.
- Radlo, J. Edward. "Legal Issues in Cryptography." *Computer Law* 13, no. 5 (1996).

- Ramadge, Andrew. "Education 'as Effective as Internet Filtering.'" *News.com.au*, February 26, 2008. <http://www.news.com.au/technology/story/0,25642,23272997-5014239,00.html>.
- Rasch, Mark. "Post to Bugtraq—Go to Jail." *Security Focus*, August 5, 2002. <http://www.securityfocus.com/columnists/100>.
- Rasmussen, J. "Skills, Rules, and Knowledge: Signals, Signs, and Symbols, and Other Distinctions in Human Performance Models." *IEEE Transactions on Systems, Man, and Cybernetics* 13, no. 257 (1983).
- Rauhofer, Judith. "Privacy Is dead—Get Over It! Article 8 and the Dream of a Risk-Free Society." *GIKII*. <http://www.law.ed.ac.uk/ahrc/gikii/docs2/rauhofers.pdf>.
- Raymond, Eric Steven. *The Cathedral and the Bazaar*. <http://www.catb.org/esr/writings/cathedral-bazaar/cathedral-bazaar/>.
- Reardon, Marguerite. "Cisco to Patent Security Fix." *CNET News.com*, May 19, 2004. http://news.com.com/Cisco+to+patent+security+fix/2100-1002_3-5216494.html?tag=nl.
- Reed, Chris. "Manifesto for Inertia in a Web 2.0 World." September 20, 2007. <http://blog.script.blogspot.com/2007/09/manifesto-for-inertia-in-web-20-world.html>.
- Regan, Priscilla. *Legislating Privacy: Technology, Social Values and Public Policy*. Chapel Hill, NC: University of North Carolina Press, 1995.
- Reidenberg, Joel R. "Lex Informatica: The Formulation of Information Policy Rules Through Technology." *Texas Law Review* 76 (1998): 553.
- Reisner, Lorin. "Transforming Trade Secret Theft Violations into Federal Crimes: The Economic Espionage Act." *Touro Law Review* 15 (1998): 139, 145.
- Religious Technology Center v. Lerma*. 908 F.Supp. 1362 (E.D.Va., 1995).
- Religious Technology Center v. Netcom*. 823 F.Supp 1231, 1239 (N.D. Cal., 1995).
- Report of the Board of Trustees. *AMA*. <http://www.ama-assn.org/ama/pub/upload/mm/475/bot17106.doc>.
- Respondent Network Associates' Memorandum of Law in Opposition to Petition of Attorney General, *Spitzer v. Network Associates, Inc. dba McAfee Software*. 2–6.
- Restatement of the Law (Third) of Unfair Competition*. Washington, DC: American Law Institute, 1995.
- Restatement of the Law (Second), Contracts*. Washington, DC: American Law Institute, 1981.
- Restatement of the Law (Second) of Agency*. Washington, DC: American Law Institute, 1958.
- Reuters. "Man Pleads Guilty in Massive Identity Theft." *CNET*, September 15, 2004. http://news.com.com/Man+pleads+guilty+in+massive+identity+theft/2100-1029_3-5367658.html?tag=st.rc.targ_mb.
- "Review of the Personal Health Record (PHR) Service Provider Market: Privacy and Security." *Altarum*. January 5, 2007. http://www.hhs.gov/healthit/ahic/materials/01_07/ce/PrivacyReview.pdf (accessed December 11, 2007).
- "Rise of Zombie PCs 'Threatens UK.'" *BBC News*, March 22, 2005. <http://news.bbc.co.uk/1/hi/technology/4369891.stm> (accessed August 16, 2005).

- "RMs Need to Safeguard Computerized Patient Records to Protect Hospitals." *Hospital Risk Management* 9 (1993): 129–40.
- Roberts, Paul. "Universities Struggling with SSL-Busting Software." *PCWorld.com*, November 30, 2004. <http://www.pcworld.com/news/article/0,aid,118757,00.asp>.
- Rodriguez, James F. "Software End User Licensing Agreements: A Survey of Industry Practices in the Summer of 2003." www.ucita.com/pdf/EULA_Research_Final5.pdf.
- Rogers, Everett. *Diffusion of Innovations*. New York: Free Press, 1995.
- Rogers, Marc. "Understanding Deviant Computer Behavior: A Moral Development And Personality Trait Approach." *Canadian Psychological Association Abstracts*. Summer 2003.
- "Rootkit." *ZDNet*. <http://dictionary.zdnet.com/index.php?d=rootkit> (accessed March 10, 2008).
- Rose, Nikolas. *Powers of Freedom: Reframing Political Thought*. Cambridge: Cambridge University Press, 1999.
- Roschelle, Jeremy M., Roy D. Pea, Christopher M. Hoadley, Douglas N. Gordin, and B. M. Means. "Changing How and What Children Learn in School with Computer-Based Technologies." *The Future of Children* (2000): 76–101.
- Rothstein, Mark A., and Meghan K. Talbott. "Compelled Authorizations for Disclosure of Health Records: Magnitude and Implications." *American Journal of Bioethics* 7 (2007): 38–45.
- Rothstein, Mark A., and Sharona Hoffman. "Genetic Testing, Genetic Medicine, and Managed Care." *Wake Forest Law Review* 34 (1999): 849, 887.
- Rowe, Elizabeth A. "Saving Trade Secret Disclosures on the Internet through Sequential Preservation." *Wake Forest Law Review* 42 (2007): 1.
- . "When Trade Secrets Become Shackles: Fairness and the Inevitable Disclosure Doctrine." *Tulane Journal of Technology & Intellectual Property* 7 (2005): 167, 183–91.
- Royal Carbo Corp. v. Flameguard, Inc.*, 229 A.D.2d 430, 645 N.Y.S.2d 18, 19 (2d Dep't 1996).
- RSA Data Security, Inc. v. Cylink Corporation*. Civ. No. 96-20094 SW, 1996 WL 107272, *1–3.
- RSA Laboratories. "What Are the Important Patents in Cryptography?" <http://www.rsasecurity.com/rsalabs/node.asp?id=2326> (accessed April 15, 2005).
- RSA Security Inc. <http://www.rsasecurity.com> (accessed April 15, 2005).
- Rubin, Paul, and Thomas M. Lenard. *Privacy and the Commercial Use of Personal Information*. Springer, 2002.
- Rubner v. Gursky*, 21 N.Y.S.2d 558, 561 (Sup. Court. N.Y. County 1940).
- Ruhl, J. B. "The Coevolution of Sustainable Development and Environmental Justice: Cooperation, Then Competition, Then Conflict." *Duke Environmental Law and Policy Forum* 9 (1999): 161.
- . "The Fitness of Law: Using Complexity Theory to Describe the Evolution of Law and Society and Its Practical Meaning for Democracy." *Vanderbilt Law Review* 49 (1996): 1407.

- Ruhl, J. B., and James Salzman. "Mozart and the Queen: The Problem of Regulatory Accretion in the Administrative State." 91 (2003): 757.
- Russinovich, Mark. "Sony, Rootkits and Digital Rights Management Gone Too Far." *Mark's Sysinternals Blog*. October 31, 2005. <http://www.sysinternals.com/blog/2005/10/sony-rootkits-and-digital-rights.html>.
- Salbu, Steven R. "The European Union Data Privacy Directive and International Relations." *Vanderbilt Journal of Transnational Law* 35 (2002): 655, 691.
- Saltzer, Jerome, and Michael D. Schroeder. "The Protection of Information in Computer Systems." *Communications of the ACM* 17, no. 7 (1974).
- Salzman, James, J. B. Ruhl, and Kai-Sheng Song. "Regulatory Traffic Jams." *Wyoming Law Review* 2 (2002): 253.
- Samuelson, Pamela. "Privacy as Intellectual Property." *Stanford Law Review* 52 (2000): 1125.
- Samuelson, Pamela, and Suzanne Scotchmer. "The Law and Economics of Reverse Engineering." *Yale Law Journal* 111 (2002): 1575.
- Sandeem, Sharon K. "The Sense and Nonsense of Website Terms of Use Agreements." *Hamline Law Review* 26 (2003): 499, 508.
- Satterfield v. Lockheed Missiles and Space Co.* 617 (F.Supp. 1359, 1369, S.C. 1985).
- Savage, Joseph F. Jr., Darlene Moreau, and Dianna Lamb. "Defending Cybercrime Cases: Selected Statutes and Defenses." In *Cybercrime: The Investigation, Prosecution and Defense of a Computer Related Crime*, edited by Ralph D. Clifford. Durham, NC: Carolina Academic Press, 2006.
- Schechter, Stuart E., Rachna Dhamija, Andy Ozment, and Ian Fisher. "The Emperor's New Security Indicators." IEEE Symposium on Security and Privacy. 2007.
- Schlafly v. Public Key Partners*. No.Civ.94-20512 SW, 1997 WL 542711 *2 (N.D.Cal., Aug. 29, 1997).
- Schneier, Bruce. "Cyber Underwriters Lab?" *Communications of the ACM* 44, no. 4 (2001a). <http://www.schneier.com/essay-024.html>.
- . "Facebook and Data Control." *Schneier on Security*. September 21, 2006. http://www.schneier.com/blog/archives/2006/09/facebook_and_da.html.
- . "Full Disclosure." *Cryptogram*. November 15, 2001b. <http://www.schneier.com/crypto-gram-0111.html#1>.
- . "Information Security and Externalities." *Schneier on Security*. January 18, 2007. http://www.schneier.com/blog/archives/2007/01/information_sec_1.html.
- . "Real Story of The Rogue Rootkit." *Wired.com*, November 17, 2005. <http://www.wired.com/news/privacy/0,1848,69601,00.html>.
- Schwartz, Alan, and Louis L. Wilde. "Imperfect Information in Markets for Contract Terms: The Examples of Warranties and Security Interests." *Virginia Law Review* 69 (1983): 1387, 1450.
- Schwartz, John. "Victoria's Secret Reaches A Data Privacy Settlement." *New York Times*, October 21, 2003. <http://query.nytimes.com/gst/fullpage.html?res=9C03EEDC1E3EF932A15753C1A9659C8B63&sec=&spon=&pagewanted=1>.

- Schwartz, Paul M. "Notification of Data Security Breaches." *Michigan Law Review* 105 (2007): 913.
- Security in Clinical Information Systems*, January 12, 1996. <http://www.cl.cam.ac.uk/users/rja14/policy11/policy11.html>.
- Sega Enterprises, Ltd. v. Accolade, Inc.* 977 F. 2d 1510 (9th Circuit Court, 1992).
- Shapiro, Carl. "Navigating the Patent Thicket: Cross Licenses, Patent Pools, and Standard Setting." Social Science Research Network, Working Paper. March 2001. http://papers.ssrn.com/sol3/papers.cfm?abstract_id=273550.
- Sheinfeld, Stephen L., and Jennifer M. Chow. "Protecting Employer Secrets and the 'Doctrine of Inevitable Disclosure'" *PLI/Lit* 600 (1999): 367.
- Shepard, Jessica, and David Shariatmadari. "Would-Be Students Checked on Facebook." *The Guardian*, January 11, 2008. <http://education.guardian.co.uk/universityaccess/story/0,,2238962,00.html>.
- Sheyner, Oleg, Joshua Haines, Somesh Jha, Richard Lippmann, and Jeannette M. Wing. "Automated Generation and Analysis of Attack Graphs." *IEEE Symposium on Security and Privacy Proceedings* (2002): 273.
- Simmons, John. "Harry Potter, Marketing Magician." *The Observer*, June 26, 2005.
- Simons, Mary M. "Benchmarking Wars: Who Wins and Who Loses with the Latest in Software Licensing." *Wisconsin Law Review* (1996): 165–66.
- Singel, Ryan. "Feds Avoid Showdown by Giving Montana Real ID Waiver It Didn't Ask For." *Wired*, March 21, 2008. <http://blog.wired.com/7bstroke6/2008/03/feds-avoid-show.html>.
- Singer, Dorothy G., and Jerome L. Singer. *Handbook of Children and the Media*. Thousand Oaks, CA: Sage Publications, 2001.
- Skibell, Reid. "Cybercrimes & Misdemeanors: A Reevaluation of the Computer Fraud and Abuse Act." *Berkeley Technology Law Journal* (2003): 909.
- . "The Myth of the Computer Hacker." *Information, Communication and Society* (2002): 336.
- Skinner, Carrie-Ann. "Facebook Faces Privacy Probe." *PC World*, January 23, 2008. <http://www.pcworld.com/article/id,141607-page,1/article.html>.
- Skype. "End User License Agreement." <http://www.skype.com/company/legal/eula/>.
- Sobel, Richard. "The HIPAA Paradox: The Privacy Rule That's Not." *Hastings Center Report*, July-August 2007: 40–50.
- "Social Network Service." *Wikipedia*. March 20, 2008. http://en.wikipedia.org/wiki/Social_network_service.
- "Social Networking Sites." *ZDNet*. <http://dictionary.zdnet.com/definition/social+networking+site.html> (accessed February 20, 2008).
- Social Security Administration. "Identity Theft and Your Social Number." Social Security Administration publication No. 05-10064." *Social Security Online*, October 2007. <http://www.ssa.gov/pubs/10064.html#new> (accessed February 2008).
- . "Social Security Numbers Chronology." <http://www.socialsecurity.gov/history/ssn/ssnchron.html> (accessed March 2008).

- Solove, Daniel J. *The Digital Person: Technology and Privacy in the Informational Age*. New York: NYU Press, 2004.
- Soma, John T., Sharon K. Black, and Alexander R. Smith. "Antitrust Pitfalls in Licensing." *Practicing Law Institute - Patent* 449 (1996): 349.
- Sony Entertainment Inc. v. Connectix Corp.* 203 F.3d 596 (9th Circuit Court, 2000).
- Sookman, Barry B. *Sookman Computer, Internet and Electronic Commerce Law*. Scarborough: Carswell, 2006.
- Sophos. "Sophos Facebook ID Probe Shows 41% of Users Happy to Reveal All to Potential Identity Thieves." *Sophos*, August 14, 2007. <http://www.sophos.com/pressoffice/news/articles/2007/08/facebook.html>.
- "Spam." *ZDNet*. <http://dictionary.zdnet.com/index.php?d=spam> (accessed March 10, 2008).
- Spitzer v. Network Associates, Inc. dba McAfee Software*. 758 N.Y.S.2d 466 (Supreme Court New York, 2003).
- Spitzer, Eliot. "Spitzer Sues Software Developer to Protect Consumers' Free Speech Rights." Office of the New York State Attorney General. February 7, 2002. http://www.oag.state.ny.us/press/2002feb/feb07a_o2.html.
- "Spoofing." *Webopedia*. http://www.webopedia.com/TERM/I/IP_spoofing.html (accessed November 26, 2004).
- Spradlin, Kimber. "Data Privacy Standards, American Style." *CNET News*. October 11, 2005. http://www.news.com/Data-privacy-standards,-American-style/2010-1029_3-5892395.html.
- "Spyware." *ZDNet*. <http://dictionary.zdnet.com/index.php?d=spyware> (accessed March 10, 2008).
- Stafford, Rob. "Why Parents Must Mind MySpace." *NBC News*, April 5, 2006. <http://www.msnbc.msn.com/id/11064451/>.
- "Standards and Guidelines." University of Maryland. <http://www.otal.umd.edu/guse/standards.html> (accessed March 10, 2008).
- Staniford, Stuart, Vern Paxson, and Nicholas Weaver. "How to Own the Internet in Your Spare Time." *USENIX Security Symposium Proc.* 2002. <http://www.icir.org/vern/papers/cdc-usenix-seco2/>.
- State Lawsuit Attacks Spammers' Fraudulent Emails*. December 18, 2003. http://www.oag.state.ny.us/press/2003/dec/dec18b_o3.html.
- State St. Bank & Trust Co. v. Signature Fin. Group, Inc.* 149 F.3d 1368, 1375 (Fed. Cir., 1998).
- "Statement of Aetna CEO and President Ronald A. Williams on Data Security." http://www.aetna.com/news/2006/pr_20060426.htm (accessed December 11, 2007).
- Sterling, Bruce. *The Hacker Crackdown*. New York: Bantam, 1993.
- Stone, Katherine. "The New Psychological Contract: Implications of the Changing Workplace for Labor and Employment Law." *UCLA Law Review* 48 (2001): 519.
- Stonebumer, Gary, et al. "Risk Management Guide for Information Technology Systems." *National Institute of Standards and Technology*. 2002. <http://csrc.nist.gov/publications/nistpubs/800-30/sp800-30.pdf>.

- Stuart, Suasn P. "Lex-Praxis of Educational Informational Privacy for Public Schoolchildren." *Nebraska Law Review* 84 (2006): 1158.
- Submission by Ed Felten and J. Alex Halderman to the U.S. Copyright Office seeking an exemption to the DMCA prohibition on the circumvention of copyright protection systems for access control technologies. December 1, 2005. <http://www.freedom-to-tinker.com/doc/2005/dmccacomment.pdf> at p.7.
- Sullivan, Bob. "ChoicePoint to Pay \$15 Million over Data Breach." *MSNBC*, January 26, 2006. <http://www.msnbc.msn.com/id/11030692/>.
- Swinton Creek Nursery v. Edisto Farm Credit*. 514 (S.E. 2d 126, 131, S.C. 1999).
- Swire, Peter P. "A Model for When Disclosure Helps Security: What Is Different About Computer and Network Security?" *Journal on Telecommunication and High Technology Law* 3 (2004): 163.
- . "Theory of Disclosure for Security and Competitive Reasons: Open Source, Proprietary Software, and Government Systems." *Houston Law Review* 42 (2006): 1333.
- Swire, Peter P., and Lauren B. Steinfeld. "Security and Privacy After September 11: The Health Care Example." *Minnesota Law Review* 86 (2002): 1515.
- Symposium on Usable Privacy and Security*. <http://cups.cs.cmu.edu/soups/2007>.
- Ta, L. "District Attorney Warns Students of Risk of Identity Theft." *The Daily Pennsylvanian*, March 31, 2006.
- "Teen Content Creators and Consumers." *Pew Internet and American Life Project*. November 2, 2005. http://www.pewinternet.org/PPF/r/166/report_display.asp.
- "Teens and Technology: Youth Are Leading the Transition to a Fully Wired and Mobile Nation." *Pew Internet and American Life Project*. July 27, 2005.
- Terry, Nicolas P. "To HIPAA, a Son: Assessing the Technical, Conceptual, and Legal Frameworks for Patient Safety Information." *Widener Law Review* 12 (2005): 133, 164.
- "Testimony of Thomas M. Dailey, Chair and President U.S. Internet Service Providers Association, General Counsel, Verizon Online, Before the Subcommittee on Technology, Information Policy, Intergovernmental Relations and the Census." June 16, 2004. <http://reform.house.gov/UploadedFiles/Dailey%20Testimony1.pdf>.
- Thomas, Douglas. *Hacker Culture*. Minneapolis, MN: University of Minnesota Press, 2002.
- Tipping Point. "Zero Day Initiative." *Tipping Point*. <http://www.zerodayinitiative.com/faq.html#20.0> (accessed January 4, 2007).
- "TJX Agrees to Class-Action Settlement." *Security Focus*, September 24, 2007. <http://www.securityfocus.com/brief/594>.
- Toffler, Alvin. *The Third Wave*. London: Pan Books, 1981.
- Tollefson v. Price*. 430 P.2d 990 (Ore., 1967).
- "Trojan." *ZDNet*. <http://dictionary.zdnet.com/index.php?d=trojan> (accessed March 10, 2008).
- "Trusted Computing Group Backgrounder." January 2005. https://www.trustedcomputinggroup.org/downloads/background_docs/TCGBackgrounder_revised_012605.pdf.

- Turnley, William H., and Daniel C. Feldman. "The Impact of Psychological Contract Violations on Exit, Voice, Loyalty, and Neglect." *Human Relations* 52 (1999): 7, 917.
- Turow, Joseph. "Privacy Policies on Children's Websites: Do They Play by the Rules?" *The Annenberg Public Policy Center of the University of Pennsylvania*. 2001. <http://www.asc.upenn.edu/usr/jturow/PrivacyReport.pdf>.
- "12 Principles for Fair Commerce in Software and Other Digital Products, Technical Version." *AFFECT*. 2005. <http://www.fairterms.org/12PrincTechnical.htm>.
- "2005 Electronic Monitoring & Surveillance Survey: Many Companies Monitoring, Recording, Videotaping-and Firing-Employees." August 29, 2006. <http://www.amanet.org/press/amanews/emso5.htm>.
- 2005 FBI Computer Crime Survey. <http://www.digitalriver.com/v2.0-img/operations/naievgi/site/media/pdf/FBIccs2005.pdf> (accessed August 15, 2006).
- U.S. Department of Labor, *Fact Sheet: Health Insurance Portability and Accountability Act*. <http://www.dol.gov/ebsa/newsroom/fshipaa.html> (accessed November 30, 2004).
- "U.S. Healthcare Industry HIPAA Compliance Survey Results: Summer 2006." *Health-care Information and Management Systems Society & Phoenix Health Systems*. 2006. <http://www.hipaadvisory.com/action/surveynew/results/summer2006.htm>.
- U.S. National Institutes of Health, *ClinicalTrials.gov*. <http://www.clinicaltrials.gov> (accessed December 7, 2006).
- U.S. Patent No. 5,575,405, issuing in 1996 and expiring in 2003 (Juicy Whip patent).
- U.S. Patent No. 3,962,539, issuing in 1976 and expiring in 1993 (IBM DES patent).
- U.S. Patent No. 4,200,770, issuing in 1980 and expiring in 1997 (Diffie-Hellman patent).
- U.S. Patent No. 4,218,582, issuing in 1980 and expiring in 1997 (Hellman-Merkle patent).
- U.S. Patent No. 4,405,822, issuing in 1983 and expiring in 2000 (RSA patent).
- "U.S. Says Personal Data on Millions of Veterans Stolen." *Washington Post*, May 22, 2006. <http://www.washingtonpost.com/wp-dyn/content/article/2006/05/22/AR2006052200690.html>.
- U.S. v. Martin*. 228 F.3d 1, 6 (Me, 2000).
- U.S. v. Yang*. 281 F.3d 534, 541 (N.D. Oh., 2002).
- UK Information Commissioner. "4.5 Million Young Brits' Futures Could Be Compromised by Their Electronic Footprint." *Information Commissioner's Office*. November 23, 2007. http://www.ico.gov.uk/upload/documents/pressreleases/2007/social_networking_press_release.pdf
- UK Information Commissioner. "Data Protection Topline Report." UK Information Commissioner's Office. October 31, 2007. http://www.ico.gov.uk/upload/documents/library/data_protection/detailed_specialist_guides/research_results_topline_report.pdf.
- "Unfair Terms in Consumer Contracts Regulations." *Statutory Instrument 1999 No. 2083 The Unfair Terms in Consumer Contracts Regulations 1999*. July 22, 1999. <http://www.opsi.gov.uk/si/si1999/19992083.htm>.
- Uniform Computer Information Transactions Act. "National Conference of Commissioners on Uniform State Laws." 2002. <http://www.law.upenn.edu/bll/ulc/ucita/2002final.htm>.

- United States. "National Strategy to Secure Cyberspace." 2003. <http://www.whitehouse.gov/pcipb/>.
- United States Attorney, Southern District of New York. "U.S. Announces Arrests in Case Involving Scheme to Steal AOL Customer List and Sell it to Spammers." United States Department of Justice. June 23, 2004. <http://www.usdoj.gov/usao/nys/Press%20Releases/JUNE04/AOL%20Complaint%20>.
- United States Department of Health & Human Services, Compliance and Enforcement. <http://www.hhs.gov/ocr/privacy/enforcement/numbersglance.html>.
- United States Department of Justice, Federal Bureau of Investigations. "Two Defendants Sentenced in Health Care Fraud, HIPAA, and Identity Theft Conspiracy." May 3, 2007. <http://miami.fbi.gov/dojpressrel/pressrel07/mm20070503.htm>.
- . Press release, August 19, 2004. http://www.usdoj.gov/usao/waw/press_room/2004/aug/gibson.htm.
- United States v. Bigmailbox.Com, Inc., et al.*, No. 01-605-A, Eastern Division of Virginia. Federal Trade Commission. April 19, 2001. <http://www.ftc.gov/os/2001/04/bigmailboxorder.pdf>.
- United States v. Bonzi Software, Inc.*, No. CV-04-1048 RJK, Western District of California. Federal Trade Commission. February 18, 2003. <http://www.ftc.gov/os/caselist/bonzi/040217decreebonzi.pdf>.
- United States v. Hershey Foods Corp.*, No. 4:03-CV-00350-JEJ, Middle District of Pennsylvania. Federal Trade Commission. February 27, 2003. <http://www.ftc.gov/os/2003/02/hersheyconsent.htm>.
- United States v. Industrious Kid, Inc. and Jeanette Symons*, CV No. 08-0639, Northern District of California. Federal Trade Commission. January 30, 2008. <http://www.ftc.gov/os/caselist/0723082/080730cons.pdf>.
- United States v. Lisa Frank, Inc.*, Eastern District of Virginia. Federal Trade Commission. October 2, 2001. <http://www.ftc.gov/os/2001/10/lfconsent.pdf>.
- United States v. Looksmart, Ltd.*, No. 01-606-A, Eastern Division of Virginia. Federal Trade Commission. April 19, 2001. <http://www.ftc.gov/os/2001/04/looksmartorder.pdf>.
- United States v. Mitnick*, 145 F.3d 1342 (9th Cir. 1998).
- United States v. Monarch Servs., Inc., et al.*, No. AMD 01-CV-1165, District of Maryland. Federal Trade Commission. April 19, 2001. <http://www.ftc.gov/os/2001/04/girlslifeorder.pdf>.
- United States v. Mrs. Fields Famous Brands, Inc.*, No. 2:03-CV-00205, District of Utah. Federal Trade Commission. February 23, 2003. <http://www.ftc.gov/os/2003/02/mrs-fieldsconsent.htm>.
- United States v. Pop Corn Co.*, Northern District of Iowa. Federal Trade Commission. February 14, 2002. <http://www.ftc.gov/os/2002/02/popcornconsnt.pdf>.
- United States v. The Ohio Art Co.*, Northern District of Ohio. Federal Trade Commission. April 22, 2002. <http://www.ftc.gov/os/2002/04/ohioartconsent.htm>.
- United States v. UMG Recordings, Inc.*, No. CV-04-1050 JFW, Central District of California. Federal Trade Commission. February 18, 2003. <http://www.ftc.gov/os/caselist/umgrecordings/040217cagumgrecordings.pdf>.

- United States v. Xanga.com, Inc.*, No. 06-CIV-682(SHS), Southern District of New York. Federal Trade Commission. September 7, 2006. <http://www.ftc.gov/os/caselist/0623073/xangaconsentdecree.pdf>.
- Valett, Harry A. "Mastering the Dark Arts of Cyberspace: A Quest for Sound Internet Safety Policies." *Stanford Technology Law Review* (2004): 2, 12.
- Vamosi, Robert. "TJX Agrees to Settlement in Class Action Suits." *CNET News*, September 25, 2007. http://www.news.com/8301-10784_3-9784465-7.html.
- Varian, Hal. "Managing Online Security Risks." *NYTimes.com*, June 1, 2000. www.nytimes.com/library/financial/columns/060100econ-scene.html.
- "Verisign iDefense Services." *iDefense*. <http://www.iddefense.com/services/index.php>.
- Vetter, Greg R. "The Collaborative Integrity of Open Source Software." *Utah Law Review* (2004): 563.
- "Vhost Sitepal." *Oddcast*. <http://www.oddcast.com/sitepal/?promotionId=235&bannerId=128> (accessed November 26, 2004).
- Viegas, Fernanda B. "Blogger's Expectations of Privacy and Accountability; An Initial Survey." *Journal of Computer-Mediated Communication* 10 (2005): 3.
- Vijayan, Jaikumar. "Chicago Elections Board Sued over Data Breach." *Computerworld*, January 23, 2007. <http://www.computerworld.com/action/article.do?command=viewArticleBasic&articleId=9008909>.
- "Violating NY Data Breach Law Costs Chicago Firm \$60,000." IT Compliance Institute. April 30, 2007. <http://www.itcinstitute.org/display.aspx?id=3474>.
- "Virus." *ZDNet*. <http://dictionary.zdnet.com/index.php?d=virus> (accessed March 10, 2008).
- Visa. "Visa Security Program." http://usa.visa.com/personal/security/visa_security_program/3_digit_security_code.html (accessed March 2008).
- Vogel v. W. T. Grant Co.* 327 A.2d 133, 137 (Pa., 1974).
- "Vulnerability Disclosure Publications and Discussion Tracking." University of Oulu, Finland. May 23, 2006. <http://www.ee.oulu.fi/research/ouspg/sage/disclosure-tracking/index.html#h-refio>.
- Waddams, S. M. *The Law of Contracts*. 4th edition. Aurora, Ontario: Canada Law Book Inc., 1999.
- Ward, Mark. "Cyber Thieves Target Social Sites." *BBC News*, January 3, 2008. <http://news.bbc.co.uk/1/hi/technology/7156541.stm>.
- Wayner, Peter. "A Patent Falls, and the Internet Dances." <http://www.nytimes.com/library/cyber/week/090697patent.html> (accessed April 15, 2005).
- Webb, Cynthia L. "CEOs Plan a Phish Fry." *Washington Post*, June 15, 2004.
- Weber, Tim. "Criminals May Overwhelm The Web." *BBC News*, January 25, 2007. <http://news.bbc.co.uk/1/hi/business/6298641.stm>.
- Werlinger, Rodrigo, and David Botta. "Detecting, Analyzing, and Responding to Security Incidents: A Qualitative Analysis." *Workshop on Usable IT Management Proceedings*. 2007. http://cups.cs.cmu.edu/soups/2007/workshop/Security_Incidents.pdf.
- "What Is the Trusted Computing Group?" <https://www.trustedcomputinggroup.org/home> (accessed April 18, 2005).

- Wheeler, Tracy. "Records Exposed: It's Possible Hackers Got Children's Hospital Data on 230,000 Patients, Families, 12,000 Donors." *Akron Beacon Journal*, October 2006.
- "White Hat." *Wikipedia*. June 29, 2006. http://en.wikipedia.org/wiki/White_hat.
- White House. "National Strategy to Secure Cyberspace." 2003. <http://www.whitehouse.gov/pcipb/>.
- Whitten, Alma, and J. D. Tygar. "Why Johnny Can't Encrypt: A Usability Evaluation of PGP 5.0." *USENIX Security Symposium Proceedings*. 1999. <http://citeseer.ist.psu.edu/whitten99why.html>.
- Williams, Chris. "Prosecutors Target First 'Facebook Harassment' Conviction." *The Register*, March 6, 2008. <http://www.out-law.com/page-8913>.
- Wilson, Mark. "Chips, Bits and the Law: An Economic Geography of Internet Gambling." *Environment and Planning A* (2003): 1245.
- "Windows Update." <http://windowsupdate.microsoft.com> (accessed March 10, 2008).
- Windows Update FAQ. Microsoft. <http://update.microsoft.com/windowsupdate/v6/default.aspx?ln=en-us>.
- Winn, Jane Kaufman, and James R. Wrathall. "Who Owns the Customer?" *Business Lawyer* 56 (2000): 213, 233.
- Wolinsky, Art. "WiredKids, from Safety and Privacy to Literacy and Empowerment." *Infotoday*, September 2000. <http://www.infotoday.com/mmschools/sep00/wolinsky.htm>.
- Wong, Rebecca. "Data Protection Online: Alternative Approaches to Sensitive Data?" *Journal of International Communication Law and Technology* 2 (2007): 1.
- Wright, Benjamin. "IT Security Law." *Tax Administration*. http://www.taxadmin.org/fta/meet/04tech_pres/wright.pdf.
- Wu, Min, Robert C. Miller, and Simson L. Garfinkel. "Do Security Toolbars Actually Prevent Phishing Attacks." *CHI*. 2006.
- XCon. <http://xcon.xfocus.org/> (accessed March 10, 2008).
- Zeller, Tom. "Black Market in Stolen Credit Card Data Thrives on Internet." *NYTimes.com*, June 21, 2005. www.nytimes.com/2005/06/21/technology/21data.html.
- "Zero Day Initiative, How Does It Work?" *Tipping Point*. <http://www.zerodayinitiative.com/details.html>.
- Zetter, Kim. "California Woman Sues ChoicePoint." *Wired.com*, February 24, 2005a. <http://www.wired.com/politics/security/news/2005/02/66710>.
- . "CardSystem's Data Left Unsecured." *Wired*, June 22, 2005b. <http://www.wired.com/science/discoveries/news/2005/06/67980>.
- . "Cisco Security Hole a Whopper." *Wired.com*, July 27, 2005c. <http://www.wired.com/politics/security/news/2005/07/68328>.
- . "Confessions of a Cybermule." *Wired.com*, July 28, 2006a. <http://www.wired.com/politics/onlinights/news/2006/07/71479>.
- . "Crime Boards Come Crashing Down." *Wired.com*, February 1, 2007a. <http://www.wired.com/science/discoveries/news/2007/02/72585>.
- . "Devious Tactic Snags Phone Data." *Wired.com*, January 17, 2006b. <http://www.wired.com/science/discoveries/news/2006/01/70027>.

- . “E-Gold Gets Tough on Crime.” *Wired.com*, December 11, 2006b. <http://www.wired.com/science/discoveries/news/2006/12/72278>.
- . “Feds Rethinking RFID Passport.” *Wired.com*, April 26, 2005d. <http://www.wired.com/politics/security/news/2005/04/67333>.
- . “Guilty Pleas in ID Theft Bust.” *Wired.com*, November 17, 2005e. <http://www.wired.com/techbiz/it/news/2005/11/69616>.
- . “ID Theft Victims Could Lose Twice.” *Wired.com*, February 23, 2005f. <http://www.wired.com/politics/security/news/2005/02/66685>.
- . “ID Theft: What You Need to Know.” *Wired.com*, June 29, 2005g. <http://www.wired.com/politics/security/news/2005/06/68032>.
- . “Inside the Mind of JJ Abrams.” *Wired.com*, March 8, 2007b. <http://www.wired.com/politics/security/news/2007/03/72914>.
- . “I Was a Cybercrook for the FBI.” *Wired.com*, January 30, 2007c. http://blog.wired.com/27bstroke6/files/FBI_Cybercrook.pdf.
- . “Protect Yourself from Pretexting.” *Wired.com*, September 14, 2006c. <http://www.wired.com/science/discoveries/news/2006/09/71769>.
- . “Router Flaw Is a Ticking Bomb.” *Wired News.com*, August 1, 2005h. <http://www.wired.com/news/privacy/0,1848,68365,00.html>.
- . “Tightening the Net on Cybercrime.” *Wired.com*, January 31, 2007d. <http://www.wired.com/politics/onlinights/news/2007/01/72581>.
- . “Tracking the Russian Scammers.” *Wired.com*, January 31, 2007e. <http://www.wired.com/politics/onlinights/news/2007/01/72605>.
- . “Viruses, Trojans and Remote Snooping: Hackers Release Their Own iPhone SDK.” *Wired.com*, October 17, 2007f. http://www.wired.com/gadgets/wireless/news/2007/10/iphone_hacks.
- . “Whistle-Blower Faces FBI Probe.” *Wired.com*, August 2, 2005i. http://www.wired.com/news/politics/0,1283,68356,00.html?tw=wn_tophead_3.
- . “Yo, Mr. CEO, Get Our Point Now?” *Wired.com*, October 24, 2003. <http://www.wired.com/techbiz/media/news/2003/10/60964>.
- Zittrain, Jonathan. “Internet Points of Control.” *British Colombia Law Review* 44 (2003): 653.
- Zoller, Thierry. “Zango Adware—Insecure Auto-Update and File Execution.” *Security Focus*, May 9, 2006. <http://www.securityfocus.com/archive/1/archive/1/433566/100/0/threaded>.
- Zook, Matthew. “Underground Globalization: Mapping the Space of Flows of the Internet Adult Industry.” *Environment and Planning A* (2003): 1261.

Index

- o-days, 27, 249n69
- 3Com, 27
- 12 Principles for Fair Commerce in Software and Other Digital Products (AFFECT), 165–66, 170, 183–84, 186, 188, 198–201
- ABA (American Bar Association), 199
- Abraham, Lynne, 274n29
- Acxiom Corporation, 41, 43, 142, 246n59, 252–53n25, 252n23, 266n3
- Adobe, 192
- Advanced Encryption Standard (AES), 88–89
- advertising and marketing on SNSs, third-party, 215–19
- adware, 283n148–49
- AdWords, 218
- AES (Advanced Encryption Standard), 88–89
- Aetna, 107
- AFFECT (Americans for Fair Electronic Commerce Transactions), 165–66, 170, 183–84, 186, 188, 198–201
- Aftab, Parry, 269–70n9
- aggregated consumer data, corporate hoarding of. *See* retention of data
- Ainsworth, Mary, 272n15
- Aitel, David, 279n67
- Alderman, Ellen, 151, 274n29
- ALI (American Law Institute), 159, 192–93, 198–99
- Altiris, 26
- AMA (American Medical Association), 107
- Amazon, 195
- Amazon.com, 216–17
- American Bar Association (ABA), 199
- American Express, 133
- American Law Institute (ALI), 159, 192–93, 198–99
- American Medical Association (AMA), 107
- Americans for Fair Electronic Commerce Transactions (AFFECT), 165–66, 170, 183–84, 186, 188, 198–201
- Americans with Disabilities Act, 108, 110–11
- Anderson, Ross, 21, 195
- Anderson, Tom, 269n9

- anti-benchmarking clauses, 161–67
- anti-circumvention provisions of Canadian Copyright Act and DMCA, 179–80
- anti-reverse-engineering clauses, 167–70
- AOL, 12, 56
- Apple, 249n59
- apps, third party, on SNSs, 212–15
- Aquisti, Alessandro, 206, 209, 215
- Aristotle, 56–57
- asset value diminution caused by information breaches, importance of recognizing, 9–10
- ATM cards. *See* payment cards and payment card fraud
- attack surfaces, 26
- Attrition.org, 38
- auditing and monitoring. *See* monitoring
- Australia, SNSs in, 222
- automatic data expiration, 225
- automatic update systems, abuse of, 186–89
- AutoPatcher, 26, 249n62
- Avery Dennison, 97

- backdoors, 83, 283n148
- banks and banking. *See* financial data
- Barnes, Susan, 210
- Beattie, Steve, 26
- Bebo, 203, 204, 222
- benchmark tests, software licensing clauses restricting, 161–67
- Bennett, Colin, 220
- Berry, Justin, 271n9
- “best mode” test, patents, 72
- best practices standard for health data protection, 119–20
- birth date and place, as security question, 60, 268n44
- Black Hat, 28
- Blankinship, Sarah, xi, 13, 19, 229
- Blaster worm, 186, 237n38, 246n63
- Blogger, 212
- blogs and blogging, 152, 215, 273n25
- Blue Card (American Express), 132–33
- Blue Hat series, 28
- Blumenthal, Richard, 270n9
- bot herders, 249n65
- botnets (zombie drones), 7, 194–95, 237n37–38
- Botterill, Jackie, 154
- bottom-up versus top-down approach to corporate information security, 292n3
- BP (British Petroleum), 105
- bragging by violators of security systems, 53–54
- Braucher, Jean, 166–67, 183, 198, 284n185, 284n187, 285n200, 287n234
- Brennan, William J., 277n23
- British Petroleum (BP), 105
- broadcasting media and children’s data, 148–50
- brokerage breaches and vulnerabilities, 55–56
- Brown, Ian, xi, 17, 202, 229
- Bush, George W., 103
- business methods exception from statutory subject matter test, patents, 255n8
- Butler, Shawn, 24, 25

- CAC (Common Access Card), 141
- California data breach notification statute, 36–38, 45, 142, 245–46n54, 253n5
- Canada
 - Copyright Act, revision of, 179–80
 - Ontario Consumer Protection Act, 276n7, 286n224
 - public policy, unenforceability of contracts contrary to, 196–97
 - SNSs in, 222
- CanSecWest, 28
- “Cap’n Crunch” (John Draper), 236n32
- card-not-present (CNP) transactions, 123
- Card Systems Solutions, 142, 266n4

- card validation value (CVV) numbers, 123, 133, 266n6, 266n8
- CarderPlanet, 54
- Carnegie Mellon University, SNS use at, 206, 209
- CAs (Certificate Authorities), 258–59n40
- case law. *See* court cases
- Cavazos, E. A., 35
- CDA (Communications Decency Act of 1996), 269n9
- cell phone data brokers, 58–60
- Census Bureau, 33, 39
- Center for Digital Democracy, 218
- Centers for Medicare and Medicaid Services (CMS), 115, 119–20
- centralized data collections, 5
- CERIAS, 174
- CERT (Computer Emergency Response Team), 120
- Certicom, 260n75
- Certificate Authorities (CAs), 258–59n40
- CFAA (Computer Fraud and Abuse Act), 35–36, 47
- Chandler, Jennifer, xii, 17, 159, 230
- Charles Schwab Corp., 246n61
- Chicago Board of Elections, 33
- Child Online Protection Act (COPA), 269n9
- children and children's data, 16, 145–56, 229
 - blogging and other content creation by children, 152
 - COPA, 269n9
 - COPPA. *See* Children's Online Privacy Protection Act
 - developmental perspective on, 147–48, 272–73n15–19
 - filter technology, 153–54, 275n38
 - internet, child interaction with, 148, 150–55, 268–69n4, 273–74n24–25
 - parental empowerment, importance of, 153–55
 - retention of data, 151
 - security/privacy, lack of attention to, 151–53, 210–12, 227, 270–71n9
 - sexual exploitation of, 270n9
 - sexual exploitation of children, 270n9
 - SNSs, use of, 150–55, 204, 220–21, 269–71n9
 - television and other broadcasting media, 148–50
 - virtual gaming, 153
- Children's Hospital, Akron, OH, 107
- Children's Online Privacy Protection Act (COPPA)
 - critique of, 146–47
 - inappropriate content protections, 269–71n9
 - purposes and provisions of, 146, 241–43n52
 - regulation of children's data by, 8, 16
- Children's Television Act, 149
- "chip and PIN" cards in EU, 132
- ChoicePoint, Inc., 12, 33, 62–63, 142, 244n53, 266n3
- Church of Scientology, 97–98
- circumvention of technological protections, Canadian Copyright Act provisions prohibiting, 179–80
- Cisco, 58, 168, 172
- Citibank, 236n31
- claims, patents, 65–67, 66, 73, 254n4, 255–56n13
- Classmates.com, 203
- Cleveland Clinic, 106
- ClinicalTrials.gov, 106
- Clipper Chip, 274n29
- Club Penguin, 203
- CMS (Centers for Medicare and Medicaid Services), 115, 119–20
- CNP (card-not-present) transactions, 123
- codes of corporate information security conduct, importance of, 228, 231–34
- collection of networked aggregated data. *See* retention of data

- commercial organizations, incidence of exposed records from, 40, 41
- commercial trust, erosion of, 8–9
- Common Access Card (CAC), 141
- common law contract doctrines used to control software licensing, 195–97
- Communication Act of 1934, 149
- Communications Decency Act of 1996 (CDA), 269n9
- community standards test, 250n10
- Compare Me (Facebook app), 212–15
- Computer Emergency Response Team (CERT), 120
- Computer Fraud and Abuse Act (CFAA), 35–36, 47
- computer games, child involvement in, 153
- computer information, security of. *See* corporate information security
- computer science, social science approach to. *See* social science approach to computer science
- conference presentations on information security breaches and vulnerabilities, 54, 168, 172
- confidentiality. *See* privacy and confidentiality
- Congressional hearings, 54
- consent
 - backdoors, 283n148
 - SNSs, 207, 216–21, 226
 - software licenses requiring consent for risky practices, 184–91
- Consumers Union, 165
- Content Scrambling System (CSS), 260n61
- contract law
 - adhesion contracts involving inequality of bargaining power, 221–22
 - common law doctrines of, 195–97
 - failure of end users to read/understand contracts, 192–95, 217
 - freedom of contract, freedom of speech, and free market, 164–65, 276–77n23
 - internet privacy contracts, 155
 - software licensing. *See* software licensing
 - third party applications for SNSs, 213
- contracts of silence, 164–65
- cookies, 106
- COPA (Child Online Protection Act), 269n9
- COPPA. *See* Children's Online Privacy Protection Act
- corporate information security, 3–18
 - bottom-up versus top-down approach to, 292n3
 - children's data, 16, 145–56, 229. *See also* children and children's data
 - common errors or lapses in, 11–13, 57–61
 - cryptography. *See* cryptography
 - culture and codes of conduct, importance of building, 228, 231–34
 - emergent and process-driven nature of, 228, 229–30
 - employee theft. *See* employees and employee theft
 - exposures, responsibility for, 13–14, 33–49, 231. *See also* responsibility for exposed digital records
 - financial data, 16, 121–44, 231. *See also* financial data
 - future issues in, 13–18
 - health data, 15–16, 103–20, 231. *See also* health data
 - historical development of organizational behavior regarding, 51–52
 - human focus, need for, 228, 229
 - multiple contexts, simultaneous situation in, 228, 230–31
 - organizational code, 230, 292n4–5
 - patenting, 14, 64–91, 230. *See also* patenting cryptographic technology

- process versus one-time nature of, 51–52
- reasons for data vulnerability, 4–11
- regulation of. *See* regulation of information security
- reporting breaches in, 14, 50–63, 230.
See also reporting information security breaches and vulnerabilities
- SNSs, 17, 202–27, 229. *See also* social networking sites
- as social science, 13, 19–29, 229. *See also* social science approach to computer science
- software licensing, 17, 159–201, 230.
See software licensing
- trade secrets, 15, 92–99, 231. *See also* trade secrets
- court cases
- Acara v. Banks*, 265n61
- American Bar Association v. Federal Trade Commission*, 241n51
- AT&T v. Excel Communications*, 257n20
- Beard v. Akzona, Inc.*, 264n33
- Board of Education v. Pico*, 277n23
- Charles Schwab Corp. v. Comm’r*, 246n61
- Diamond v. Chakrabarty*, 255n10
- Diamond v. Diehr*, 255n11
- Diaz v. Oakland Tribune*, 264n32
- Ford Motor Co. v. Lane*, 98
- Horne v. Patton*, 110, 264n34
- IMS Health Inc. v. Ayotte*, 264n31
- IMS Health v. Rowe*, 264n31
- IMS Health v. Sorrell*, 264n31
- Juicy Whip, Inc. v. Orange Bang, Inc.*, 255n12
- Kewanee Oil Co. v. Bicron Corp.*, 277n40
- Neville v. Dominion of Canada News Co. Ltd.*, 167
- North Texas Preventive Imaging, L.L.C. v. Eisenberg*, 251n12
- Religious Technology Center v. Lerma*, 97
- Satterfield v. Lockheed Missiles and Space Co.*, 264n33
- Spitzer v. Network Associates, Inc.*, 162–63, 170–71
- State St. Bank & Trust Co. v. Signature Fin. Group, Inc.*, 257n20
- Swinton Creek Nursery v. Edisto Farm Credit S.C.*, 264n33
- Tollefson v. Price*, 264n33
- United States v. Bigmailbox.Com, Inc., et al.*, 243n52
- United States v. Bonzi Software, Inc.*, 243n52
- United States v. Hershey Foods Corp.*, 243n52
- United States v. Industrious Kid, Inc. and Jeanette Symons*, 243n52
- United States v. Lisa Frank, Inc.*, 243n52
- United States v. Looksmart, Ltd.*, 243n52
- United States v. Mitnick*, 251n13
- United States v. Monarch Servs.*, 243n52
- United States v. Mrs. Fields Famous Brands, Inc.*, 243n52
- United States v. The Ohio Art Co.*, 243n52
- United States v. Pop Corn Co.*, 243n52
- United States v. Thomas*, 250n10
- United States v. UMG Recordings, Inc.*, 243n52
- United States v. Xanga.com, Inc.*, 242–43n52
- Universal City Studios, Inc. v. Reim-erdes*, 250n9
- Vogel v. W. T. Grant Co.*, 264n33
- von Hannover (ECHR)*, 210
- court documents
- on information security breaches and vulnerabilities, 54
- security breaches uncovered using, 57

- credit cards. *See* payment cards and payment card fraud
- credit ratings
 - defaulted loans and identity theft, 126–27
 - as monitoring system, 137
 - SSNs, problems with permanent validity of, 139
- cryptography
 - defined and described, 79–81, 257n26
 - embedded nature of, 80, 86–87
 - exports, government regulation of, 80–81
 - network effects/network value of, 76–77
 - patenting. *See* patenting cryptographic technology
 - public key, 81–82, 128, 258–59n40
 - revocation, 129–30
 - standards, government regulation of, 81, 82–83
- CS Stars, 245n54
- CSS (Content Scrambling System), 260n61
- culture of corporate information security, importance of building, 228, 231–34
- customer screening, 12
- CVV (card validation value) numbers, 123, 133, 266n6, 266n8
- CyberPatrol, 153
- cybersecurity. *See* internet security
- data breach notification. *See* reporting information security breaches and vulnerabilities; state data breach notification statutes
- data brokers, 58–60
- Data Encryption Standard (DES) patent, 82–83, 84, 88
- Data Protection Act 1998 (UK), 238n43
- Data Protection Directive (DPD), EU, 7–8, 205–7, 216–17, 221, 237–38n43, 291n68
- debit cards. *See* payment cards and payment card fraud
- decentering in child development, 146–47, 272n15–16
- default settings, 207–12, 214, 216–17, 223–25
- defaulted loans and identity theft, 126–27
- DefCon, 28
- Defense, Department of, 141
- definiteness test, patents, 72
- Slaughter-Defoe, Diana T., xii, 16, 145, 229
- Denning, Peter, 20
- Department of Defense, 141
- Department of Health and Human Services, 104, 111, 114, 115
- Department of Veterans Affairs, 33, 107
- DES (Data Encryption Standard) patent, 82–83, 84, 88
- DeWolfe, Chris, 269n9
- dictionary attacks, 23
- Diffie-Hellman patent, 82, 83, 84
- Digital Millennium Copyright Act (DMCA), 161, 175, 177–80
- digital rights management (DRM) software, 28–29
- Digital Security Coalition, 180
- digital signature standard (DSS), 259n49
- disclaimers in software licenses, 160
- disclosure of vulnerabilities
 - reporting and notification. *See* reporting information security breaches and vulnerabilities
 - software licensing terms restricting. *See under* software licensing
- disclosure requirement, patents, 71–72
- Disney, 61
- DMCA (Digital Millennium Copyright Act), 161, 175, 177–80
- document management systems, 236n16
- Doyle, Brian J., 270n9
- DPD (Data Protection Directive), EU, 7–8, 205–7, 216–17, 221, 237–38n43, 291n68
- Draper, John (“Cap’n Crunch”), 236n32

- drug prescriptions, 105–6
- Drugstore.com, 105–6
- DSS (digital signature standard), 259n49
- DSW Shoe Warehouse, 244n53
- DVD pool, 260n61
- Dwyer, Catherine, 211
- eBay, 5, 173, 205
- ECHR (European Court of Human Rights), 210
- economic investment in security, failure to make, 58
- Edelman, Ben, 188
- Edinburgh University Facebook network, 208
- education
 - health data of students
 - FERPA protections, 111
 - organizational interest in, 108
 - incidence of exposed records from, 40, 41
 - television, educational programming requirements for, 149
- Edwards, Lilian, xii, 17, 202, 229
- eEye Digital Security, 172, 279n74
- EHI (electronic health information). *See* health data
- EHR (electronic health records). *See* health data
- eID (electronic ID) systems, 142
- Electronic Communications Privacy Act, 239n48
- Electronic Frontier Foundation, 175, 178
- electronic health records (EHR)/information (EHI). *See* health data
- electronic ID (eID) systems, 142
- electronic information security. *See* corporate information security
- Electronic Privacy Information Center (EPIC), 222
- Eli Lilly and Company, 244n53
- emergent nature of corporate information security, 228, 229–30
- EMI Music, 178
- Empire Blue Cross and Blue Shield of New York, 107
- employees and employee theft
 - combating theft, means of, 98–99
 - confidential nature of employer–employee relationship, 84–95
 - loyalty
 - decline in, 95
 - employee duty of, 94
 - as major security problem, 12, 92
 - nondisclosure agreements (restrictive covenants), 94–95, 164
 - private disclosures, 96–97
 - public disclosures, 97–98
 - of trade secrets, 15, 92–99, 231
 - workplace use of computers, rise in, 95
- end user license agreements (EULAs), 199, 203, 220
- end users
 - behavioral information, use of, 218
 - contracts, failure to read/understand, 192–95, 217
 - FEULA (model fair end-user license agreement), 199
 - human error/fallibility studies, 22–24
 - Model End User Licensing Act, 198
 - responsibility for exposed digital records, 25–251n11, 34, 48
- EPIC (Electronic Privacy Information Center), 222
- equivalents, patent doctrine of, 73–74
- Erickson, Kris, xii, 13–14, 33, 231
- error, social science approach to study of, 22–24
- EULAs (end user license agreements), 199, 203, 220
- Europe/European Union (EU)
 - advertising and marketing requirements, 218–19
 - contract protections in, 222
 - DPD, 7–8, 205–7, 216–17, 221, 237–38n43, 291n68

- eID systems in, 141–42
- privacy issues in, 238–38n47
- smartcards, use of, 132
- SNSs in, 203, 204
- zombie drones in, 237n38
- European Court of Human Rights (ECHR), 210
- examiners of patents, 254n5
- expiration of data, automatic, 225
- exploits, 249n67, 249n69
- exported cryptography, government regulation of, 80–81
- exposed digital records, responsibility for. *See* responsibility for exposed digital records
- Extended Copy Protection (XCP), 176, 177
- Facebook, 270n9
 - advertising and marketing, third-party, 215–19
 - Compare Me and other third party applications, 212–15
 - data control problems and potential solutions, 220–23, 225–26
 - Oxford University Facebook case, 207–12
 - personal data disclosed on, 205–7
 - popularity of, 202–5
 - university networks, 208
- Facebook Beacon, 215–19, 223
- failure and recovery of financial security systems, designing for, 129–30, 138–39
- Fair Credit Billing Act, 125
- Fair Credit Reporting Act (FCRA), 111, 137–38
- fallibility studies, 22–24
- Family Education Rights and Privacy Act (FERPA), 111
- FBI (Federal Bureau of Investigation), 54, 59, 96, 97, 190, 237n40, 274n29
- FCRA (Fair Credit Reporting Act), 111, 137–38
- Federal Bureau of Investigation (FBI), 54, 59, 96, 97, 190, 237n40, 274n29
- Federal Trade Commission (FTC)
 - on economic costs of identity theft, 6, 236n26, 246n56
 - end user behavior information, use of, 218
 - powers of, 243–45n53
 - regulation of information security by, 8
 - SNSs, problems with permanent validity of, 139
- federal websites, security breaches involving, 57
- Felten, Edward, 175–77
- FERPA (Family Education Rights and Privacy Act), 111
- FEULA (model fair end-user license agreement), 199
- filter technology, 153–54, 275n38
- financial data, 16, 121–44, 231
 - comparing payment card and new account fraud, 125–27
 - failure and recovery, designing for, 129–30, 138–39
 - GLBA, 8, 240–41n51, 292–93n9
 - identifying risks, 122–27
 - identity management systems, 141–42
 - incentives to protect, 134–35, 140, 142
 - least privilege approach to, 127–28
 - legacy design problem, 122, 132
 - mitigation of fraud regarding, 127–30
 - monitoring, 128–29, 136–38
 - new account fraud, 123–27, 135, 137
 - online banking, 51, 137, 190
 - payment (credit/debit/ATM) cards. *See* payment cards and payment card fraud
 - “quasi-secret” nature of, 130–31, 142–44
 - risk management, 139–42

- SSNs. *See* Social Security numbers
- unnecessary retention of, 128, 135–36
- unreported bank and brokerage breaches and vulnerabilities, 55–56
- widespread distribution of, 131–35, 267n28
- financial investment in security, failure to make, 58
- Financial Modernization Act of 1999 (Gramm-Leach-Bliley Act or GLBA), 8, 240–41n51, 292–93n9
- Firefox, 249n59
- firewalls, 51–52, 253n3
- First4Internet, 176, 177
- Flaubert, Gustave, 202
- Flavell, John, 147
- Flickr, 212
- Flooz, 190
- Ford Motor Co., 98
- Forno, Richard, 188
- Foster, Ed, 199, 285n199
- France, legal restrictions on security researchers in, 174–75
- Franklin, Benjamin, 127
- free and open source software movement, 89–90
- freedom of contract, freedom of speech, and free market, 164–65, 276–77n23
- Freedom of Information Act of 1966, 110
- Fridman, G. H. L., 286n217
- FTC. *See* Federal Trade Commission
- gambling, online, 12, 35, 250n11, 274n28
- games, virtual, child involvement in, 153
- Geico, 60
- GLBA (Gramm-Leach-Bliley Act or Financial Modernization Act of 1999), 8, 240–41n51, 292–93n9
- Global State of Information Security Survey, 11
- GMail, 218
- GNU/Linux, 26, 90
- Google, 5, 61, 105, 205, 211, 218, 219, 227, 289–90n34
- government regulation. *See* regulation of information security
- Gramm-Leach-Bliley Act (GLBA, or Financial Modernization Act of 1999), 8, 240–41n51, 292–93n9
- Granick, Jennifer, 26, 278n52, 280n82, 282n139
- GripeWiki, 285n199
- Gross, Ralph, 206, 209, 215
- Guess.com, Inc., 244n53
- Hack-in-the-Box, 28
- hackers
- bragging by, 53–54
 - customer screening for, 12
 - exposure of digital records by, 34–36, 41–43, 42, 44, 46–49, 252n22
 - regulation of, 35–36
 - script kiddies, 56
 - social science approach to culture of, 22, 28
- Halderman, Alex, 175–77
- Harry Potter merchandising, 153, 274–75n36
- Hasbro, 212
- Health and Human Services, Department of, 104, 111, 114, 115
- health data, 15–16, 103–20, 231
- advantages and disadvantages of electronic records, 103–4
 - persons and organizations maintaining, 105–6
 - recommendations for improving protection of, 117–20
 - regulation of
 - common law protections, 109–10
 - federal laws, 110–11. *See also* Health Insurance Portability and Accountability Act
 - insufficient protection offered by, 114
 - state laws, 109

- responsibility for exposed digital records, medical organizations'
 - low incidence of, 40, 41
- of students
 - FERPA protections, 111
 - organizational interest in, 108
- vulnerabilities of, 106–9
- Health Insurance Portability and Accountability Act (HIPAA), 111–20
 - best practices standard for, 119–20
 - compliance problems, 115–16
 - covered entities, need to expand, 117–18
 - critique of, 16, 114–17
 - disclosures allowed under, 116–17
 - enforcement mechanisms, 113, 118–19
 - PHI, 111–17
 - Privacy Rule, 111, 112, 118
 - private right of action, allowing, 118–19
 - purposes and provisions of, 239–40n50
 - recommendations for improving, 117–20
 - regulation of health data by, 8, 15–16
 - right of inquiry under, 118
 - Security Rule, 111, 112–13, 119–20
 - transitivity of information risk, recognition of, 292–93n9
- HealthStatus.com, 106
- Hellman, Martin E., 82
- Hellman-Merkle patent, 82, 83, 84
- Hesse, Thomas, 176
- Hewlett-Packard (HP), 179
- Hill, Alex, 207–9
- Hiltz, Star, 211
- HIPAA. *See* Health Insurance Portability and Accountability Act
- HIT (health information technology). *See* health data
- hoarding of networked aggregated data. *See* retention of data
- Hoffman, Sharona, xii, 15–16, 103, 231
- Howard, Philip N., xii, 13–14, 33, 231
- HP (Hewlett-Packard), 179
- Human Control, 204
- human error studies, 22–24
- human focus of corporate information security, need for, 228, 229
- IBM, 82–83, 84, 88, 90, 260–61n76, 260n72
- iDefense, 27, 172–73, 279–80n78
- identity management systems, 141–42
- identity theft
 - common errors or lapses contributing to, 57–61
 - defaulted loans and credit ratings, 126–27
 - lucrative nature of, 5–7
 - medical, 108
 - monitoring systems, 137–38
 - new account fraud, 125, 126–27
 - responsibility for exposure of digital records and, 34, 44, 46–47
 - SSNs and, 125, 138–39
- Identity Theft Resource Center, 38
- IDEXX, 96–97
- IEC (International Engineering Council), 119
- IEEE (Institute of Electrical and Electronics Engineers), 88
- IETF (Internet Engineering Task Force), 260n66
- information security. *See* corporate information security
- informed minority argument for pre-transaction disclosure of software terms, 193–94
- infringements of patents, 73–75
- Institute of Electrical and Electronics Engineers (IEEE), 88
- Intel, 105
- intellectual property
 - Canadian Copyright Act, revision of, 179–80
 - patents. *See* patenting cryptographic technology

- software. *See* software licensing
- trade secrets. *See* trade secrets
- WIPO treaties, 179
- International Engineering Council (IEC), 119
- International Organization for Standardization (ISO), 119
- Internet Archive, Wayback Machine, 238n45
- Internet Engineering Task Force (IETF), 260n66
- internet security
 - child interaction with internet, 148, 150–55, 268–69n4, 273–74n24–25
 - ISPs, breaches involving, 56
 - online banking, 51, 137, 190
 - online data brokers, 58–60
 - online software sales, 192
 - self-regulation on, 155
 - social networking sites. *See* social networking sites
- Internet Security Systems (ISS), 168
- interoperability of data, 226
- investment in security, failure to make, 58
- ISO (International Organization for Standardization), 119
- ISPs (internet service providers),
 - breaches involving, 56
- ISS (Internet Security Systems), 168
- ITSA (Uniform Trade Secrets Act), 93
- Jordan, Amy, 149, 272–73n19–20
- journalistic reporting on information
 - security. *See* reporting information
 - security breaches and vulnerabilities
- JP Morgan Chase, 268n35
- judicial cases. *See* court cases
- judicial documents. *See* court documents
- Kaner, Cem, 199
- Kennedy, Caroline, 151, 274n29
- Kesan, Jay, 223, 224
- Kimberley-Clark, 257n19
- Kline, Stephen, 154, 273n24
- Kodak Corporation, 96
- Korobkin, Russell, 193–94, 197–99, 285n192
- least privilege approach to financial data, 127–28
- Leff, Arthur, 197
- legacy design problem in financial data, 122, 132
- legal acquisition of data for illegal purposes, 12, 56–57
- legal regulation. *See* regulation of information security
- Lessig, Lawrence, 209, 222, 223
- Lexis-Nexis, 38, 54, 63
- Li, Paul, 25
- liability issues pertaining to online materials, 250n10
- liability limitations in software licenses, 160
- licensing
 - cryptographic patents, 82–83
 - RAND (reasonable and nondiscriminatory) terms, 88
 - software. *See* software licensing
- LifeJournal, 212
- limitations on liability in software licenses, 160
- Linux, 26, 90
- Live Journal, 215
- Livingstone, Sonia, 210
- loans, defaulted, and identity theft, 126–27
- locks and lock-picking, 171
- London Facebook Network, 208, 209
- loyalty, employee
 - decline in, 95
 - duty of, 94
- Lynn, Michael, 168
- Maine health data laws, 109
- Maksimovic, Ivko, 212
- marketing and advertising on SNSs,
 - third-party, 215–19

- Marketscore, 190–91, 284n178–79
- Massachusetts Institute of Technology (MIT), 82
- Mastercard, 189, 283n171
- Mattel, 212
- Matwyshyn, Andrea M., xi, 3, 228
- Mayer-Schoenberger, Viktor, 225
- McCarty, Eric, 174
- measuring information security, 24–26
- media reporting on information security.
See reporting information security breaches and vulnerabilities
- MediaMax, 176–77
- medical data. *See* health data
- Meiklejohn, Alexander, 277n23
- Meunier, Pascal, 174
- Microsoft Corp.
 AutoPatcher and, 249n62
 culture of security in, 292n6
 FTC complaints against, 244n53
 health data and, 105
 patches provided by, 249n59, 249n62
 social science, computer science as, 26, 28
 software licensing, 161, 167, 173, 186–89, 192, 195, 261n76
- Mill, John Stuart, 276–77n23
- minors. *See* children and children's data
- MIT (Massachusetts Institute of Technology), 82
- Model End User Licensing Act, 198
- model fair end-user license agreement (FEULA), 199
- monitoring
 continuous need for, corporate failure to comprehend, 51–52
 employee theft of trade secrets, preventing, 99
 financial data protections, 128–29, 136–38
 parental empowerment over children's data, importance of, 153–55
- Monster.com, 7, 237n34, 253n4
- Moore, H. D., 174
- Morin, D., 35
- Mosaic browser, 7, 237n42
- mother's maiden name, as security question, 60, 268n44
- multiple contexts, simultaneous situation of corporate information security in, 228, 230–31
- MyDoom, 237n38
- MySpace, 154–55, 204–5, 217–18, 268–69n4, 269–71n9, 271n11
- National Conference of Commissioners on Uniform State Laws (NCCUSL), 198–99
- National Health Information Network (NHIN), 103, 114
- national ID proposals, 141–42
- National Institute of Standards and Technology (NIST), 88–89, 119
- Naughton, Patrick, 270n9
- NCCUSL (National Conference of Commissioners on Uniform State Laws), 198–99
- negligence claims, health data disclosures, 110
- Net Nanny, 153
- Network Associates, 162–63, 170–71, 277n24
- network effects/network value of cryptography, 76–77
- networked aggregated data, corporate hoarding of. *See* retention of data
- new account fraud, 123–27, 135, 137
- New Hampshire health data laws, 109
- New York data breach notification statute, 45
- NewsFeed, 226
- Next Generation Software Ltd., 171
- NHIN (National Health Information Network), 103, 114
- NIST (National Institute of Standards and Technology), 88–89, 119
- nondisclosure agreements (restrictive covenants), 94–95, 164

- nonobviousness criterion, patents, 67, 70–71
- notification of breaches. *See* reporting information security breaches and vulnerabilities; state data breach notification statutes
- novelty criterion, patents, 67, 69–70
- Oakley, Robert, 198, 277n28
- OASIS (Organization for the Advancement of Structured Information Standards), 90
- obscenity, online, 250n10, 269n9
- “obscurity is security” myth, 58, 136, 171–72, 182, 267n34
- OECD (Organisation for Economic Co-operation and Development), 206, 209, 218
- offshoring health information processing, 107
- online banking, 51, 137, 190
- online data brokers, 58–60
- online software sales, 192
- Ontario Consumer Protection Act, 276n7, 286n224
- open source software movement, 89–90
- OpenBSD, 26
- Operation Boca Grande, 54
- Oracle, 279n71
- Organisation for Economic Co-operation and Development (OECD), 206, 209, 218
- Organization for Internet Safety, 279n70
- Organization for the Advancement of Structured Information Standards (OASIS), 90
- organizational code, 230, 292n4–5
- organizational recognition of need for information security, development of, 51–52
- organizational responsibility for exposed digital records, 33–34, 36–38, 40, 41–49, 42, 44
- Ostwald, Tomasz, xiii, 13, 19, 229
- outsourcing health information processing, 107
- ownership/use of data, 226
- Oxford University Facebook case, 207–12, 214, 222
- Pacer, 57
- parental empowerment over children’s data, importance of, 153–55
- Passerini, Katia, 211
- passwords, 56, 60, 132
- patches, 25–26, 186–89, 247n1
- patenting cryptographic technology, 14, 64–91, 230
 - applications, 65, 84
 - “best mode” test, 72
 - business methods exception from statutory subject matter, 255n8
 - claims, 65–67, 66, 73, 254n4, 255–57n13–17
 - definiteness test, 72
 - definition of patents, 65
 - disclosure requirement, 71–72
 - equivalents, doctrine of, 72
 - examiners of patents, 254n5
 - free and open source software movement, 89–90
 - historical development and expansion of technology patents, 75–79, 81–86, 85
 - infringements, 73–75, 85–86
 - licensing, 82–83
 - nondiscriminatory nature of patents, 78, 258n27
 - nonobviousness criterion, 67, 70–71
 - novelty criterion, 67, 69–70
 - pooling, 64, 79, 83, 87, 259–60n61
 - portfolio management of patents, 64, 79, 90–91
 - prior art, 67–71
 - PTO, 65, 67, 71, 77, 78, 84, 254n3–5, 260n71

- standard setting
 - government regulation of, 81, 82–83
 - patent-aware, 64, 79, 87–89
 - statutory bars to, 70
 - statutory subject matter test, 68–69
 - thickets or patent density, 14, 64, 78–79, 84, 86–91
 - utility criterion, 69, 255n12
 - validity of patents
 - criteria for, 67–68
 - invalidity risks, 74–75
- Patriot Act, 35
- Paya, Cem, xiii, 16, 121, 231
- Payment Card Industry Data Security Standards (PCIDSS), 130, 135
- payment cards and payment card fraud, 122–23
 - CNP transactions, 123
 - CVV numbers, 123, 133, 266n6, 266n8
 - loss risks, containment of, 126, 134–35
 - monitoring protections, 136–37
 - new account fraud compared, 125–27, 135
 - PINs, 131, 133
 - “quasi-secret” problem, 130–31, 142–43
 - risk management of, 140
 - risk pool model for dealing with, 126, 143
 - smartcards, 132–33
 - software licensing, risks stemming from, 189–91
- PC Pitstop, 284n189
- PCIDSS (Payment Card Industry Data Security Standards), 130, 135
- personal health records (PHRs), 105
- personal identification numbers (PINs), 131, 133
- Petco, 244n53
- Pew Internet and American Life Project, 145, 146, 151, 153, 154, 204
- PGP (Pretty Good Privacy), 77
- PHI (protected health information)
 - under HIPAA, 111–17
- phishing, 6–7, 23, 39, 236–37n25–33, 247n7
- phNeutral, 28
- photo-tagging, 214–14
- PHRs (personal health records), 105
- Piaget, Jean, 147
- Pincus, Jonathan, xiii, 13, 19, 21, 229
- PINs (personal identification numbers), 131, 133
- Podgurski, Andy, xiii, 15–16, 103, 231
- pooling
 - patents, 64, 79, 83, 87, 259–60n61
 - payment card fraud, risk pool model for dealing with, 126, 143
- portability of data, 226
- portfolio management of patents, 64, 79, 90–91
- prescriptions, 105–6
- pretexting, 58–59
- Pretty Good Privacy (PGP), 77
- Principles for Fair Commerce in Software and Other Digital Products (AFFECT), 165–66, 170, 183–84, 186, 188, 198–201
- Principles of the Law of Software Transactions (ALI project), 159, 192–93, 198–99
- prior art and patents, 67–71
- Privacy Act of 1974, 110
- privacy and confidentiality
 - children’s and youths’ lack of attention to, 151–53, 210–12, 227, 270–71n9
 - employer-employee relationship, confidential nature of, 84–95
 - health data, regulation of. *See under* health data
 - HIPAA Privacy Rule, 111, 112, 118
 - informational privacy, difficulty of maintaining, 274n29
 - internet privacy contracts, 155

- nondisclosure agreements (restrictive covenants), 94–95
- OECD privacy principles, 206, 209, 218
- public space, expectations of privacy in, 210–11, 214
- SNSs, data control on. *See* social networking sites
- as social benefit versus individual right, 220–21
- US versus EU concepts of, 238–38n47
- Privacy Rights Clearinghouse, 266n3
- process-driven nature of corporate information security, 228, 229–30
- professional spammers, profits of, 236n23
- ProQuest, 38
- protected health information (PHI) under HIPAA, 111–17
- PTO (Patent and Trademark Office), 65, 67, 71, 77, 78, 84, 254n3–5, 260n71
- public disclosure of software vulnerabilities, licensing terms restricting. *See under* software licensing
- public hearings and documents on information security breaches and vulnerabilities, 54
- Public Interest Research Group, 218
- public key cryptography, 81–82, 128, 258–59n40
- public policy, unenforceability of contracts contrary to, 196–97
- public space, expectations of privacy in, 210–11, 214
- “quasi-secret” nature of financial data, 130–31, 142–43
- Raab, Charles, 220
- radiofrequency identification (RFID), 133, 221
- RAND (reasonable and nondiscriminatory) licensing terms, 88
- Raymond, Eric, 292n5
- Real ID Act, 142
- reasonable and nondiscriminatory (RAND) licensing terms, 88
- reasonable expectations, contract law doctrine of, 195–96
- recovery from failure of financial security systems, designing for, 129–30, 138–39
- Regan, Priscilla, 220–21, 226
- regulation of information security
 - CFAA, 35–36, 47
 - children’s data. *See* Children’s Online Privacy Protection Act
 - cryptography
 - exports, 80–81
 - patenting. *See* patenting cryptographic technology
 - standards, 81, 82–83
 - data breach notification. *See* state data breach notification statutes
 - evolution of, 35–38
 - health data. *See under* health data
 - liability issues, 250n10
 - rise of, 7–8
- removal of software, impediments to, 185–89
- reporting information security breaches and vulnerabilities, 14, 50–63, 230
 - at conference presentations, 54, 168, 172
 - failure to heed external reports, 11–12
 - historical development of, 50–52
 - increase in media attention, 44–45, 62
 - individual victims, reporting by, 52–53
 - “obscurity is security” myth, 58
 - perpetrators, bragging by, 53–54
 - potential victims, failure to inform, 53, 54, 58, 59–60
 - public hearings and documents, 54
 - responsible disclosure protocol, 27
 - social science approach to, 26–28

- software licensing terms and practices suppressing public knowledge of vulnerability, 159–60. *See also* under software licensing
- state statutes requiring. *See* state data breach notification statutes
- unreported and underreported breaches, 55–57
- whistleblowing by information security professionals, 53
- Rescorla, Eric, 21
- responsibility for exposed digital records, 13–14, 33–49, 231
 - analysis of compromised records (1980–2007), 38–45
 - end user responsibility, 25–25n11, 34, 48
 - hacker responsibility, 34–36, 41–43, 42, 44, 46–49, 252n22
 - media reporting, possible skewing of results by, 44–45
 - organizational responsibility, 33–34, 36–38, 40, 41–49, 42, 44
 - regulation, evolution of, 35–38
 - sectoral distribution of compromised records, 39–41, 40
 - state data breach notification statutes identifying, 36–38, 45–47
 - type of breach, distribution of compromised records by, 42, 43
- responsible disclosure protocol, 27, 172
- restrictive covenants (nondisclosure agreements), 94–95, 164
- retention of data
 - automatic expiration of data, 225
 - children's data, 151
 - corporate tendencies regarding, 4–5, 60–61
 - financial data, 128, 135–36
- Retrocoder, 161–62
- reverse engineering, software licensing clauses restricting, 167–70
- revocation, 129–30, 138
- RFID (radiofrequency identification), 133, 221
- Rijndael algorithm, 88
- risk management
 - of financial data, 139–42
 - payment card fraud, risk pool model for dealing with, 126, 143
 - planning, need for, 10–11
 - transitivity of information risk, 233–34, 292–93n9
- rookits, 175–78, 247n4
- Rowe, Elizabeth A., xiii, 14–15, 92, 231
- RSA, 28, 82, 83, 259n53
- Russinovich, Mark, 175, 177
- SAEM (security attribute evaluation method), 25
- sales of data used for illegal purposes, 12, 56–57
- Saltzer, Jerome, 23
- Samuelson, Pamela, 169, 277–78n40–41, 278n54
- Schneier, Bruce, 177, 187, 220
- Schroeder, Michael, 23
- Scientology, 97–98
- Scotchmer, Suzanne, 169, 277–78n40–41, 278n54
- Scrabbulous, 212
- script kiddies, 56
- Secret Crush (Facebook app), 215
- Secure Sockets Layer (SSL) protocol, 129
- security attribute evaluation method (SAEM), 25
- security of corporate information. *See* corporate information security
- security questions, 61
- Security Rule, HIPAA, 111, 112–13, 119–20
- security-through-obscurity myth, 58, 136, 171–72, 182, 267n34
- self-regulation of internet sites, 155
- sexual exploitation of children, 270n9
- Shadowcrew, 54
- Shah, Rajiv, 223, 224
- shrinkwrap licensing, 192

- silence, contracts of, 164–65
- simultaneous situation of corporate information security in multiple contexts, 228, 230–31
- skimming, 53
- Skype, 183
- Slaughter-Defoe, Diana T., xii, 16, 145, 229
- smartcards, 132–33
- Snipemail.com, 253n25
- SnoSoft, 179
- SNSs. *See* social networking sites
- social comparison, children's use of, 147, 272n18, 275n42
- social engineering attacks, 58–60
- social networking sites (SNSs), 17, 202–27, 229. *See also* specific site names, e.g. Facebook
 - advertising and marketing, third-party, 215–19
 - amounts of personal data disclosed on, 205–7
 - apps, third party, 212–15
 - children's use of, 150–55, 204, 220–21, 269–71n9
 - code solutions to problems with, 222–26
 - conflict between desire for data security and desire to self-disclose, 202
 - consent issues, 207, 216–21, 226
 - data control problems and potential solutions, 219–26
 - data expiration, automatic, 225
 - default settings, 207–12, 214, 216–17, 223–25
 - defined, 202–3
 - ENISA report on, 215, 220, 226
 - expectations of privacy on, 208–12, 214
 - ownership and use of data, 226
 - photo-tagging, 214–14
 - portability and interoperability of data, 226
 - prevalence of, 204–5
 - social science approach to computer science, 13, 19–29, 229
 - defining computer science and computer security, 20–21, 29
 - interdisciplinary perspective, advantages of, 21–22
 - limitations of purely technological approach, 19–20
 - measuring security, 24–26
 - reporting information security breaches and vulnerabilities, 26–28
 - user error/human error/fallibility studies, 22–24
- Social Security numbers (SSNs), 16, 123–25
 - California data breach notification statute on, 36
 - in health data, 108
 - monitoring use of, 137
 - new account fraud and, 123–25, 135, 137
 - permanent validity of, problems with, 138–39
 - “quasi-secret” nature of, 130–31, 142–44
 - rate of compromise of, 4
 - risk management of, 141–42
 - special risks associated with, 122
 - state and federal information sites, ready availability via, 56–57
 - unnecessary use and retention of, 60, 122, 124–25
- software licensing, 17, 159–201, 230
 - AFFECT's 12 Principles, 165–66, 170, 183–84, 186, 188, 198–201
 - ALI project “Principles of the Law of Software Transactions,” 159, 192–93, 198–99
 - anti-benchmarking clauses, 161–67
 - anti-reverse-engineering clauses, 167–70
 - consent obtained by license for risky practices, 184–86

- disclaimers, 160
- DMCA, 161, 175, 177–80
- FEULA, 199
- free and open source software movement, 89–90
- legislation specific to, need for, 197–99
- limitations on liability in, 160
- methods for addressing problems raised by, 191–99
- Model End User Licensing Act, 198
- pre-transaction disclosure of terms, 191, 192–95
- public disclosure of vulnerabilities, terms restricting, 170–84
 - anti-circumvention provisions of Canadian Copyright Act, 179–80
 - chilling effects of, 173–80
 - enforcement, arguments against, 180–84
 - “obscurity is security” myth, 171–72
 - payment for notification, 172–73
 - responsible disclosure protocol, 172
- public policy, unenforceability of contracts contrary to, 196–97
- reasonable expectations, doctrine of, 195–96
- removal of software, impediments to, 185–89
- shrinkwrap licensing, 192
- terms suppressing public knowledge about security vulnerabilities, 159–61
- third party risks, practices creating, 189–91
- traditional contract law doctrines used to control, 195–97
- UCITA. *See* Uniform Computer Information Transactions Act
- unconscionability, doctrine of, 195
- update system abuses, 186–89
- Sony rookit, 175–77, 184
- spam and spamming, 224, 236n23, 247n6
- speech, freedom of, 164–65, 276–77n23
- Spitzer, Eliot, 162
- spoofing, 6, 39, 236n30
- SpyMon, 161–62, 276n14
- spyware, 247n5
- SSL (Secure Sockets Layer) protocol, 129
- SSNs. *See* Social Security numbers
- standards
 - best practices standard for health care data protection, 119–20
 - cryptographic technology government regulation of, 81, 82–83
 - patent-aware, 64, 79, 87–89
- Stanford patents, 82, 83, 84
- state data breach notification statutes advantages and disadvantages of, 61–63
 - purposes and provisions, 47–48, 245–46n54
 - responsibility for digital records exposed by, 36–38, 45–47
 - visibility of financial data problem raised by, 142
- state health data laws, 109
- statutory subject matter test, patents, 68–69
- Sunbelt Software, 161–62
- SunnComm, 176–77, 281n108
- Superior Mortgage Corp., 240–41n51
- surveillance. *See* monitoring
- Swire, Peter, 181–82
- Sybase, 171, 278n63
- Symmantec, 192
- Target, 133, 269n4
- TCG (Trusted Computing Group), 88
- Technology Entertainment Design (TED) conference, 61
- Teledata Communications, Inc., 246n62
- television and children’s data, 148–50

- theft of information
 - by employees. *See* employees and employee theft
 - of identities. *See* identity theft
 - lucrative nature of, 5–7
- thickets or patent density, 14, 64, 78–79, 84, 86–91
- third-parties
 - SNSs
 - advertising and marketing on, 215–19
 - apps for, 212–15
 - ownership and use of data on, 226
 - software licensing practices creating risks for, 189–91
- Three-hour Rule, 149
- 3Com, 27
- TippingPoint, 27, 172–73, 280n78
- TJX Companies Inc., 3, 8, 9, 12–13, 134, 244–45n53
- Toffler, Alvin, 273n24
- top-down versus bottom-up approach to corporate information security, 292n3
- Tower Records, 244n53
- trade secrets, 15, 231
 - combating threats to, 98–99
 - data leaks endangering status as trade secrets, 246n60
 - defined, 93
 - employees as threats to, 15, 92–99, 231
 - misappropriation of, 93–94, 261n10
 - private disclosures, 96–97
 - public disclosures, 97–98
 - UTSA, 93, 261n5
- transitive closure, 232, 292n8
- transitivity of information risk, 233–34, 292–93n9
- Trojans, 247n3
- trust in commercial transactions, erosion of, 8–9
- TrustE, 222
- Trusted Computing Group (TCG), 88
- 12 Principles for Fair Commerce in Software and Other Digital Products (AFFECT), 165–66, 170, 183–84, 186, 188, 198–201
- Tygar, J. D., 23–24
- UCC (Uniform Commercial Code), 198
- UCITA. *See* Uniform Computer Information Transactions Act
- UCLA (University of California at Los Angeles), 245n54
- unconscionability, contract law doctrine of, 195
- Unfair Contract Terms Act 1976 (UK), 222
- Unfair Terms Directive 1993 (EU), 222
- Uniform Commercial Code (UCC), 198
- Uniform Computer Information Transactions Act (UCITA), 159
 - anti-benchmarking clauses, 165–67
 - anti-reverse-engineering clauses, 170
 - delayed disclosure of license terms accepted by, 192–93
 - production and adoption of, 198–99
 - shortcomings of, 200, 288n249
- Uniform Trade Secrets Act (UTSA), 93
- uninstalling software, impediments to, 185–89
- United Kingdom
 - contract protections in, 222
 - data protections in, 222, 238n43
 - SNSs in, 203, 204–5, 207–12, 222
- United States. *See also* specific names of U.S. Acts and federal departments
 - advertising and marketing requirements, 218–19
 - contract protections. *See* contract law
 - federal websites, security breaches involving, 57
 - identity management system problems in, 141–42
 - privacy issues in, 238–38n47
 - regulation of information security in, 7–8
 - smartcards, use of, 132–33

- SNSs in, 203, 204, 206, 209, 210
- software licensing
 - specific legislation needed to address, 197–99
 - traditional contract law doctrines used to control, 195–97
- zombie drones in, 237n38
- University of California at Los Angeles (UCLA), 245n54
- UNIX, 90, 179
- updates
 - abuse of system for, 186–89
 - security importance of, 12–13
- U.S. Department of Defense, 141
- U.S. Department of Health and Human Services, 104, 111, 114, 115
- U.S. Department of Veterans Affairs, 33, 107
- USA Patriot Act, 35
- “usable security,” concept of, 23
- use/ownership of data, 226
- user error studies, 22–24
- user names, 56
- users generally. *See* end users
- utility criterion, patents, 69, 255n12
- voter registration data, sale of, 56–57
- WabiSabiLabi, 27
- Waddams, S. M., 286n217, 286n219
- Wal-Mart, 105
- Wang, Zhenlin, xiv, 16, 145, 229
- Watson, Paul, 172
- Way Back Machine, 211, 238n45
- WEP, 12–13
- WGA (Windows Genuine Advantage) Notification Application, 161, 166, 186, 187, 276n10, 277n38
- whistleblowing by information security professionals, 53
- Whitten, Alma, 21, 23–24
- Wikipedia, 203, 205
- Windows Genuine Advantage (WGA) Notification Application, 161, 166, 186, 187, 276n10, 277n38
- WIPO (World Intellectual Property Organization), 179
- WiredSafety.org, 269n9
- Worden, Harold, 96
- World Intellectual Property Organization (WIPO), 179
- Xanga.com, 242–43n52, 270n9
- XCon, 28
- XCP (Extended Copy Protection), 176, 177
- You are Gay (Facebook app), 212
- YouTube, 205
- ZENworks, 26
- o-days, 27, 249n69
- Zetter, Kim, xiv, 14, 50, 230
- zombie drones (botnets), 7, 194–95, 237n37–38
- zombie network operators, 249n65
- zoning, 275n45